Invisibles : Reprenez le contrôle de votre vie numérique

Le guide pratique pour configurer vos navigateurs, appareils et applications contre le profilage publicitaire

Oussama Ghorbel

Bibliothèque Oussama Ghorbel

© 2026 Oussama Ghorbel. Tous droits réservés.

Aucune partie de cet ouvrage ne peut être reproduite, stockée ou transmise, sous quelque forme ou par quelque moyen que ce soit, sans l’autorisation écrite préalable de l’auteur, sauf courtes citations dans le cadre d’une critique ou d’une recension, conformément aux lois sur la propriété intellectuelle.

Ouvrage conçu et dirigé par Oussama Ghorbel, rédigé avec l’assistance d’outils d’intelligence artificielle.

Bibliothèque Oussama Ghorbel — Première édition, 2026.

Avertissement

Le présent ouvrage est fourni à titre strictement éducatif et informatif. Il ne constitue en aucun cas un conseil financier personnalisé, une recommandation d'investissement, ni une sollicitation à acheter ou vendre un instrument financier.

Les informations contenues dans ce livre sont générales et ne tiennent pas compte de votre situation financière personnelle, de vos objectifs ni de votre tolérance au risque. Avant toute décision d'investissement, consultez un conseiller financier agréé et indépendant.

L'auteur et l'éditeur déclinent toute responsabilité quant aux pertes éventuelles résultant de l'utilisation des informations présentées dans cet ouvrage.

Table des matières

Introduction 6

Partie 1 : Comprendre la matrice de la surveillance 22

Chapitre 1 – Le vrai prix de la gratuité 23

Chapitre 2 – L'anatomie d'un profil fantôme 37

Chapitre 3 – Les algorithmes de l'influence 48

Chapitre 4 – L'audit de votre exposition numérique 59

Chapitre 5 – Le RGPD et vos droits numériques 70

Chapitre 6 – La philosophie de la frugalité numérique 81

Partie 2 : Le bouclier numérique (Web et Identité en ligne) 92

Chapitre 7 – Blinder son navigateur web 93

Chapitre 8 – L'arsenal des extensions anti-pistage 105

Chapitre 9 – Moteurs de recherche et confidentialité 119

Chapitre 10 – L'art de l'emailing furtif et des alias 131

Chapitre 11 – Réseaux sociaux : verrouiller les écoutilles 142

Chapitre 12 – E-commerce et paiements sans traces 152

Partie 3 : Le cœur du réacteur (Appareils et OS) 163

Chapitre 13 – iOS et Android : décortiquer la télémétrie 164

Chapitre 14 – Le nettoyage des permissions mobiles 179

Chapitre 15 – Messageries et appels inviolables 189

Chapitre 16 – Le Cloud souverain et le chiffrement 200

Chapitre 17 – Coffres-forts numériques et authentification 212

Chapitre 18 – L'ordinateur de bureau : Windows, Mac et Linux 223

Partie 4 : La forteresse domestique et l'identité 234

Chapitre 19 – Le routeur : sentinelle du réseau local 235

Chapitre 20 – La maison connectée et l'IoT 246

Chapitre 21 – Biométrie, santé et objets portables 259

Chapitre 22 – Chasser les courtiers en données 270

Chapitre 23 – Gérer les fuites et le vol d'identité 288

Chapitre 24 – La routine d'hygiène numérique 301

Conclusion 314

Bibliographie commentée 324

© 2026 Oussama Ghorbel

Introduction

Introduction : L'ère de la transparence subie et le droit à l'opacité

Le malaise numérique : quand l'écran nous observe

Vous avez déjà ressenti ce frisson. Cette sensation fugace mais tenace que votre téléphone, posé là, sur la table, face cachée, vous écoute. Vous avez parlé d'un projet de voyage, d'un modèle de chaussures, ou d'un symptôme médical avec un proche, sans jamais taper le moindre mot sur un clavier. Et pourtant, quelques heures plus tard, en ouvrant une application d'actualités ou en faisant défiler votre fil d'actualité, la publicité est là. Précise. Insidieuse. Parfaitement ciblée.

Bien sûr, les géants de la technologie s'empressent de nier toute écoute microphone à des fins publicitaires. Et d'un point de vue strictement technique, ils disent vrai : ils n'ont pas besoin de vous écouter. La réalité est bien plus vertigineuse. Ils n'ont pas besoin de capter vos mots parce qu'ils possèdent déjà vos intentions. Ils connaissent vos routines, votre géolocalisation, la vitesse à laquelle vous faites défiler un texte, le temps d'hésitation de votre curseur avant de cliquer, et les corrélations invisibles entre votre profil et celui de millions d'autres utilisateurs qui vous ressemblent. L'algorithme n'a pas entendu votre conversation ; il a simplement prédit, avec une précision statistique terrifiante, ce que vous alliez désirer avant même que vous ne l'exprimiez.

Nous vivons dans une architecture de la transparence subie. Chaque interaction, chaque déplacement, chaque battement de cœur enregistré par notre montre connectée laisse derrière nous ce que les experts en sécurité appellent des « gaz d'échappement numériques » (*data exhaust*). Ces résidus, invisibles à l'œil nu, sont aspirés, agrégés et revendus sur des marchés aux enchères en temps réel (le *Real-Time Bidding*), où votre attention et vos vulnérabilités sont mises à prix en quelques millisecondes, à chaque fois que vous chargez une page web.

Comme l'a brillamment théorisé la chercheuse Shoshana Zuboff dans ses travaux sur le capitalisme de surveillance, notre expérience vécue

© 2026 Oussama Ghorbel

n'est plus seulement un espace de vie ; elle est devenue une matière première gratuite, extraite pour être transformée en données comportementales, puis revendue sous forme de prédictions. Nous ne sommes plus les clients de l'industrie numérique. Nous sommes sa matière première.

L'illusion du consentement et la fatigue cognitive

Face à cette machinerie, quelle a été notre défense ? Des bannières de cookies.

Lorsque le Règlement Général sur la Protection des Données (RGPD) est entré en vigueur en Europe, l'espoir était immense. Nous allions enfin reprendre le contrôle. Nous allions pouvoir dire « non ». Mais l'industrie a rapidement muté, transformant une législation pensée pour la protection en une arme de fatigue cognitive. Aujourd'hui, le consentement n'est qu'une illusion de design. Les « dark patterns » (interfaces truquées) rendent le refus si fastidieux, si caché, si exigeant en clics, que l'abandon devient notre seul refuge. Nous cliquons sur « Tout accepter » non pas par choix, mais par épuisement.

Cette résignation est le plus grand triomphe de l'économie de la surveillance. Elle nous a convaincus que la perte de notre intimité était le prix inévitable de la modernité, le péage obligatoire pour emprunter les autoroutes de l'information. Nous avons intégré l'idée que pour exister numériquement, il fallait s'abandonner.

Edward Snowden a un jour formulé cette vérité fondamentale : « Dire que vous ne vous souciez pas du droit à la vie privée parce que vous n'avez rien à cacher n'est pas différent de dire que vous ne vous souciez pas de la liberté d'expression parce que vous n'avez rien à dire. » La vie privée n'est pas le refuge des coupables ; elle est le socle de la liberté individuelle. C'est l'espace mental et physique dans lequel nous pouvons explorer, douter, changer d'avis, et grandir sans être jugés, notés, ou monétisés par des entités dont nous ignorons jusqu'au nom.

Pourquoi la vie privée est l'affaire de tous

Pendant longtemps, la cybersécurité et la protection de la vie privée ont été perçues comme des domaines réservés aux informaticiens, aux journalistes d'investigation, aux dissidents politiques ou aux marginaux.

© 2026 Oussama Ghorbel

Une sorte de paranöia de niche. C'est une erreur profonde. Aujourd'hui, la défense de votre identité numérique est une compétence de survie de base, au même titre que de savoir verrouiller la porte de son appartement ou de gérer son compte bancaire.

Le profilage ne se limite plus à vous vendre des chaussures. Il détermine le prix de votre assurance automobile, votre éligibilité à certains crédits, la visibilité de votre CV sur les plateformes de recrutement, et même la nature des informations politiques qui s'afficheront sur votre écran à la veille d'une élection. Les algorithmes de l'influence ne se contentent pas de refléter nos désirs ; ils les façonnent, les polarisent et les orientent.

De plus, la multiplication des objets connectés (IoT), des assistants vocaux et des capteurs biométriques a fait tomber les dernières frontières entre le monde numérique et notre sanctuaire physique. Votre salon, votre chambre, votre poignet sont devenus des points de collecte. L'enjeu n'est plus seulement de protéger votre historique de navigation, mais de préserver votre intégrité cognitive et physique face à des systèmes conçus pour optimiser votre temps de cerveau disponible.

Ce que signifie réellement devenir « invisible »

Le titre de ce livre, *Invisibles*, peut prêter à confusion. Devenir invisible, dans le contexte de ce guide, ne signifie pas disparaître d'Internet. Il ne s'agit pas de vous retirer dans une cabane au fond des bois, de jeter votre smartphone dans un lac, ou de vous entourer de papier d'aluminium. L'invisibilité absolue, dans un monde hyperconnecté, est un mythe. Quiconque vous promettra un anonymat total et garanti vous ment.

L'invisibilité dont nous parlons ici est une stratégie. C'est l'art de contrôler votre signal et votre bruit. C'est la capacité de vous fondre dans la masse numérique, de brouiller les pistes, d'utiliser des alias, de compartimenter votre vie, et de rendre le coût de votre profilage supérieur à la valeur que vous représentez pour les courtiers en données.

Être invisible, c'est devenir une cible non rentable. C'est introduire de la friction dans la machine à extraire. C'est choisir la frugalité numérique non pas comme une privation, mais comme une

© 2026 Oussama Ghorbel

émancipation. Lorsque vous maîtrisez vos outils, lorsque vous comprenez comment un navigateur web dialogue avec un serveur, lorsque vous savez chiffrer vos communications et masquer votre empreinte technique (fingerprint), vous cessez d'être un produit pour redevenir un utilisateur. Vous reprenez les commandes.

À qui s'adresse ce livre ?

J'ai conçu cet ouvrage pour toutes celles et ceux qui ressentent ce malaise face à l'omniprésence du pistage, mais qui ne savent pas par où commencer pour s'en protéger.

Ce livre est pour **le citoyen ordinaire** qui en a assez de recevoir des appels de démarchage non sollicités et de voir ses données personnelles revendues à son insu.

Il est pour **le parent** qui souhaite protéger l'empreinte numérique de ses enfants et sécuriser les appareils de la maison contre les intrusions et les contenus prédateurs.

Il est pour **le professionnel, le freelance ou l'entrepreneur** qui doit protéger ses secrets d'affaires, ses communications avec ses clients, et qui ne peut se permettre une fuite de données ou un vol d'identité.

Il est pour **le curieux et l'autodidacte** qui veut comprendre les rouages de la matrice numérique, non pas pour la détruire, mais pour y naviguer en souveraineté.

Vous n'avez pas besoin d'être un développeur chevronné ou un expert en cryptographie pour appliquer les méthodes de ce livre. J'ai écrit ce guide avec une obsession : la pédagogie et le pragmatisme. Chaque concept technique sera vulgarisé, chaque configuration sera expliquée pas à pas. Mon objectif n'est pas de vous noyer sous le jargon, mais de vous donner les clés de votre propre maison numérique.

La méthode : pragmatisme et frugalité numérique

La démarche de ce livre repose sur un principe fondamental : la sécurité et la confidentialité ne doivent pas être des freins à votre vie quotidienne, mais des fondations invisibles qui la soutiennent. Si une mesure de protection est trop complexe, trop lente ou trop contraignante, vous finirez par l'abandonner. C'est la nature humaine.

© 2026 Oussama Ghorbel

C'est pourquoi je vous proposerai des solutions graduées. Nous commencerons par des actions rapides, à fort impact et à faible effort (ce que l'on appelle les *quick wins*), avant d'aborder des configurations plus avancées pour ceux qui souhaitent aller plus loin. Nous adopterons la philosophie de la « défense en profondeur » : aucune mesure n'est infaillible seule, mais la superposition de plusieurs couches de protection (navigateur, réseau, appareil, identité) crée un bouclier extrêmement résilient.

Nous parlerons également de frugalité numérique. La meilleure donnée est celle qui n'est jamais collectée. Avant d'apprendre à chiffrer ou à bloquer, nous apprendrons à supprimer, à refuser, et à nous détacher des services toxiques qui ne nous apportent aucune valeur réelle en échange de notre intimité.

Note importante : Bien que ce livre aborde des sujets liés à l'identité numérique, aux fuites de données et aux courtiers en informations (qui ont des implications financières directes), le contenu présenté ici est strictement informatif, technique et préventif. Il ne constitue en aucun cas un conseil juridique ou financier personnalisé. En cas de vol d'identité avéré ou de fraude bancaire, il est impératif de vous rapprocher des autorités compétentes et de votre établissement financier.

Votre feuille de route : le plan de bataille

Pour vous guider dans cette reconquête, j'ai structuré cet ouvrage en quatre grandes parties, conçues comme un voyage progressif. Nous partirons de la compréhension globale du système pour descendre progressivement vers le cœur de vos appareils, jusqu'à votre réseau domestique.

Partie 1 : Comprendre la matrice de la surveillance

Avant de démonter la machine, il faut comprendre comment elle fonctionne. Cette première partie est votre éveil.

Dans le **Chapitre 1**, nous décortiquerons le vrai prix de la gratuité et les modèles économiques basés sur l'extraction de données. Le **Chapitre 2** vous révélera l'anatomie de votre « profil fantôme », cette base de données parallèle que les courtiers ont bâtie sur vous. Le **Chapitre 3**

© 2026 Oussama Ghorbel

explorera les algorithmes de l'influence et la manière dont ils exploitent nos biais cognitifs.

Ensuite, nous passerons à l'action avec le **Chapitre 4**, qui vous apprendra à réaliser votre propre audit d'exposition numérique (ce que le web sait de vous aujourd'hui). Le **Chapitre 5** démystifiera le RGPD et vous donnera les modèles de lettres et les méthodes légales pour forcer les entreprises à supprimer vos données. Enfin, le **Chapitre 6** posera les bases de la frugalité numérique, une philosophie essentielle pour assainir votre écosystème.

Partie 2 : Le bouclier numérique (Web et Identité en ligne)

C'est ici que nous commencerons à verrouiller les portes et les fenêtres de votre vie en ligne. Le web est le premier vecteur de pistage.

Le **Chapitre 7** vous apprendra à blinder votre navigateur web (Firefox, Chrome, Brave, Safari) en modifiant des paramètres cachés et en bloquant la télémétrie. Le **Chapitre 8** dressera l'arsenal des extensions anti-pistage indispensables, en vous apprenant à éviter les fausses extensions de sécurité qui revendent vos données.

Le **Chapitre 9** traitera des moteurs de recherche et de la confidentialité, vous montrant comment sortir de l'emprise des bulles de filtres. Le **Chapitre 10** est l'un des plus cruciaux : il vous enseignera l'art de l'emailing furtif, l'utilisation des alias (comme SimpleLogin ou AnonAddy) et la gestion des mots de passe pour que chaque service que vous utilisez soit isolé des autres.

Les **Chapitres 11 et 12** s'attaqueront aux géants : nous verrons comment verrouiller les écoutilles de vos réseaux sociaux pour limiter la casse, et comment effectuer des achats en ligne (e-commerce) en minimisant les traces financières et postales.

Partie 3 : Le cœur du réacteur (Appareils et OS)

Une fois le web sécurisé, nous devons nous occuper des terminaux que vous tenez dans vos mains et qui reposent sur votre bureau. Vos appareils sont des mouchards potentiels bien plus puissants que n'importe quel site web.

© 2026 Oussama Ghorbel

Le **Chapitre 13** décortiquera la télémétrie intégrée d'iOS et d'Android, et vous montrera comment la réduire au strict minimum. Le **Chapitre 14** vous guidera dans le grand nettoyage des permissions mobiles (pourquoi votre application de lampe torche a-t-elle besoin de votre géolocalisation ?).

Le **Chapitre 15** abordera un sujet vital : les messageries et les appels inviolables. Nous comparerons les protocoles de chiffrement de bout en bout (Signal, Matrix, etc.) et vous apprendrez à communiquer sans laisser de métadonnées exploitables.

Le **Chapitre 16** vous expliquera comment reprendre le contrôle de vos fichiers grâce au Cloud souverain et au chiffrement local (Zero Knowledge). Le **Chapitre 17** transformera votre téléphone en coffre-fort numérique avec une authentification forte (clés de sécurité, YubiKey, TOTP). Enfin, le **Chapitre 18** traitera de l'ordinateur de bureau, avec des guides de durcissement pour Windows, Mac et Linux, afin de protéger votre environnement de travail des malwares et de la télémétrie système.

Partie 4 : La forteresse domestique et l'identité

La dernière partie de ce livre concerne votre environnement physique et la pérennité de votre identité.

Le **Chapitre 19** fera de votre routeur la sentinelle de votre réseau local, en bloquant les requêtes malveillantes et les pisteurs au niveau du DNS avant même qu'ils n'atteignent vos appareils. Le **Chapitre 20** s'attaquera au cauchemar de la maison connectée et de l'IoT (Internet des Objets), en vous apprenant à isoler ces appareils peu sécurisés sur des réseaux virtuels (VLAN).

Le **Chapitre 21** abordera les enjeux colossaux de la biométrie, des données de santé et des objets portables (montres, bagues connectées), qui représentent le nouveau graal des assureurs et des courtiers.

Les **Chapitres 22 et 23** vous armeront pour le combat hors ligne : comment chasser les courtiers en données (Data Brokers) qui revendent votre adresse et votre numéro, et comment gérer les fuites de données, le *doxing* et le vol d'identité si le pire devait arriver.

© 2026 Oussama Ghorbel

Enfin, le **Chapitre 24** synthétisera tout cet apprentissage en une routine d'hygiène numérique. Car la sécurité n'est pas un état, c'est une pratique. Je vous y livrerai mes checklists hebdomadaires, mensuelles et annuelles pour maintenir votre forteresse intacte sans y consacrer des heures.

En route vers la souveraineté

Le chemin qui s'ouvre devant vous n'est pas celui de la peur, mais celui de la clarté. En refermant ce livre, vous ne regarderez plus jamais votre smartphone, votre box internet ou votre navigateur de la même manière. Vous verrez les fils invisibles qui tentent de vous manipuler, et plus important encore, vous saurez exactement où couper ces fils.

L'ère de la transparence subie s'arrête ici. L'ère de votre souveraineté numérique commence maintenant.

Tournez la page, et entrons ensemble dans la matrice.

Chapitre 1 – Le vrai prix de la gratuité

Le mythe du client roi et la sémantique de la marchandise

« Si c'est gratuit, c'est vous le produit. » Cette maxime, popularisée au début des années 2010, est devenue le lieu commun par excellence de la critique du web moderne. On la retrouve dans les dîners en ville, dans les articles de presse grand public et dans les manuels d'introduction au marketing digital. Pourtant, aussi percutante soit-elle, cette phrase est fondamentalement inexacte. Et cette inexactitude n'est pas qu'une question de sémantique ; elle masque la véritable mécanique du capitalisme de surveillance.

Vous n'êtes pas le produit.

Pour comprendre pourquoi, il faut se placer du point de vue de celui qui paie. Les véritables clients des géants du numérique (les GAFAM, mais aussi la myriade de courtiers en données et de régies publicitaires qui gravitent autour d'eux) sont les annonceurs. Ces annonceurs n'achètent pas *vous*. Ils n'achètent pas votre personne, ni même votre attention directe. Ce qu'ils achètent, c'est une **prédiction comportementale**.

© 2026 Oussama Ghorbel

Votre personne, vos clics, vos hésitations, vos heures de connexion et vos déplacements géographiques constituent la *matière première*. Cette matière première est extraite, raffinée, agrégée et transformée en un produit fini : la certitude statistique que vous serez réceptif à un message spécifique, à un instant précis, dans un contexte émotionnel donné. Vous êtes la carcasse dont on extrait le minerai ; la prédiction de votre comportement futur est le lingot d'or qui s'échange sur les marchés.

Cette distinction est cruciale. Si vous étiez le produit, vous auriez un droit de regard sur votre propre vente, une capacité à négocier votre valeur, ou à vous retirer de l'étalage. Mais en tant que matière première, vous êtes subordonné au processus d'extraction. L'industrie n'a aucun intérêt à ce que vous compreniez votre propre valeur marchande, car cette prise de conscience introduirait de la friction dans la chaîne d'approvisionnement. Le but ultime de l'architecture numérique actuelle est de rendre l'extraction de vos données aussi fluide, indolore et invisible que l'extraction du pétrole l'était pour le consommateur du XXe siècle avant les grandes prises de conscience écologiques.

L'ère de la captologie et le design comportemental

Pour extraire cette matière première en continu, il faut que la source ne tarisse jamais. Il faut que vous restiez connecté, que vous scrolliez, que vous cliquiez, que vous partagiez. C'est ici qu'intervient la captologie, un terme forgé à la fin des années 1990 par B.J. Fogg, chercheur à l'université de Stanford, pour désigner l'étude de l'informatique persuasive.

À ses débuts, l'informatique persuasive avait des ambitions nobles : encourager les gens à faire plus d'exercice, à réduire leur consommation d'énergie ou à adopter des habitudes saines. Mais très vite, les géants de la Silicon Valley ont réalisé que ces mêmes mécanismes psychologiques pouvaient être détournés pour maximiser le « temps de cerveau disponible ».

Chaque application « gratuite » que vous utilisez a été conçue par des équipes d'ingénieurs, de designers et de psychologues comportementaux dont l'unique indicateur de performance (KPI) est votre rétention. Le design de ces interfaces n'est pas le fruit du hasard ; c'est une architecture de la dépendance.

© 2026 Oussama Ghorbel

Prenons l'exemple du « pull-to-refresh », ce geste qui consiste à tirer l'écran vers le bas pour actualiser un fil d'actualité. Ce mécanisme n'a aucune utilité technique stricte ; une actualisation automatique en arrière-plan serait beaucoup plus élégante. Mais le pull-to-refresh reproduit exactement la mécanique d'un levier de machine à sous. Vous tirez, il y a un bref instant de suspense (le chargement), et vous découvrez votre récompense : une notification flatteuse, une nouvelle vidéo divertissante, ou un message d'un proche. Cette récompense à intervalle variable déclenche une libération de dopamine dans votre cerveau, créant une boucle de rétroaction neurologique qui vous pousse à répéter l'action.

La gratuité de ces services n'est donc pas un cadeau qui vous est fait. C'est l'appât d'un piège comportemental. En échange de l'accès à une plateforme de messagerie ou à un réseau social, vous payez avec votre capacité d'attention, votre santé mentale et votre autonomie cognitive. Le coût de la gratuité se mesure ici en heures de sommeil perdues, en crises d'anxiété nourries par la comparaison sociale, et en une fragmentation extrême de notre capacité de concentration.

Le Real-Time Bidding (RTB) : la salle des marchés de votre intimité

Si la captologie explique comment la matière première est extraite, le *Real-Time Bidding* (RTB), ou enchère en temps réel, explique comment elle est écoulée sur les marchés financiers de la donnée. C'est le cœur battant, bien que totalement invisible, de l'économie de la surveillance.

Imaginez la scène suivante : vous ouvrez votre navigateur et tapez l'adresse d'un site d'actualités. Entre le moment où vous appuyez sur la touche « Entrée » et le moment où la page s'affiche sur votre écran, il s'écoule environ 200 à 300 millisecondes. Dans cet intervalle de temps infime, une transaction financière colossale vient de se jouer à votre insu.

Dès que votre navigateur envoie une requête au site d'actualités, ce dernier contacte une bourse d'échanges publicitaires (*Ad Exchange*). Le site envoie un signal contenant votre « empreinte » : votre adresse IP approximative, le modèle de votre appareil, votre système d'exploitation, votre niveau de batterie, la liste des autres sites que vous avez visités

© 2026 Oussama Ghorbel

récemment, et parfois même des inférences sur votre orientation sexuelle, vos opinions politiques ou votre état de santé, déduites de vos habitudes de navigation.

Ce profil éphémère est diffusé à des centaines, voire des milliers de courtiers en données et de réseaux publicitaires. Ces entités lancent alors des algorithmes qui évaluent votre valeur en quelques microsecondes. Un annonceur de chaussures de sport va surenchérir s'il sait que vous avez cherché des marathons récemment ; une clinique privée pourrait enchérir si votre profil suggère une vulnérabilité psychologique ; un parti politique pourrait miser sur votre profil s'il correspond à une cible électorale indécise.

L'enchère la plus haute l'emporte, et la publicité de ce gagnant s'affiche sur votre écran au moment précis où la page termine son chargement.

Note : Les concepts économiques, marchés et mécanismes d'enchères décrits dans cette section sont analysés exclusivement sous l'angle de la protection de la vie privée, de la sécurité informatique et de la souveraineté numérique. Ils ne constituent en aucun cas des conseils en investissement financier, en stratégie d'entreprise ou en placement boursier.

Le problème majeur du RTB n'est pas seulement que votre attention est vendue au plus offrant. Le problème est la **fuite structurelle de vos données**. Pour qu'un annonceur puisse évaluer s'il doit enchérir sur votre profil, il doit recevoir les données de votre « bidstream » (le flux d'enchères). Or, une fois que ces données sont envoyées à des centaines d'acteurs tiers pour évaluer l'enchère, il est techniquement impossible de contrôler ce qu'ils en font. Même si vous n'avez pas cliqué sur la publicité, même si l'enchérisseur n'a pas gagné, il a tout de même reçu et potentiellement stocké votre profil comportemental.

C'est ainsi que des données ultra-sensibles (votre géolocalisation en temps réel, vos recherches médicales, votre présence dans un lieu de culte ou un centre de planning familial) se retrouvent aspirées par des agrégateurs de données, puis revendues à des assureurs, des employeurs potentiels, ou des officines d'influence politique. La gratuité du site d'actualités que vous visitez est subventionnée par la liquidation de votre

© 2026 Oussama Ghorbel

intimité sur un marché mondial non régulé.

Le matériel subventionné : le cheval de Troie physique

Jusqu'à présent, nous avons parlé de la gratuité logicielle et des services en ligne. Mais la matrice de la surveillance a compris que pour capter encore plus de données, il fallait sortir de l'écran et s'inviter dans notre réalité physique. C'est l'avènement du matériel subventionné, ou le modèle du *Hardware as a Service* déguisé.

Avez-vous déjà remarqué à quel point certaines télévisions connectées (Smart TV) de très grande taille sont vendues à des prix défiant toute concurrence, parfois à peine plus cher que le coût de leurs composants ? Avez-vous déjà été surpris par le prix dérisoire de certaines montres connectées, de caméras de surveillance domestiques ou d'assistants vocaux ?

Ce n'est pas de la générosité corporative. C'est un modèle économique où le matériel est vendu à prix coûtant, voire à perte, car le véritable retour sur investissement se fera sur l'exploitation continue des données générées par l'appareil.

Une Smart TV à bas prix est en réalité un mouchard de salon. Les conditions générales d'utilisation (que personne ne lit) incluent souvent des clauses autorisant le fabricant à capter des métadonnées sur ce que vous regardez, à quelle heure, à quel volume, et même à utiliser le microphone de la télécommande pour « améliorer la reconnaissance vocale ». Ces données de télémétrie sont ensuite revendues à des instituts de mesure d'audience ou à des régies publicitaires pour cibler les membres de votre foyer.

De même, les applications de santé gratuites, les montres qui comptent vos pas et les balances connectées qui analysent votre masse graisseuse ont un accès privilégié à votre intimité biologique. Dans un monde où les données de santé sont le Saint Graal pour les compagnies d'assurance et les mutuelles, confier ces informations à des serveurs tiers en échange d'un badge virtuel félicitant vos 10 000 pas quotidiens relève de la naïveté. Le coût de ce gadget « gratuit » ou bon marché pourrait bien se chiffrer, des années plus tard, par une surprime d'assurance ou un refus de couverture face à une maladie que vos données biométriques

© 2026 Oussama Ghorbel

auront laissé présager.

Le matériel subventionné est un cheval de Troie. Il franchit les murs de votre forteresse domestique parce que vous l'y avez invité vous-même, séduit par l'apparence d'une bonne affaire financière.

Les externalités invisibles : quand la gratuité dégrade la société

Si le coût de la gratuité se limitait à de la publicité ciblée pour des vacances ou des baskets, le problème serait purement esthétique et gérable avec quelques bons bloqueurs de publicités. Mais l'économie de l'extraction de données produit des externalités négatives bien plus profondes, qui dégradent le tissu même de nos sociétés démocratiques.

Pour maximiser l'engagement et donc la collecte de données, les algorithmes de recommandation des plateformes gratuites ont rapidement découvert une vérité neurologique implacable : l'indignation, la peur et la colère génèrent beaucoup plus d'interactions que la nuance, la joie ou le consensus. Le contenu qui suscite une réaction viscérale est le contenu qui retient l'utilisateur le plus longtemps sur la plateforme, générant ainsi plus de points de données à revendre.

En optimisant mathématiquement pour l'engagement, les plateformes gratuites ont accidentellement (puis intentionnellement) optimisé pour la polarisation. Elles ont créé des chambres d'écho où chaque utilisateur est enfermé dans une réalité sur mesure, alimentée en continu par des informations confirmant ses biais cognitifs et diabolisant le camp adverse.

Le vrai prix de la gratuité de ces réseaux sociaux, c'est l'érosion de notre espace public commun. C'est la difficulté croissante à s'accorder sur des faits objectifs. C'est la montée des extrémismes, facilitée par des algorithmes qui ont compris que la radicalisation d'un utilisateur est un excellent moyen de garantir sa fidélité à la plateforme. Nous avons troqué la cohésion sociale et la santé de nos démocraties contre la possibilité de partager des photos de nos vacances et de jouer à des quiz gratuits.

De plus, cette économie de la gratuité a tué l'innovation diversifiée sur le web. Comment une start-up respectueuse de la vie privée, qui

© 2026 Oussama Ghorbel

souhaiterait faire payer un abonnement modeste et honnête pour un service de qualité, peut-elle rivaliser avec un géant qui offre un service équivalent « gratuitement » en s'appuyant sur une infrastructure mondiale de surveillance ? La gratuité subventionnée par la data a créé des monopoles naturels, étouffant la concurrence et réduisant nos choix à une poignée de plateformes hégémoniques.

L'illusion du contrat social numérique

Face à ce constat, l'industrie oppose souvent l'argument du « contrat social » : les utilisateurs acceptent volontairement de céder leurs données en échange de services qui leur facilitent la vie. Après tout, personne ne vous force à créer un compte, à télécharger l'application ou à accepter les cookies.

Cet argument repose sur l'illusion du consentement éclairé. Un contrat n'est valide que si les deux parties comprennent les termes de l'accord et disposent d'une alternative réelle. Or, les conditions générales d'utilisation (CGU) des services numériques sont délibérément conçues pour être illisibles. Des études ont montré qu'il faudrait à un internaute moyen plus de 76 jours de lecture par an, à temps plein, pour lire les politiques de confidentialité de l'ensemble des sites qu'il visite.

Le consentement n'est pas libre, il est extorqué par le design. C'est ce qu'on appelle les *dark patterns* (interfaces truquées). Le bouton « Tout accepter » est mis en évidence, coloré, large et invitant. Le bouton « Refuser » ou « Paramétrer » est caché, grisé, relégué au bas de page ou nécessite de cliquer sur cinq sous-menus obscurs. L'architecture du choix est biaisée pour exploiter la fatigue cognitive de l'utilisateur.

Pire encore, l'alternative fait souvent défaut. Comment postuler à un emploi si vous refusez d'utiliser le réseau social professionnel dominant ? Comment garder le lien avec votre famille dispersée si vous boycottez l'application de messagerie hégémonique ? Comment utiliser votre smartphone si vous refusez les conditions d'utilisation de son système d'exploitation ? La gratuité n'est pas un choix de marché ; c'est un péage obligatoire sur les autoroutes de la vie moderne, où le seul moyen de paiement accepté est votre identité numérique.

Vers une économie de la valeur réelle : le coût de la frugalité

© 2026 Oussama Ghorbel

Prendre conscience du vrai prix de la gratuité est la première étape, indispensable, vers la reconquête de votre souveraineté. Mais cette prise de conscience doit s'accompagner d'un changement de paradigme : nous devons réapprendre à payer pour les outils que nous utilisons.

C'est le fondement de la philosophie de la frugalité numérique que nous développerons tout au long de ce livre. La frugalité ne consiste pas à se priver, mais à consommer mieux, en pleine conscience. Lorsque vous payez un abonnement mensuel de quelques euros pour un service de messagerie chiffrée, pour un moteur de recherche indépendant ou pour un gestionnaire de mots de passe souverain, vous changez radicalement la nature de votre relation avec l'éditeur.

Vous redevenez le client.

Lorsque vous êtes le client, l'intérêt économique de l'entreprise s'aligne enfin avec le vôtre. Son objectif n'est plus de maximiser votre temps d'écran pour revendre votre profil, mais de vous fournir le service le plus efficace, le plus sûr et le plus respectueux possible pour que vous renouveliez votre abonnement l'année suivante. La confidentialité devient alors un argument de vente, une caractéristique premium du produit, et non plus une anomalie à contourner.

Bien sûr, tout le monde n'a pas les moyens financiers de multiplier les abonnements payants. C'est pourquoi ce livre mettra également en avant les alternatives libres, open-source et communautaires, maintenues par des passionnés et des fondations à but non lucratif dont le modèle économique ne repose pas sur l'extraction de données. Nous apprendrons à distinguer le « gratuit toxique » (subventionné par la surveillance) du « gratuit vertueux » (financé par des dons, des subventions publiques ou le bénévolat).

Le véritable coût de la protection de votre vie privée n'est pas financier. Il est temporel et cognitif. Il vous en coûtera un peu de temps pour configurer vos appareils, pour changer vos habitudes, pour apprendre à utiliser de nouveaux outils. Mais ce temps investi est un investissement sur votre liberté future. C'est le temps nécessaire pour forger votre bouclier numérique.

Conclusion du chapitre : la fin de la naïveté

© 2026 Oussama Ghorbel

En refermant ce premier chapitre, le voile de la naïveté doit se déchirer. Vous ne regarderez plus jamais le bouton « Connexion avec Facebook » ou l'application de lampe torche « gratuite » de la même manière. Vous savez désormais que derrière chaque service qui ne vous facture pas d'argent, une machinerie complexe s'active pour vous facturer en données, en attention et en influence.

Vous avez compris que vous êtes la matière première d'une industrie qui a bâti des empires financiers sur l'exploitation de votre intimité. Vous avez saisi les mécanismes du Real-Time Bidding et les dangers du matériel subventionné. Vous avez pris la mesure des externalités qui pèsent sur notre société.

Mais la colère ou le cynisme ne sont pas des stratégies de défense. Maintenant que vous connaissez les règles du jeu, il est temps d'apprendre à jouer vos propres cartes. Dans le chapitre suivant, nous allons plonger dans les profondeurs de cette machinerie pour découvrir exactement ce que l'industrie sait de vous. Nous allons disséquer l'anatomie de votre profil fantôme, cette ombre numérique qui vous précède partout sur la toile, et nous verrons comment commencer à lui couper les vivres.

La matrice n'est pas invincible. Elle repose sur votre coopération passive. Il est temps de retirer votre consentement.

© 2026 Oussama Ghorbel

Partie 1 : Comprendre la matrice de la surveillance

© 2026 Oussama Ghorbel

Chapitre 1 – Le vrai prix de la gratuité

Nous avons grandi avec une promesse fondamentale de l'ère numérique : l'accès universel et gratuit à l'information, aux outils et au divertissement. Cette promesse a façonné nos habitudes, nos réflexes et notre manière d'interagir avec le monde. Aujourd'hui, les applications les plus sophistiquées, les réseaux sociaux les plus vastes et les moteurs de recherche les plus puissants sont accessibles sans que nous ayons à débourser le moindre centime. Pourtant, en économie comme en physique, rien ne se crée, rien ne se perd, tout se transforme. Si vous ne payez pas avec votre portefeuille, vous payez avec autre chose.

Dans ce premier chapitre, nous allons lever le voile sur la mécanique invisible qui finance notre confort numérique apparent. Comprendre cette matrice n'est pas seulement un exercice intellectuel ; c'est la première étape, absolument indispensable, pour reprendre le contrôle. On ne peut pas se défendre contre un adversaire dont on ignore la nature, les motivations et les armes. Il est temps de démystifier le modèle économique de la publicité ciblée et de l'industrie des données, pour passer du statut de ressource exploitable à celui de citoyen numérique souverain.

L'illusion du client : pourquoi vous êtes le produit

Il existe un adage bien connu dans la Silicon Valley, souvent attribué à l'écrivain Andrew Orlowski ou popularisé par les lanceurs d'alerte de la tech : « Si c'est gratuit, c'est vous le produit. » Cette phrase, bien que devenue un lieu commun, ne perd rien de sa pertinence. Elle résume à elle seule le basculement historique qui s'est opéré au tournant des années 2000.

À l'aube de l'informatique personnelle, le logiciel était un produit. Vous achetiez une licence, vous possédiez un outil. L'entreprise qui concevait le logiciel était votre fournisseur, et vous étiez son client. Vos intérêts étaient théoriquement alignés : l'entreprise voulait créer le meilleur outil possible pour que vous l'achetiez. Aujourd'hui, le modèle a radicalement muté. La grande majorité des services que nous utilisons quotidiennement ne sont plus des produits, mais des vitrines. Le véritable produit, c'est l'espace publicitaire personnalisé qui s'affiche sur

votre écran, et la matière première nécessaire à la fabrication de ce produit, c'est votre attention et vos données personnelles.

La professeure émérite à la Harvard Business School, Shoshana Zuboff, a théorisé ce phénomène sous le nom de « capitalisme de surveillance ». Dans son ouvrage fondateur, elle explique que l'expérience humaine est désormais traitée comme une matière première gratuite, extraite, traitée et transformée en données comportementales. Ces données ne servent pas uniquement à améliorer le service qui vous est rendu ; elles sont revendues sur des marchés à terme comportementaux où les acheteurs parient sur ce que vous ferez dans le futur.

Cette inversion du contrat commercial a des conséquences profondes. Lorsque vous êtes le client, l'entreprise a intérêt à protéger votre vie privée et à respecter votre temps. Lorsque vous êtes le produit, l'entreprise a intérêt à vous extraire le maximum de données possible, à capter votre attention par tous les moyens (y compris les plus addictifs ou anxiogènes), et à réduire votre vie privée à la portion congrue. Le conflit d'intérêts est structurel, permanent et insoluble dans le cadre de ce modèle économique. Vous n'êtes pas l'utilisateur d'une plateforme gratuite ; vous êtes le bétail d'une ferme de données, et votre temps de cerveau disponible est la marchandise qui s'échange à la bourse de l'attention.

La chaîne de valeur de la AdTech en temps réel

Pour bien saisir l'ampleur de cette exploitation, il faut plonger au cœur du réacteur de la publicité en ligne : la AdTech (Advertising Technology). Derrière chaque bannière publicitaire qui s'affiche sur votre écran se cache une infrastructure technologique d'une complexité et d'une rapidité stupéfiantes, fonctionnant en temps réel.

Imaginez que vous ouvrez une application de météo gratuite sur votre smartphone pour vérifier s'il va pleuvoir demain. En une fraction de seconde, avant même que les nuages n'apparaissent sur votre écran, une enchère programmatique (Real-Time Bidding, ou RTB) se déclenche. Voici comment cette chaîne de valeur opère, en moins de 200 millisecondes :

© 2026 Oussama Ghorbel

1. **L'éditeur (Publisher)** : L'application météo dispose d'un espace vide réservé à la publicité.

2. **La SSP (Supply-Side Platform)** : L'application envoie une requête à sa plateforme de gestion, indiquant qu'un espace est disponible.

3. **L'Ad Exchange** : C'est la bourse d'échange, le marché où se rencontrent l'offre et la demande. L'Ad Exchange reçoit un "paquet de données" vous concernant. Ce paquet contient votre identifiant publicitaire unique (IDFA sur iOS ou GAID sur Android), votre géolocalisation approximative, le modèle de votre téléphone, votre langue, votre opérateur, et le contexte de l'application.

4. **La DSP (Demand-Side Platform)** : L'Ad Exchange diffuse cette requête à des dizaines, voire des centaines de DSP, qui représentent les annonceurs (marques de vêtements, constructeurs automobiles, éditeurs de jeux mobiles, etc.).

5. **L'enchère** : Chaque DSP analyse votre profil en le croisant avec ses propres bases de données. Si un annonceur de chaussures de running a ciblé les "hommes de 25 à 34 ans, géolocalisés à Lyon, ayant montré un intérêt pour le sport", sa DSP fait une offre de 0,003 centime d'euro pour afficher sa bannière.

6. **L'adjudication** : L'Ad Exchange sélectionne l'offre la plus élevée. La bannière gagnante est renvoyée à l'application météo et s'affiche sous vos yeux.

Ce processus, d'une efficacité redoutable, pose un problème majeur de confidentialité : pour que les annonceurs puissent enchérir, ils doivent tous recevoir votre paquet de données. Même s'ils ne remportent pas l'enchère, des dizaines d'entreprises tierces ont capté votre localisation, votre identifiant unique et vos métadonnées à chaque chargement de page ou d'application.

C'est une fuite de données massive, continue et totalement invisible. Vous ne visitez pas seulement un site d'information ; vous diffusez en continu votre identité numérique à un écosystème de centaines d'intermédiaires dont vous ignorez jusqu'à l'existence. La AdTech n'est pas un simple panneau d'affichage numérique ; c'est un réseau de surveillance panoptique financiarisé, où chaque micro-geste de votre

© 2026 Oussama Ghorbel

navigation est monétisé à la milliseconde.

Les courtiers en données (Data Brokers) : l'industrie de l'ombre

Si la AdTech représente le marché public de vos données, les courtiers en données (Data Brokers) en sont le marché noir, ou du moins le marché de l'ombre. Ce sont des entreprises qui collectent, agrègent, analysent et revendent des informations personnelles sur des millions d'individus, sans jamais avoir de relation directe avec eux. Vous n'avez jamais accepté les conditions d'utilisation d'Acxiom, d'Experian ou de CoreLogic, et pourtant, ces entreprises savent probablement où vous habitez, quel est votre revenu estimé, si vous êtes propriétaire de votre logement, et quelles sont vos pathologies médicales probables.

Comment opèrent-ils ? Leur force réside dans la fusion des mondes. Ils achètent des données à des applications mobiles, à des programmes de fidélité de supermarchés, à des sites de e-commerce, mais ils les croisent également avec des données hors ligne (offline) : registres publics, actes de propriété, fichiers de recensement, dossiers de crédit, et même abonnements à des magazines papier.

L'objectif est de créer un "double numérique" d'une précision chirurgicale. Un courtier en données ne se contente pas de savoir que vous avez acheté des couches en ligne. Il sait que vous avez acheté une maison de quatre chambres dans une banlieue spécifique il y a six mois, que votre véhicule est un modèle familial, et que vos revenus correspondent à la tranche supérieure de votre code postal. En recoupant ces éléments, il peut déduire avec une marge d'erreur infime que vous êtes parents de jeunes enfants, et revendre cette information sous forme de "segment d'audience" à des marques de jouets, d'assurances vie ou d'établissements bancaires.

L'industrie des Data Brokers est un colosse aux pieds d'argile en matière de régulation. Contrairement aux agences de notation de crédit, qui sont strictement encadrées car elles influencent directement votre capacité à emprunter, les courtiers en données opèrent dans un flou juridique savamment entretenu. Ils ne vendent pas techniquement "votre nom" ; ils vendent des "profils probabilistes" ou des "identifiants pseudonymisés". Pourtant, la ré-identification d'un profil pseudonymisé

© 2026 Oussama Ghorbel

est un jeu d'enfant pour quiconque dispose d'assez de points de données (il suffit de croiser un code postal, une date de naissance et un genre pour identifier une personne de manière unique dans la grande majorité des cas).

Cette industrie de l'ombre crée une asymétrie d'information terrifiante. Les entreprises savent tout de vous, de vos faiblesses financières à vos vulnérabilités émotionnelles, tandis que vous ignorez tout d'elles. Il est presque impossible pour un consommateur moyen de demander la suppression de ses données chez un courtier, car il faudrait d'abord savoir qui il est, prouver son identité (en envoyant... encore plus de données personnelles), et naviguer dans des procédures d'opt-out volontairement byzantines.

Le profilage prédictif et comportemental

La collecte de données ne se limite plus à décrire ce que vous avez fait dans le passé. Grâce à l'avènement du Machine Learning et de l'intelligence artificielle, l'industrie est passée du profilage descriptif au profilage prédictif. L'objectif n'est plus de savoir qui vous êtes, mais de prédire ce que vous allez faire, ressentir ou acheter, avant même que vous n'en ayez conscience.

Les algorithmes se nourrissent de ce que les chercheurs appellent la "poussière numérique" (digital exhaust) : les métadonnées comportementales qui semblent anodines prises isolément, mais qui, agrégées, révèlent les secrets les plus intimes. La vitesse à laquelle vous faites défiler une page, l'heure à laquelle vous êtes le plus actif, la manière dont vous tenez votre téléphone, le niveau de batterie de votre appareil au moment d'un achat, ou encore les micro-hésitations de votre curseur sur un bouton "Acheter". Tout est enregistré, pondéré et analysé.

En 2012, le journaliste Charles Duhigg du *New York Times* révélait comment le géant de la distribution Target avait développé un modèle prédictif capable d'identifier les femmes enceintes en analysant de légers changements dans leurs habitudes d'achat (comme l'achat soudain de lotions sans parfum ou de compléments alimentaires spécifiques). Target envoyait ensuite des coupons de réduction pour des articles de puériculture, devançant parfois l'annonce officielle de la grossesse au sein même de la famille. Ce qui était à l'époque une anecdote choquante

© 2026 Oussama Ghorbel

est aujourd'hui la norme industrielle.

Aujourd'hui, les modèles prédictifs peuvent inférer votre orientation sexuelle, vos convictions politiques, votre état de santé mental, ou votre propension à l'addiction, simplement en analysant les "J'aime" sur un réseau social ou les sémantiques de vos recherches. Le profilage comportemental permet de créer des audiences "lookalike" (sosies). Si l'algorithme détecte que vous partagez 85 % des micro-comportements numériques avec un groupe de personnes ayant contracté un crédit à la consommation à taux élevé, il vous classera dans la même catégorie et vous proposera les mêmes produits financiers prédateurs, même si vous n'avez jamais cherché de crédit.

Note de l'auteur : Il est crucial de rappeler que ces modèles prédictifs sont probabilistes, et non infaillibles. Ils génèrent des erreurs de classement qui peuvent avoir des conséquences réelles sur votre accès à certains services. Ce contenu est informatif et vise à expliquer les mécanismes de la collecte de données ; il ne constitue en aucun cas un conseil financier ou juridique sur la manière de gérer votre crédit ou votre identité administrative.

L'impact invisible sur nos choix quotidiens et nos prix

L'argument le plus souvent avancé par les défenseurs de la publicité ciblée est le suivant : « Je n'ai rien à cacher, et au moins, les publicités que je vois sont pertinentes. » C'est une illusion qui mérite d'être déconstruite. L'impact de la surveillance de masse ne se limite pas à l'affichage de bannières pour des chaussures que vous avez consultées la veille. Il altère profondément la réalité qui vous est présentée, vos choix, et même le prix que vous payez pour les biens et services.

Le premier impact est la **discrimination tarifaire dynamique**. Puisque les courtiers et les plateformes savent quel appareil vous utilisez, d'où vous vous connectez, et quelle est votre sensibilité au prix estimée par leurs algorithmes, ils peuvent adapter les prix en temps réel. Il a été démontré par le passé que certains sites de voyage affichaient des tarifs d'hôtels plus élevés aux utilisateurs naviguant sur des ordinateurs Mac (statistiquement associés à des revenus plus élevés) qu'à ceux sur PC. Aujourd'hui, cette personnalisation des prix est beaucoup plus subtile et individualisée. Vous ne payez pas le prix du marché ; vous

© 2026 Oussama Ghorbel

payez le prix maximum que l'algorithme estime que vous êtes prêt à accepter, basé sur votre profil de vulnérabilit ou d'urgence.

Le second impact est la **manipulation de l'environnement informationnel**. Les algorithmes de recommandation, optimisés pour maximiser le temps d'engagement (et donc les revenus publicitaires), ont tendance à favoriser les contenus qui suscitent des réactions émotionnelles fortes : l'indignation, la peur, la colère. En vous enfermant dans des bulles de filtres et des chambres d'écho, le profilage comportemental modèle votre perception du monde. Vous ne voyez pas la réalité ; vous voyez une version de la réalité conçue pour maintenir votre attention captive et confirmer vos biais cognitifs.

Enfin, il y a l'impact sur notre **libre arbitre**. Le profilage prédictif permet de déclencher des incitations (nudges) au moment précis où votre volonté est la plus faible. Une notification push pour une application de livraison de repas arrivera exactement à l'heure où l'algorithme sait que vous ressentez habituellement de la fatigue et une baisse de glycémie. Une publicité pour un jeu d'argent apparaîtra lors d'un événement sportif, ciblée sur un utilisateur identifié comme présentant des traits impulsifs. La surveillance n'est pas un miroir passif de nos désirs ; c'est un outil actif qui les façonne, les anticipe et les exploite. Nous perdons progressivement la sérendipité, cette capacité à faire des choix imprévus, hors de tout cadre algorithmique.

Introduction à la défense asymétrique du consommateur

Face à cette machinerie, le sentiment d'impuissance est la réaction la plus naturelle. Comment un individu isolé, armé de son seul smartphone, peut-il espérer lutter contre des conglomérats qui disposent de milliards de dollars, de supercalculateurs et des meilleurs ingénieurs en intelligence artificielle de la planète ?

La réponse réside dans le concept de **défense asymétrique**. Dans un conflit asymétrique, le plus faible ne peut pas gagner en affrontant le plus fort sur son propre terrain. Si vous essayez de jouer selon les règles fixées par l'industrie de la AdTech, vous avez déjà perdu.

L'industrie a conçu le cadre du "Notice and Consent" (Notification et Consentement). C'est cette fameuse bannière de cookies qui apparaît à

© 2026 Oussama Ghorbel

chaque visite, vous demandant d'accepter des politiques de confidentialité de 50 pages rédigées en jargon juridique. Ce cadre est un piège. Il transfère la charge de la protection de la vie privée de l'entreprise (qui devrait la garantir par défaut) vers le consommateur (qui doit se battre à chaque clic pour la préserver). Lire les politiques de confidentialité est une tâche impossible ; les accepter par fatigue est une abdication. La défense symétrique (lire, comprendre, négocier) est vouée à l'échec.

La défense asymétrique consiste à changer les règles du jeu. Au lieu de tenter de négocier avec chaque tracker, nous allons couper les routes d'approvisionnement. Au lieu de demander poliment à un courtier en données de nous oublier, nous allons rendre nos données inutilisables, bruitées, ou carrément invisibles.

Cette approche repose sur trois piliers que nous développerons tout au long de ce livre :

1. **La frugalité numérique** : Réduire la surface d'attaque en n'utilisant que les outils strictement nécessaires, en privilégiant les logiciels libres et les modèles économiques basés sur l'abonnement ou l'achat unique plutôt que sur la publicité.
2. **Le blocage systémique** : Utiliser la technologie pour bloquer les requêtes réseau vers les serveurs publicitaires et les trackers, au niveau du navigateur, du routeur et du système d'exploitation.
3. **Le camouflage et la dilution** : Utiliser des alias, des emails jetables et des identifiants temporaires pour fragmenter votre profil et empêcher la création d'un double numérique unifié.

Vous n'avez pas besoin de devenir un expert en cryptographie ou de vivre dans une grotte sans connexion internet pour reprendre le contrôle. Il suffit d'appliquer quelques principes de bon sens technologique, de configurer vos appareils une bonne fois pour toutes, et de laisser la technologie travailler pour vous, en silence, en arrière-plan. La forteresse que nous allons bâtir ensemble dans les chapitres suivants n'est pas une prison qui vous coupe du monde ; c'est un bouclier qui vous permet d'y participer sans y laisser votre âme.

Exercice pratique : Cartographier vos applications

© 2026 Oussama Ghorbel

La théorie ne vaut rien sans la confrontation au réel. Avant de commencer à blinder vos appareils dans la Partie 2 de ce livre, il est essentiel que vous preniez conscience de l'étendue de la surveillance qui s'opère actuellement dans votre poche.

Pour cet exercice, nous allons utiliser **Exodus Privacy**, une organisation à but non lucratif qui propose un outil d'analyse open-source et respectueux de la vie privée, permettant de scanner les applications Android pour y détecter les trackers et les permissions abusives.

Étape 1 : Sélectionner vos cibles

Choisissez 5 applications gratuites installées sur votre smartphone. Pour que l'exercice soit parlant, sélectionnez des applications qui n'ont pas de lien évident avec la publicité ou les réseaux sociaux. Par exemple :

• Une application de lampe torche ou de calculatrice.

• Une application de prévisions météo.

• Une application de recettes de cuisine.

• Un jeu mobile gratuit (type puzzle ou solitaire).

• Une application de suivi de cycle menstruel ou de fitness.

Étape 2 : L'analyse

Rendez-vous sur le site web d'Exodus Privacy (exodus-privacy.eu.org) depuis le navigateur de votre ordinateur ou de votre téléphone. Utilisez la barre de recherche pour trouver chacune de vos 5 applications. Si vous êtes sur Android et que l'application n'est pas encore dans leur base de données, vous pouvez installer l'application mobile Exodus Privacy (disponible sur F-Droid) pour lancer un scan directement depuis votre appareil.

Étape 3 : L'audit et la réflexion

Pour chaque application, notez deux éléments :

1. **Le nombre et le nom des trackers** (ex: Google Firebase Analytics, Facebook Ads, AppsFlyer, Crashlytics).

© 2026 Oussama Ghorbel

2. **Les permissions requises** (ex: accès à la géolocalisation précise, accès aux contacts, lecture du stockage).

Questions pour votre journal de bord numérique :

• *Pourquoi une application de lampe torche a-t-elle besoin d'accéder à ma géolocalisation et d'embarquer 5 trackers publicitaires ?*

• *Quel est le lien entre un jeu de solitaire gratuit et un tracker d'attribution d'installation comme AppsFlyer ?*

• *Suis-je prêt à continuer à "payer" ces services gratuits avec mes données de localisation et mes habitudes comportementales, maintenant que je sais comment elles sont revendues en temps réel ?*

Cet exercice est souvent un choc. C'est le moment précis où la matrice de la surveillance devient tangible. Ne désinstallez pas encore vos applications ; gardez cette prise de conscience en mémoire. C'est le carburant qui vous motivera à appliquer les configurations de sécurité et les alternatives que nous allons explorer dès le chapitre suivant. Le vrai prix de la gratuité vient de vous être facturé ; il est temps d'apprendre à contourner le péage.

Le mythe de l'anonymat dans la foule numérique

Lorsque l'on aborde ces questions, on fait invariablement face à la même objection, souvent formulée avec un mélange de résignation et de scepticisme : « Je ne suis qu'une goutte d'eau dans l'océan. Pourquoi des multinationales s'intéresseraient-elles à moi ? Je n'ai rien à cacher, et je ne suis personne d'important. »

C'est ce que j'appelle le mythe de l'anonymat par la masse. L'idée reçue veut que la quantité astronomique de données collectées chaque seconde noie l'individu dans un brouillard statistique, rendant toute identification précise impossible. C'est une erreur fondamentale de compréhension de la manière dont fonctionne le *Big Data*. L'industrie de la donnée ne cherche pas à vous identifier par votre nom et votre prénom ; elle cherche à vous identifier par votre *motif* (pattern).

En science des données, il existe un concept appelé l'« effet mosaïque ». Pris isolément, un point de donnée est inoffensif et

© 2026 Oussama Ghorbel

anonyme. Savoir qu'un utilisateur a acheté un café latte à 8h14 dans une gare parisienne ne révèle rien. Savoir qu'un terminal mobile s'est connecté à une borne Wi-Fi spécifique à 23h30 ne signifie pas grand-chose. Mais lorsque vous agrégerez des centaines de ces points de données apparemment anodins, la mosaïque se forme et le visage apparaît.

La chercheuse Latanya Sweeney a brillamment démontré les limites de l'anonymisation des données. En croisant un jeu de données de santé « anonymisé » (où les noms et numéros de sécurité sociale avaient été supprimés) avec un registre d'électeurs acheté pour quelques centaines de dollars, elle a pu identifier de manière unique une grande partie des individus du premier jeu de données. L'anonymat sur le web est une illusion d'optique. Il suffit de trois points de géolocalisation précis, relevés à des heures différentes, pour identifier de manière unique 95 % des individus dans une base de données mobile.

De plus, l'industrie a développé des techniques de « cross-device tracking » (suivi inter-appareils). Vous pensez être anonyme parce que vous naviguez sur un ordinateur professionnel le matin, puis sur votre smartphone personnel le soir, et enfin sur votre tablette le week-end. Pourtant, les courtiers en données utilisent des empreintes numériques (fingerprinting), des identifiants partagés et des corrélations probabilistes (par exemple, les trois appareils se connectent chaque nuit à la même adresse IP résidentielle) pour fusionner ces identités éparses en un seul et même profil maître. Vous n'êtes pas une goutte d'eau perdue dans l'océan ; vous êtes une goutte d'eau qui a été colorée, tracée et cataloguée dès son entrée dans le courant.

L'architecture de la fatigue et les interfaces trompeuses

Si la collecte de données est le moteur de cette industrie, la fatigue cognitive en est le carburant. Pour maintenir l'illusion du consentement et se prémunir contre les régulateurs, l'industrie de la AdTech a déployé une arme redoutable : les *Dark Patterns*, ou interfaces trompeuses.

Le cadre légal, notamment le RGPD en Europe, exige que le consentement soit « libre, spécifique, éclairé et univoque ». Sur le papier, c'est une victoire pour la vie privée. Dans la pratique, c'est devenu un champ de bataille où l'utilisateur est structurellement

© 2026 Oussama Ghorbel

désavantagé. Les concepteurs d'interfaces (UX/UI designers) sont souvent incités à utiliser des biais cognitifs pour épuiser votre volonté et vous faire capituler.

Prenons l'exemple classique du bandeau de cookies. Le bouton « Tout accepter » est généralement mis en évidence : il est large, coloré, situé au centre de l'écran et ne nécessite qu'un seul clic. À l'inverse, le chemin vers le refus est un labyrinthe conçu pour vous décourager. Il faut cliquer sur « Paramétrer mes choix », ce qui ouvre une nouvelle fenêtre contenant parfois des dizaines de curseurs, répartis sur plusieurs onglets, avec une terminologie volontairement confuse (« Partenaires », « Vendeurs », « Intérêts légitimes »).

C'est ce qu'on appelle la *friction asymétrique*. Accepter la surveillance est sans friction ; la refuser demande un effort cognitif et temporel considérable. Face à cette friction, le cerveau humain, qui cherche naturellement à économiser son énergie, active le biais de statu quo et finit par cliquer sur « Tout accepter » par pure lassitude. L'industrie appelle cela le « consentement ». En réalité, c'est de la capitulation par épuisement.

D'autres techniques sont encore plus insidieuses, comme le *confirmshaming* (culpabilisation par confirmation). Lorsque vous essayez de refuser une offre ou un partage de données, le bouton de refus est libellé de manière à vous faire culpabiliser : « Non merci, je préfère ne pas profiter de réductions exclusives » ou « Non, je ne me soucie pas de la sécurité de mon compte ». Ces interfaces ne sont pas des accidents de parcours ; elles sont le fruit de tests A/B rigoureux, conçus pour maximiser le taux d'acceptation et gonfler les bases de données des courtiers. Comprendre que ces interfaces sont des armes psychologiques est essentiel pour ne plus subir la culpabilité artificielle qu'elles tentent de vous inoculer.

Le tribut cognitif : vers une écologie de l'attention

Au-delà des enjeux financiers et juridiques, le vrai prix de la gratuité se paie dans une monnaie bien plus précieuse et non renouvelable : notre attention. L'attention n'est pas simplement une fonction cognitive ; c'est la matière première de notre conscience, le filtre par lequel nous construisons notre réalité et notre identité.

© 2026 Oussama Ghorbel

Le modèle économique de la publicité ciblée exige une croissance infinie de l'engagement. Or, le temps humain est fini. Pour capter une part toujours plus grande de ce temps de cerveau disponible, les algorithmes de recommandation ont dû évoluer. Ils ne se contentent plus de vous montrer ce que vous aimez ; ils vous montrent ce qui vous retient. Et les études en neurosciences l'ont prouvé maintes fois : ce qui retient le plus efficacement l'attention humaine, ce n'est pas la joie ou la sérénité, mais l'indignation, la peur, le conflit et l'outrage moral.

En acceptant passivement les services gratuits financés par ce modèle, nous avons laissé s'installer une écologie de l'attention toxique. Nos fils d'actualité sont optimisés pour susciter des réactions limbiques, court-circuitant notre cortex préfrontal, siège de la réflexion et de la nuance. Le profilage comportemental permet de savoir exactement quel type de contenu provoquera chez vous une réaction émotionnelle suffisante pour vous empêcher de fermer l'application. Si l'algorithme détecte que vous êtes sensible aux théories du complot, il vous les servira. S'il détecte que vous êtes anxieux concernant votre santé, il vous inondera d'articles alarmistes sur des maladies rares, avant de vous proposer, quelques secondes plus tard, la publicité ciblée pour une mutuelle premium.

Cette surexcitation constante de notre système nerveux a un coût invisible mais profond : l'érosion de notre capacité à la concentration profonde, à l'ennui créatif et à la sérendipité. Nous perdons la capacité de flâner numériquement, de découvrir des idées en dehors de notre spectre idéologique ou de nos habitudes de consommation. La gratuité apparente des outils nous a coûté notre souveraineté attentionnelle.

Adopter une posture de défense asymétrique, ce n'est donc pas seulement protéger son numéro de carte bancaire ou cacher sa géolocalisation. C'est un acte de préservation cognitive. C'est refuser que notre environnement informationnel soit dicté par des algorithmes dont la seule métrique de succès est le temps passé à l'écran. La frugalité numérique, que nous explorerons en détail dans la suite de cet ouvrage, est d'abord une écologie personnelle. Il s'agit de nettoyer notre habitat numérique pour qu'il redevienne un espace de création et d'outil, plutôt qu'un casino comportemental.

© 2026 Oussama Ghorbel

Conclusion du chapitre : De la prise de conscience à l'action

Au terme de ce premier chapitre, le voile est levé. Vous comprenez désormais que la gratuité sur internet est un leurre sémantique, un contrat léonin où vous cédez votre identité comportementale en échange de services dont le coût réel de maintenance est infinitésimal par rapport à la valeur de revente de vos données. Vous avez vu comment la AdTech opère en temps réel, transformant chaque clic en enchère financière. Vous avez plongé dans l'industrie de l'ombre des Data Brokers, découvert la puissance prédictive des algorithmes, et réalisé comment cette architecture influence vos choix, vos prix et votre perception du monde.

Mais la prise de conscience, si elle est nécessaire, n'est pas suffisante. L'indignation est une émotion à courte durée de vie. Face à la fatigue du consentement et à l'asymétrie des forces en présence, il est facile de sombrer dans le cynisme ou la résignation, en se disant que la bataille est perdue d'avance. C'est exactement ce que l'industrie espère. Votre sentiment d'impuissance est leur meilleur allié.

L'objectif de ce livre n'est pas de vous faire peur, mais de vous armer. La matrice de la surveillance est vaste, mais elle n'est pas invulnérable. Elle repose sur des protocoles techniques, des requêtes réseau, des identifiants et des points de friction. Et tout ce qui est technique peut être configuré, bloqué, contourné ou dilué.

Dans le chapitre qui suit, nous allons passer de la théorie économique à l'anatomie technique. Nous allons disséquer ce que j'appelle votre « profil fantôme » : cette entité numérique qui vous précède sur le web, qui négocie à votre place et qui décide de ce que vous avez le droit de voir. Nous allons apprendre à lire les étiquettes de ce profil, à comprendre comment il se construit à votre insu, et surtout, nous allons commencer à le démanteler, pièce par pièce.

Vous avez fait le premier pas en refusant l'illusion. Vous avez cartographié vos applications et constaté l'ampleur de la fuite. Maintenant, il est temps de colmater les brèches. L'ère de la gratuité subie est terminée ; l'ère de la souveraineté numérique commence. Tournez la page, et entrons ensemble dans l'anatomie de votre double fantôme.

© 2026 Oussama Ghorbel

Chapitre 2 – L'anatomie d'un profil fantôme

Vous est-il déjà arrivé de chercher un billet d’avion pour une destination précise, d’en discuter brièvement avec un proche, ou simplement de vous attarder quelques secondes de trop sur la photo d’une paire de chaussures, pour ensuite voir ces mêmes offres vous poursuivre sur chaque page web, chaque application, chaque réseau social que vous ouvrez ? Ce n’est pas de la paranoïa. Ce n’est pas non plus votre téléphone qui vous écoute en permanence pour capter vos conversations de salon – une légende urbaine tenace, mais techniquement infondée pour la grande majorité des appareils grand public. La réalité est à la fois moins spectaculaire et infiniment plus vertigineuse : vous êtes suivi par une ombre numérique, un double virtuel qui en sait souvent plus sur vos habitudes, vos désirs et vos vulnérabilités que vos amis les plus proches.

Dans l’industrie de la donnée, on appelle cela un « profil fantôme » ou *shadow profile*. C’est une base de données massivement distribuée, constamment mise à jour, qui agrège des milliers de points de données vous concernant. Ce profil n’a pas besoin de connaître votre nom de famille ou votre numéro de sécurité sociale pour être extrêmement lucratif. Il lui suffit de connaître vos routines, vos horaires de connexion, votre sensibilité émotionnelle à certaines heures de la journée, et la probabilité que vous cliquiez sur un bouton « Acheter » après avoir lu un article anxiogène.

Pour reprendre le contrôle de votre vie numérique, il est impératif de cesser de considérer le pistage comme une vague notion abstraite. Nous devons ouvrir le capot. En tant qu'auteur et chercheur dans ce domaine, je compare souvent cette démarche à l'apprentissage de l'anatomie pour un chirurgien : on ne peut pas extraire une tumeur si l'on ne comprend pas le réseau veineux qui l'alimente. Dans ce chapitre, nous allons disséquer les mécanismes techniques du pistage web. Nous allons explorer les outils invisibles que les courtiers en données et les régies publicitaires déploient pour cartographier votre existence en ligne. Préparez-vous à voir la matrice pour ce qu'elle est réellement.

© 2026 Oussama Ghorbel

Cookies premiers et tiers : la mémoire du web

Pour comprendre le pistage, il faut remonter aux origines du web et à un problème fondamental du protocole HTTP : son absence de mémoire. HTTP est un protocole « sans état ». Cela signifie que chaque fois que votre navigateur demande une page à un serveur, c'est comme s'ils se rencontraient pour la toute première fois. Le serveur ne sait pas qui vous êtes, ce que vous avez mis dans votre panier d'achat il y a cinq minutes, ou si vous êtes déjà connecté à votre compte.

Pour résoudre ce problème, en 1994, Lou Montulli, un développeur de Netscape, a adapté le concept du « magic cookie » (un jeton d'identification informatique) pour créer le cookie web. Un cookie n'est rien d'autre qu'un minuscule fichier texte que le serveur demande à votre navigateur de stocker sur votre disque dur. À chaque visite suivante sur ce même domaine, le navigateur renvoie ce fichier au serveur. C'est l'équivalent du ticket de vestiaire : vous le présentez, et le serveur vous rend votre manteau (votre session, votre panier, vos préférences).

Ces cookies, créés par le site que vous visitez directement, sont appelés **cookies premiers** (ou *first-party cookies*). Ils sont essentiels au fonctionnement du web moderne. Sans eux, vous seriez déconnecté de votre boîte mail à chaque clic, et les sites de e-commerce seraient inutilisables.

Le dérapage, et la naissance de la surveillance de masse, survient avec l'invention des **cookies tiers** (*third-party cookies*). Le mécanisme est d'une ingéniosité redoutable. Imaginez que vous visitiez un site d'actualités. La page principale provient du domaine `journal-exemple.com`. Cependant, cette page contient des encarts publicitaires gérés par une régie externe, disons `pub-reseau.com`. Lorsque votre navigateur charge la page, il contacte `journal-exemple.com` pour le texte, mais il contacte *aussi* `pub-reseau.com` pour télécharger l'image de la publicité.

C'est à cet instant précis que `pub-reseau.com` peut déposer un cookie sur votre machine. Aux yeux de votre navigateur, ce cookie est légitime car il provient du serveur qui a fourni la publicité. Vous fermez l'onglet et allez ensuite sur un site de cuisine, qui utilise la même régie publicitaire. Votre navigateur, en chargeant la nouvelle publicité,

© 2026 Oussama Ghorbel

renvoie le cookie à `pub-reseau.com`. La régie sait alors que le même utilisateur a visité un site d'actualités puis un site de cuisine. Multipliez ce processus par les centaines de sites que vous visitez chaque semaine, et vous obtenez une cartographie complète de vos centres d'intérêt, le tout sans que vous n'ayez jamais interagi directement avec `pub-reseau.com`.

Aujourd'hui, sous la pression des réglementations comme le RGPD en Europe et des changements de politiques de navigateurs (comme Safari et Firefox qui les bloquent par défaut, et Chrome qui tente de les éliminer progressivement via sa *Privacy Sandbox*), le cookie tiers est en déclin. Mais ne vous y trompez pas : l'industrie de la publicité ne s'est pas arrêtée de tourner. Elle a simplement muté vers des techniques bien plus insidieuses et difficiles à bloquer.

Le fingerprinting : l'empreinte digitale de votre navigateur

Si le cookie est une étiquette que l'on attache à votre manteau pour vous reconnaître, le *fingerprinting* (ou prise d'empreinte numérique) consiste à analyser votre démarche, votre taille, la couleur de vos yeux et votre accent pour vous identifier dans la foule. C'est une méthode de pistage « sans état », ce qui signifie qu'elle ne stocke absolument rien sur votre appareil. Tout se passe du côté des serveurs qui vous observent.

Lorsque votre navigateur se connecte à un site web, il envoie une requête HTTP accompagnée de métadonnées, les fameux « en-têtes » (headers). Ces en-têtes contiennent des informations techniques nécessaires au bon affichage de la page : votre *User-Agent* (le nom et la version de votre navigateur et de votre système d'exploitation), les langues que vous acceptez, le type de compression que vous supportez, et votre fuseau horaire. Pris isolément, ces éléments sont banals. Mais combinés, ils commencent à former un profil.

Le vrai génie (ou la noirceur) du fingerprinting réside dans l'utilisation de scripts JavaScript pour interroger les capacités matérielles et logicielles de votre machine. Un tracker peut ainsi récupérer :

- La résolution exacte de votre écran et la profondeur de couleur.
- La liste des polices de caractères installées sur votre système.

© 2026 Oussama Ghorbel

- Le niveau de batterie de votre appareil (une API désormais restreinte, mais qui a fait les beaux jours des trackers).
- Le nombre de cœurs logiques de votre processeur.
- La disposition de votre clavier.

L'arme la plus puissante de cet arsenal est le **Canvas Fingerprinting**. Le Canvas est une balise HTML5 qui permet de dessiner des graphiques en 2D ou 3D via JavaScript. Les trackers vont demander à votre navigateur de dessiner une forme géométrique complexe ou un texte avec une police spécifique, en arrière-plan, de manière invisible pour vous. L'image générée est ensuite convertie en un hachage cryptographique (une sorte de signature numérique).

Pourquoi est-ce une empreinte unique ? Parce que le rendu d'une image sur un écran dépend d'une multitude de facteurs microscopiques : le moteur de rendu du navigateur, le système d'exploitation, et surtout la carte graphique (GPU) et ses pilotes. Les algorithmes d'anti-aliasing (le lissage des bords des formes) varient d'une puce graphique à l'autre. Deux ordinateurs apparemment identiques, achetés le même jour, peuvent produire des rendus Canvas infimement différents au niveau du pixel. Le tracker récupère cette signature, et vous êtes identifié avec une précision stupéfiante.

Le paradoxe du fingerprinting est qu'il punit ceux qui tentent de se protéger. Si vous utilisez un navigateur obscur, configuré avec des paramètres de sécurité rares et des extensions anti-pistage très spécifiques, vous vous démarquez. Dans la foule des internautes, vous êtes comme une personne avec des cheveux violets fluorescents. En voulant vous cacher, vous devenez l'individu le plus facilement identifiable de la base de données. C'est tout l'enjeu de la protection moderne : il ne faut pas seulement bloquer les trackers, il faut se fondre dans la masse en adoptant une empreinte numérique commune, partagée par des millions d'autres utilisateurs.

Les pixels espions et les balises web (web beacons)

Parmi les outils de l'arsenal de surveillance, les pixels espions sont les plus discrets. Littéralement. Il s'agit le plus souvent d'images d'un seul pixel sur un seul pixel, rendues totalement transparentes, insérées

© 2026 Oussama Ghorbel

dans le code HTML d'une page web ou, plus insidieusement encore, dans le corps d'un email.

Leur fonctionnement repose sur une règle de base du web : pour afficher une image, votre logiciel (navigateur ou client mail) doit faire une requête au serveur qui héberge cette image. Supposons que vous lisiez un article sur un blog. Le texte est hébergé sur le serveur du blogueur. Mais au bas de la page, le code HTML contient une ligne demandant à votre navigateur de charger `image-transparente.gif` depuis le serveur d'une entreprise d'analyse de données comme *DataCorp*.

Pour récupérer ce pixel invisible, votre navigateur contacte *DataCorp*. Dans cette requête, il transmet automatiquement votre adresse IP, l'heure exacte de la consultation, la page d'où provient la requête (le *referer*), et les éventuels cookies associés à *DataCorp*. Le blogueur n'a pas besoin de vous espionner lui-même ; il a simplement loué un espace invisible sur sa page à un tiers qui, lui, collecte la donnée.

C'est dans le domaine de l'emailing que les pixels espions (ou balises web) révèlent leur pouvoir le plus frustrant. Avez-vous déjà reçu un email d'un expéditeur inconnu, que vous n'avez jamais ouvert, pour recevoir ensuite une relance affirmant « Vous avez aimé notre dernier message » ? Ou avez-vous déjà ouvert une newsletter commerciale pour recevoir, deux heures plus tard, un appel téléphonique d'un commercial ?

Lorsque vous ouvrez un email contenant des images, votre client mail (Gmail, Outlook, Apple Mail) télécharge ces images depuis les serveurs de l'expéditeur. Le pixel espion est chargé. L'expéditeur sait alors instantanément trois choses :

1. L'email a été ouvert.
2. Il a été ouvert à telle heure précise (ce qui renseigne sur vos habitudes de sommeil ou de travail).
3. L'adresse IP de l'appareil qui l'a ouvert (ce qui permet de vous géolocaliser ou de faire le lien avec votre profil de navigation web si vous utilisez le même réseau Wi-Fi).

C'est ainsi que les marketeurs calculent le fameux « taux d'ouverture » de leurs campagnes. La seule parade radicale consiste à configurer son client mail pour qu'il ne télécharge *jamais* les images distantes par

© 2026 Oussama Ghorbel

défaut, et à ne les afficher que manuellement pour les expéditeurs de confiance.

Le cross-device tracking : comment on vous suit du mobile au PC

Un profil fantôme serait bien incomplet s'il se limitait à un seul écran. Notre quotidien est fragmenté : nous cherchons une idée de voyage sur notre smartphone dans les transports, nous comparons les prix sur notre tablette le soir devant la télévision, et nous finalisons l'achat sur notre ordinateur de bureau au travail. Pour les annonceurs, relier ces trois sessions à une seule et même personne est le Saint Graal. C'est ce qu'on appelle le *cross-device tracking* (pistage inter-appareils).

Il existe deux méthodes principales pour y parvenir : l'approche déterministe et l'approche probabiliste.

L'approche déterministe est la plus simple et la plus fiable. Elle repose sur l'identification formelle. Lorsque vous vous connectez à votre compte Google, Facebook, Amazon ou Apple sur votre téléphone, puis sur votre ordinateur, vous fournissez vous-même la clé qui relie vos appareils. Les géants du web (les *walled gardens* ou jardins clos) n'ont aucun besoin de deviner qui vous êtes ; vous le leur dites. Ils peuvent ainsi synchroniser votre historique de recherche mobile avec les publicités affichées sur votre ordinateur portable. C'est aussi pour cette raison que de nombreux sites de e-commerce ou médias vous incitent constamment à créer un compte ou à vous connecter via les boutons « Continuer avec Google/Facebook » : c'est le moyen le plus sûr d'ancrer votre profil fantôme à une identité persistante.

L'approche probabiliste, en revanche, relève de la magie noire des algorithmes et du *machine learning*. Elle est utilisée par les courtiers en données et les régies publicitaires qui n'ont pas la chance de posséder votre adresse email. Comment relier votre téléphone à votre PC sans que vous ne vous connectiez ? En observant les métadonnées de votre environnement.

Imaginez que le serveur d'un tracker reçoive des requêtes de deux appareils différents.

© 2026 Oussama Ghorbel

- L'appareil A (un smartphone) et l'appareil B (un ordinateur portable) partagent exactement la même adresse IP publique (celle de votre box internet à la maison).
- Ils se connectent aux mêmes heures (le soir entre 19h et 23h).
- Ils visitent des sites aux thématiques similaires.
- Ils utilisent le même fuseau horaire et la même langue.

L'algorithme va calculer une probabilité statistique. S'il y a 95 % de chances que ces deux appareils appartiennent au même foyer, et plus spécifiquement à la même personne, le tracker va fusionner les deux profils fantômes en un seul.

Cette technique va encore plus loin avec l'utilisation des réseaux Wi-Fi et du Bluetooth. Votre téléphone peut détecter les noms des réseaux Wi-Fi environnants (les SSID) et les balises Bluetooth (beacons) dans les magasins. Si votre téléphone et votre ordinateur portable rapportent tous les deux la présence des mêmes réseaux Wi-Fi voisins au même moment, la certitude de l'appareillage augmente. C'est ainsi que vous pouvez regarder une vidéo sur YouTube sur votre téléphone, et voir une publicité pour le produit mentionné s'afficher sur le site d'actualités que vous ouvrez sur votre PC cinq minutes plus tard. Le fantôme a unifié vos écrans.

Les identifiants publicitaires (IDFA et GAID)

Jusqu'à présent, nous avons surtout parlé du web. Mais une grande partie de notre temps d'écran se déroule à l'intérieur d'applications natives, où les cookies traditionnels n'ont pas cours. Pour permettre le pistage et l'attribution publicitaire dans l'écosystème mobile, Apple et Google ont intégré au cœur de leurs systèmes d'exploitation des identifiants uniques : l'**IDFA** (*Identifier for Advertisers*) sur iOS et le **GAID** (*Google Advertising ID*) sur Android.

Ces identifiants sont de longues chaînes de caractères alphanumériques, générées de manière unique pour chaque appareil. Contrairement à l'adresse MAC de votre carte réseau (qui est gravée dans le matériel et immuable), l'IDFA et le GAID ont été conçus pour être « réinitialisables » par l'utilisateur dans les paramètres du téléphone. L'idée, à l'origine, était de permettre à l'utilisateur de « changer d'identité

© 2026 Oussama Ghorbel

» publicitaire s'il se sentait trop ciblé, un peu comme on changerait de carte de fidélité.

Dans la pratique, cette réinitialisation était un leurre. D'abord parce que moins de 5 % des utilisateurs savaient que cette option existait. Ensuite, parce que les applications utilisaient des techniques de *fingerprinting* mobile (basées sur le modèle de l'appareil, la version de l'OS, l'espace de stockage disponible, la charge de la batterie) pour reconnaître que le « nouvel » appareil était en fait le même, et recréer le lien avec l'ancien profil fantôme.

Le véritable séisme a eu lieu en avril 2021, lorsque Apple a déployé sa fonctionnalité **ATT** (*App Tracking Transparency*) avec la mise à jour iOS 14.5. Soudainement, chaque application souhaitant accéder à l'IDFA devait afficher une fenêtre contextuelle (pop-up) demandant explicitement l'autorisation de l'utilisateur : « Autorisez-vous [Nom de l'App] à suivre votre activité dans les apps et les sites web d'autres entreprises ? ».

Le résultat fut sans appel : environ 80 % des utilisateurs ont cliqué sur « Demander à l'app de ne pas suivre ». Privées de l'IDFA, des plateformes comme Facebook (Meta) ont vu leur capacité à cibler et à mesurer l'efficacité des publicités s'effondrer sur les appareils Apple, ce qui a coûté des milliards de dollars de revenus à l'industrie.

Google, de son côté, a joué la montre. Son modèle économique reposant massivement sur la publicité ciblée, la firme de Mountain View a proposé une approche plus douce avec sa *Privacy Sandbox* sur Android, visant à remplacer l'identifiant unique par des systèmes de cohortes thématiques (regrouper les utilisateurs par centres d'intérêt plutôt que de les pister individuellement). Cependant, le déploiement de ces alternatives reste complexe, et l'industrie s'adapte en forçant les utilisateurs à se connecter (approche déterministe) ou en collectant massivement les données en « première partie » (first-party data) pour contourner les restrictions des systèmes d'exploitation.

L'illusion du mode « navigation privée »

Il est temps de s'attaquer à l'un des mythes les plus tenaces et les plus dangereux de la culture numérique grand public : le mode « navigation

© 2026 Oussama Ghorbel

privée » (ou *Incognito* sur Chrome, *InPrivate* sur Edge, *Navigation privée* sur Safari et Firefox).

Interrogez votre entourage, et la majorité vous dira que ce mode permet de « ne pas être tracké sur Internet » ou de « devenir anonyme ». C'est faux. Et cette méconnaissance est le terreau sur lequel prospère l'illusion de la confidentialité.

Pour comprendre ce que fait réellement ce mode, il faut revenir à son intention originelle. Le mode privé a été conçu au milieu des années 2000 pour résoudre un problème domestique et local : le partage d'ordinateur. Il s'agissait de permettre à un utilisateur d'acheter un cadeau de Noël sur l'ordinateur familial sans que l'historique de navigation ou les suggestions de saisie automatique ne trahissent la surprise aux autres membres de la famille qui utiliseraient le même PC plus tard.

Techniquement, lorsque vous ouvrez une fenêtre de navigation privée, votre navigateur crée une session temporaire, isolée. Il n'utilise pas les cookies déjà stockés sur votre disque dur. Pendant la session, il mémorise les nouveaux cookies et l'historique des pages visitées. Mais dès que vous fermez cette fenêtre, le navigateur procède à une amnésie locale totale : il efface l'historique, les cookies de session, le cache et les données de formulaires.

Ce que le mode privé fait :

• Il vous cache de votre conjoint, de vos enfants ou de votre colocataire qui aurait accès physique à votre machine.

• Il vous permet de vous connecter à un second compte sur un même site sans être déconnecté du premier.

• Il évite que vos recherches embarrassantes ou vos achats ne modifient les recommandations algorithmiques de votre compte principal (par exemple, chercher des alliances de mariage sans que YouTube ne vous propose des publicités de mariage pendant six mois).

Ce que le mode privé ne fait absolument pas :

• **Il ne vous rend pas anonyme sur le réseau.** Votre fournisseur d'accès à Internet (FAI), votre employeur (si vous êtes sur le réseau

© 2026 Oussama Ghorbel

de l'entreprise), et l'administrateur de votre box Wi-Fi voient parfaitement toutes les requêtes DNS et les adresses IP que vous contactez.

• **Il ne vous cache pas des sites web que vous visitez.** Votre adresse IP publique est toujours visible. Le site sait d'où vous venez, votre ville, et votre fournisseur d'accès.

• **Il ne bloque pas le fingerprinting.** Votre navigateur envoie toujours les mêmes en-têtes HTTP, possède la même résolution d'écran, les mêmes polices et la même carte graphique. Les trackers utilisant le Canvas ou le WebGL vous identifieront comme le même individu que celui qui navigue en mode normal.

• **Il ne vous protège pas des pixels espions** ni des scripts de télémétrie intégrés aux pages.

Se fier au mode navigation privée pour protéger sa vie numérique face aux courtiers en données, c'est comme fermer les rideaux de son salon en pensant que cela empêche les satellites de prendre des photos thermiques de la maison. C'est une mesure d'hygiène locale, pas un bouclier réseau. La vraie protection nécessite des outils qui agissent au niveau des requêtes réseau, du blocage de scripts et de la modification de l'empreinte du navigateur, ce que nous explorerons en détail dans la Partie 2 de ce livre.

Exercice pratique : Révéler votre fantôme

L'outil : Le projet *Cover Your Tracks* de l'Electronic Frontier Foundation (EFF), l'une des organisations de défense des droits numériques les plus respectées au monde.

La démarche :

1. Ouvrez votre navigateur habituel, celui que vous utilisez tous les jours (n'activez pas le mode privé pour cet exercice, nous voulons voir votre empreinte réelle).

2. Rendez-vous sur le site : **coveryourtracks.eff.org**

3. Cliquez sur le bouton **« Test your browser »**.

© 2026 Oussama Ghorbel

4. L'outil va simuler le chargement de plusieurs pages web contenant des trackers publicitaires connus et va analyser la signature unique de votre navigateur.

Comment interpréter les résultats :

• **Is your browser blocking tracking ads? / invisible beacons?** : Cela vous indique si votre navigateur (ou vos extensions actuelles) parvient à bloquer les requêtes vers les serveurs publicitaires connus. Si tout est vert, c'est un bon début.

• **Is your browser blocking third-party trackers?** : Vérifie si les cookies tiers sont effectivement rejetés.

• **Does your browser protect from fingerprinting?** : C'est le point le plus critique. L'EFF va vous attribuer un score d'unicité. Si le site vous annonce que votre navigateur a une empreinte « unique » ou « rare » parmi les millions de tests effectués, cela signifie que vous êtes facilement identifiable par le fingerprinting, même sans cookies.

Prenez un moment pour observer le détail de votre empreinte (cliquez sur « See detailed fingerprint information »). Vous verrez la liste vertigineuse des paramètres que votre navigateur crie au monde entier à chaque clic : votre en-tête User-Agent, votre fuseau horaire, votre résolution, vos plugins.

Cet exercice n'est pas là pour vous culpabiliser, mais pour matérialiser l'invisible. Votre profil fantôme n'est pas une abstraction ; il est composé de ces lignes de code, de ces métadonnées, de ces pixels transparents. Maintenant que vous connaissez l'anatomie de la bête, que vous savez comment elle vous flaire, vous suit et vous mémorise, nous sommes prêts à aborder l'étape suivante. Car une fois ce profil fantôme constitué, il ne sert pas seulement à vous vendre des chaussures. Il sert à modeler votre perception du monde.

Préparez-vous, dans le prochain chapitre, à plonger dans les algorithmes de l'influence.

© 2026 Oussama Ghorbel

Chapitre 3 – Les algorithmes de l'influence

Vous avez probablement déjà vécu cette expérience étrange : vous parlez d'un sujet précis avec un ami, un sujet de niche qui vous passionne ou vous inquiète, et vous décidez de faire une recherche rapide sur votre téléphone pour lui montrer un article. Mais au moment où vous ouvrez votre navigateur ou votre application d'actualités, la première page qui s'affiche ne ressemble en rien à ce que votre ami voit sur son propre écran. Les titres sont différents, l'angle est opposé, et les publicités qui bordent le contenu semblent cibler des anxiétés qui vous sont propres.

Ce n'est pas un hasard. Ce n'est pas non plus une simple personnalisation de confort. C'est la manifestation visible de la matrice de surveillance dans laquelle nous évoluons. Dans le chapitre précédent, nous avons disséqué l'anatomie de votre profil fantôme, cette somme colossale de données brutes accumulées à votre insu. Mais une base de données, aussi immense soit-elle, est inerte. Sa véritable valeur ne réside pas dans le stockage, mais dans l'action.

Ce chapitre est le cœur du réacteur de l'économie de l'attention. Nous allons décrypter comment les géants du numérique et les courtiers en données transforment votre profil fantôme en leviers d'influence. L'objectif n'est plus seulement de vous vendre une paire de chaussures, mais de modeler votre perception de la réalité, d'orienter vos opinions politiques, de dicter vos comportements d'achat et, in fine, de prédir et contrôler vos choix. Comprendre ces mécanismes est la condition sine qua non pour reprendre le contrôle de votre vie numérique.

La bulle de filtres et l'enfermement cognitif

En 2011, l'activiste internet Eli Pariser popularise un concept qui allait redéfinir notre compréhension du web moderne : la « bulle de filtres » (filter bubble). Dans son ouvrage éponyme, il explique que les algorithmes de personnalisation, conçus pour nous montrer ce que nous sommes « le plus susceptibles d'aimer », nous enferment en réalité dans une prison invisible de nos propres biais.

© 2026 Oussama Ghorbel

Il est crucial de distinguer la bulle de filtres de la « chambre d'écho » (echo chamber). La chambre d'écho est un phénomène sociologique : nous avons tendance à fréquenter des gens qui partagent nos opinions et à consommer des médias qui confirment nos croyances. C'est un choix, conscient ou non, guidé par notre biais de confirmation. La bulle de filtres, en revanche, est une architecture algorithmique. Elle vous est imposée de manière opaque, sans que vous ayez votre mot à dire sur les critères de tri. Vous n'avez pas choisi d'ignorer les opinions contradictoires ; c'est le code qui a décidé de ne plus vous les montrer, car elles génèrent statistiquement moins de clics de votre part.

Comment cette bulle se forme-t-elle ? Les plateformes utilisent principalement deux types de filtrage. Le premier est le *filtrage basé sur le contenu* : si vous regardez trois vidéos sur la permaculture, l'algorithme vous en proposera dix autres sur le même sujet. Le second, plus insidieux, est le *filtrage collaboratif* : l'algorithme vous associe à des milliers d'autres utilisateurs ayant un historique de clics similaire au vôtre, et vous injecte le contenu qu'ils ont consommé, même si vous n'avez jamais manifesté d'intérêt direct pour celui-ci.

L'enfermement cognitif qui en résulte est profond. À force de ne voir que des informations qui valident votre vision du monde, votre cerveau intègre l'idée que cette vision est la norme, voire la vérité absolue. C'est ce que les psychologues appellent l'effet de faux consensus. Vous commencez à surestimer le nombre de personnes partageant vos opinions et à sous-estimer la légitimité des points de vue adverses.

Prenons un exemple concret. Deux personnes effectuent la même recherche sur un événement géopolitique majeur. La première, dont l'historique montre une sensibilité écologiste et de gauche, recevra des articles de presse axés sur les conséquences humanitaires et environnementales du conflit, accompagnés de vidéos d'analyses critiques envers les grandes puissances industrielles. La seconde, dont le profil indique un intérêt pour la finance et des convictions conservatrices, verra des analyses sur les répercussions du conflit sur les marchés boursiers, l'approvisionnement énergétique et la nécessité de renforcer la sécurité nationale.

Aucune de ces deux personnes n'a conscience de ce que l'autre voit. Elles ont l'illusion de consulter le même internet, d'avoir accès à la

© 2026 Oussama Ghorbel

même information objective. En réalité, elles consultent deux réalités parallèles, sur mesure, optimisées pour maintenir leur engagement en ne heurtant jamais leurs convictions profondes. La bulle de filtres ne se contente pas de vous cacher le monde ; elle vous cache le fait qu'on vous cache le monde.

Le ciblage psychographique (l'exemple de Cambridge Analytica)

Si la bulle de filtres s'attaque à ce que vous voyez, le ciblage psychographique s'attaque à ce que vous êtes. Le marketing traditionnel segmente les populations par critères démographiques : âge, sexe, catégorie socio-professionnelle, lieu de résidence. Mais savoir qu'une femme de 35 ans habite à Lyon et gagne 3000 euros par mois ne dit rien de ses peurs, de ses motivations profondes ou de sa réactivité face à un message anxiogène.

C'est ici qu'intervient la psychométrie, et plus particulièrement le modèle des « Big Five » (ou modèle OCEAN), qui évalue la personnalité selon cinq grands traits :

1. **O**uverture à l'expérience (curiosité, créativité vs pragmatisme, routine).
2. **C**onscience (organisation, rigueur vs flexibilité, spontanéité).
3. **E**xtraversion (sociabilité, énergie vs introspection, calme).
4. **A**gréabilité (coopération, empathie vs défi, scepticisme).
5. **N**évrosisme (anxiété, vulnérabilité au stress vs stabilité émotionnelle).

Au début des années 2010, le chercheur Michal Kosinski a démontré qu'il était possible de déduire le profil OCEAN d'un individu en analysant simplement ses « J'aime » sur Facebook. Avec seulement 10 likes, l'algorithme pouvait évaluer votre personnalité mieux qu'un collègue de travail. Avec 70 likes, il vous connaissait mieux qu'un ami proche. Avec 300 likes, il vous connaissait mieux que votre conjoint.

C'est sur cette base scientifique que s'est construite la désormais tristement célèbre entreprise Cambridge Analytica. En 2014, via une application de quiz psychologique apparemment anodine, l'entreprise a

© 2026 Oussama Ghorbel

aspiré les données de dizaines de millions d'utilisateurs de Facebook (le chiffre de 87 millions a été avancé lors des auditions au Congrès américain). Mais le véritable coup de génie malveillant de Cambridge Analytica n'a pas été la collecte ; ça a été l'application de ces données.

L'entreprise a créé des milliers de variantes de messages publicitaires, notamment lors de campagnes électorales, pour cibler les vulnérabilités psychologiques spécifiques de chaque micro-segment de l'électorat.

- À l'électeur classé comme hautement « Névrosé » et craintif, on montrait des images sombres, des statistiques alarmantes sur la criminalité, et un candidat se posant en rempart protecteur.
- À l'électeur classé comme très « Consciencieux » et attaché à l'ordre, on vantait les valeurs traditionnelles, la famille et la rigueur budgétaire.
- À l'électeur « Ouvert » et rebelle, on proposait un message de rupture, de progrès et de changement radical.

Le scandale de Cambridge Analytica a éclaté en 2018, provoquant une onde de choc mondiale. L'entreprise a fait faillite, ses dirigeants ont été poursuivis, et Facebook a écopé d'une amende record. Il serait cependant dangereux de croire que le problème a été résolu. Cambridge Analytica n'était qu'un symptôme, un acteur particulièrement maladroit et médiatisé d'un écosystème qui, lui, est toujours florissant.

Aujourd'hui, le ciblage psychographique est la norme dans l'industrie de la publicité programmatique. Les courtiers en données (data brokers) agrègent vos achats en ligne, vos déplacements géolocalisés, vos recherches de santé et vos habitudes de sommeil pour créer des segments ultra-précis : « Mères célibataires anxieuses pour l'avenir financier de leurs enfants », « Hommes d'âge mûr frustrés par leur carrière et nostalgiques de leur jeunesse », « Jeunes adultes impulsifs sensibles aux tendances de mode ».

Soyez particulièrement vigilant dans le domaine de l'investissement, où les plateformes de trading et les promoteurs de cryptomonnaies utilisent massivement ces techniques pour cibler les profils impulsifs avec des promesses de rendements irréalistes.

© 2026 Oussama Ghorbel

Le ciblage psychographique transforme la publicité en une arme de manipulation asymétrique. Celui qui diffuse le message connaît vos failles psychologiques ; vous, vous ne voyez qu'une bannière inoffensive qui, par un étrange hasard, appuie exactement là où ça fait mal.

L'optimisation de l'engagement par l'indignation

Pourquoi, malgré notre désir de nous informer et de nous divertir, finissons-nous si souvent épuisés, énervés ou anxieux après une heure de défilement sur nos réseaux sociaux ? La réponse réside dans la métrique reine qui gouverne l'architecture des plateformes : l'engagement.

Dans l'économie de l'attention, votre temps de cerveau disponible est la marchandise. Comme le disait le prix Nobel d'économie Herbert Simon : « Ce que l'information consomme, c'est l'attention de ses destinataires. » Pour maximiser les revenus publicitaires, les algorithmes doivent vous garder sur la plateforme le plus longtemps possible. Mais comment capter et retenir l'attention humaine dans un environnement saturé de stimuli ? La neuroscience nous donne la réponse : par l'émotion, et plus spécifiquement par les émotions à forte activation (high-arousal emotions).

La joie, la tristesse ou la sérénité sont des émotions à faible activation ; elles incitent à la contemplation ou au repos. La colère, l'indignation morale et la peur, en revanche, sont des émotions à très forte activation. Elles préparent le corps à l'action (le fameux *fight or flight*), accélèrent le rythme cardiaque et focalisent l'esprit.

Les ingénieurs des plateformes l'ont compris très tôt. Les algorithmes de recommandation, basés sur l'apprentissage automatique (machine learning), n'ont pas de morale. Leur seule fonction objectif est d'optimiser le temps passé et les interactions (likes, commentaires, partages). En testant des millions de combinaisons, l'algorithme a découvert par lui-même une vérité implacable : le contenu qui génère le plus d'engagement est celui qui suscite l'indignation.

Une étude menée par des chercheurs de l'Université de New York a démontré que chaque mot « moral-émotionnel » (comme « honte », « blâmer », « détruire », « trahir ») ajouté à un tweet augmentait sa probabilité d'être partagé de 20 %. L'indignation morale est le carburant

© 2026 Oussama Ghorbel

le plus pur de la viralité.

Conséquence directe : les algorithmes amplifient structurellement les contenus clivants, extrémistes, faux ou exagérés. Un article nuancé, équilibré et factuel sur un sujet de société complexe générera peu de réactions. À l'inverse, une vidéo montrant un individu (réel ou mis en scène) tenant des propos outranciers, ou un titre d'article volontairement trompeur conçu pour provoquer la colère d'un camp politique, sera propulsé au sommet des fils d'actualité.

Ce mécanisme a des conséquences désastreuses sur le tissu social. Il crée une illusion de polarisation extrême. Les voix modérées, qui représentent la majorité silencieuse, sont étouffées car elles ne génèrent pas d'indignation. Seuls les extrêmes, les provocateurs et les algorithmes de désinformation occupent l'espace médiatique. Nous finissons par croire que le monde est beaucoup plus hostile, divisé et en colère qu'il ne l'est en réalité.

De plus, l'exposition chronique à l'indignation algorithmique épuise nos ressources cognitives. Le *doomscrolling* (le défilement compulsif de mauvaises nouvelles) n'est pas un manque de volonté de votre part ; c'est le résultat d'un système conçu pour pirater votre amygdale, le centre de la peur et de la détection des menaces dans votre cerveau. L'algorithme vous maintient dans un état d'alerte permanent, vous donnant l'illusion que vous devez rester informé pour vous protéger, alors qu'il ne fait que vous nourrir de poison émotionnel pour vendre votre attention au plus offrant.

Les dark patterns : quand l'interface vous manipule

Si les algorithmes manipulent le contenu que vous consommez, les *dark patterns* (ou interfaces truquées) manipulent la manière dont vous interagissez avec le service. Le terme a été inventé en 2010 par le spécialiste de l'expérience utilisateur (UX) Harry Brignull pour désigner des choix de design délibérément conçus pour tromper l'utilisateur, le pousser à faire quelque chose qu'il n'avait pas l'intention de faire, ou l'empêcher de faire ce qu'il souhaitait.

Le design d'interface n'est pas neutre. Chaque bouton, chaque couleur, chaque texte est le résultat d'une intention. Dans une éthique de

© 2026 Oussama Ghorbel

design centrée sur l'utilisateur, l'interface vise à faciliter la tâche de ce dernier. Dans le cas des dark patterns, l'interface est une arme au service des intérêts de l'entreprise, souvent au détriment direct de l'utilisateur.

Voici les architectures de manipulation les plus courantes que vous croisez quotidiennement :

1. Le Roach Motel (Le motel à cafards)

Le principe est simple : on y entre très facilement, mais il est presque impossible d'en sortir. C'est la technique reine des abonnements. S'abonner à un service de streaming ou à une box de produits se fait en un clic, avec un bouton vert proéminent « Commencer l'essai gratuit ». En revanche, pour résilier, vous devrez naviguer dans cinq sous-menus obscurs, appeler un numéro de téléphone disponible uniquement aux heures de bureau, ou envoyer un courrier recommandé. L'objectif est d'exploiter la friction et la procrastination pour conserver des clients qui ne souhaitent plus payer.

2. Le Confirmshaming (Le shaming de confirmation)

Cette technique utilise la culpabilité pour vous dissuader de refuser une offre. Au lieu d'un simple bouton « Non merci », l'interface vous propose un choix biaisé. Par exemple, une pop-up vous propose de vous inscrire à une newsletter pour sauver la planète. Les deux boutons sont : « Oui, je veux sauver la planète » et « Non, je préfère ignorer l'environnement ». En refusant, l'interface vous force à endosser une identité négative. C'est une manipulation émotionnelle pure, très courante dans les formulaires de désinscription ou les refus de cookies.

3. Les coûts cachés et le Drip Pricing

Vous ajoutez un billet d'avion ou une place de concert à votre panier. Le prix affiché est attractif. Mais au moment du paiement final, après que vous avez déjà investi du temps à remplir vos informations personnelles (ce qui crée un biais d'engagement), des frais s'ajoutent goutte à goutte : frais de dossier, frais de service, assurance optionnelle pré-cochée, taxes locales. Le prix final est souvent 20 à 30 % supérieur au prix initial, mais la friction pour annuler et recommencer ailleurs est devenue trop grande dans votre esprit.

4. La fausse urgence et la fausse rareté

© 2026 Oussama Ghorbel

« Plus que 2 chambres disponibles à ce prix ! » ou « 14 personnes regardent cet article en ce moment ». Ces mentions, omniprésentes sur les sites de voyage et d'e-commerce, sont très souvent générées aléatoirement par des scripts. Elles exploitent le biais de rareté et la peur de manquer une opportunité (FOMO) pour court-circuiter votre réflexion rationnelle et vous forcer à un achat impulsif.

5. La misdirection (Détournement d'attention)

C'est l'art de diriger votre regard loin de l'information importante. Lors de l'installation d'un logiciel gratuit, la case « Accepter d'installer un logiciel tiers indésirable » est pré-cochée, mise en gras et en couleur, tandis que le bouton « Installation personnalisée » (qui permet de la décocher) est grisé, minuscule et relégué en bas à gauche. De même, les bannières de cookies sont conçues avec un bouton « Tout accepter » immense et coloré, tandis que « Paramétrer mes choix » nécessite trois clics supplémentaires dans une fenêtre modale illisible.

Ces dark patterns ne sont pas de simples maladresses de design. Ce sont des stratégies A/B testées des millions de fois, validées par des données prouvant qu'elles augmentent le taux de conversion de quelques pourcents. À l'échelle de millions d'utilisateurs, ces pourcents représentent des milliards de dollars de revenus. Reconnaître ces interfaces truquées est la première étape pour désamorcer leur emprise sur vos décisions.

Comment briser ses propres boucles de rétroaction

Face à la puissance de calcul des serveurs de la Silicon Valley et aux milliards investis dans l'ingénierie comportementale, il est facile de se sentir impuissant. Pourtant, vous n'êtes pas sans défense. Les algorithmes ont besoin de votre coopération passive pour fonctionner. En modifiant vos habitudes numériques, vous pouvez introduire du bruit dans la matrice, dégrader la qualité de votre profil fantôme et reprendre le contrôle de votre environnement informationnel.

Voici un plan d'action concret pour briser vos boucles de rétroaction algorithmiques :

1. Pratiquez l'empoisonnement de données (Data Poisoning)

© 2026 Oussama Ghorbel

Puisque vous ne pouvez pas empêcher totalement la collecte, vous pouvez la corrompre. L'objectif est de rendre votre profil fantôme si confus et contradictoire que les algorithmes renoncent à vous catégoriser précisément.

• Utilisez des extensions comme *TrackMeNot* ou *AdNauseam* qui génèrent des requêtes de recherche aléatoires en arrière-plan ou cliquent automatiquement sur toutes les publicités d'une page, noyant vos véritables intérêts sous un déluge de faux positifs.

• Diversifiez volontairement vos consommations. Si vous êtes passionné d'histoire, allez regarder des tutoriels de maquillage, des vidéos de mécanique agricole ou des documentaires sur la pêche sous-marine. Forcez l'algorithme à élargir votre bulle.

2. Privilégiez les flux chronologiques et les abonnements directs

L'algorithme de recommandation est un intermédiaire dont vous n'avez pas besoin.

• Sur les réseaux sociaux (X/Twitter, Instagram, Facebook), cherchez dans les paramètres l'option pour basculer sur le fil chronologique (« Following » ou « Abonnements ») plutôt que le fil « Pour vous » ou « À la une ». Vous ne verrez que ce que vous avez explicitement choisi de suivre, dans l'ordre de publication.

• Pour l'actualité et les blogs, revenez aux fondamentaux : utilisez un lecteur RSS (comme Feedly ou NetNewsWire). C'est vous qui choisissez les sources, c'est vous qui décidez quand les lire. Il n'y a pas d'algorithme de tri, pas de mise en avant par l'indignation, pas de lecture automatique de la vidéo suivante.

3. Adoptez la recherche active contre la consommation passive

L'algorithme se nourrit de votre passivité. Quand vous ouvrez YouTube et que vous cliquez sur la première vidéo suggérée en page d'accueil, vous renforcez la bulle.

• Prenez l'habitude de taper vos requêtes dans la barre de recherche.

• Ne laissez jamais les vidéos se lancer automatiquement (désactivez l'option *Autoplay* sur toutes les plateformes). Le choix de continuer à regarder doit être une action consciente, nécessitant un clic, et non

© 2026 Oussama Ghorbel

une conséquence par défaut.

4. Purgez régulièrement votre historique et vos identifiants

Les plateformes utilisent votre historique pour affiner leurs prédictions.

• Sur YouTube, allez dans les paramètres de votre compte et mettez en pause l'historique des recherches et l'historique des vidéos regardées. Pensez à supprimer l'historique existant de temps en temps pour forcer l'algorithme à repartir de zéro.

• Sur vos appareils mobiles, réinitialisez régulièrement votre identifiant publicitaire (IDFA sur iOS, AAID sur Android). Cela coupe le lien entre votre comportement passé et les publicités qui vous sont servies aujourd'hui.

5. Cultivez la frugalité attentionnelle

La meilleure défense contre l'optimisation de l'indignation est de refuser de jouer le jeu. Quand vous sentez la colère monter en lisant un titre ou en voyant une vidéo, reconnaissez le signal : c'est le signe que vous êtes manipulé. Fermez l'onglet. Ne commentez pas, même pour contredire. Ne partagez pas, même pour dénoncer. Aux yeux de l'algorithme, votre indignation est un engagement valide qui mérite d'être récompensé par plus de contenu similaire. Le silence et le départ sont vos armes les plus puissantes.

Exercice pratique : Le test du miroir numérique

Pour prendre conscience de l'ampleur de votre bulle de filtres et de la personnalisation de votre réalité numérique, je vous propose une expérience simple mais révélatrice. Vous aurez besoin de votre ordinateur ou de votre smartphone, et d'un peu de temps.

Étape 1 : L'observation de votre réalité personnalisée

1. Connectez-vous à votre compte principal sur YouTube et sur votre moteur de recherche habituel (Google, Bing, etc.).

2. Sur YouTube, notez les 5 premières vidéos qui vous sont recommandées sur la page d'accueil. Regardez les thèmes, les

© 2026 Oussama Ghorbel

émotions véhiculées par les miniatures, les titres.

3. Sur votre moteur de recherche, tapez un mot-clé générique mais sujet à interprétation (par exemple : « climat », « immigration », « investissement immobilier » ou « régime alimentaire »). Notez les 3 premiers résultats organiques (hors publicité) et le type de suggestions automatiques qui apparaissent quand vous tapez.

Étape 2 : L'observation de la réalité neutre

1. Ouvrez une fenêtre de navigation totalement isolée. N'utilisez pas seulement la navigation privée de votre navigateur habituel (qui peut conserver certaines empreintes). L'idéal est d'utiliser le navigateur **Tor**, ou à défaut, un navigateur comme **Brave** ou **Firefox** en mode navigation privée, avec toutes les protections contre le pistage activées, et sans vous connecter à aucun compte.

2. Allez sur YouTube (sans vous connecter). Notez les 5 premières vidéos recommandées.

3. Allez sur le même moteur de recherche, tapez exactement les mêmes mots-clés qu'à l'étape 1. Notez les résultats et les suggestions.

Étape 3 : L'analyse

Comparez les deux séries de résultats. Vous serez probablement stupéfait par les différences. La session anonyme vous montrera un internet « par défaut », souvent plus générique, parfois plus consensuel, ou basé sur la popularité globale. Votre session connectée, en revanche, est un miroir déformant de vos anxiétés, de vos biais et de vos habitudes passées, soigneusement assemblé pour maximiser votre temps d'écran.

Gardez les résultats de cet exercice en tête. La prochaine fois que vous penserez que « tout le monde parle de ce sujet » ou que « la vérité est évidente » en regardant votre fil d'actualité, souvenez-vous que vous ne regardez pas le monde. Vous regardez le reflet algorithmique de votre propre profil fantôme. Et il est grand temps de briser ce miroir.

Dans le chapitre suivant, nous allons passer de la théorie à la pratique en réalisant l'audit complet de votre exposition numérique actuelle, afin d'identifier précisément les brèches par lesquelles vos données s'échappent.

© 2026 Oussama Ghorbel

Chapitre 4 – L'audit de votre exposition numérique

« Dire que vous ne vous souciez pas du droit à la vie privée parce que vous n'avez rien à cacher, c'est comme dire que vous ne vous souciez pas de la liberté d'expression parce que vous n'avez rien à dire. » Cette phrase, souvent attribuée au lanceur d'alerte Edward Snowden, résume à elle seule l'impasse dans laquelle nous nous trouvons face à la surveillance de masse. Vous n'avez peut-être rien à cacher, mais vous avez incontestablement quelque chose à protéger : votre autonomie, votre tranquillité d'esprit, et l'intégrité de votre identité.

Avant de plonger dans les configurations techniques, les extensions de navigateur et les systèmes d'exploitation alternatifs qui constitueront votre bouclier numérique, il est impératif de faire un état des lieux. On ne rénove pas une maison sans l'ausculter d'abord ; on ne soigne pas un patient sans poser de diagnostic. Ce chapitre est votre salle d'examen. Nous allons ensemble évaluer l'étendue réelle, souvent vertigineuse, de votre empreinte numérique actuelle.

L'objectif n'est pas de vous culpabiliser ni de vous noyer sous l'anxiété. Il s'agit de passer du déni à la lucidité. En cartographiant votre exposition, vous allez identifier les brèches les plus critiques dans votre forteresse personnelle. Préparez-vous à découvrir votre double numérique, ce profil fantôme qui vit, respire et consomme sur les serveurs du monde entier, souvent à votre insu.

L'ego-surveillance : se googler intelligemment

L'ego-surfing, ou l'acte de se rechercher soi-même sur internet, est souvent perçu comme une pratique narcissique. Dans le cadre de la frugalité numérique et de la protection de la vie privée, c'est au contraire un exercice de salubrité publique personnelle. C'est ce que les professionnels du renseignement en sources ouvertes (OSINT) appellent l'ego-surveillance.

Pour que cet audit soit pertinent, vous devez abandonner vos habitudes de recherche classiques. Si vous tapez simplement votre nom

© 2026 Oussama Ghorbel

dans votre navigateur habituel, les algorithmes vous renverront des résultats personnalisés, filtrés par votre historique, votre localisation et vos préférences. Vous ne verrez pas ce qu'un inconnu, un recruteur, un courtier en données ou un harceleur voit.

La méthode de l'investigation en sources ouvertes :

1. **Le mode navigation privée :** Ouvrez toujours une fenêtre de navigation privée (ou utilisez un navigateur axé sur la confidentialité comme Brave ou Firefox, sans être connecté à vos comptes). Cela neutralise les bulles de filtres et les cookies de personnalisation.

2. **Les opérateurs de recherche avancés :** Ne vous contentez pas de taper `Prénom Nom`. Utilisez les guillemets pour forcer l'expression exacte : `"Prénom Nom"`.

3. **Les recoupements croisés :** Affinez vos recherches en ajoutant des mots-clés contextuels. Essayez `"Prénom Nom" + "Ville"`, `"Prénom Nom" + "Profession"`, ou `"Prénom Nom" + "@votrefournisseurmail.com"`.

4. **L'exploration des réseaux sociaux et forums :** Utilisez la commande `site:` pour chercher votre nom à l'intérieur de plateformes spécifiques. Par exemple, `site:linkedin.com "Prénom Nom"` ou `site:reddit.com "Prénom Nom"`. Vous pourriez être surpris de retrouver des commentaires vieux de dix ans sur des forums obscurs, indexés et accessibles à tous.

5. **La recherche inversée d'images :** Prenez votre photo de profil principale (celle que vous utilisez sur LinkedIn ou WhatsApp) et soumettez-la à des moteurs de recherche inversée comme TinEye, Yandex Images ou Google Images. Vous découvrirez peut-être que votre visage est associé à des bases de données publiques, des annuaires d'entreprises, ou pire, qu'il a été aspiré par des systèmes de reconnaissance faciale.

L'ego-surveillance vous confronte à votre « ombre numérique ». Notez précieusement chaque URL, chaque base de données et chaque forum où votre identité apparaît. Ce seront vos premières cibles pour les demandes de droit à l'oubli, un levier puissant que nous détaillerons dans le chapitre dédié au RGPD.

© 2026 Oussama Ghorbel

Vérifier les fuites de mots de passe (Have I Been Pwned)

Dans la matrice de la surveillance et du capitalisme de données, les fuites de données (data breaches) ne sont pas des accidents isolés ; elles sont une certitude statistique. La question n'est pas de savoir *si* vos données ont été compromises, mais *quand*, *combien de fois*, et *quelles informations* précisément ont été exposées.

Pour auditer cette facette de votre exposition, l'outil de référence absolue est **Have I Been Pwned** (HIBP), créé par l'expert en sécurité Troy Hunt. Ce service agrège des milliards de comptes compromis issus de piratages de bases de données (Adobe, LinkedIn, Dropbox, et des milliers d'autres services moins connus).

Comment fonctionne l'audit sur HIBP ?

Rendez-vous sur le site et entrez votre adresse email principale, puis vos adresses secondaires. Le moteur de recherche va croiser votre identifiant avec sa base de données de fuites. Si votre email apparaît, la page listera les incidents (les "Pwns") avec la date de la fuite, le type de données compromises (mots de passe, dates de naissance, numéros de téléphone, adresses physiques) et la source.

Le danger du "Credential Stuffing" (bourrage d'identifiants) :

Si vous découvrez que votre mot de passe a fui lors du piratage d'un obscur site de e-commerce en 2018, vous pourriez vous dire : « Ce n'est pas grave, je n'utilise plus ce site. » C'est une erreur fatale. Les cybercriminels achètent ces bases de données sur le dark web et utilisent des bots pour tester automatiquement ces combinaisons email/mot de passe sur des milliers de services critiques (banques, boîtes mail, réseaux sociaux). C'est le bourrage d'identifiants. Si vous avez eu la mauvaise habitude de réutiliser ce mot de passe (ou une variante proche comme `Motdepasse2018!`), votre forteresse est déjà tombée.

Que faire face à ce constat ?

1. **Ne paniquez pas, mais agissez immédiatement.**
2. Pour chaque fuite listée, identifiez le mot de passe que vous utilisiez à l'époque.

© 2026 Oussama Ghorbel

3. Si vous avez réutilisé ce mot de passe sur d'autres services actifs, changez-le sur-le-champ pour un mot de passe unique et complexe.

4. Inscrivez-vous à la fonction "Notify me" de HIBP pour recevoir une alerte immédiate si votre email apparaît dans une future fuite.

5. Vérifiez également la section "Passwords" du site, qui vous permet de vérifier si un mot de passe spécifique (sans taper votre email) a déjà été compromis, grâce à une technique cryptographique appelée k-anonymité qui garantit que votre mot de passe n'est jamais transmis en clair au serveur de Troy Hunt.

Cet audit est souvent un électrochoc. Il transforme la menace abstraite du "piratage" en une réalité tangible et documentée, vous préparant psychologiquement à adopter un gestionnaire de mots de passe, outil indispensable que nous aborderons dans la Partie 3.

Auditer les connexions OAuth (Se connecter avec Google/Facebook)

Nous avons tous cédé à cette facilité. Vous découvrez une nouvelle application, un site d'actualités, ou un jeu mobile. Au moment de créer un compte, on vous propose deux options : remplir un long formulaire avec votre email et inventer un nouveau mot de passe, ou cliquer sur le bouton magique « Se connecter avec Google » (ou Facebook, Apple, X).

Ce mécanisme s'appelle **OAuth**. Techniquement, c'est une merveille de fluidité. OAuth permet à une application tierce d'accéder à certaines de vos données sans que vous ayez à lui confier votre mot de passe principal. Mais en termes de confidentialité, c'est souvent un cheval de Troie.

Le coût caché de la facilité :

Lorsque vous cliquez sur ce bouton, vous ne faites pas que vous authentifier ; vous *autorisez*. Une fenêtre pop-up s'affiche, listant les permissions que l'application demande. Dans la précipitation, nous cliquons sur "Accepter" sans lire. Pourtant, certaines applications demandent l'accès en lecture à vos emails, le droit de voir votre liste de contacts, la permission de publier en votre nom, ou l'accès à votre localisation en arrière-plan.

© 2026 Oussama Ghorbel

Pire encore, ces connexions OAuth créent un lien permanent. Même si vous désinstallez l'application de votre téléphone ou ne visitez plus le site web, le "token" d'autorisation reste actif sur les serveurs de Google ou de Meta. L'application tierce peut continuer à aspirer vos métadonnées, à profiler vos habitudes et à nourrir son propre algorithme, tout en restant invisiblement accrochée à votre identité principale.

L'audit de vos autorisations tierces :

Il est temps de couper les tentacules. Voici comment auditer et révoquer ces connexions fantômes :

• **Sur Google :** Rendez-vous sur `myaccount.google.com`. Allez dans l'onglet **Sécurité**, puis cherchez la section **Vos connexions aux applis et services tierces** (ou "Applications tierces ayant accès à votre compte"). Vous y trouverez la liste exhaustive de tous les services connectés. Cliquez sur chacun d'eux pour voir les permissions exactes. Révoquez impitoyablement tout ce que vous n'utilisez plus, ou tout service qui demande des accès disproportionnés (un jeu de puzzle n'a pas besoin d'accéder à votre Google Drive).

• **Sur Facebook / Meta :** Allez dans les **Paramètres et confidentialité** > **Paramètres** > **Applications et sites web**. Vous verrez trois catégories : Actives, Expirées et Supprimées. Nettoyez la liste des applications actives.

• **Sur Apple (iOS) :** Allez dans **Réglages** > **[Votre Nom]** > **Connexion et sécurité** > **Connexion avec Apple**. Ici, vous pouvez masquer votre email (grâce à la fonction "Relais privé" d'Apple qui génère des alias) ou révoquer l'accès.

• **Sur X (Twitter) et LinkedIn :** Les menus de sécurité de ces plateformes contiennent également des sections dédiées aux "Applications et sessions" qu'il faut auditer régulièrement.

En révoquant ces accès, vous fermez des vannes de données que vous aviez vous-même ouvertes. C'est une étape cruciale pour reprendre le contrôle de votre identité en ligne et limiter la surface d'attaque de votre profil.

Lister ses abonnements et comptes oubliés

© 2026 Oussama Ghorbel

Notre vie numérique ressemble souvent à un grenier encombré. Au fil des années, nous accumulons des comptes sur des forums, des sites de e-commerce éphémères, des applications de productivité abandonnées, des newsletters que nous ne lisons plus, et des services SaaS (Software as a Service) dont les prélèvements automatiques continuent de ponctionner notre compte bancaire.

Ce cimetière numérique n'est pas seulement un problème de frugalité financière ; c'est une faille de sécurité béante. Les courtiers en données (data brokers) adorent ces vieux comptes. Ils agrègent ces informations pour enrichir votre profil fantôme. De plus, ces "zombies" numériques sont souvent hébergés sur des serveurs mal entretenus, non mis à jour, et constituent des cibles faciles pour les pirates. Si vous y avez laissé une adresse email et un mot de passe (même partiellement réutilisé), c'est une porte dérobée vers votre vie actuelle.

La méthode de l'archéologie de la boîte mail :

Votre boîte de réception est le registre fossile de votre vie numérique. Ouvrez votre client mail et utilisez la barre de recherche avec des mots-clés spécifiques pour exhumer vos inscriptions passées. Tapez des requêtes comme :

- `"Confirmez votre compte"`
- `"Bienvenue sur"` ou `"Welcome to"`
- `"Vérifiez votre adresse email"`
- `"Abonnement"` ou `"Newsletter"`
- `"Votre commande"`

L'audit des prélèvements bancaires :

Téléchargez vos relevés bancaires des douze derniers mois. Recherchez les abonnements récurrents. Vous pourriez découvrir que vous payez toujours pour ce service de stockage cloud que vous n'utilisez plus, ou pour cette application de méditation téléchargée il y a trois ans. En plus d'assainir vos finances, annuler ces services vous obligera à fermer les comptes associés, réduisant ainsi votre empreinte.

La stratégie de suppression (Le droit à l'effacement) :

© 2026 Oussama Ghorbel

Listez tous ces comptes sur un fichier texte. Pour chacun d'eux, connectez-vous une dernière fois. Ne vous contentez pas de vider le compte ou de désinstaller l'application. Cherchez le paramètre de **suppression définitive du compte** (souvent caché dans les tréfonds des menus "Confidentialité" ou "Sécurité").

Si le site ne propose pas de bouton de suppression, c'est là que votre connaissance du RGPD (pour les services européens) ou des lois locales sur la protection des données (comme la CCPA en Californie) devient votre meilleure arme. Envoyez un email formel au DPO (Délégué à la protection des données) de l'entreprise pour exiger l'effacement total de vos données personnelles de leurs serveurs et de leurs bases de données de sauvegarde. Des annuaires en ligne, comme le projet collaboratif *JustDelete.me*, peuvent vous aider à trouver les liens directs de suppression et à évaluer la difficulté de la procédure pour des milliers de services populaires.

Évaluer l'exposition de ses proches et de ses enfants

Votre audit ne peut s'arrêter à votre propre personne. Dans l'écosystème interconnecté qui est le nôtre, la faiblesse d'un maillon compromet toute la chaîne. Votre empreinte numérique inclut également les données que vous avez générées, partagées ou exposées concernant votre entourage.

Le phénomène du "Sharenting" :

Ce terme, contraction de *sharing* (partage) et *parenting* (parentalité), désigne l'habitude des parents de documenter massivement la vie de leurs enfants sur les réseaux sociaux. Avant même qu'un enfant n'ait l'âge de tenir un smartphone, son profil fantôme est déjà riche de milliers de données : sa date de naissance exacte, le nom de son école, ses hobbies, ses problèmes de santé, et des centaines de photos de son visage en haute résolution.

Ces données sont aspirées par les algorithmes de reconnaissance faciale et peuvent être utilisées pour alimenter des modèles d'IA, ou pire, détournées par des prédateurs. L'audit familial implique de revoir vos propres publications. Supprimez ou privez l'accès aux photos de vos enfants. Ne publiez jamais d'images d'eux en uniforme scolaire, devant

© 2026 Oussama Ghorbel

votre domicile, ou dans des situations d'intimité. Respectez leur futur droit à l'autodétermination numérique.

La vulnérabilité des aînés :

Nos parents et grands-parents sont souvent les cibles privilégiées des ingénieries sociales et des arnaques téléphoniques. Les escrocs utilisent les données publiques (avis de décès, arbres généalogiques en ligne, publications Facebook publiques où vous les identifiez) pour monter des scénarios d'arnaque ultra-personnalisés (le fameux "faux enlèvement" ou l'appel du "faux petit-fils en détresse").

Auditez l'exposition de vos aînés : leurs numéros de téléphone sont-ils en libre accès sur des annuaires inversés ? Leurs profils sociaux sont-ils verrouillés ? Prenez le temps de configurer leurs appareils avec eux, en activant les filtres anti-spam et en verrouillant leurs paramètres de confidentialité.

L'audit des adolescents (avec consentement) :

Si vous avez des adolescents, l'audit de leurs appareils ne doit pas être une fouille policière, mais un exercice pédagogique partagé. Asseyez-vous avec eux et montrez-leur comment vérifier les permissions de leurs applications (TikTok, Snapchat, Instagram). Expliquez-leur comment les algorithmes de recommandation fonctionnent et comment leurs "likes" construisent une prison psychologique. L'objectif est de les rendre acteurs de leur propre hygiène numérique, en transformant l'audit en un rituel de responsabilisation plutôt qu'en une mesure de contrôle parental autoritaire.

Créer son tableau de bord de risque personnel

À ce stade du chapitre, vous avez probablement accumulé une quantité vertigineuse d'informations : des liens OSINT, des alertes de fuites HIBP, une liste d'applications OAuth à révoquer, et un cimetière de comptes à supprimer. Pour ne pas être paralysé par l'ampleur de la tâche, vous devez structurer ces données dans un **tableau de bord de risque personnel**.

Imaginez que vous soyez un médecin aux urgences. Vous devez pratiquer le triage : identifier les blessés critiques qui nécessitent une

© 2026 Oussama Ghorbel

intervention immédiate, et ceux qui peuvent attendre. Votre tableau de bord servira à cela.

Ouvrez un tableur (Excel, LibreOffice, ou un tableau Notion) et créez les colonnes suivantes :

1. **Service / Plateforme** (ex: Gmail, Banque X, Forum Y)
2. **Email associé** (votre email principal ou un alias ?)
3. **Statut du mot de passe** (Unique et complexe / Réutilisé / Compromis)
4. **Authentification à deux facteurs (2FA)** (Activée / Désactivée)
5. **Données sensibles exposées** (ex: Carte bancaire, géolocalisation, contacts)
6. **Niveau de priorité** (Critique / Élevé / Moyen / Faible)
7. **Action requise** (ex: Changer MDP, Activer 2FA, Supprimer le compte)

La règle des "Joyaux de la Couronne" :

Dans votre tableau de bord, identifiez vos "Joyaux". Ce sont les comptes qui, s'ils étaient compromis, donneraient les clés de tout votre royaume numérique. En général, il s'agit de :

• Votre adresse email principale (la clé de réinitialisation de tous vos autres comptes).

• Votre gestionnaire de mots de passe.

• Vos comptes bancaires et financiers.

• Votre identifiant Apple ou Google (qui contrôle la géolocalisation et la sauvegarde de votre téléphone).

Ces Joyaux doivent être classés en priorité **Critique**. Ils nécessitent des mots de passe de plus de 20 caractères, générés aléatoirement, et une authentification à deux facteurs basée sur une clé physique (comme une YubiKey) ou une application d'authentification (comme Raivo ou Aegis), et surtout *jamais* par SMS.

Une fois vos Joyaux sécurisés, vous pourrez vous attaquer, à votre rythme, aux priorités Élevées (réseaux sociaux, e-commerce) puis Moyennes (forums, newsletters). Ce tableau de bord n'est pas figé ; c'est

© 2026 Oussama Ghorbel

un document vivant qui évoluera au fil de votre apprentissage et de l'adoption des outils que nous découvrirons dans les chapitres suivants.

Note importante : Vous pourriez être tenté, face à l'ampleur de la tâche, de vous tourner vers des services payants promettant de "nettoyer votre vie numérique" ou de "supprimer vos données du web" en échange d'un abonnement mensuel onéreux. Soyez prudent. Bien que certains de ces services (les data brokers removal services) puissent faire gagner du temps, ils ne sont pas une baguette magique et ne remplacent pas une bonne hygiène numérique personnelle.

Exercices pratiques : votre premier rapport d'audit

La théorie ne vaut rien sans la pratique. Pour clore ce chapitre et ancrer ces concepts, je vous invite à réaliser ces deux exercices dès maintenant. Ils vous permettront de générer votre tout premier rapport d'audit, la fondation de votre reprise de contrôle.

Exercice 1 : L'outil "Vos données dans la Recherche" de Google

Google a récemment déployé un outil puissant permettant de reprendre le contrôle sur ce qui s'affiche à votre sujet dans son moteur de recherche.

1. Connectez-vous à votre compte Google et accédez à la page de gestion de votre compte.

2. Cherchez la section **Sécurité** ou **Confidentialité**, puis localisez l'outil **"Vos données dans la Recherche"** (parfois appelé "Résultats vous concernant" ou "Results about you").

3. Suivez le processus de configuration. Google vous demandera vos identifiants (noms, adresses email, numéros de téléphone, adresses physiques).

4. Activez l'option pour être **alerté** lorsque de nouveaux résultats contenant vos informations personnelles apparaissent dans la Recherche Google.

5. *Action :* Pour les résultats les plus sensibles (votre adresse personnelle, votre numéro de téléphone personnel), utilisez le bouton de demande de suppression intégré à l'outil. Google évaluera la demande et masquera ces résultats de son moteur. C'est votre

© 2026 Oussama Ghorbel

première victoire concrète contre le profilage public.

Exercice 2 : Le bilan de santé des mots de passe

Plutôt que de tout vérifier manuellement sur HIBP, laissez votre écosystème faire un premier tri.

• **Si vous utilisez Chrome / Google :** Allez dans `passwords.google.com`. Cliquez sur **Vérifier les mots de passe**. L'outil va analyser tous les mots de passe enregistrés dans votre compte et vous signaler en rouge ceux qui ont été compromis dans des fuites de données, en jaune ceux qui sont trop faibles, et en orange ceux que vous réutilisez sur plusieurs sites.

• **Si vous êtes sur Apple (iOS/Mac) :** Allez dans **Réglages** > **Mots de passe**. Le système affichera automatiquement des **Recommandations de sécurité** en haut de l'écran, listant les fuites de données connues et les mots de passe faciles à deviner.

• *Action :* Exportez ou notez le nombre total de mots de passe compromis et réutilisés. Inscrivez ce chiffre en haut de votre nouveau tableau de bord de risque. Ce sera votre point de départ, votre "score" initial. L'objectif des prochains chapitres sera de faire tomber ce chiffre à zéro.

Vous venez de terminer l'audit. Vous avez scruté votre ombre numérique, confronté les fuites de vos identifiants, coupé les liens OAuth toxiques et cartographié vos risques. Le diagnostic est posé. Il est temps, désormais, de passer à l'action et de commencer à construire votre bouclier. Tournez la page, nous entrons dans la matrice pour la démonter de l'intérieur.

© 2026 Oussama Ghorbel

Chapitre 5 – Le RGPD et vos droits numériques

Jusqu’à présent, dans les chapitres précédents, nous avons exploré les rouages de la matrice de la surveillance. Nous avons vu comment votre profil fantôme est construit, monétisé et utilisé pour influencer vos choix. Vous avez compris que la gratuité des services numériques est un leurre, et que vous êtes le produit. Mais face à cette architecture d'extraction massive, vous n'êtes pas sans défense. Il existe une arme, forgée par des années de luttes législatives, conçue pour rééquilibrer le rapport de force entre le citoyen et les géants de la donnée. Cette arme, c’est le droit.

Plus précisément, c'est le Règlement Général sur la Protection des Données (RGPD).

Trop souvent perçu comme une simple contrainte administrative générant d'agaçantes bannières de cookies, le RGPD est en réalité le bouclier juridique le plus puissant au monde en matière de vie privée. Dans ce chapitre, nous n'allons pas faire un cours de droit assommant. Nous allons apprendre à utiliser la loi comme un levier tactique pour forcer les entreprises à ouvrir leurs livres, à rectifier leurs dossiers et, surtout, à détruire vos données. Vous allez apprendre à reprendre le contrôle légal de votre identité numérique.

Les principes fondamentaux du RGPD et de la CNIL

Entré en application le 25 mai 2018, le RGPD a opéré ce que les juristes appellent une « révolution copernicienne ». Avant lui, la donnée personnelle était souvent considérée comme la propriété de l'entreprise qui la collectait. Le RGPD a renversé cette logique : la donnée personnelle est une extension de la personne elle-même. Vous n'êtes pas un simple fournisseur de matière première ; vous en êtes le propriétaire exclusif. L'entreprise n'en est que le dépositaire temporaire, soumis à des règles strictes.

Pour comprendre comment utiliser cette arme, il faut en maîtriser les principes fondamentaux. Le RGPD repose sur piliers que toute

© 2026 Oussama Ghorbel

organisation traitant des données de citoyens européens doit respecter :

1. **Licéité, loyauté et transparence** : Une entreprise ne peut pas collecter vos données en secret. Elle doit vous informer clairement de ce qu'elle fait, dans un langage compréhensible, et avoir une base légale pour le faire (votre consentement, un contrat, ou une obligation légale).

2. **Limitation des finalités** : Si vous donnez votre adresse email pour recevoir une facture, cette adresse ne peut pas être réutilisée pour vous envoyer des publicités ciblées ou être revendue à un courtier en données. La donnée doit être collectée pour un objectif précis et explicite.

3. **Minimisation des données** : C'est l'un des principes les plus puissants. Une entreprise ne doit collecter que les données *strictement nécessaires* à la finalité déclarée. Une application de lampe torche n'a pas besoin de votre géolocalisation.

4. **Exactitude** : Les données doivent être correctes et mises à jour. Vous avez le droit d'exiger la rectification d'informations erronées.

5. **Limitation de la conservation** : Les données ne peuvent pas être gardées éternellement. Une fois la finalité atteinte (ou le contrat terminé), elles doivent être supprimées ou anonymisées de manière irréversible.

6. **Intégrité et confidentialité** : L'entreprise doit garantir la sécurité de vos données contre les accès non autorisés, les fuites ou les piratages.

7. **Responsabilité (Accountability)** : Ce n'est plus à vous de prouver que l'entreprise abuse de vos données, c'est à l'entreprise de prouver qu'elle respecte la loi à chaque étape.

En France, le gardien de ces principes est la CNIL (Commission Nationale de l'Informatique et des Libertés). La CNIL n'est pas seulement un gendarme qui distribue des amendes records aux GAFAM ; c'est une ressource à votre disposition. Elle possède un pouvoir de contrôle, de sanction, mais aussi d'accompagnement. Selon une formule souvent attribuée à Marie-Laure Denis, présidente de la CNIL : « La protection des données n'est pas un frein à l'innovation, c'est une condition de la confiance. » Si une entreprise bafoue vos droits, la CNIL

© 2026 Oussama Ghorbel

est l'arbitre vers lequel vous pouvez vous tourner pour la rappeler à l'ordre, gratuitement et sans avocat.

Le droit d'accès : comment récupérer son fichier complet

L'article 15 du RGPD vous confère le « droit d'accès ». C'est l'équivalent d'une radiographie complète de votre âme numérique telle qu'elle est perçue par une entreprise spécifique. Vous avez le droit d'obtenir la confirmation que vos données sont traitées et, le cas échéant, d'en recevoir une copie intégrale dans un format structuré et lisible par machine (comme un fichier JSON, CSV ou XML).

Pourquoi est-ce une étape cruciale ? Parce que c'est la seule façon de découvrir l'étendue réelle de votre « profil fantôme » (évoqué au chapitre 2).

Lorsque vous téléchargez vos données depuis un réseau social, un moteur de recherche ou une application de livraison, vous ne récupérez pas seulement vos publications ou vos historiques de commandes. Vous mettez la main sur les métadonnées et les inférences. Vous y découvrirez peut-être des catégories publicitaires dans lesquelles l'algorithme vous a classé à votre insu (« intéressé par les crédits à la consommation », « profil politique modéré », « parent d'un enfant en bas âge »), l'historique précis de vos connexions (adresses IP, modèles d'appareils), ou encore les données de géolocalisation enregistrées en arrière-plan.

Comment exercer son droit d'accès ?

La plupart des grandes plateformes ont automatisé ce processus pour éviter d'être submergées par les demandes manuelles.

1. Rendez-vous dans les paramètres de votre compte.
2. Cherchez la section « Confidentialité », « Sécurité » ou « Vos données ».
3. Cliquez sur « Télécharger vos données » ou « Obtenir une copie de vos données ».
4. Sélectionnez le format (préférez JSON ou HTML pour la lisibilité) et la plage de dates (depuis la création du compte).

Cependant, pour les entreprises qui ne proposent pas de bouton de téléchargement direct (comme de nombreux sites e-commerce, courtiers

© 2026 Oussama Ghorbel

en données, ou fournisseurs de services locaux), vous devez faire une demande formelle. Vous devrez alors identifier le DPO (Délégué à la Protection des Données) de l'entreprise. Son adresse email est généralement trouvable dans la « Politique de confidentialité » du site, souvent sous la forme `dpo@entreprise.com` ou `privacy@entreprise.com`.

La loi impose à l'entreprise de vous répondre dans un délai d'**un mois** à compter de la réception de la demande. Ce délai peut être prolongé de deux mois supplémentaires si la demande est particulièrement complexe, mais l'entreprise doit vous en informer dans le premier mois. L'accès doit être gratuit, sauf si vos demandes sont manifestement infondées ou excessives.

L'avertissement d'Oussama : Préparez-vous psychologiquement à ouvrir ces fichiers. Voir l'ampleur de la surveillance comportementale dont vous faites l'objet, cristallisée dans des tableurs froids et méthodiques, peut être une expérience déroutante, voire angoissante. C'est le prix à payer pour prendre conscience de la réalité de la matrice.

Le droit à l'oubli et à l'effacement

Si le droit d'accès est la lanterne qui éclaire l'ombre, le droit à l'effacement (Article 17 du RGPD) est l'épée qui tranche le lien. Souvent appelé à tort « droit à l'oubli », ce droit vous permet d'exiger la suppression pure et simple de vos données personnelles des bases de données d'une entreprise.

La différence cruciale entre « supprimer un compte » et « exercer son droit à l'effacement »

C'est ici que de nombreux utilisateurs se font piéger. Lorsque vous cliquez sur le bouton « Supprimer mon compte » dans les paramètres d'un site web, vous ne faites souvent que désactiver votre accès frontal. L'entreprise peut conserver votre historique d'achats, vos logs de connexion et votre profil publicitaire dans ses archives sous prétexte de « sécurité », d'« analyse statistique interne » ou de « prévention de la fraude ».

Exercer votre droit à l'effacement via une requête RGPD formelle oblige l'entreprise à détruire la donnée personnelle elle-même, ou à

© 2026 Oussama Ghorbel

l'anonymiser de manière irréversible (de sorte qu'elle ne puisse plus jamais être reliée à vous).

Dans quels cas pouvez-vous exiger l'effacement ?

• Les données ne sont plus nécessaires au regard des finalités pour lesquelles elles ont été collectées.

• Vous retirez votre consentement (nous y reviendrons).

• Vous vous opposez au traitement fondé sur l'intérêt légitime de l'entreprise.

• Les données ont fait l'objet d'un traitement illicite.

• Les données doivent être effacées pour respecter une obligation légale.

Les limites du droit à l'effacement

Il est important de garder à l'esprit que ce droit n'est pas absolu. Les entreprises peuvent légalement refuser de supprimer certaines données si elles entrent dans le cadre d'exceptions prévues par la loi. Par exemple, si vous fermez votre compte dans une banque en ligne ou sur une plateforme d'investissement financier, l'institution ne supprimera pas immédiatement vos données de transaction. Les lois de lutte contre le blanchiment d'argent et le financement du terrorisme (LCB-FT) ainsi que les obligations fiscales exigent la conservation de ces documents pendant une durée minimale (souvent 5 à 10 ans). Rappelons que la gestion de vos investissements financiers reste soumise à ces strictes obligations légales de conservation.

De même, une entreprise peut conserver les données strictement nécessaires pour constater, exercer ou défendre un droit en justice (par exemple, si un litige commercial est en cours).

L'effet cascade

L'un des aspects les plus puissants de l'Article 17 est l'obligation d'information. Si l'entreprise a rendu vos données publiques (ou les a partagées avec des partenaires) et que vous demandez leur effacement, elle est tenue de prendre des « mesures raisonnables » pour informer les autres responsables de traitement qui exploitent ces données que vous avez demandé l'effacement de tout lien vers celles-ci, ou de toute copie

© 2026 Oussama Ghorbel

de celles-ci.

Le retrait du consentement (opt-out) : la fin du harcèlement

Le consentement est l'une des six bases légales du RGPD. Pour qu'il soit valide, il doit être **libre, spécifique, éclairé et univoque**. C'est sur ce terrain que la bataille contre le profilage publicitaire et le harcèlement commercial se joue.

Le mythe du consentement éternel

L'Article 7 du RGPD est formel : vous avez le droit de retirer votre consentement à tout moment. Le retrait du consentement doit être aussi simple que la manière dont il a été donné. Si vous avez coché une case pour recevoir la newsletter et des offres de partenaires lors de votre inscription, vous devez pouvoir vous désinscrire et retirer ce consentement en un clic, sans avoir à justifier votre décision ni à subir de conséquences négatives (comme la perte d'accès à un service essentiel).

L'opposition au traitement fondé sur l'« intérêt légitime »

C'est l'arme secrète du RGPD, souvent ignorée du grand public. Les entreprises n'utilisent pas toujours votre « consentement » pour vous pister. Elles utilisent souvent une autre base légale appelée l'**« intérêt légitime »** (Article 6.1.f). C'est sur cette base que de nombreux courtiers en données (data brokers) agrègent des informations publiques ou achetées pour créer des profils marketing, arguant que leur "intérêt légitime" à faire du commerce ne prévaut pas sur vos droits fondamentaux.

L'Article 21 du RGPD vous donne le **droit de vous opposer** à tout moment, pour des raisons tenant à votre situation particulière, à un traitement fondé sur l'intérêt légitime. Dès que vous exercez ce droit d'opposition, l'entreprise doit cesser le traitement, à moins qu'elle ne démontre qu'il existe des motifs légitimes et impérieux pour le traitement qui prévalent sur vos intérêts (ce qui est extrêmement difficile à prouver pour du marketing ciblé).

La lutte contre les Dark Patterns

Lors de votre navigation, vous avez sûrement remarqué ces bannières de cookies où le bouton « Tout accepter » est vert, énorme et

© 2026 Oussama Ghorbel

clignotant, tandis que le bouton « Refuser » est caché, gris, ou nécessite de cliquer sur trois sous-menus différents. Ces interfaces trompeuses s'appellent des *Dark Patterns* (interfaces manipulatoires). Le RGPD, soutenu par les lignes directrices du Comité Européen de la Protection des Données (EDPB), interdit formellement ces pratiques. Le refus doit être aussi simple que l'acceptation.

Pour mettre fin au harcèlement, vous devez systématiquement refuser les cookies non essentiels, et si vous avez déjà accepté par erreur ou par fatigue, vous devez utiliser le droit de retrait. La plupart des sites disposent aujourd'hui d'un icône en bas de page (souvent un petit bouclier ou un engrenage) permettant de « Modifier mes choix de cookies » à tout moment. Utilisez-le.

Modèles de lettres et de requêtes automatiques

Pour forcer une entreprise à agir, le formalisme est votre allié. Une demande vague sera traitée comme un simple message de support client et finira à la poubelle. Une demande structurée, citant les articles précis du RGPD, déclenchera immédiatement une alerte au service juridique ou au DPO de l'entreprise.

Voici les modèles que je vous recommande d'utiliser. Vous pouvez les envoyer par email à l'adresse du DPO (ou via le formulaire de contact en précisant "À l'attention du Délégué à la Protection des Données"), ou par lettre recommandée avec accusé de réception pour les entités les plus récalcitrantes.

Modèle 1 : Demande d'accès (Article 15)

> ***Objet : Demande d'accès à mes données personnelles (Article 15 du RGPD)***
>
> *Madame, Monsieur,*
>
> *Par la présente, j'exerce mon droit d'accès tel que prévu par l'article 15 du Règlement Général sur la Protection des Données (RGPD).*
>
> *Je vous prie de bien vouloir me confirmer que vous traitez ou non des données personnelles me concernant. Si tel est le cas, je vous demande de me fournir une copie intégrale de ces données dans un*

© 2026 Oussama Ghorbel

format structuré et couramment utilisé (lisible par machine).

Conformément à l'article 15, je vous demande également de me fournir les informations suivantes :

- Les finalités du traitement ;

- Les catégories de données personnelles concernées ;

- Les destinataires ou catégories de destinataires auxquels les données ont été ou seront communiquées ;

- La durée de conservation des données envisagée ;

- L'existence d'un processus décisionnel automatisé, y compris le profilage, et la logique sous-jacente.

Vous trouverez ci-joint une copie de ma pièce d'identité pour vérifier mon identité (vous pouvez masquer les données non nécessaires à cette vérification).

Je vous rappelle que vous disposez d'un délai d'un mois pour répondre à cette demande, conformément à l'article 12 du RGPD.

Dans l'attente de votre retour, je vous prie d'agréer, Madame, Monsieur, l'expression de mes salutations distinguées.

[Votre Prénom et Nom]

[Votre adresse email associée au compte]

[Votre adresse postale - optionnel]

Modèle 2 : Demande d'effacement et Droit à l'oubli (Article 17)

Objet : Demande d'effacement de mes données personnelles (Article 17 du RGPD)

Madame, Monsieur,

Par la présente, j'exerce mon droit à l'effacement (droit à l'oubli) conformément à l'article 17 du Règlement Général sur la Protection des Données (RGPD).

© 2026 Oussama Ghorbel

Je vous demande de bien vouloir procéder à la suppression immédiate de l'ensemble des données personnelles me concernant que vous détenez, et ce pour les motifs suivants :

- Les données ne sont plus nécessaires au regard des finalités pour lesquelles elles ont été collectées.

- Je retire mon consentement au traitement de mes données.

- Je m'oppose au traitement de mes données.

Je vous demande également, conformément à l'article 17.2, de prendre toutes les mesures raisonnables pour informer les autres responsables de traitement qui traitent ces données que j'ai demandé l'effacement de tout lien vers celles-ci, ou de toute copie de celles-ci.

Merci de me confirmer par écrit la bonne exécution de cette suppression dans le délai légal d'un mois.

[Votre Prénom et Nom]

[Votre adresse email associée au compte]

Modèle 3 : Opposition au profilage et à la prospection (Article 21)

Objet : Opposition au traitement de mes données à des fins de prospection et de profilage (Article 21 du RGPD)

Madame, Monsieur,

Conformément à l'article 21 du RGPD, je m'oppose par la présente à tout traitement de mes données personnelles me concernant à des fins de prospection commerciale, de publicité ciblée et de profilage marketing.

Cette opposition s'applique également à tout partage ou revente de mes données à des partenaires commerciaux ou à des courtiers en données (data brokers).

Je vous prie de cesser tout traitement fondé sur votre intérêt légitime ou sur mon consentement pour ces finalités spécifiques, et de me confirmer la prise en compte de mon opposition dans le délai d'un mois.

© 2026 Oussama Ghorbel

[Votre Prénom et Nom]

[Votre adresse email associée au compte]

L'automatisation au service de la vie privée

Rédiger ces lettres manuellement est fastidieux, surtout si vous décidez de nettoyer l'ensemble de votre historique numérique. Heureusement, l'écosystème de la protection des données a vu naître des outils d'automatisation. Des services comme *MyDataMyPrivacy*, *Incogni* (spécialisé dans la chasse aux courtiers en données), ou les générateurs de requêtes proposés directement sur le site de la CNIL, permettent d'envoyer ces requêtes en masse.

Cependant, je vous conseille de toujours garder la main sur les demandes les plus sensibles. Les outils automatisés sont excellents pour le nettoyage de masse, mais face à un géant du numérique ou un courtier en données particulièrement opaque, une lettre recommandée avec accusé de réception, rédigée par vos soins, possède un poids psychologique et juridique bien supérieur.

Que faire en cas de silence ou de refus ?

Si l'entreprise ne répond pas dans le délai d'un mois, ou si elle vous oppose un refus qui vous semble injustifié, ne baissez pas les bras. C'est là que la CNIL entre en jeu. Vous pouvez déposer une plainte en ligne sur le site de la CNIL (cnil.fr). Il vous suffira de joindre la copie de votre demande initiale, la preuve de son envoi, et l'absence de réponse (ou la réponse insatisfaisante). La CNIL se chargera alors de contacter l'entreprise, et croyez-moi, un email provenant de l'autorité de contrôle française a le don de débloquer miraculeusement les situations les plus stagnantes. Les sanctions pouvant atteindre 4% du chiffre d'affaires mondial annuel de l'entreprise, le service juridique de celle-ci préférera toujours supprimer vos données plutôt que de risquer un contrôle.

Exercice pratique : Passer à l'action

La théorie ne vaut rien sans la pratique. Le RGPD est un muscle qui se développe en l'utilisant. Pour clore ce chapitre et ancrer ces connaissances, je vous mets au défi de réaliser l'exercice suivant dès aujourd'hui.

© 2026 Oussama Ghorbel

Votre mission : Chasser un fantôme

1. **Identifiez la cible** : Trouvez un site e-commerce sur lequel vous n'avez pas acheté depuis plus de deux ans, un ancien réseau social que vous avez abandonné, ou un courtier en données (data broker) dont vous avez découvert l'existence lors de votre audit d'exposition numérique (Chapitre 4).

2. **Localisez le contact** : Fouillez la politique de confidentialité de ce site pour trouver l'adresse email du DPO ou le formulaire de contact dédié à la confidentialité.

3. **Frappez fort** : Envoyez le **Modèle 2 (Demande d'effacement)** en exigeant la destruction complète de votre profil et de votre historique. N'oubliez pas d'inclure l'adresse email ou le nom d'utilisateur associé à ce vieux compte pour faciliter leur recherche en base de données.

4. **Le suivi** : Créez une alerte dans votre agenda numérique à exactement 31 jours de l'envoi.

5. **L'escalade (si nécessaire)** : Si au 31e jour vous n'avez aucune nouvelle, ou si l'entreprise vous répond qu'elle "désactive" simplement le compte sans supprimer les données, connectez-vous sur le site de la CNIL et remplissez le formulaire de plainte en ligne.

En accomplissant cet exercice, vous ne nettoyez pas seulement une petite parcelle de votre empreinte numérique. Vous envoyez un signal fort au marché. Vous forcez les bases de données à se purger, vous rendez votre profil fantôme moins précis, moins monétisable, et donc moins attractif pour les algorithmes de l'influence.

Vous ne subissez plus la matrice ; vous commencez à la démanteler, ligne de code par ligne de code, article de loi par article de loi. Dans le prochain chapitre, nous quitterons les tribunaux et les serveurs pour aborder une philosophie de vie essentielle à votre survie numérique : la frugalité.

© 2026 Oussama Ghorbel

Chapitre 6 – La philosophie de la frugalité numérique

Jusqu'ici, nous avons passé en revue les rouages de la surveillance et les outils pour s'en prémunir. Mais il y a un piège classique que je veux vous aider à éviter : celui de la réforme sans conversion. On désinstalle quelques applications, on branche un bloqueur de publicité, on change de moteur de recherche… puis, six mois plus tard, on se retrouve avec un téléphone aussi chargé qu'avant, cinq nouveaux comptes créés « juste pour essayer », et une empreinte numérique qui a repoussé plus vite qu'auparavant.

La protection de la vie privée n'est pas une liste de courses qu'on coche une fois. C'est une manière de décider. Ce chapitre est le pivot du livre : il ne parle plus d'outils, mais de posture. Il s'agit d'adopter ce que les concepteurs de logiciels appellent le *Privacy by Design* — la confidentialité dès la conception — non pas pour une application, mais pour votre propre vie numérique.

Comme l'a résumé Bruce Schneier, la sécurité est un processus, pas un produit. Il en va de même de la vie privée : elle se cultive par des habitudes, pas par des achats.

Le minimalisme digital : moins d'apps, plus de valeur

Commençons par le geste le plus radical et le plus libérateur : supprimer.

Le modèle économique de l'écosystème mobile repose sur l'attention. Chaque application installée est un poste d'observation potentiel, une notification possible, une source de données de localisation, d'usage et d'interaction. Le simple fait d'avoir cinquante applications sur son téléphone multiplie les fenêtres par lesquelles un profil peut se reconstituer — même si chacune, prise isolément, paraît inoffensive.

Le minimalisme digital, ce n'est pas le refus de la technologie. C'est l'application d'un critère de valeur nette : est-ce que cette application m'apporte suffisamment de valeur justifier ce qu'elle observe, ce qu'elle stocke et ce qu'elle m'épuise ?

© 2026 Oussama Ghorbel

La méthode des trois questions. Avant d'installer quoi que ce soit, posez-vous systématiquement :

1. **Puis-je faire cela autrement ?** Un site web accessible depuis le navigateur remplace souvent une application native. Un carnet papier remplace parfois une application de gestion de tâches. Un lecteur de flux RSS remplace trois applications de réseau social.

2. **Que donne-t-elle comme autorisations, et pourquoi ?** Une application de lampe torche qui demande l'accès à vos contacts n'a aucune justification légitime. Refusez, ou supprimez.

3. **Que se passe-t-il si elle disparaît demain ?** Si la réponse est « rien de grave », vous n'en avez probablement pas besoin. Une application à laquelle vous êtes psychologiquement accroché mais qui n'apporte aucune valeur concrète est un risque, pas un outil.

Le test de remplacement en profondeur. Certaines applications sont difficiles à remplacer parce qu'elles sont devenues des plateformes. Prenez les réseaux sociaux : ils ne sont pas seulement des outils de publication, ce sont aussi des annuaires, des moyens de contact, des sources d'information. Les remplacer demande un travail de migration vers d'autres canaux. Ce travail, il faut le faire une fois, consciemment, plutôt que de reporter la décision indéfiniment sous prétexte que « tout le monde y est ».

Le budget applicatif. Une discipline utile consiste à se fixer un plafond : un nombre maximum d'applications sur le téléphone. Par exemple : messagerie, navigateur, banque, transport, appareil photo, horloge. Tout le reste doit justifier sa place à chaque fois que vous rangez votre écran d'accueil. Ce plafond crée une contrainte saine : pour ajouter, il faut retirer.

Attention, cependant, à ne pas tomber dans une inversion perverse : la culpabilité à propos de chaque outil numérique. Le minimalisme n'est pas l'ascétisme. Une application de streaming, un jeu, un outil de productivité : tout cela peut avoir sa place, à condition que la place soit choisie et non subie.

La règle de la compartimentation des identités

© 2026 Oussama Ghorbel

Un principe fondamental de l'ingénierie de sécurité consiste à limiter les dégâts d'une compromission en isolant les systèmes. Si un serveur est attaqué, les autres doivent continuer de fonctionner. Transposé à votre vie numérique, ce principe donne la *compartimentation* : ne jamais laisser un seul identifiant relier toutes vos activités.

Le problème de l'identité unique — une seule adresse email, un seul numéro de téléphone, un seul nom, utilisés partout — c'est qu'elle transforme votre vie en un tableau de bord unique et lisible. Achats, recherches médicales, déplacements, opinions politiques, relations : tout converge vers le même point. Un courtier en données, un fuite, un employeur curieux ou une autorité qui overreach : n'importe qui peut reconstituer le puzzle en quelques requêtes.

Les niveaux de compartimentation.

• **Niveau 1 : les adresses email.** Règle simple : jamais votre adresse principale sur un service commercial. Utilisez des alias (nous y reviendrons dans le chapitre 10) ou, à minima, une adresse dédiée aux inscriptions. L'objectif est que la fuite d'une base de données d'un site ne révèle pas qui vous êtes sur les autres.

• **Niveau 2 : les numéros de téléphone.** De plus en plus de services exigent un numéro. Réfléchissez à l'usage réel : avez-vous besoin de recevoir des SMS de ce service ? Un numéro secondaire, une carte SIM dédiée ou un service de réacheminement peut suffire. La numérotation est l'un des identifiants les plus puissants qui existent : elle relie votre vie numérique à votre identité civile et à vos déplacements.

• **Niveau 3 : les profils professionnels et personnels.** Ne publiez pas votre CV et vos opinions sous le même nom. Séparez les contextes : ce que vous dites à vos collègues, à vos amis, à vos clients et aux inconnus n'est pas la même communication.

• **Niveau 4 : les appareils.** Un téléphone personnel et un téléphone professionnel, c'est un luxe, je le reconnais. Mais même sans matériel supplémentaire, on peut compartimenter par profils, comptes ou espaces de travail isolés sur de nombreux systèmes.

La règle d'or : pas de ponts inutiles. Un pont, c'est une connexion qui relie deux compartiments : une authentification unique (OAuth) qui

© 2026 Oussama Ghorbel

relie votre compte Google à un service tiers, une synchronisation automatique qui envoie vos contacts à une application, un connecteur qui relie votre calendrier à un outil en ligne. Chaque pont est un point de fusion possible. Réduire le nombre de ponts, c'est réduire le nombre de chemins par lesquels vos données peuvent converger.

Compartimenter demande un effort initial : gérer plusieurs adresses, plusieurs mots de passe, plusieurs habitudes. Cet effort est réel. Mais il est ponctuel, contrairement à la surveillance, qui est permanente.

Le coût cognitif de la surveillance permanente

Il existe un argument que l'industrie de la donnée adore : « Je n'ai rien à cacher. » Cet argument mérite qu'on s'y arrête, non pas seulement pour la réponse classique — le droit à la vie privée n'est pas réservé aux gens qui ont quelque chose à cacher — mais pour une raison plus pratique : il ignore le coût psychologique de la surveillance.

Les recherches en psychologie sociale ont depuis longtemps documenté ce qu'on appelle l'*effet du spectateur* ou l'*auto-censure contextuelle* : lorsqu'on sait qu'on est observé, on module son comportement. On hésite avant de chercher une information sensible. On évite une conversation délicate par message. On renonce à une recherche anodine mais gênante. Ce n'est pas de la paranoïa : c'est le fonctionnement normal d'un esprit social qui se sait regardé.

Le coût cognitif de la surveillance permanente se mesure en plusieurs devises :

• **L'attention fragmentée.** Chaque notification, chaque bannière publicitaire personnalisée est une sollicitation. L'économie de l'attention repose sur la fragmentation : plus votre attention est éclatée, plus elle est monnayable. Le résultat, ce n'est pas seulement de la productivité perdue, c'est une capacité réduite à la réflexion profonde.

• **La charge décisionnelle.** Choisir entre quatre applications de livraison, gérer les autorisations de chacune, comparer les politiques de confidentialité, décider si ce nouveau service mérite votre numéro de téléphone : chaque micro-décision prélève une part de votre énergie cognitive. La frugalité digitale consiste précisément à

© 2026 Oussama Ghorbel

réduire le nombre de ces décisions.

• **Le bruit de fond anxieux.** Le sentiment d'être traqué, même lorsqu'il est rationnellement fondé, entretient un état d'alerte diffuse. Cette tension n'est pas neutre : elle consomme de la bande passante mentale que vous n'investissez pas dans ce qui compte pour vous.

• **L'épuisement du consentement.** À force de devoir accepter des cookies, des conditions générales, des notifications et des mises à jour, on finit par cliquer « accepter » sans lire. C'est ce qu'on appelle la *fatigue du consentement* : elle profite directement aux entreprises qui collectent, puisqu'un consentement épuisé n'est plus un consentement éclairé.

La frugalité numérique n'est donc pas seulement une stratégie de protection des données : c'est une stratégie de préservation de soi. Moins d'outils, moins de comptes, moins de notifications : plus de place pour penser.

Définir son niveau de menace personnel (Threat Modeling)

Tout le monde n'a pas les mêmes risques. Un journaliste d'investigation, un défenseur des droits humains, un lanceur d'alerte, un professionnel de santé, un militant, ou simplement une personne qui sort d'une relation de contrôle : leurs menaces ne sont pas comparables à celles d'un utilisateur lambda. Prétendre le contraire conduit à deux échecs opposés : soit une sécurité surdimensionnée, épuisante et abandonnée en trois semaines, soit une insouciance dangereuse.

Le *threat modeling* — la modélisation des menaces — est une démarche simple en apparence : savoir contre qui on se protège, ce qu'on veut protéger, et à quel coût.

Étape 1 : identifier vos actifs. Qu'est-ce qui, pour vous, mérite une protection réelle ? Liste concrète : votre adresse physique, votre historique de recherche, vos données de santé, vos photos de famille, vos documents professionnels, votre réputation, votre localisation en temps réel, votre carnet d'adresses. Tout le monde n'a pas la même liste, et c'est normal.

Étape 2 : identifier les acteurs potentiels. Qui pourrait vouloir ces informations ?

© 2026 Oussama Ghorbel

• Les courtiers en données et les annonceurs (menace de masse, mais peu ciblée).

• Les criminels opportunistes (hameçonnage, usurpation, chantage).

• Des individus précis : un ex-conjoint, un employeur, un harceleur, un voisin.

• Des entités institutionnelles : employeur, administration, autorités.

• Des acteurs étrangers : services de renseignement, groupes organisés.

Étape 3 : évaluer la probabilité et l'impact. Une menace improbable mais dévastatrice (le vol d'identité complet) mérite une attention différente d'une menace probable mais mineure (le profilage publicitaire). Construisez mentalement une grille simple : probabilité × impact.

Étape 4 : choisir des contre-mesures proportionnées. C'est ici que la frugalité entre en jeu : on ne se protège pas de tout, on se protège de ce qui compte, avec des moyens que l'on peut tenir dans la durée. Une mesure que vous abandonnerez en un mois ne vaut rien. Une mesure modeste que vous appliquez pendant dix ans vaut mieux qu'une forteresse abandonnée au bout de trois semaines.

Trois profils types, à titre indicatif.

• *Profil « citoyen lambda »* : on cherche surtout à limiter le profilage publicitaire, à protéger les comptes bancaires et à éviter l'usurpation d'identité. Les bases suffisent : mot de passe unique par compte, authentification à deux facteurs, navigateur durci, alias email.

• *Profil « sensible »* : profession de santé, avocat, journaliste, personnel encadrant. La confidentialité des échanges devient critique. On ajoute : messagerie chiffrée de bout en bout, séparation stricte des contextes pro/perso, attention aux métadonnées, chiffrement des disques.

• *Profil « élevé »* : personnes exposées, victimes de harcèlement, personnes en danger. La localisation, les métadonnées et les proches deviennent des vecteurs d'attaque. La compartimentation devient vitale : téléphones séparés, numéros dédiés, interdiction de géolocalisation, procédures de fuite.

© 2026 Oussama Ghorbel

Ce classement n'est pas figé : votre niveau de menace évolue avec votre vie. Un changement de poste, une séparation, un engagement militant, un litige judiciaire : autant de moments où il faut reprendre le exercice du threat modeling.

La frugalité comme acte de résistance écologique et politique

On aborde souvent la vie privée sous l'angle individuel : *moi*, mes données, mon profil. Mais la frugalité numérique a aussi une portée collective, et à deux titres.

Premier titre : l'écologie. Le numérique n'est pas immatériel. Datacenters, câbles sous-marins, smartphones, box internet, objets connectés : tout cela consomme de l'énergie, de l'eau, des métaux rares, et génère des déchets. Les estimations varient selon les méthodes de calcul, mais il est établi que la fabrication d'un smartphone représente une part importante de son empreinte carbone totale — souvent supérieure à celle de son utilisation sur plusieurs années. Allonger la durée de vie d'un appareil, refuser le renouvellement fréquent, désinstaller les applications qui tournent en arrière-plan et sollicitent inutilement le réseau : ce sont des gestes à la fois privés et écologiques.

Le cloud n'échappe pas à la règle. Stocker des données que l'on ne consulte jamais — doublons de photos, anciens projets, archives mortes — a un coût matériel. Le droit à l'oubli n'est pas seulement juridique : il est aussi physique. Chaque octet inutile est un octet stocké, servi, sécurisé, refroidi.

Second titre : la politique. Les modèles économiques de l'internet grand public reposent massivement sur la collecte et la monétisation des comportements. Chaque refus d'installer une application superflue, chaque abandon d'un service qui refuse de respecter ses utilisateurs, chaque opt-out assumé est un signal. Les marchés réagissent aux signaux, lentement, mais ils y réagissent.

Il y a aussi une dimension de cohérence politique. Beaucoup de nos concitoyens s'inquiètent de la surveillance de masse, tout en utilisant des outils qui la nourrissent paradoxalement. La frugalité numérique permet d'aligner ses pratiques sur ses convictions : c'est ce qu'Albert Camus appelait, dans un tout autre registre, donner une cohérence à sa vie. Je

© 2026 Oussama Ghorbel

cite ici non pas pour faire beau, mais parce que l'idée s'applique : on ne défend pas durablement une valeur qu'on contredit chaque jour par ses habitudes.

Attention, cependant, à ne pas moraliser. La fracture numérique est réelle : tout le monde n'a pas le temps, ni les compétences, ni les moyens de faire des choix optimaux. La frugalité n'est pas un marqueur de supériorité. C'est une voie possible, à parcourir à son rythme, sans jugement envers ceux qui en sont plus éloignés.

Préparer sa transition vers une hygiène numérique durable

Nous arrivons au moment où les outils et la posture doivent se rencontrer. Le risque, après un chapitre comme celui-ci, c'est l'élan : tout vouloir changer en un week-end, se surcharger de nouvelles règles, et abandonner dès la première friction. La psychologie du changement est bien documentée : les réformes radicales et immédiates ont un taux d'abandon élevé. Les transitions graduelles et ancrées dans des routines tiennent mieux.

Principe 1 : commencer par l'irréversible. Les actions à fort effet et difficilement réversibles d'abord : changer les mots de passe des comptes critiques, activer l'authentification à deux facteurs, supprimer les applications qui accèdent à votre localisation en permanence, revoir les autorisations accordées aux applications sociales. Une fois fait, ces gains tiennent.

Principe 2 : une action à la fois, répétée. Chaque semaine ou chaque mois, une seule nouvelle habitude. Exemple de calendrier sur trois mois : semaine 1-2, migration de l'adresse email principale vers un système d'alias ; semaine 3-4, audit complet des permissions mobiles ; semaine 5-6, bascule vers un moteur de recherche respectueux et configuration du navigateur ; semaine 7-8, nettoyage des comptes dormants ; semaine 9-10, mise en place d'un coffre-fort de mots de passe ; semaine 11-12, rédaction et relecture de votre charte personnelle.

Principe 3 : automatiser ce qui peut l'être. La volonté est une ressource limitée. Les bloqueurs de traqueurs, les réglages de confidentialité par défaut, les mots de passe générés automatiquement, les alias créés à la volée : tout ce qui fonctionne sans y penser est un

© 2026 Oussama Ghorbel

allié. L'objectif n'est pas de réfléchir à chaque connexion, mais de mettre en place un système qui protège même quand vous n'y pensez pas.

Principe 4 : prévoir les régressions. Vous installerez à nouveau une application « juste pour voir ». Vous accepterez un cookie par distraction. Vous donnerez votre numéro à un commerçant pressé. Ce n'est pas un échec, c'est la vie. L'important est d'avoir prévu un point de reprise : une revue mensuelle, un checklist de remise en état, un moment où l'on remet de l'ordre. L'hygiène numérique, comme l'hygiène corporelle, se pratique régulièrement, pas parfaitement.

Principe 5 : transmettre. Les bons réflexes se propagent par l'exemple plus que par le discours. Aider un parent à désactiver la publicité personnalisée, expliquer à un collègue pourquoi un alias email est utile, montrer à un ami comment vérifier les permissions d'une application : chaque transmission multiplie l'effet de vos choix individuels. La vie privée n'est pas seulement un droit personnel, c'est un bien commun qui se protège aussi collectivement.

Le point de bascule. Il arrive un moment, dans tout travail de ce type, où les nouvelles habitudes cessent d'être des efforts pour devenir la norme. Vous n'ouvrez plus un site sans vérifier les cookies. Vous n'installez plus une application sans lire les permissions. Vous ne donnez plus votre adresse principale sans raison impérieuse. Ce point de bascule n'a pas de date fixe : il arrive quand le nouveau comportement coûte moins cher que l'ancien. Votre travail, en attendant, est de rendre ce nouvel comportement le plus facile possible.

Exercices

Exercice 6.1 : Rédiger sa charte personnelle de confidentialité

Cet exercice est, à mon sens, le plus important du chapitre. Il s'agit de formaliser noir sur blanc vos règles non négociables — les principes que vous vous engagez à appliquer dans la durée, comme on établirait une constitution pour sa vie numérique.

Mode opératoire.

1. Prenez une feuille ou un document vierge.

© 2026 Oussama Ghorbel

2. Écrivez cinq règles strictes, formulées à l'impératif, sans ambiguïté. Chaque règle doit être testable : on doit pouvoir dire, dans chaque situation, si on l'a respectée ou non.

3. Pour chacune, notez en une ligne la justification (quelle menace elle adresse).

4. Signez-dated. Relisez-vous chaque trimestre.

Exemple de charte (à adapter, jamais à copier telle quelle) :

Ma charte personnelle de confidentialité

*1. **Jamais de connexion OAuth.** Je crée un compte propre sur chaque service, sans lier Google, Facebook ou Apple. Justification : éviter la fusion des compartiments d'identité.*

*2. **Alias email systématique.** Aucun site commercial ne reçoit mon adresse principale ; j'utilise un alias révocable. Justification : limiter l'impact des fuites et identifier la source d'un spam.*

*3. **Aucune application sans justification écrite.** Avant d'installer, je note la réponse aux trois questions du minimalisme. Justification : réduire la surface d'observation.*

*4. **Géolocalisation désactivée par défaut.** Seules deux applications y ont accès, explicitement. Justification : la localisation est l'un des identifiants les plus révélateurs.*

*5. **Revue mensuelle des autorisations.** Le premier dimanche du mois, je passe en revue permissions, comptes connectés et applications inactives. Justification : l'hygiène se pratique régulièrement.*

N'hésitez pas à faire évoluer votre charte. Cinq règles strictes valent mieux que vingt règles floues : la force d'un principe vient de sa simplicité mémorable.

Exercice 6.2 : Mon budget applicatif

1. Comptez le nombre d'applications installées sur votre téléphone principal.

2. Classez-les en trois colonnes : *indispensable*, *utile*, *superflu*.

3. Notez combien d'entre elles ont accès à votre localisation, à vos contacts, à votre microphone ou à votre appareil photo.

© 2026 Oussama Ghorbel

4. Fixez-vous un plafond (par exemple : 15 applications). Identifiez les cinq premières suppressions à mener cette semaine.

Exercice 6.3 : Mon threat modeling en une page

Rédigez un document d'une page qui répond à quatre questions :

1. Quels sont mes trois actifs numériques les plus précieux ?
2. Quels sont les trois acteurs les plus susceptibles de les viser (et pourquoi) ?
3. Quelle est, pour chacun, la probabilité × l'impact ?
4. Quelles sont les deux contre-mesures que je m'engage à tenir pendant au moins six mois ?

Ce document n'a pas besoin d'être parfait. Il a besoin d'exister : un threat modeling écrit vaut mieux qu'une intuition vague, parce qu'il peut être relu, corrigé, et comparé à votre charte.

La frugalité numérique n'est pas une destination. C'est une direction. Vous n'arrivez jamais « au bout » : vous progressez, parfois vous reculez, vous corrigez, vous simplifiez. Mais à mesure que vos habitudes se stabilisent, vous constaterez quelque chose de contre-intuitif : moins d'outils, moins de comptes et moins de notifications ne rendent pas votre vie plus pauvre. Ils la rendent plus lisible. Et une vie numérique lisible est, en général, une vie plus libre.

© 2026 Oussama Ghorbel

Partie 2 : Le bouclier numérique (Web et Identité en ligne)

© 2026 Oussama Ghorbel

Chapitre 7 – Blinder son navigateur web

Votre navigateur est la porte d'entrée de votre vie numérique. C'est lui que vous ouvrez des dizaines de fois par jour, lui qui voit passer vos recherches, vos achats, vos lectures, vos messages et vos moments de faiblesse. Chaque onglet que vous laissez ouvert est une fenêtre potentiellement entrebaillée. Dans ce chapitre, je vais vous montrer comment transformer ce logiciel si commun en une véritable forteresse : le bon choix d'installation, la configuration fine, l'hygiène quotidienne, et les réflexes à adopter quand la menace change d'échelle.

L'objectif n'est pas la perfection paranoïaque. Il s'agit de reprendre la main, pas de se couper du monde. Un navigateur bien réglé reste confortable, rapide et compatible avec la quasi-totalité des sites que vous utilisez réellement. La différence, c'est que ce sera vous qui décidez de ce qui sort, et de ce qui reste.

Chrome vs Firefox vs Brave vs Safari : le comparatif

Tous les navigateurs se ressemblent à l'usage : une barre d'adresse, des onglets, un bouton favori. Pourtant, sous le capot, leurs philosophies sont radicalement différentes. Et en matière de vie privée, la philosophie finit toujours par dicter le comportement.

Google Chrome domine largement le marché mondial. Il est rapide, universellement compatible, et profite de l'écosystème Google si vous utilisez déjà Gmail, Drive ou Android. C'est aussi, de loin, le navigateur qui collecte le plus de données sur ses utilisaires. La télémétrie, les identifiants publicitaires, la synchronisation par défaut, l'envoi d'échantillons de pages vers Google : tout est conçu pour alimenter un modèle économique fondé sur la réclame ciblée. Je ne dis pas que Chrome est un « mauvais » logiciel — techniquement, c'est un excellent moteur de rendu. Mais utiliser Chrome sans le configurer massivement, c'est livrer sa clé d'entrée à la plus grande machine publicitaire du monde. Même avec des réglages poussés, le simple fait d'être connecté à un compte Google annule une grande partie des efforts.

Mozilla Firefox est la seule grande solution véritablement indépendante. Mozilla est une fondation à but non lucratif, financée

principalement par des partenariats de recherche et — signalons-le honnêtement — par un contrat avec Google, qui finance par défaut la recherche dans Firefox. Ce conflit d'intérêts existe, mais le modèle économique de Mozilla n'est pas la revente de profil. Firefox propose les réglages de confidentialité les plus fins du marché, un moteur de rendu distinct qui évite la domination totale de Chromium, et un écosystème d'extensions mature. Sa faiblesse historique : une consommation mémoire parfois plus élevée et un nombre de sites qui testent en priorité sur Chrome. Ces écarts se sont réduits ces dernières années.

Brave part de la base Chromium — donc de la compatibilité de Chrome — et ajoute par défaut un bloqueur de traqueurs très efficace, un mode de navigateur privé avec Tor intégré, et un système de protection contre les empreintes numériques. Brave « brave » vraiment ? En partie. La protection est réelle et immédiate, sans configuration. Mais Brave développe aussi son propre modèle publicitaire basé sur des « récompenses » et une cryptomonnaie, ce qui ajoute une couche de complexité et de controverses. Si votre priorité est la simplicité avec un bon niveau de protection de départ, Brave est un excellent choix. Si vous voulez le maximum de contrôle sur chaque brique, Firefox reste supérieur.

Safari est le navigateur d'Apple, sur Mac et iOS. Sa force : une intégration étroite avec le système, et une position commerciale intéressante. Apple ne vit pas de la publicité ciblée — du moins pas encore au même niveau que Google — et son modèle économique repose sur la vente de matériel. Safari bloque par défaut les cookies tiers, limite le pistage entre sites et inclut l'Intelligent Tracking Prevention. En usage quotidien sur un iPhone ou un Mac, Safari est donc déjà assez protecteur. Ses limites : un écosystème d'extensions plus restreint, des réglages moins granulaires, et le fait que vous vous enfermez dans l'univers Apple. Et n'oublions pas qu'Apple continue de collecter des données d'usage, y compris dans Safari, via sa télémétrie.

Mon choix, en pratique : je recommande Firefox comme navigateur principal pour toute personne qui veut comprendre et maîtriser sa configuration. Brave est un excellent second choix pour ceux qui veulent une protection forte sans y passer une heure. Safari reste pertinent sur mobile si vous êtes déjà dans l'écosystème Apple et que vous ne voulez

© 2026 Oussama Ghorbel

pas installer autre chose. Chrome, quant à lui, je vous recommande de le réserver aux cas où un outil professionnel l'impose — et dans ce cas, de l'utiliser dans un profil séparé, déconnecté de tout compte.

Quel que soit votre choix, une règle s'applique : **un seul navigateur principal**. Multiplier les navigateurs, c'est multiplier les empreintes à gérer et les réglages à maintenir.

Configuration avancée de Firefox pour la vie privée (about:config)

Firefox est le seul navigateur grand public qui vous laisse ouvrir le capot et toucher à presque tous ses réglages. Cette porte d'entrée s'appelle `about:config`.

Pour y accéder, tapez `about:config` dans la barre d'adresse. Firefox vous avertira que modifier ces préférences peut fragiliser votre navigateur. Cet avertissement est sincère : un réglage mal compris peut casser un site, désactiver une fonction ou réduire votre sécurité. C'est pourquoi je vous propose une méthode simple : **comprendre avant de changer**, et **noter l'état initial** pour pouvoir revenir en arrière.

Voici les préférences qui, selon moi, méritent votre attention. Je les présente par intention, pas par ordre alphabétique, parce que c'est ainsi qu'il faut réfléchir.

Limiter le pistage inter-sites. Recherchez `privacy.firstparty.isolate` et mettez-le à `true`. Cette option isole les cookies et le stockage local par domaine de premier ordre : un site ne peut plus voir ce que vous avez fait sur un autre site via des identifiants partagés. C'est puissant, mais attention : cela peut casser certains connecteurs OAuth, certains sites de paiement ou la synchronisation dans certains cas. Testez pendant quelques jours avant de vous y fier définitivement.

Renforcer la protection contre les empreintes numériques. Firefox inclut désormais une protection renforcée contre l'empreinte digitale (`privacy.fingerprintingProtection`). Activez-la dans les paramètres de confidentialité, ou passez par `about:config` pour affiner les listes de protection. L'empreinte digitale, rappelons-le, c'est cette combinaison de votre navigateur, de votre système, de vos polices et de

© 2026 Oussama Ghorbel

votre carte graphique qui vous rend identifiable même sans cookie.

Réduire l'envoi de requêtes distantes. La fonctionnalité « safe browsing » de Firefox peut envoyer des adresses d'URL à Google ou à Mozilla pour vérifier si un site est dangereux. Dans `about:preferences#privacy`, vous pouvez choisir le niveau de protection. Le mode « standard » n'envoie que les URL reconnues comme suspectes. Si vous voulez un fonctionnement 100 % local, choisissez de désactiver cette vérification à distance — mais vous perdrez alors une couche anti-phishing. Personnellement, je vous conseille de garder la vérification locale si elle est disponible sur votre version, et de rester vigilant sur le reste.

Couper les mises à jour par défaut silencieuses. Non, je ne vous encourage pas à rester à jour ancien — c'est dangereux. Mais comprenez que Firefox vérifie les mises à jour, envoie des rapports de crash et peut transmettre des données d'usage. Ces éléments se règlent aussi dans `about:config` : `app.update.auto`, `datareporting.healthreport.uploadEnabled`, `datareporting.policy.dataSubmissionEnabled`. Mettez le dernier à `false` pour désactiver l'envoi de rapports de données.

Empêcher les redirections de recherche. Firefox redirige parfois les recherches vers son propre service ou vers des services partenaires. Passez par les paramètres de recherche pour définir votre moteur, et vérifiez qu'aucune redirection cachée ne subsiste.

Une méthode de travail propre. Avant toute modification, créez un favori de vos préférences actuelles : `about:support` vous offre un « profil » exportable. Vous pouvez aussi noter chaque clé modifiée et sa valeur d'origine dans un fichier texte. En cas de problème, une recherche rapide vous ramène à la case départ.

Et surtout : ne recopiez pas aveuglément des « listes durcies » trouvées sur Internet. Certaines sont excellentes, d'autres datent de versions antérieures et cassent des fonctions essentielles. La règle que je vous recommande d'appliquer est simple : **si vous ne savez pas expliquer un réglage en une phrase, ne l'appliquez pas.**

Gestion stricte des cookies et du stockage local

© 2026 Oussama Ghorbel

Les cookies ne sont pas l'ennemi. Ils sont le mécanisme qui vous garde connecté à votre messagerie, qui retient le contenu de votre panier, qui mémorise vos préférences de langue. Le problème n'est pas le cookie en soi : c'est le cookie **tiers**, celui déposé par un domaine tiers — publicitaire, réseau social, analyse — quand vous visitez un site qui l'héberge en cachette.

La stratégie de base est celle-ci : **bloquer les cookies tiers, autoriser les cookies de premier ordre, purger régulièrement.**

Dans Firefox : `Paramètres -> Vie privée et sécurité -> Cookies et données de sites`. Choisissez « Bloquer les cookies et données de sites tiers ». Activez aussi « Effacer les données de connexion et les cookies à la fermeture » si vous ne souhaitez pas rester connecté en permanence — mais acceptez alors devoir vous reconnecter à chaque session, ce qui peut devenir pénible sur vos services quotidiens.

Ensuite, pensez au stockage local : `localStorage`, `sessionStorage`, les bases IndexedDB, les Service Workers. Ce sont des mécanismes plus discrets que les cookies, souvent utilisés par les sites modernes, et parfois exploités pour vous reconnaître. Firefox les gère dans les mêmes réglages de données de sites. Si vous voulez une purge complète : `Paramètres -> Vie privée et sécurité -> Effacer les données`. Cochez les cookies, le cache, et l'historique si nécessaire. Pour les données de sites plus profondes, utilisez « Données de sites -> Gérer les données » et supprimez site par site ceux que vous ne reconnaissez pas.

Le chiffre à retenir : la plupart des traqueurs ont besoin d'un identifiant persistant. Si vous purifiez régulièrement votre stockage, vous cassez cette persistance. Ce n'est pas une protection absolue — l'empreinte digitale peut vous suivre — mais c'est une gêne sérieuse pour la collecte.

Je vous conseille une routine simple : une fois par semaine, effacer les cookies des sites que vous n'utilisez pas habituellement, en conservant ceux de vos services essentiels. Firefox vous permet d'exempter des sites précis de la purge automatique. C'est le bon compromis entre confort et confidentialité.

Un mot sur les « bannières de consentement » que vous rencontrez partout depuis le RGPD : accepter ou refuser ne change presque rien au

© 2026 Oussama Ghorbel

niveau de pistage réel. Ces mécanismes ont été largement critiqués pour leur opacité. Votre meilleure défense reste technique : bloqueur de contenu, cookies tiers bloqués, conteneurs (que nous allons voir juste après). Le consentement seul ne suffit pas.

Isoler les contextes : les profils et les conteneurs

Voici l'une des leçons les plus importantes de ce chapitre : **votre navigateur ne doit pas être une seule et même salle de verre.**

Quand tout se mélange — travail, banque, réseaux sociaux, navigation privée occasionnelle —, vous créez une continuité d'identité. Les traceurs adorent cette continuité. La parade consiste à découper votre activité en contextes séparés, de sorte qu'aucun ne puisse se relier aux autres.

Les profils Firefox sont la première coupe. Menu -> Nouveau profil. Créez-en deux au minimum : un pour la vie personnelle, un pour le travail. Chacun a son propre historique, ses cookies, ses extensions. Vous pouvez les lancer côte à côte, avec des thèmes différents pour ne jamais les confondre. Je vous suggère d'ajouter un troisième profil « jetable » pour tester un site douteux ou ouvrir un lien reçu par message.

Les conteneurs Firefox vont plus loin, et c'est là que la magie opère. Une extension officielle — Multi-Account Containers — vous permet de créer des onglets colorés, chacun avec son propre bac à sable de cookies. Votre banque dans un conteneur « Finance » bleu, vos réseaux sociaux dans un conteneur « Social » orange, vos achats dans un conteneur « Shopping » vert. Quand vous ouvrez facebook.com dans le conteneur Social, il ne voit pas votre session de la banque, ni votre historique d'achats. Les conteneurs coexistent dans une seule fenêtre, ce qui est bien plus confortable que de jongler entre profils.

L'extension propose aussi des listes de sites à envoyer automatiquement dans un conteneur précis. Définissez vos habitudes une fois, et l'isolation fonctionne ensuite toute seule.

Le navigateur privé (Ctrl+Maj+N dans la plupart des navigateurse navigateur privé** a une réputation qu'il ne mérite pas. Il ne vous rend pas anonyme : votre employeur, votre fournisseur d'accès et les sites que vous visitez voient toujours votre trafic. Ce qu'il fait, c'est isoler la

© 2026 Oussama Ghorbel

session : à la fermeture, historique, cookies et cache de cette session sont supprimés. C'est utile pour un site que vous ne voulez pas dans votre historique, ou pour un compte secondaire. Ce n'est pas un bouclier contre la surveillance.

Brave propose un concept voisin : les « profils » et les emplacements de travail (workspaces), qui permettent de séparer les contextes avec des onglets et des cookies distincts. **Safari** offre des « profils de profil » depuis ses versions récentes, dans le même esprit.

Quelle que soit la solution, la règle est la même : **un contexte, un objectif, un bac à sable.** Plus votre navigation est compartimentée, plus il devient coûteux pour un traceur de reconstituer une histoire cohérente sur vous.

Le protocole HTTPS et la sécurité des certificats

Un site en HTTP, c'est une carte postale : tout le monde peut lire le contenu en transit, y compris votre fournisseur d'accès, le Wi-Fi de l'aéroport, et tout dispositif de surveillance sur le chemin. HTTPS chiffre la connexion entre votre navigateur et le site. Le contenu devient illisible pour les tiers, et l'intégrité des données est protégée : impossible de modifier une requête ou une réponse sans que cela soit détecté.

Depuis quelques années, HTTPS est devenu la norme. Mais deux pièges subsistent.

Premier piège : les exceptions silencieuses. Si un site refuse HTTPS, votre navigateur peut afficher un avertissement — ou, dans certaines configurations, laisser passer la connexion. Firefox dispose d'une option « Activer HTTPS First Mode » (ou Strict dans les navigateurs récents) qui tente HTTPS avant HTTP. Activez-la. Si le site casse, vous pouvez le laisser en HTTP, mais vous devez savoir que vous le faites consciemment.

Deuxième piège : les certificats falsifiés ou interceptés. Un certificat valide atteste que vous parlez bien au site attendu. Si une entité — entreprise, État, logiciel malveillant — injecte son propre certificat autorité, elle peut intercepter votre connexion sans que vous le remarquiez. C'est ce qu'on appelle une attaque par homme du milieu (MITM). Sur un réseau d'entreprise ou un pays restrictive, cela arrive.

© 2026 Oussama Ghorbel

Firefox, comme Chrome, inclut un mécanisme de « certificate pinning » partiel et des listes de transparence des certificats. Vous pouvez renforcer la vigilance : si vous voyez un avertissement de certificat sur un site que vous connaissez parfaitement, **ne cliquez pas sur « continuer »**. C'est précisément le moment de fermer l'onglet et d'investiguer. Le réflexe de contourner l'avertissement est le réflexe le plus dangereux de tout internaute.

Un dernier conseil : installez les mises à jour de votre navigateur dès qu'elles sortent. Les correctifs HTTPS, TLS et de gestion de certificats sont régulièrement intégrés à ces versions. Un navigateur non mis à jour est comme une porte blindée dont on aurait retiré le verrou.

Désactiver la télémétrie intégrée au navigateur

Tous les navigateurs modernes remontent des données à leurs éditeurs. Firefox parle de « données de santé », Chrome de « statistiques d'utilisation », Brave de « rapports ». Officiellement, ces informations servent à améliorer le produit : détection de bugs, suivi des performances, compréhension des fonctionnalités utilisées. Officieusement, elles constituent aussi une source de connaissance sur vos habitudes.

La bonne nouvelle : chez Firefox, cette télémétrie est désactivable proprement.

Rendez-vous dans `Paramètres -> Vie privée et sécurité -> Données de rapports et d'études`. Décochez « Autoriser Firefox à envoyer des données d'utilisation et d'études techniques à Mozilla » et « Autoriser Firefox à envoyer des rapports de crash ». Pour un contrôle total, complétez dans `about:config` :

- `datareporting.policy.dataSubmissionEnabled` -> `false`
- `datareporting.healthreport.uploadEnabled` -> `false`
- `toolkit.telemetry.enabled` -> `false`
- `browser.newtabpage.activity-stream.feeds.telemetry` -> `false`
- `browser.ping-centre.telemetry` -> `false`

Vous pouvez aussi empêcher les études expérimentales (« studies ») qui injectent des comportements variables selon des cohortes

© 2026 Oussama Ghorbel

d'utilisateurs : `app.normandy.enabled` -> `false`.

Avec Brave, cherchez `brave.stats.enabled` et `brave.p3a.enabled` dans `brave://settings/privacy`, ainsi que les options de recherche privée. Avec Chrome, la désactivation réelle est plus limitée : les options existent dans `chrome://settings/syncSetup` et `chrome://settings/privacy`, mais le lien avec l'écosystème Google rend la coupure incomplète. C'est une raison de plus à mes yeux à privilégier Firefox pour les utilisateurs soucieux.

Un point d'équilibre à connaître : désactiver les rapports de crash rend les bugs plus difficiles pour Mozilla à corriger. Si vous voulez soutenir le projet sans ouvrir votre vie numérique, vous pouvez laisser les rapports de crash actifs tout en coupant les données d'usage. C'est un choix personnel, et aucun n'est « mauvais » — l'important est qu'il soit éclairé.

L'usage rationnel du réseau Tor pour les cas extrêmes

Nous arrivons à l'outil lourd. Tor (The Onion Router) envoie votre trafic à travers une succession de relais chiffrés dans le monde entier, de sorte qu'aucun acteur unique ne voit à la fois votre identité et votre destination. Pour certaines situations — recherche sensible, délation, journalisme, activité dans un pays censuré —, c'est incontournable.

Mais Tor a un coût, et il faut être honnête dessus.

Le coût en vitesse : chaque saut ajoute de la latence. Les sites lourds deviennent pénibles, les vidéos impossible en HD.

Le coût en compatibilité : de nombreux sites bloquent Tor, affichent des captcha sans fin ou refusent les connexions suspectes. Certaines banques et plateformes vous couperont l'accès.

Le coût en identité : si vous vous connectez à votre compte Google ou Facebook via Tor, vous annulez une grande partie de l'anonymat — le réseau voit que ce compte et cette session proviennent de la même adresse à un moment donné.

Le coût en discipline : Tor n'est pas un super-pouvoir. Utilisé à côté d'une session habituelle avec la même identité, il peut donner un faux sentiment de sécurité. Le principe de base : **n'utilisez jamais Tor pour**

© 2026 Oussama Ghorbel

vous connecter à des comptes identifiables, et n'utilisez jamais votre session habituelle pour des activités que vous voulez cacher.

Dans Firefox, `about:config` propose des paramètres de mode Tor, mais la bonne pratique est d'utiliser le navigateur Tor Browser, une distribution de Firefox rigoureusement durcie : connexions forcées en HTTPS, scripts de fingerprinting limités, fenêtre en taille standard pour uniformiser l'empreinte, plugins intégrés. L'installation est simple, l'usage est instantané.

Mon conseil : gardez Tor Browser dans un dossier à part, pour les cas où l'enjeu le justifie. Pour 95 % de votre vie numérique, un Firefox bien configuré, avec conteneurs et cookies tiers bloqués, est largement suffisant. Tor est un outil de précision, pas une solution quotidienne.

Et rappelez-vous : Tor protège votre trafic réseau, pas vos erreurs. Une photo publiée, un message envoyé depuis votre vrai compte, un identifiant réutilisé : autant de failles que le chiffrement ne répare pas.

Ce qu'il faut retenir avant d'aller plus loin

Votre navigateur est le poste-frontière de votre vie numérique. Le blinder demande trois gestes qui se cumulent :

1. **Choisir un moteur indépendant et configurable** — Firefox en tête.
2. **Couper la télémétrie, isoler les contextes, purger le stockage** — trois actions que vous pouvez mener en une heure.
3. **Distinguer l'ordinaire de l'extrême** — un navigateur durci au quotidien, Tor pour les cas qui l'exigent.

Aucune de ces mesures ne vous rend invisible. Ensemble, elles changent radicalement le rapport de force : vous ne disparaissez pas, mais vous cessez d'être une source inépuisable et silencieuse de données. C'est déjà une victoire.

Exercices pratiques

Exercice 1 — Installer Firefox et appliquer une configuration « Hardened »

© 2026 Oussama Ghorbel

1. Téléchargez Firefox depuis `mozilla.org` (attention aux faux sites de téléchargement).

2. Avant toute chose, exportez votre état initial : ouvrez `about:support` et notez les préférences modifiées.

3. Ouvrez `about:config`, acceptez l'avertissement, et créez un fichier `user.js` dans votre profil Firefox avec les clés suivantes (vous pouvez retrouver le chemin du profil via `about:support -> Informations du dossier du profil`) :

4. Redémarrez Firefox. Vérifiez que vos sites habituels fonctionnent. Si un site casse, commentez la ligne responsable dans `user.js` plutôt que d'abandonner l'ensemble.

5. Conservez une copie de votre `user.js` dans un dossier hors ligne : il vous servira à reproduire votre configuration sur un autre ordinateur.

Note importante : `privacy.resistFingerprinting` peut affecter l'affichage de certains sites (zones horaires, taille de fenêtre). Testez avant de vous y fier durablement, et n'adoptez jamais une liste de préférences que vous n'avez pas vérifiée.

Exercice 2 — Créer des conteneurs pour les réseaux sociaux

1. Installez l'extension officielle « Firefox Multi-Account Containers » depuis les add-ons Mozilla.

2. Créez au moins trois conteneurs : `Social`, `Travail`, `Finance`.

3. Ouvrez votre réseau social préféré dans le conteneur `Social` (clic droit sur l'onglet -> Ouvrir dans un conteneur).

4. Configurez les redirections automatiques : à partir de maintenant, tout lien vers un réseau social s'ouvrira dans le conteneur Social.

5. Testez l'isolation : connectez-vous à un service bancaire dans `Finance`, puis ouvrez le réseau social dans `Social`. Vérifiez qu'aucun des deux ne « voit » l'autre (cookies distincts, pas de connexion partagée).

6. Pour aller plus loin, créez un quatrième conteneur « Douteux » pour les liens reçus par message ou les sites que vous testez pour la première fois.

© 2026 Oussama Ghorbel

Exercice 3 — Vérifier HTTPS et la télémétrie

1. Dans `about:config`, activez `dom.security.https_only_mode` à `true`. Rechargez vos sites habituels et notez ceux qui affichent un avertissement.

2. Dans `about:preferences#privacy`, décochez l'envoi de données d'utilisation et de rapports de crash. Relancez le navigateur et vérifiez que `about:config -> datareporting.policy.dataSubmissionEnabled` est bien à `false`.

3. Visitez `badssl.com` et parcourez quelques-unes des pages de test (expired, self-signed, wrong.host). C'est une excellente école pour reconnaître les avertissements légitimes — et comprendre pourquoi il ne faut jamais les contourner par réflexe.

À la fin de ces trois exercices, votre navigateur principal n'est plus le même. Prenez quelques jours pour vous habituer, notez les sites qui posent problème, ajustez un réglage à la fois. La forteresse se construit brique par brique.

© 2026 Oussama Ghorbel

Chapitre 8 – L'arsenal des extensions anti-pistage

L'arsenal des extensions anti-pistage

Au chapitre précédent, j'ai posé les bases de la sécurisation de votre navigateur : mise à jour, paramètres de confidentialité, navigation en fenêtre privée. Mais un navigateur, même correctement réglé, reste une porte ouverte par défaut. Chaque page que vous chargez déclenche des dizaines — parfois des centaines — de requêtes vers des serveurs tiers : des serveurs publicitaires, des compteurs d'audience, des réseaux sociaux, des courtiers en données. Les extensions anti-pistage sont votre première ligne de défense côté client : elles interceptent ces requêtes avant même qu'elles ne quittent votre machine.

Le paradoxe est que l'écosystème des extensions est lui-même un terrain de risque. Trop d'extensions, mal choisies, peuvent annuler vos efforts, ralentir votre navigation, voire devenir une source de collecte supplémentaire. Ce chapitre a pour objectif de vous aider à constituer un arsenal minimal, cohérent et suffisant — pas une collection accumulée au fil des années.

Pourquoi trop d'extensions tuent la confidentialité

Commençons par le compteur. Ouvrez la liste des extensions installées dans votre navigateur et posez-vous une question simple : savez-vous exactement ce que fait chacune d'elles ? Si la réponse est non, vous avez déjà identifié un problème.

Chaque extension que vous installez accorde, par nature, un niveau d'accès élevé à votre navigation. Une extension de modification de page peut lire et modifier le contenu de chaque site que vous visitez. Une extension de gestion de mots de passe doit connaître les formulaires que vous remplissez. Une extension d'analyse de liens inspecte les URL que vous cliquez. Ces permissions sont légitimes quand elles servent l'objectif déclaré de l'outil. Elles deviennent dangereuses quand elles sont inutiles ou quand l'éditeur change de politique.

© 2026 Oussama Ghorbel

Voici les risques concrets d'une accumulation d'extensions :

La surface d'attaque. Chaque extension est du code qui s'exécute dans votre navigateur, souvent sur chaque site. Un code non maintenu, une faille dans une extension abandonnée, et c'est potentiellement l'accès à vos sessions, vos cookies, vos formulaires. Les attaquants raffolent des extensions populaires abandonnées : ils les rachètent sur les stores et y injectent du code malveillant, en profitant de la confiance accumulée par l'éditeur précédent.

Les conflits de filtrage. Deux extensions de blocage simultanées se livrent une guerre silencieuse. L'une supprime un élément du DOM, l'autre essaie de le masquer à son tour, une troisième tente de bloquer la requête réseau correspondante. Résultat : des pages cassées, des boutons qui ne répondent plus, une consommation mémoire inutile, et paradoxalement des failles dans le filtrage, car les règles de l'une peuvent court-circuiter celles de l'autre.

La fuite par l'extension elle-même. Certaines extensions, souvent gratuites, financent leur développement en collectant des données anonymisées — ou pas tant que cela. Le modèle économique « gratuit mais financé par les données » que vous combattez côté sites web se retrouve exactement à l'identique dans le monde des extensions. Lisez la politique de confidentialité avant d'installer.

Le coût performance. Chaque extension ajoute un surcoût à chaque page chargée : analyse du DOM, application des règles, écoute des événements. Avec dix ou quinze extensions actives, vous cumulez des secondes perdues à chaque navigation et une consommation mémoire non négligeable, surtout sur un portable modeste.

La règle que je propose est celle du **minimum vital** : une extension doit répondre à un besoin précis, être maintenue activement, avoir une politique de données claire, et ne pas se chevaucher avec une autre. En pratique, quatre à six extensions bien choisies suffisent largement. Au-delà, vous ajoutez de la complexité sans gain réel.

Un dernier point souvent négligé : la visibilité. Une extension qui affiche un compteur de « trackers bloqués » crée un effet de réassurance — vous vous sentez protégé, vous baissez votre vigilance. Or le chiffre affiché ne dit rien de la qualité du blocage : bloquer mille requêtes

© 2026 Oussama Ghorbel

publicitaires triviales ne vous protège pas contre le traceur subtil qui passe entre les mailles. Utilisez les compteurs comme un indicateur, pas comme une garantie.

uBlock Origin : le roi du filtrage réseau et DOM

Si vous ne deviez en installer qu'une seule, ce serait uBlock Origin. Développé initialement par Raymond Hill (gorhill), cet outil n'est pas — contrairement à ce que son nom suggère — un simple bloqueur de publicités. C'est un moteur de filtrage à la fois réseau et DOM, d'une efficacité et d'une légèreté remarquables.

Le filtrage réseau intervient avant l'envoi de la requête. L'extension compare chaque URL demandée (scripts, images, iframes, requêtes XHR) à ses listes de filtres et bloque celles qui correspondent. La requête ne quitte jamais votre machine : le serveur tiers ne sait même pas que vous avez tenté de la joindre. C'est la défense la plus forte, car elle supprime toute communication.

Le filtrage DOM intervient après le chargement, pour les éléments déjà présents dans la page ou insérés dynamiquement. Il s'agit des éléments « cosmetiques » : bannières, emplacements réservés à la publicité, conteneurs de suivi injectés par JavaScript. Le filtre réseau ne peut pas tout attraper — certains scripts légitimes injectent du contenu — et c'est là qu'intervient cette seconde couche.

L'un des atouts majeurs de uBlock Origin est son architecture multipointeurs (« static net filtering » et « static cosmetic filtering »), qui permet d'appliquer des règles très performantes sans ralentir la navigation. Contrairement à certaines alternatives, il ne pousse pas à la monétisation et ne collecte aucune donnée utilisateur.

Installation et configuration de base

Installez uBlock Origin depuis le store officiel de votre navigateur (Firefox Add-ons ou Chrome Web Store). Attention : sur Chrome/Edge, depuis la transition vers Manifest V3, la version recommandée est « uBlock Origin Lite», tandis que Firefox conserve la version complète. Si vous utilisez Firefox, privilégiez la version classique, qui offre un contrôle plus fin.

© 2026 Oussama Ghorbel

Une fois installée, l'icône du bouclier apparaît dans la barre d'outils. Par défaut, uBlock Origin active déjà des listes de filtres robustes. Pour vérifier et ajuster :

1. Cliquez sur l'icône puis sur le bouton d'ouverture du tableau de bord.
2. Rendez-vous dans l'onglet « Listes de filtres ».
3. Vous y trouverez des catégories prédéfinies : listes de base, listes de privacité, listes de langues, listes de multipartite.

Les listes « de base » suffisent pour un usage courant. Mais pour renforcer la protection, activez les listes de privacy (dont EasyPrivacy et AdGuard Tracking Protection) et, si vous êtes francophone, les listes de filtres régionales correspondant à votre langue.

Le mode avancé

uBlock Origin possède un mode avancé, désactivé par défaut, qui débloque des options supplémentaires : contrôle par onglet, forçage des règles cosmetiques, gestion fine des permissions par site. Pour l'activer : tableau de bord -> Paramètres -> cocher « Je suis un utilisateur avancé ».

Dans ce mode, vous accédez à des réglages puissants :

• **Désactiver le JavaScript par défaut** sur les sites que vous jugez peu fiables. C'est une mesure radicale mais redoutablement efficace : la majorité des traçages modernes reposent sur JavaScript.

• **Appliquer un mode strict** par onglet ou par site via les paramètres avancés (uiLogLevel, strictBlockBalance).

• **Gérer les permissions** : blocage des redirigeurs, des pop-ups, des redirections.

Attention : désactiver le JavaScript casse de nombreux sites. Utilisez ce levier au cas par cas, en vérifiant toujours le rendu de la page.

Le journal des requêtes : votre meilleur outil de diagnostic

Le tableau de bord de uBlock Origin contient un onglet « Journal » (ou « Reading log ») d'une richesse extrême. Il liste en temps réel toutes les requêtes générées par la page courante, avec leur statut (bloquée, autorisée, insérée dans le DOM), leur type (script, image, xhr,

© 2026 Oussama Ghorbel

sous-document), la liste de filtres responsable du blocage, et le domaine d'origine.

Cet outil a deux usages principaux :

1. **Diagnostiquer une page cassée.** Si un site ne fonctionne pas après activation d'uBlock, ouvrez le journal, rechargez la page, et repérez la requête bloquée qui coïncide avec l'élément manquant. Vous pourrez alors créer une exception ponctuelle (cliquer sur l'icône du bouclier et décocher le blocage pour ce site) plutôt que de désactiver entièrement l'extension.

2. **Comprendre l'ampleur du pistage.** Le journal est souvent révélateur : une page d'actualité moyenne peut générer des dizaines de requêtes vers des domaines que vous n'avez jamais entendus nommer. C'est une expérience pédagogique puissante, que nous pratiquons en exercice à la fin de ce chapitre.

Créer ses propres règles

uBlock Origin utilise une syntaxe de filtres relativement simple. Quelques exemples :

- `||example.com^` bloque tout domaine example.com et ses sous-domaines.
- `||example.com^$third-party` bloque uniquement quand le domaine est appelé par un autre site (le cas typique d'un traceur).
- `@@||example.com^$document` crée une exception pour un domaine sur un document donné.
- `##.banniere-pub` masque par règle cosmetique un élément portant cette classe.

La règle d'or : commencez toujours par le filtrage réseau (`||domaine^`) avant de passer au masquage cosmétique. Bloquer la requête est toujours préférable à masquer son résultat.

Privacy Badger et l'apprentissage heuristique

Si uBlock Origin repose sur des listes de filtres — donc sur le travail collaboratif de la communauté — Privacy Badger adopte une approche radicalement différente : l'apprentissage automatique.

© 2026 Oussama Ghorbel

Développé par l'Electronic Frontier Foundation (EFF), Privacy Badger observe le comportement des tiers sur les sites que vous visitez. Si un même domaine est présent sur trois sites distincts et tente de vous identifier via un identifiant persistant (cookie, stockage local), Privacy Badger le considère comme un traceur et bloque ses tentatives de suivi inter-sites. Il ne bloque pas la publicité en soi : il bloque le pistage.

Ce fonctionnement présente un avantage considérable : il s'adapte en temps réel à l'évolution des pratiques, sans dépendre d'une liste mise à jour quotidiennement. Là où une liste de filtres court toujours après les nouveaux acteurs, Privacy Badger apprend de l'observation directe.

Complémentarité avec uBlock Origin

La question revient souvent : faut-il installer les deux ? La réponse est oui, à condition de comprendre leurs rôles respectifs. uBlock Origin est votre filtre principal, exhaustif et documenté. Privacy Badger agit comme un filet de sécurité heuristique, capable d'attraper ce qui échappe aux listes. Ils opèrent à des niveaux différents (liste statique vs comportement dynamique) et ne se chevauchent que marginalement.

Cependant, évitez d'empiler les bloqueurs au-delà de ces deux-là. Ajouter un troisième outil de filtrage introduit plus de conflits que de protection.

Configuration recommandée

Privacy Badger est volontairement simple : il fonctionne presque sans réglage. Quelques options méritent votre attention dans les paramètres :

• **Désactiver le suivi par cookie tiers** : activé par défaut, gardez-le.

• **Envoyer un signalement Do Not Track (DNT)** : option discutable. Certaines études suggèrent que le signal DNT, quand il est actif, peut paradoxalement vous rendre plus identifiable — un marqueur parmi des millions. À activer selon votre philosophie personnelle.

• **Apprentissage automatique** : gardez-le activé, c'est le cœur du fonctionnement de l'outil.

© 2026 Oussama Ghorbel

Privacy Badger affiche un tableau de bord par site : il vous montre quels tiers ont été bloqués, autorisés ou mis en « lecture seule » (autorisation partielle). Prenez le temps de consulter ce tableau de bord régulièrement : il constitue une cartographie vivante de qui tente de vous suivre.

Une nuance importante : Privacy Badger ne remplace pas uBlock Origin pour le blocage publicitaire classique. Il ne cible pas la publicité en tant que telle, seulement les mécanismes de suivi. Si votre objectif est aussi la réduction du bruit publicitaire et la performance des pages, uBlock Origin reste indispensable.

ClearURLs : nettoyer les liens de tracking (UTM)

Vous avez déjà remarqué ces URL interminables quand vous cliquez sur un lien depuis une newsletter ou un réseau social ? Quelque chose comme :

`https://boutique-exemple.fr/produit?id=42&utm_source=newsletter&utm_medium=email&utm_campaign=soldes_2024&fbclid=IwAR2xyz...`

Les paramètres `utm_*` (Medium, Source, Campaign, Term, Content) sont des marqueurs de campagne publicitaire. `fbclid`, `gclid`, `msclkid` sont des identifiants attribués par Facebook, Google et Bing. `igshid` identifie Instagram. Ces paramètres ne servent à rien pour le bon fonctionnement de la page : ils servent uniquement à attribuer votre visite à une campagne, et donc à vous suivre dans votre parcours d'achat ou de navigation.

ClearURLs est une extension légère qui intervient au moment où vous cliquez sur un lien. Elle analyse l'URL, retire les paramètres de traçage connus, et vous redirige vers l'URL « propre ». La requête part sans vos empreintes.

Ce que ClearURLs supprime

Le cœur de l'extension repose sur des règles de nettoyage maintenues par la communauté. Elle retire notamment :

• Les paramètres `utm_*` (les plus répandus).

© 2026 Oussama Ghorbel

• Les identifiants de clic publicitaire (`fbclid`, `gclid`, `dclid`, `msclkid`, `twclid`, etc.).

• Les identifiants d'affiliation excessifs (dans une moindre mesure).

• Certains fragments de tracking dans les URLs raccourcies ou redirigées.

L'extension traite également les redirections : certains liens passent d'abord par un domaine intermédiaire qui vous identifie, puis vous redirige vers la destination. ClearURLs peut intercepter et nettoyer cette chaîne.

Limites à connaître

ClearURLs ne vous protège pas contre le pistage par cookie, par empreinte navigateur ou par identifiant côté serveur. Si le site vous reconnaît parce que vous êtes connecté, le nettoyage de l'URL ne change rien. C'est un outil de réduction d'empreinte, pas un bouclier complet. Il est complémentaire, non substituable.

De plus, un nettoyage trop agressif peut, dans de rares cas, casser un lien qui dépend légitimement d'un paramètre. Si un lien ne fonctionne plus après installation, vous pouvez désactiver temporairement ClearURLs et vérifier.

Sa légèreté est son atout : elle n'analyse pas le DOM, n'écoute pas les requêtes réseau, se contente de transformer les URL. Le coût performance est quasi nul. C'est une des rares extensions qu'on peut installer sans hésitation.

LocalCDN : remplacer les bibliothèques externes

Voici un risque souvent invisible : les **CDN de scripts tiers**.

De nombreux sites importent leurs bibliothèques JavaScript (jQuery, Bootstrap, Font Awesome, Angular, React, etc.) non pas depuis leur propre serveur, mais depuis un CDN tiers : `code.jquery.com`, `cdn.jsdelivr.net`, `ajax.googleapis.com`, `cdnjs.cloudflare.com`, et d'autres.

Quand votre navigateur charge une page contenant `<script src="https://ajax.googleapis.com/ajax/libs/jquery/3.6.0/jquery.min.js">`, il

© 2026 Oussama Ghorbel

contacte le serveur Google. Même si le script est public et ne contient aucun traceur, cette requête transmet des informations : votre adresse IP, votre User-Agent, l'URL exacte de la page que vous consultez, la date, l'heure. Le CDN concerné — s'il est tenu par une grande entreprise — croise ces données avec tout ce qu'il sait déjà de vous via ses autres services. Vous avez ainsi « révélé » votre visite à un tiers qui n'avait absolument pas besoin de le savoir.

LocalCDN résout ce problème en interceptant ces requêtes et en les servant depuis des copies locales stockées dans l'extension. Le fichier jQuery chargé est le même (vérifié par hash de contenu), mais la requête ne quitte pas votre machine.

Comment ça fonctionne

LocalCDN maintient une base de données des fichiers les plus courants, avec leur hash d'intégrité. Quand une page demande un fichier depuis un CDN connu, l'extension :

1. Détecte l'URL du CDN.
2. Vérifie si elle dispose localement de la version exacte demandée.
3. Si oui, elle sert le fichier local à la place, et la requête externe est annulée.
4. Si non (version inconnue), elle laisse passer la requête d'origine pour ne pas casser la page.

Ce mécanisme est transparent : le site fonctionne normalement, mais ne contacte plus le CDN tiers.

Quand l'utiliser ?

LocalCDN est particulièrement pertinent si :

• Vous utilisez uBlock Origin en mode strict et voulez éviter de dépendre d'un CDN pour le fonctionnement des sites.

• Vous souhaitez réduire votre exposition aux grands fournisseurs d'infrastructure web (Google, Cloudflare, Amazon).

• Vous naviguez sur des connexions lentes : les fichiers servis localement se chargent instantanément après le premier téléchargement.

© 2026 Oussama Ghorbel

Attention à un point : l'extension ne couvre pas tous les CDN, et pas toutes les versions. Un site utilisant une version très récente d'une bibliothèque ne sera peut-être pas pris en charge. C'est acceptable : le repli est toujours la requête d'origine.

LocalCDN n'est pas une extension critique au même titre qu'uBlock Origin. Installez-la si le concept vous parle et si vous voulez un contrôle maximal ; sinon, elle peut attendre.

Gérer les permissions et les mises à jour de sécurité

Installer une extension, ce n'est pas « l'installer et oublier ». C'est entrer dans une relation continue avec un logiciel qui dispose d'un accès étendu à votre vie numérique. Voici comment maintenir cette relation sous contrôle.

Lire les permissions avant d'installer

Les stores affichent les permissions demandées par chaque extension. Prenez-les au sérieux :

- **« Lire et modifier toutes les données des sites web »** : c'est le niveau le plus élevé. Justifié pour un bloqueur de contenu (il doit analyser le DOM), abusif pour une extension qui se contente de changer l'apparence d'une icône.
- **« Accéder à votre historique de navigation »** : nécessaire pour certaines extensions de gestion de l'historique, suspect pour un thème visuel.
- **« Gérer vos téléchargements »**, **« communiquer avec les applications natives »**, **« accéder aux onglets »** : chaque permission est une porte. Multipliez-les et vous multipliez les accès.

Si une extension demande des permissions sans lien avec son fonctionnement déclaré, passez votre chemin. Les meilleurs outils demandent le minimum.

Vérifier régulièrement les extensions installées

Toutes les deux ou trois mois, prenez cinq minutes pour :

1. Ouvrir la page des extensions de votre navigateur.

© 2026 Oussama Ghorbel

2. Pour chacune, vérifier la date de dernière mise à jour. Une extension sans mise à jour depuis plus d'un an est un signal d'alarme — sauf si elle est par nature stable et sans dépendances.

3. Vérifier qu'elle est toujours publiée par le même éditeur (le changement d'éditeur est un indicateur classique de rachat malveillant).

4. Lire les permissions actuelles, qui peuvent avoir évolué entre deux versions.

5. Désactiver ou supprimer celles que vous n'utilisez plus.

Les mises à jour de sécurité

Les navigateurs modernes mettent à jour les extensions automatiquement, y compris pour les vulnérabilités de sécurité. Ce mécanisme est votre allié. Ne le désactivez pas.

En revanche, restez vigilant face aux mises à jour qui modifient substantiellement les permissions. Un outil qui demande soudainement l'accès à l'historique de navigation alors qu'il n'en avait pas besoin hier mérite que vous lisiez le changelog (journal des modifications) avant d'accepter.

Sur Firefox, vous pouvez limiter les mises à jour automatiques à la seule catégorie « sécurité » via les préférences, si vous préférez garder la main. Sur Chrome, le contrôle est plus limité.

Le principe de moindre privilège appliqué aux extensions

Emprunté à la cybersécurité, ce principe s'énonce ainsi : chaque composant ne doit disposer que des droits strictement nécessaires à son fonctionnement. Appliquez-le à votre arsenal :

• Si une extension n'a pas besoin d'accéder à tous les sites, restreignez son domaine d'action.

• Si une extension peut être désactivée sur les sites sensibles (banque, messagerie), faites-le.

• Si deux extensions font la même chose, gardez celle dont la politique de données est la plus claire.

© 2026 Oussama Ghorbel

Une note sur les « super-extensions »

Méfiez-vous des extensions qui promettent tout : blocage de publicité, VPN, gestionnaire de mots de passe, générateur de mots de passe, chiffrement de fichiers, lecteur QR, conversion d'unités, météo — le tout en un seul paquet. Ce type d'outil concentre trop de permissions, augmente la surface d'attaque, et rend impossible l'analyse fine de son comportement. Préférez des outils spécialisés, audités, avec une base de code quand elle est ouverte.

Un VPN installé comme extension mérite lui aussi votre prudence : une extension VPN doit capturer tout votre trafic pour le rediriger. C'est exactement le type de permission que vous devriez accorder avec le plus de réflexion. (Nous y reviendrons dans le chapitre sur le cloud souverain et le chiffrement.)

Exercice pratique : configurer uBlock Origin et analyser le journal

L'objectif de cet exercice est double : renforcer votre liste de filtres, puis apprendre à lire le journal des requêtes pour comprendre ce qui se passe réellement quand vous chargez une page.

Durée estimée : 30 à 45 minutes.

Étape 1 : activer les listes de filtres avancées

1. Ouvrez uBlock Origin (icône du bouclier -> tableau de bord).

2. Allez dans l'onglet « Listes de filtres ».

3. Recherchez et activez les listes suivantes :

• **EasyPrivacy** : la référence pour le blocage des outils de suivi, maintenue par la communauté FilterLists.

• **AdGuard Tracking Protection** : complémentaire, cible les traceurs connus avec une approche différente.

• *(Optionnel)* **Peter Lowe's Ad and tracking server list** : liste compacte, efficace, à faible coût en performance.

4. Cliquez sur « Appliquer les changements » (icône des ronds en bas à gauche). Patientez le temps que les listes se téléchargent.

© 2026 Oussama Ghorbel

Vérifiez ensuite que le compteur de listes actives a bien augmenté.

Étape 2 : ouvrir le journal et charger une page

1. Allez dans l'onglet « Journal » du tableau de bord.

2. Dans une nouvelle fenêtre, chargez un site que vous visitez régulièrement (un site d'actualités, un blog, un site marchand).

3. Revenez au journal. Vous verrez s'afficher une liste de requêtes, avec pour chacune :

• Le domaine demandé.

• Le type (script, image, css, xhr, sous-document, média…).

• Le statut (bloquée, autorisée, masquée).

• La raison (quelle liste de filtres a déclenché le blocage).

Étape 3 : analyser

Prenez dix minutes pour observer et noter :

1. **Combien de requêtes ont été bloquées ?** Comparez le chiffre global à ce que vous imaginiez.

2. **Quels domaines apparaissent le plus souvent ?** Vous découvrirez probablement des noms comme `doubleclick.net`, `scorecardresearch.com`, `criteo.com`, `hotjar.com`, `taboola.com` — autant de sociétés dont l'activité première est la collecte de données.

3. **Quelles listes sont responsables des blocages ?** Cliquez sur une ligne bloquée : le journal indique la règle et la liste d'origine. Vous constaterez qu'EasyPrivacy et AdGuard Tracking interviennent massivement.

4. **Repérez une requête légitime bloquée à tort** (si la page semble cassée). Essayez de créer une exception ponctuelle pour elle.

Étape 4 : la comparaison sans extension

Pour mesurer l'impact, désactivez temporairement uBlock Origin (clic droit sur l'icône -> « Désactiver sur ce site ») et rechargez la page. Ouvrez l'onglet Réseau des outils de développement (F12 -> Réseau) et observez le nombre de requêtes. Réactivez uBlock, rechargez, comparez.

© 2026 Oussama Ghorbel

Ce type de mesure, faite une fois, suffit souvent à dissuader quiconque serait tenté d'abandonner ses extensions « parce que ça ralentit » ou « parce que ça casse des sites ». Dans la très grande majorité des cas, le blocage réduit le nombre de requêtes, accélère le chargement, et n'altère pas le contenu utile.

Étape 5 : ajuster sans excès

Après quelques jours d'utilisation avec les nouvelles listes, vérifiez s'il y a des sites qui posent problème. Créez des exceptions ponctuelles plutôt que de désactiver l'extension globalement. La règle est la suivante : le blocage est la norme, l'exception est l'exception — et elle doit être justifiée.

À l'issue de ce chapitre, votre navigateur dispose d'un arsenal cohérent : un moteur de filtrage réseau et DOM performant (uBlock Origin), un filet heuristique adaptatif (Privacy Badger), un nettoyeur d'URL léger (ClearURLs) et, si vous le souhaitez, un substitut local aux CDN tiers (LocalCDN). Quatre outils, des rôles distincts, aucun chevauchement majeur, et une surveillance régulière de leurs permissions.

C'est cette sobriété — et non l'accumulation — qui fait la force d'une configuration. Dans le chapitre suivant, nous déplacerons un cran plus en amont : celui de la requête initiale, du moteur de recherche que vous utilisez et des alternatives qui réduisent votre exposition avant même que le premier clic ne soit effectué.

© 2026 Oussama Ghorbel

Chapitre 9 – Moteurs de recherche et confidentialité

La barre de recherche est sans doute le confessionnal le plus intime de notre époque. Chaque jour, nous y déversons nos angoisses médicales, nos interrogations financières, nos projets de voyage, nos envies d'achat et nos curiosités les plus inavouables. Nous y tapons des questions que nous n'oserions jamais poser à voix haute, même à nos proches. Pourtant, nous livrons ces pensées brutes, ces intentions pures, à des entreprises dont le modèle économique repose sur la prédiction et la monétisation de nos comportements futurs.

Échapper à l'historique de recherche centralisé n'est pas seulement une question de confidentialité ; c'est un acte de préservation intellectuelle. C'est refuser que notre vision du monde soit modelée par des algorithmes conçus pour maximiser le temps de cerveau disponible. Dans ce chapitre, nous allons décortiquer le monopole de la recherche traditionnelle, explorer les alternatives qui respectent votre vie privée, et comprendre comment reprendre le contrôle de la porte d'entrée de votre internet.

Le monopole de Google et l'aspiration de données

Pour comprendre l'ampleur du problème, il faut d'abord saisir ce qu'est réellement un moteur de recherche moderne. Ce n'est pas un simple bibliothécaire numérique qui vous tend un livre lorsque vous lui donnez un mot-clé. C'est une machine à profiler, un aspirateur d'intentions.

Google détient une part de marché mondiale avoisinant les 90 % sur la recherche mobile et desktop. Ce monopole de facto lui confère un pouvoir sans précédent sur l'information mondiale. Mais le véritable génie de Google ne réside pas uniquement dans la pertinence de son algorithme PageRank historique ; il réside dans sa capacité à relier votre requête de recherche à l'ensemble de votre écosystème numérique.

Lorsque vous effectuez une recherche sur Google en étant connecté à votre compte (ce qui est le cas par défaut sur Android, Chrome, ou

© 2026 Oussama Ghorbel

lorsque vous utilisez Gmail), cette requête n'est pas isolée. Elle vient enrichir un profil sémantique gigantesque. Google croise votre recherche « symptômes fatigue chronique » avec votre historique de localisation (êtes-vous allé près d'une clinique ?), vos emails (avez-vous reçu des résultats d'analyses ?), et vos vidéos visionnées sur YouTube. Le résultat n'est pas seulement une liste de liens ; c'est une modélisation de votre état physique, mental et financier à un instant T.

C'est ici qu'intervient le concept de « bulle de filtre », théorisé par le militant d'internet Eli Pariser. Dans son ouvrage *The Filter Bubble*, Pariser explique que les algorithmes de personnalisation nous enferment progressivement dans un univers informationnel qui reflète et renforce nos croyances préexistantes. Si deux personnes tapent exactement la même requête sur un sujet politique ou scientifique sensible, Google ne leur affichera pas les mêmes résultats. L'algorithme va privilégier les sources qui correspondent au profil psychographique et historique de l'utilisateur.

Cette personnalisation invisible a des conséquences profondes. Elle crée une réalité sur mesure, isolant les individus dans des chambres d'écho et polarisant le débat public. Vous ne cherchez plus l'information ; c'est l'information, triée sur le volet par une intelligence artificielle optimisée pour l'engagement, qui vient à vous.

De plus, le pistage ne s'arrête pas à la page de résultats (la SERP). Google utilise des outils omniprésents comme Google Analytics ou Google Fonts sur des millions de sites tiers. Ainsi, même si vous cliquez sur un résultat et quittez le moteur de recherche, le traqueur de Google présent sur le site de destination sait que vous venez d'effectuer cette recherche spécifique. La boucle est bouclée : l'intention (la recherche) est liée à l'action (la visite, l'achat, le temps de lecture). Pour briser cette chaîne, il est impératif de changer de créancier informationnel.

DuckDuckGo : forces et limites du modèle publicitaire contextuel

Le canard orange, DuckDuckGo (DDG), a été le premier acteur majeur à populariser l'idée que la recherche sur internet pouvait se faire sans espionnage. Fondé par Gabriel Weinberg, DDG a bâti son succès sur une promesse simple et percutante : « Le moteur de recherche qui ne

© 2026 Oussama Ghorbel

vous piste pas. »

Les forces de DuckDuckGo

La force principale de DDG réside dans son refus de créer un profil utilisateur. Contrairement à Google, DuckDuckGo ne stocke pas votre adresse IP, n'utilise pas de cookies de pistage persistants et ne lie pas vos requêtes successives à un identifiant unique. Si vous recherchez « voiture électrique » le matin et « vacances en Italie » le soir, DDG ne tentera pas de vous vendre des bornes de recharge pour votre hôtel à Rome.

DuckDuckGo a également démocratisé des fonctionnalités brillantes pour la confidentialité, comme le blocage des traqueurs tiers et le forçage du chiffrement HTTPS. Son extension pour navigateurs et son application mobile dédiée offrent un bouclier de base excellent pour le grand public.

Le modèle publicitaire contextuel

Cependant, DuckDuckGo est une entreprise commerciale qui doit générer des revenus. Comment un moteur de recherche peut-il être gratuit et rentable sans vendre de données ? La réponse tient en un mot : le contexte.

DDG utilise un modèle de publicité *contextuelle* et non *comportementale*. Si vous tapez « meilleur ordinateur portable », DuckDuckGo affichera des publicités pour des ordinateurs portables. Mais ces publicités sont déclenchées uniquement par les mots-clés de votre requête immédiate, et non par votre historique des six derniers mois. Dès que vous fermez l'onglet, la publicité disparaît et n'est pas rattachée à un profil fantôme. C'est une distinction fondamentale qui préserve votre intimité tout en permettant au service de survivre.

Les limites et la controverse Microsoft

Il serait malhonnête de présenter DuckDuckGo comme une forteresse impénétrable sans aborder ses limites techniques et ses controverses. Premièrement, construire un index web mondial (la base de données de toutes les pages d'internet) coûte des milliards de dollars. DuckDuckGo ne possède pas son propre index complet ; il s'appuie principalement sur l'API de Microsoft Bing pour fournir ses résultats

© 2026 Oussama Ghorbel

organiques, complétée par quelques sources propres et du crowdsourcing. Cela signifie que les résultats que vous voyez sont, en grande partie, le reflet de l'algorithme de Microsoft.

En 2022, une controverse a éclaté lorsque des chercheurs en sécurité ont découvert que l'application mobile et l'extension de navigateur DuckDuckGo ne bloquaient pas les scripts de pistage de Microsoft (liés à LinkedIn et Bing Ads) en raison d'un accord contractuel entre les deux entreprises. Bien que DuckDuckGo ait rapidement corrigé le tir et mis fin à ces exceptions suite au tollé de sa communauté, cet incident a rappelé une règle d'or en cybersécurité : la confiance absolue n'existe pas, et la transparence doit être continue. DuckDuckGo reste une excellente passerelle pour s'éloigner de Google, mais les utilisateurs les plus exigeants chercheront peut-être une indépendance algorithmique plus poussée.

Qwant et les moteurs européens

Face à l'hégémonie des géants américains, l'Europe a tenté de développer ses propres alternatives, motivée par une volonté de souveraineté numérique et par le cadre strict du Règlement Général sur la Protection des Données (RGPD).

Qwant : la souveraineté à la française

Lancé en France, Qwant s'est positionné comme le moteur de recherche qui « respecte votre vie privée et vos libertés ». Dès ses débuts, Qwant a promis l'absence de pistage et de bulle de filtre : deux personnes recherchant le même terme au même moment obtiendront strictement les mêmes résultats.

Qwant a longtemps souffert du même syndrome que DuckDuckGo : une dépendance forte à l'index de Bing pour garantir des résultats de qualité. Cependant, l'entreprise a investi massivement ces dernières années pour développer son propre robot d'indexation (Qwantify) et bâtir un index européen indépendant. Utiliser Qwant, c'est aujourd'hui soutenir une infrastructure technique locale, soumise au droit européen, et dont les serveurs ne sont pas assujettis au Cloud Act américain (qui permet aux autorités US d'accéder aux données hébergées par des entreprises américaines, où qu'elles se trouvent).

© 2026 Oussama Ghorbel

Startpage : le proxy hollandais

Si votre priorité absolue est d'obtenir la *qualité* des résultats de Google sans subir le *pistage* de Google, Startpage est l'outil qu'il vous faut. Basé aux Pays-Bas, Startpage a adopté un modèle fascinant : celui du proxy anonyme.

Lorsque vous faites une recherche sur Startpage, le moteur agit comme un intermédiaire. Il prend votre requête, la dépouille de tous ses métadonnées identifiantes, et la soumet anonymement à Google. Google renvoie les résultats à Startpage, qui vous les affiche. Aux yeux de Google, la requête provient des serveurs de Startpage, et non de votre adresse IP. Vous bénéficiez de la pertinence de l'algorithme de Google, tout en restant un fantôme.

Startpage propose également une fonctionnalité extraordinaire appelée « Vue Anonyme » (Anonymous View). À côté de chaque résultat de recherche, une petite icône vous permet de visiter le site web via un proxy. Le site de destination ne verra que l'adresse IP de Startpage, masquant ainsi votre identité réelle, votre localisation et votre navigateur. C'est un outil inestimable pour consulter des forums sensibles, des documentation techniques pointues ou des articles de presse sans déclencher de paywalls ou de cookies de rétorsion.

Ecosia : l'alternative écologique

Il convient également de mentionner Ecosia. Bien que son modèle repose aussi sur les résultats de Bing, Ecosia se distingue par son engagement environnemental, utilisant ses revenus publicitaires pour planter des arbres. D'un point de vue strictement lié à la confidentialité, Ecosia ne vend pas vos données aux annonceurs externes et chiffre les requêtes, mais il conserve des journaux de connexion temporaires pour prévenir les fraudes. C'est un choix éthique et écologique pertinent, à condition d'accepter ce léger compromis sur l'anonymat strict au profit de la reforestation.

Brave Search et l'index indépendant

Pour les puristes de la confidentialité, la dépendance aux index de Big Tech (Google ou Bing) reste un problème. Confier ses requêtes à un moteur qui utilise l'index de Microsoft, c'est accepter que la cartographie

© 2026 Oussama Ghorbel

du web visible soit décidée par une poignée d'acteurs de la Silicon Valley. C'est pour répondre à ce problème fondamental que Brave a lancé **Brave Search**.

Brave, connu pour son navigateur bloqueur de publicités, a pris le taureau par les cornes en construisant son propre index web à partir de zéro (notamment via l'acquisition de la base de données de Tailcat). Aujourd'hui, Brave Search repose sur son propre robot d'indexation, ce qui en fait l'un des rares moteurs de recherche véritablement indépendants au monde, aux côtés de Google, Bing et Yandex.

L'indépendance algorithmique

Avoir son propre index signifie que Brave décide de ses propres règles de classement. Il n'est pas obligé de censurer, de déclasser ou de mettre en avant certains contenus pour satisfaire les annonceurs ou les pressions politiques qui pourraient s'exercer sur Microsoft ou Google. Brave Search ne vous piste pas, ne profile pas vos requêtes et offre une transparence rare sur la provenance de ses résultats.

Les Goggles : démocratiser le classement

La fonctionnalité la plus révolutionnaire de Brave Search s'appelle les « Goggles » (littéralement, des lunettes ou des filtres). Plutôt que de vous imposer une boîte noire algorithmique qui décide de ce qui est « pertinent », Brave vous permet d'appliquer vos propres règles de classement.

Par exemple, vous pouvez activer un Goggle créé par la communauté qui déclasse systématiquement les fermes de contenu SEO, les sites d'actualité remplis de publicités, et qui remonte en priorité les forums de discussion (comme Reddit ou StackOverflow) et les blogs techniques indépendants. Vous reprenez ainsi le contrôle sur la sémantique de votre recherche. Si vous cherchez une recette de cuisine, vous pouvez appliquer un Goggle qui masque les sites publiant des romans de 3000 mots avant la recette, pour ne garder que les blogs concis. C'est une avancée majeure contre la pollution du web moderne.

Recherche locale et confidentialité

La recherche locale (trouver un restaurant ou un magasin près de chez soi) est traditionnellement un cauchemar pour la vie privée, car elle

© 2026 Oussama Ghorbel

nécessite de partager sa position GPS précise. Brave Search a résolu ce problème en s'associant à Apple Maps pour les requêtes locales, mais en agissant comme un proxy. Votre requête est envoyée à Apple sans votre identifiant, et les résultats vous sont renvoyés. Vous trouvez votre pizzéria sans que votre téléphone ne trace un historique de vos déplacements gastronomiques.

Kagi et les moteurs payants sans pub

Il existe un adage bien connu dans la Silicon Valley : « Si c'est gratuit, c'est vous le produit. » Mais que se passe-t-il lorsque vous décidez de payer pour redevenir le client ? C'est le pari audacieux de **Kagi** (prononcé *kah-gee*), un moteur de recherche qui a choisi de rompre totalement avec le modèle publicitaire.

Le paradigme de l'abonnement

Kagi fonctionne sur un modèle d'abonnement mensuel (environ 10 $ par mois, avec des périodes d'essai). Ce choix radical aligne parfaitement les intérêts de l'entreprise avec ceux de l'utilisateur. Kagi n'a aucun annonceur à satisfaire, aucun clic à maximiser, aucune publicité à insérer entre vous et l'information. L'unique objectif de Kagi est de vous fournir la réponse la plus rapide, la plus propre et la plus pertinente possible, pour que vous puissiez fermer l'onglet et retourner à votre vie.

Note : Bien que souscrire à un service payant représente une dépense financière, il ne s'agit pas ici d'un conseil en investissement ou en gestion de patrimoine, mais d'une stratégie de consommation numérique visant à racheter votre temps et votre attention.

L'arsenal de la personnalisation

Kagi pousse la personnalisation à un niveau inégalé, non pas en vous profilant à votre insu, mais en vous donnant un tableau de bord explicite pour configurer votre propre moteur de recherche.

• **Blocage et Boost de domaines :** Vous en avez assez des sites de recettes truffés de pop-ups ? Bloquez-les définitivement de vos résultats. Vous préférez la documentation officielle de Mozilla ou les vidéos de la chaîne PBS ? Boostez-les pour qu'ils apparaissent

© 2026 Oussama Ghorbel

toujours en premier.

• **Les Lenses (Lentilles) :** Kagi propose des filtres de recherche préconfigurés. La lentille « Academic » restreint les résultats aux publications scientifiques et aux universités. La lentille « Forums » ne cherche que dans les discussions communautaires (Reddit, HackerNews), là où se trouve souvent la vraie expertise humaine, loin des articles générés par intelligence artificielle.

• **Résumé par IA (Quick Answer) :** Kagi intègre un modèle de langage qui synthétise les résultats de recherche en un paragraphe clair, tout en citant scrupuleusement les sources avec des liens cliquables, vous évitant de visiter cinq sites différents pour extraire une simple information.

Le rejet du pistage d'affiliation

Un détail qui illustre la philosophie de Kagi : lorsque vous cliquez sur un lien vers un produit (par exemple sur Amazon), Kagi ne modifie pas l'URL pour y insérer son propre code d'affiliation. La plupart des sites de comparaison ou des moteurs gratuits le font pour toucher une commission sur votre achat. Kagi, déjà rémunéré par votre abonnement, respecte votre transaction et votre vie privée jusqu'au bout. C'est une expérience de recherche d'une pureté absolue, qui rappelle les premières heures d'internet, avant sa marchandisation extrême.

Configurer son moteur par défaut sur tous ses appareils

Connaître les alternatives est la première étape. Les adopter au quotidien en est une autre. En psychologie comportementale, le « biais du statu quo » (ou *Default Effect*) démontre que les humains ont une tendance écrasante à conserver les options par défaut, même lorsqu'elles sont sous-optimales. Si vous devez taper manuellement l'adresse de votre moteur privé à chaque recherche, vous finirez par retomber sur Google par simple fatigue cognitive ou habitude musculaire.

La clé du succès réside dans la configuration du moteur par défaut à l'échelle du système. Voici comment verrouiller vos écoutilles sur les principaux environnements.

Sur les navigateurs de bureau

© 2026 Oussama Ghorbel

• **Firefox :** Allez dans `Paramètres > Recherche`. Dans « Moteur de recherche par défaut », choisissez votre alternative. Si elle n'apparaît pas (comme Kagi ou Startpage), cliquez sur « Ajouter d'autres moteurs de recherche » ou utilisez l'URL de recherche fournie par le service (souvent disponible dans les paramètres de votre compte sur leur site) pour l'ajouter manuellement via le champ de recherche.

• **Chrome / Edge / Brave :** Le chemin est similaire : `Paramètres > Moteur de recherche > Gérer les moteurs de recherche`. Pour les moteurs indépendants, vous devrez souvent cliquer sur « Ajouter » et renseigner trois champs : le nom du moteur, le mot-clé (ex: `kagi`), et l'URL de la requête contenant `%s` à la place des mots-clés (ex: `https://kagi.com/search?q=%s`).

• **Safari (macOS) :** Allez dans `Safari > Réglages > Recherche`. Apple, soucieux de son image en matière de vie privée, a récemment intégré DuckDuckGo et Ecosia directement dans le menu déroulant, facilitant grandement la transition.

Sur les appareils mobiles : le véritable défi

Les systèmes d'exploitation mobiles sont conçus pour verrouiller l'utilisateur dans les services de leurs créateurs.

• **iOS (iPhone/iPad) :** Apple permet de changer le moteur de recherche par défaut de Safari. Allez dans `Réglages > Safari > Moteur de recherche`. Vous pouvez y sélectionner DuckDuckGo, Ecosia ou Brave Search. Si vous préférez Startpage ou Kagi, la méthode la plus simple sur iOS est d'installer leur application officielle, qui permet d'ajouter un « Profil de configuration » ou un raccourci web agissant comme un moteur de recherche natif dans Safari.

• **Android :** Sur Chrome pour Android, Google ne permet *pas* de changer le moteur de recherche par défaut si vous êtes connecté à votre compte Google, ou limite drastiquement les choix. La solution la plus robuste sur Android consiste à abandonner Chrome au profit de Firefox pour Android ou du navigateur Brave, qui vous laissent une liberté totale pour définir n'importe quel moteur (y compris via URL personnalisée) comme défaut. Vous pouvez ensuite définir ce navigateur comme application par défaut pour ouvrir les liens web

© 2026 Oussama Ghorbel

dans les paramètres de votre téléphone.

Au niveau du système d'exploitation

N'oubliez pas les barres de recherche intégrées à votre ordinateur.

• **Sur Mac :** Des outils comme *Raycast* ou *Alfred* remplacent avantageusement le Spotlight natif d'Apple et vous permettent de configurer des raccourcis clavier qui lancent directement une recherche sur Kagi ou Brave, sans jamais passer par Safari.

• **Sur Windows :** La recherche du menu Démarrer est malheureusement profondément intégrée à Bing et à la télémétrie de Microsoft. Il est fortement recommandé d'utiliser des lanceurs d'applications tiers comme *PowerToys Run* ou *Flow Launcher*, que vous pouvez configurer pour interroger votre moteur privé favori via le raccourci `Alt + Espace`.

Exercices pratiques : Prendre le pouvoir sur vos requêtes

La théorie ne vaut rien sans la pratique. Pour ancrer ces nouvelles habitudes et rendre votre navigation à la fois plus privée et plus productive, réalisez les deux exercices suivants. Ils vous prendront moins de trente minutes, mais vous feront gagner des heures sur le long terme.

Exercice 1 : La Grande Migration et l'Audit des Raccourcis

1. **Choisissez votre champion :** En fonction de votre philosophie (DuckDuckGo pour la gratuité et la simplicité, Brave pour l'indépendance de l'index, Startpage pour la qualité Google anonymisée, ou Kagi pour la puissance absolue sans pub), sélectionnez *un* moteur principal.

2. **Appliquez le changement universel :** Prenez 15 minutes pour modifier le moteur par défaut sur votre navigateur de bureau, votre navigateur mobile, et votre application de navigation par défaut.

3. **Nettoyez les favoris :** Supprimez le raccourci « Google » de votre barre de favoris et de votre page d'accueil. Remplacez-le par votre nouveau moteur. Si vous avez l'habitude d'ouvrir un nouvel onglet pour chercher, configurez la page « Nouvel onglet » de votre navigateur pour qu'elle affiche directement la barre de recherche de

© 2026 Oussama Ghorbel

votre alternative (la plupart des extensions de ces moteurs le permettent).

4. **Vérifiez la fuite :** Après une semaine d'utilisation, consultez le tableau de bord de confidentialité de votre compte Google (Google Takeout ou Mon Activité). Vous devriez constater une chute verticale, voire un arrêt total, de l'enregistrement des activités de recherche web.

Exercice 2 : Maîtriser les « Bangs » pour une productivité fulgurante

L'une des raisons pour lesquelles les utilisateurs hésitent à quitter Google est la perte de certains raccourcis intégrés. Les moteurs comme DuckDuckGo, Brave et Kagi ont résolu ce problème avec les **Bangs** (ou raccourcis de recherche). Un Bang est un mot-clé commençant par un point d'exclamation (`!`) qui vous permet de chercher directement sur un site spécifique, sans avoir à vous y rendre d'abord.

Votre mission : Configurez et mémorisez au moins 5 Bangs essentiels à votre quotidien. Voici les plus populaires à tester dès maintenant dans votre nouvelle barre de recherche :

• **`!w` (Wikipédia) :** Tapez `!w révolution française` pour atterrir directement sur l'article Wikipédia, sans passer par la page de résultats intermédiaire.

• **`!yt` (YouTube) :** Tapez `!yt tutoriel linux` pour lancer directement la recherche sur YouTube.

• **`!a` (Amazon) ou `!r` (Reddit) :** Idéal pour chercher des avis de produits ou des discussions communautaires sans être pollué par les blogs sponsorisés.

• **`!map` (Maps) :** Tapez `!map restaurant italien lyon` pour ouvrir directement votre application cartographique préférée (comme OpenStreetMap ou Apple Maps selon le moteur).

• **`!gi` (Google Images) :** Si vous avez *vraiment* besoin de la base de données d'images de Google pour un projet précis, ce Bang vous y envoie anonymement.

Pour aller plus loin (Spécifique à Kagi et DuckDuckGo) :

© 2026 Oussama Ghorbel

Allez dans les paramètres de votre moteur pour créer vos **propres Bangs personnalisés**. Par exemple, si vous travaillez dans la tech, créez un Bang `!gh` qui pointe vers la barre de recherche de GitHub, ou un Bang `!doc` qui cherche directement dans la documentation de votre langage de programmation favori.

En maîtrisant les Bangs, vous ne vous contentez pas de protéger votre vie privée : vous créez un terminal de commande personnel, une interface de navigation à la vitesse de la pensée qui rend l'expérience de recherche traditionnelle, lente et truffée de publicités, totalement obsolète. Vous n'êtes plus le produit d'un algorithme ; vous êtes le pilote de votre propre exploration du web.

© 2026 Oussama Ghorbel

Chapitre 10 – L'art de l'emailing furtif et des alias

Il existe une adresse que vous donnez plus souvent que votre numéro de téléphone, plus souvent que votre adresse postale, et parfois même avant de révéler votre nom. Cette adresse, c'est votre email. Elle est la clé de voûte de votre existence en ligne, le sésame qui ouvre la porte de votre banque, de vos réseaux sociaux, de vos achats, de vos déclarations fiscales, de vos rendez-vous médicaux. Et pourtant, nous la distribuons avec une désinvolture déconcertante, comme on distribuerait des cartes de visite à un salon professionnel, sans nous demander qui les ramasse, qui les classe, qui les revend.

Dans ce chapitre, nous allons changer radicalement de paradigme. Votre email principal ne doit plus jamais être donné. Il doit devenir un secret, un coffre-fort auquel vous seul avez accès, tandis que le reste du monde ne voit que des façades, des alias, des leurres soigneusement orchestrés. C'est ce que j'appelle l'art de l'emailing furtif : une discipline qui mélange stratégie, technique et un brin de paranoïa salutaire.

Pourquoi votre email est votre numéro de sécurité sociale numérique

Si vous deviez choisir un seul identifiant qui résume à lui seul votre identité numérique, ce serait votre adresse email. Pas votre numéro de téléphone, qui change. Pas votre pseudo sur les réseaux sociaux, qui peut être modifié. Pas même votre nom, qui peut être partagé par des milliers d'autres personnes. Votre email, en revanche, est unique, permanent, et surtout : il est le point de convergence de tous vos autres comptes.

Réfléchissez un instant. Lorsque vous perdez le mot de passe de votre compte bancaire en ligne, où est envoyé le lien de réinitialisation ? Dans votre boîte mail. Lorsque vous activez la double authentification sur un réseau social, quelle adresse sert de secours ? Votre email. Lorsqu'un service que vous utilisez subit une fuite de données, quelle information est revendue en priorité sur les marchés noirs ? Votre email, associé au mot de passe compromis.

© 2026 Oussama Ghorbel

Votre adresse email fonctionne exactement comme un numéro de sécurité sociale numérique. Elle est l'identifiant universel qui permet aux courtiers en données de relier entre elles toutes les traces que vous laissez sur le web. Un même email utilisé sur Amazon, sur un forum de jardinage, sur une application de rencontre, sur un site d'actualités et sur votre compte impôts permet de construire un profil d'une précision chirurgicale. Le courtier sait ce que vous achetez, ce qui vous inquiète, vos opinions politiques, votre situation sentimentale, votre niveau de revenu estimé. Tout cela simplement parce que vous avez utilisé la même adresse partout, par commodité.

Il y a aussi un problème de surface d'attaque. Plus votre email principal est diffusé, plus il sera ciblé par les campagnes de phishing. Les attaquants savent que s'ils parviennent à compromettre votre boîte mail, ils tiennent en otage l'ensemble de votre vie numérique. C'est la raison pour laquelle les attaques par spear phishing — des emails ciblés et personnalisés — sont devenues si redoutables. Elles arrivent sur une adresse que vous avez vous-même rendue publique, en mentionnant des détails que vous avez vous-même semés sur le web.

La stratégie que nous allons mettre en place repose sur un principe simple : la compartimentation. Votre email principal ne servira plus qu'à recevoir les messages des services critiques (banque, impôts, assurances, santé) et les communications de vos proches. Pour tout le reste, nous allons utiliser des alias, des adresses jetables, des leurres. Chaque service que vous utiliserez verra une adresse différente, ce qui rendra le recoupement de vos données considérablement plus difficile pour les pisteurs.

Les fournisseurs mail chiffrés (Proton, Tutanota, Mailbox.org)

Avant même de parler d'alias, il faut s'assurer que la forteresse elle-même est solide. Si vous utilisez encore Gmail, Outlook.com ou Yahoo Mail comme boîte principale, vous devez savoir que vos emails y sont stockés en clair sur les serveurs de ces entreprises. Elles peuvent les analyser, les indexer, les utiliser pour affiner votre profil publicitaire — même si Google a officiellement abandonné cette pratique pour Gmail en 2017, la métadonnée, elle, reste exploitée. Surtout, en cas de

© 2026 Oussama Ghorbel

réquisition judiciaire, de fuite ou de compromission d'un compte employé chez ces fournisseurs, vos messages peuvent être lus.

Les fournisseurs de messagerie chiffrée proposent une alternative fondée sur un principe radicalement différent : le chiffrement de bout en bout ou le chiffrement au repos, combiné à une juridiction protectrice et à un modèle économique qui ne repose pas sur la publicité. En clair, ils ne peuvent techniquement pas lire vos emails, même s'ils le voulaient.

Proton Mail, basé en Suisse, est sans doute le plus connu. Fondé par des anciens du CERN, il bénéficie de la législation suisse sur la protection des données, parmi les plus strictes au monde. Proton chiffre vos messages de bout en bout lorsque vous communiquez avec d'autres utilisateurs Proton, et propose un chiffrement par mot de passe pour les destinataires extérieurs. L'interface est sobre, moderne, et l'offre gratuite permet de se familiariser avec le service avant de passer à une version payante qui débloque les alias, le stockage supplémentaire et les domaines personnalisés. Proton a également intégré Proton Pass, un gestionnaire de mots de passe, et Proton Calendar, ce qui en fait un écosystème cohérent pour qui souhaite se détacher progressivement des GAFAM.

Tutanota, désormais renommé **Tuta**, est un concurrent allemand qui se distingue par une approche encore plus radicale du chiffrement. Là où Proton chiffre le corps du message, Tuta chiffre également les objets, les pièces jointes et même les contacts. Basé à Hanovre, il bénéficie du RGPD dans son interprétation allemande, notoirement rigoureuse. L'interface est épurée, presque minimaliste, et le service met un point d'honneur à ne collecter aucune métadonnée superflue. Tuta propose aussi une fonction intéressante : la possibilité d'envoyer des emails chiffrés à des destinataires qui n'utilisent pas le service, via un lien sécurisé et un mot de passe partagé par un autre canal.

Mailbox.org, quant à lui, joue la carte de la polyvalence. Basé en Allemagne également, il ne se contente pas d'une messagerie : il propose un calendrier, des contacts, un stockage cloud, et même une suite bureautique collaborative. C'est une option intéressante pour ceux qui cherchent à remplacer en bloc l'écosystème Google Workspace. Mailbox.org est certifié par plusieurs organismes indépendants et utilise le chiffrement au repos ainsi que le protocole TLS pour les transferts. Il

© 2026 Oussama Ghorbel

est légèrement moins puriste que Proton ou Tuta sur le plan cryptographique, mais son rapport fonctionnalités-prix est souvent jugé excellent.

Comment choisir entre ces trois options ? La réponse dépend de votre profil. Si vous voulez une solution éprouvée, avec un écosystème complet et une marque reconnue, Proton est le choix naturel. Si vous privilégiez le chiffrement maximal et une interface sans fioritures, Tuta vous conviendra. Si vous cherchez une alternative globale à Google avec calendrier et cloud intégrés, Mailbox.org mérite votre attention. Dans tous les cas, retenez ceci : migrer vers un fournisseur chiffré est l'une des décisions les plus structurantes que vous puissiez prendre pour votre vie numérique. C'est le socle sur lequel reposera tout le reste.

Une précision importante : le chiffrement de bout en bout ne fonctionne pleinement qu'entre deux utilisateurs du même service, ou lorsque le destinataire dispose d'une clé PGP compatible. Nous reviendrons sur ce point. Pour l'heure, sachez que même sans chiffrement de bout en bout, le simple fait d'utiliser un fournisseur qui ne monétise pas vos données et qui est soumis à une juridiction protectrice constitue un progrès immense par rapport aux géants américains.

Le système des alias de redirection (SimpleLogin, AnonAddy)

Voici maintenant le cœur de notre stratégie : les alias de redirection. Le concept est d'une élégance trompeuse. Vous créez, pour chaque service que vous utilisez, une adresse email unique qui redirige automatiquement les messages vers votre vraie boîte mail. Ainsi, Amazon connaît l'adresse `amazon.x8k2@simplelogin.com`, votre banque connaît `banque.pr7q@simplelogin.com`, et votre forum de cuisine connaît `cuisine.m4n9@simplelogin.com`. Toutes ces adresses atterrissent bien dans votre boîte de réception principale, mais aucun de ces services ne peut deviner qu'elles appartiennent à la même personne.

Les avantages sont multiples. D'abord, la compartimentation : en cas de fuite de données chez l'un de vos fournisseurs, seule l'adresse associée est compromise, pas votre identité globale. Ensuite, la traçabilité : si vous commencez à recevoir du spam sur une adresse spécifique, vous savez exactement quel service a vendu ou perdu vos

© 2026 Oussama Ghorbel

données. C'est un outil de détection extraordinairement puissant. Enfin, la réversibilité : vous pouvez désactiver ou supprimer un alias en un clic, sans avoir à mettre à jour vos informations sur des dizaines de sites.

SimpleLogin est aujourd'hui la référence du domaine. Fondé par un développeur français, le service a été racheté par Proton en 2022, ce qui lui a apporté une stabilité financière et une intégration native avec Proton Mail. SimpleLogin vous permet de créer des alias personnalisés avec vos propres domaines, d'utiliser des alias aléatoires, de répondre aux emails via l'alias (sans révéler votre vraie adresse), et même de créer des alias « catch-all » sur un domaine entier. L'offre gratuite est généreuse, avec une dizaine d'alias, et l'offre payante, très abordable, débloque un nombre illimité d'alias et de domaines.

AnonAddy, désormais appelé **addy.io**, est une alternative open source qui séduira les utilisateurs plus techniques. Le service peut être auto-hébergé si vous disposez d'un serveur, ce qui vous donne un contrôle total sur vos données. addy.io propose également une version hébergée avec une offre gratuite intéressante. Son interface est un peu moins polie que celle de SimpleLogin, mais ses fonctionnalités sont comparables, et son engagement pour la transparence est total, le code étant publiquement auditable.

Apple, de son côté, a intégré une fonction similaire directement dans iCloud+ sous le nom de **Hide My Email**. Si vous êtes déjà dans l'écosystème Apple, c'est une option pratique qui s'intègre nativement à Safari, à l'app Mail et au remplissage automatique. Le revers de la médaille, c'est que vous restez dépendant d'Apple, et que la fonctionnalité n'est disponible que dans l'offre payante iCloud+.

Comment utiliser ces alias au quotidien ? Voici la méthode que je recommande. Commencez par identifier vos services critiques : banque, impôts, assurance, médecin. Pour ceux-là, conservez votre adresse email principale, celle de votre fournisseur chiffré. Pour tous les autres services — e-commerce, réseaux sociaux, newsletters, forums, applications mobiles —, créez un alias dédié. Prenez l'habitude de générer un nouvel alias à chaque inscription. Avec le temps, vous aurez des dizaines, voire des centaines d'alias, chacun correspondant à un service précis. C'est une petite gymnastique au début, mais cela devient vite un réflexe.

© 2026 Oussama Ghorbel

Une astuce précieuse : utilisez des domaines personnalisés si vous le pouvez. Acheter un domaine pour une dizaine d'euros par an et le configurer dans SimpleLogin vous permet de créer des alias du type `contact@mondomaine.com`, bien plus crédibles que les alias générés aléatoirement. Certains formulaires d'inscription, mal conçus, rejettent en effet les adresses visiblement jetables.

Les emails jetables pour les inscriptions à usage unique

Les alias de redirection sont parfaits pour les services que vous utiliserez durablement. Mais il existe une catégorie de sites pour lesquels vous n'avez aucune envie de créer un alias permanent : les formulaires d'inscription à usage unique, les téléchargements conditionnés à une adresse email, les tests de services que vous n'êtes pas sûr d'adopter, les WiFi publics qui exigent une adresse pour vous connecter.

Pour ces situations, les emails jetables sont l'outil idéal. Le principe est simple : vous vous rendez sur un site comme **Guerrilla Mail**, **TempMail**, **Yopmail** ou **10 Minute Mail**, et vous obtenez instantanément une adresse email temporaire. Cette adresse reçoit les messages pendant quelques minutes ou quelques heures, puis s'autodétruit. Vous pouvez ainsi valider une inscription, récupérer un lien de confirmation, et oublier l'adresse aussitôt.

Attention toutefois : ces services ne doivent jamais être utilisés pour des comptes importants. Si vous perdez l'accès à une adresse jetable, vous perdez tout moyen de récupérer le compte associé. N'utilisez donc ces adresses que pour des services sans valeur, des tests, des inscriptions ponctuelles. Par ailleurs, certains sites bloquent désormais les domaines connus d'emails jetables. Dans ce cas, un alias SimpleLogin fera parfaitement l'affaire.

Il existe aussi des services plus sophistiqués comme **DuckDuckGo Email Protection**, qui propose des adresses en `@duck.com` redirigeant vers votre vraie boîte, tout en supprimant les pisteurs contenus dans les emails. C'est une solution hybride intéressante, à mi-chemin entre l'alias permanent et le jetable, et elle a l'avantage d'être gratuite et intégrée au navigateur DuckDuckGo.

© 2026 Oussama Ghorbel

Un mot sur les emails « plus-plus », cette technique qui consiste à ajouter un `+` suivi d'un mot-clé à votre adresse Gmail (par exemple `monnom+amazon@gmail.com`). Techniquement, Gmail ignore tout ce qui suit le `+`, et le message arrive bien dans votre boîte. C'était une astuce populaire il y a quelques années, mais elle présente deux inconvénients majeurs. D'abord, elle révèle votre adresse réelle à tous les services. Ensuite, de nombreux sites refusent désormais les adresses contenant un `+`, et certains pisteurs savent normaliser cette notation pour vous identifier malgré tout. C'est une fausse bonne idée, à abandonner au profit des vrais alias.

Le chiffrement PGP : mythes et réalités pour le grand public

Parlons maintenant d'un sujet qui cristallise beaucoup de fantasmes et de malentendus : le chiffrement PGP, pour *Pretty Good Privacy*. Inventé en 1991 par Phil Zimmermann, PGP est un protocole qui permet de chiffrer des emails de bout en bout, de sorte que seul le destinataire légitime, possesseur de la clé privée correspondante, puisse les déchiffrer. Sur le papier, c'est la panacée. Dans la pratique, c'est un outil puissant mais exigeant, et il convient de démystifier quelques idées reçues.

Mythe numéro un : PGP est indispensable pour toute communication sensible. Faux. Pour la grande majorité des utilisateurs, un fournisseur de messagerie chiffrée comme Proton ou Tuta suffit amplement. Le chiffrement de bout en bout entre deux utilisateurs du même service est transparent, ne nécessite aucune configuration, et couvre 95 % des besoins de confidentialité. PGP devient pertinent lorsque vous devez communiquer avec des personnes qui utilisent d'autres fournisseurs, ou lorsque vous voulez une garantie cryptographique indépendante de tout tiers de confiance.

Mythe numéro deux : PGP est compliqué à utiliser. C'était vrai il y a dix ans, ça l'est beaucoup moins aujourd'hui. Des outils comme Proton Mail, Thunderbird avec l'extension Enigmail (désormais intégrée nativement) ou Mailvelope pour les webmails ont considérablement simplifié la gestion des clés. Le processus reste néanmoins plus lourd qu'une simple messagerie : vous devez générer une paire de clés, publier votre clé publique, vérifier les clés de vos interlocuteurs, les sauvegarder

© 2026 Oussama Ghorbel

précieusement. C'est faisable, mais cela demande un investissement initial.

Mythe numéro trois : PGP protège tout. Non. PGP chiffre le corps du message et les pièces jointes, mais pas les métadonnées. L'expéditeur, le destinataire, l'objet, la date et l'heure restent visibles par les serveurs qui transitent les emails. Pour une confidentialité totale des métadonnées, il faudrait recourir à des systèmes plus spécialisés, comme les messageries instantanées de type Signal, qui offrent des garanties différentes.

La réalité, c'est que PGP reste un outil de niche, pertinent pour les journalistes, les avocats, les lanceurs d'alerte, les chercheurs, ou toute personne dont les communications peuvent avoir des conséquences graves en cas d'interception. Pour le grand public, il représente souvent un effort disproportionné par rapport au bénéfice obtenu. Mon conseil : commencez par adopter un fournisseur chiffré et des alias. Si, avec le temps, vous ressentez le besoin d'aller plus loin, alors apprenez PGP, mais faites-le sérieusement, en comprenant les implications de la gestion des clés.

Une mise en garde importante : perdre votre clé privée PGP, c'est perdre à jamais l'accès aux messages chiffrés avec cette clé. Il n'y a pas de bouton « mot de passe oublié » en cryptographie. Sauvegardez votre clé sur un support physique sécurisé, idéalement hors ligne, et ne la confiez à aucun service cloud non chiffré.

Nettoyer et migrer son ancienne boîte mail

Si vous avez suivi ce livre depuis le début, vous avez probablement pris conscience de l'ampleur du chantier. Votre ancienne boîte mail, celle que vous utilisez depuis des années, est sans doute un capharnaüm où se côtoient des milliers de messages, des inscriptions oubliées, des newsletters que vous ne lisez plus, des services que vous n'utilisez plus depuis longtemps. Avant de migrer vers une nouvelle infrastructure, il faut faire le ménage.

La première étape consiste à identifier tous les services auxquels vous êtes inscrit. Pour cela, une méthode simple : utilisez la fonction de recherche de votre boîte mail avec des mots-clés comme « confirmer »,

© 2026 Oussama Ghorbel

« welcome », « bienvenue », « inscription », « subscribe », « unsubscribe ». Vous serez surpris du nombre de services que vous aviez oubliés. Listez-les dans un tableur, avec trois colonnes : le nom du service, l'email utilisé, et une décision à prendre (conserver, migrer, supprimer).

La deuxième étape est la plus fastidieuse mais aussi la plus importante : la suppression des comptes inutiles. Ne vous contentez pas de vous désabonner des newsletters. Allez jusqu'au bout et demandez la suppression complète de votre compte, en invoquant votre droit à l'effacement prévu par le RGPD (nous en avons parlé au chapitre 5). La plupart des services proposent désormais une option de suppression dans leurs paramètres, parfois dissimulée sous des formulations comme « fermer mon compte » ou « delete my account ». Si l'option n'est pas disponible, envoyez un email au support en mentionnant explicitement l'article 17 du RGPD. Les entreprises établies dans l'Union européenne sont tenues d'y répondre dans un délai d'un mois.

Pour vous aider dans cette tâche, des outils comme **Cleanfox**, **Leave Me Alone** ou **Unroll.me** proposent de scanner votre boîte mail et de vous désabonner en masse des newsletters. Attention toutefois : certains de ces services, notamment Unroll.me, ont été épinglés par le passé pour avoir revendu des données d'utilisateurs. Privilégiez les outils payants et transparents sur leur modèle économique, ou faites le travail manuellement. C'est plus long, mais plus sûr.

La troisième étape est la migration proprement dite. Choisissez votre nouveau fournisseur chiffré, créez votre compte, et configurez-le. La plupart des services proposent des outils d'importation qui récupèrent vos anciens emails via IMAP. Proton, par exemple, dispose d'un utilitaire appelé Proton Mail Import-Export qui fonctionne avec de nombreux fournisseurs. Une fois vos anciens messages importés, vous pouvez configurer une redirection automatique depuis votre ancienne boîte vers la nouvelle, afin de ne rien manquer pendant la transition.

Vient alors la question cruciale : faut-il supprimer définitivement l'ancienne boîte ? La réponse dépend de votre situation. Si cette adresse est connue de tous vos proches, associée à des services administratifs importants, ou utilisée comme identifiant sur des comptes que vous ne pouvez pas migrer, il peut être plus sage de la conserver en mode « passif », c'est-à-dire en y consultant de temps en temps les messages

© 2026 Oussama Ghorbel

résiduels, mais en cessant de l'utiliser pour toute nouvelle inscription. Si, en revanche, cette adresse est trop compromise, trop spamée, ou associée à une identité que vous souhaitez laisser derrière vous, la suppression définitive est une option radicale mais libératrice.

Un dernier conseil, qui relève autant de l'hygiène que de la stratégie : adoptez une convention de nommage claire pour vos nouvelles adresses et vos alias. Par exemple, réservez votre adresse principale sous la forme `prenom.nom@proton.me`, utilisez un domaine personnalisé pour vos alias sérieux (`contact@mondomaine.fr`), et gardez les alias aléatoires pour les services à risque. Cette discipline vous évitera bien des confusions lorsque vous aurez, dans quelques mois, des dizaines d'alias actifs.

Exercices pratiques

La théorie ne vaut rien sans la pratique. Voici trois exercices concrets pour ancrer les concepts de ce chapitre dans votre routine numérique. Prévoyez environ une heure pour les réaliser correctement, et munissez-vous de votre gestionnaire de mots de passe pour y consigner les nouvelles informations.

Exercice 1 : créer trois alias stratégiques. Inscrivez-vous sur SimpleLogin (ou, si vous êtes dans l'écosystème Apple, activez Hide My Email dans les réglages iCloud). Créez trois alias dédiés, chacun correspondant à une catégorie précise de services :

- Un alias pour le e-commerce, par exemple `boutiques.x7k2@simplelogin.com` ou `shops@votredomaine.com`. Cet alias sera utilisé pour toutes vos inscriptions sur des sites marchands : Amazon, Fnac, boutiques indépendantes, marketplaces.
- Un alias pour les réseaux sociaux et les divertissements, par exemple `social.m9p4@simplelogin.com`. Il servira pour Facebook, Instagram, Twitter, TikTok, mais aussi pour les forums, les jeux en ligne, les services de streaming.
- Un alias pour les démarches administratives et les services publics non critiques, par exemple `admin.q3r8@simplelogin.com`. Il concernera les services en ligne des collectivités, les abonnements à des services publics numériques, les plateformes de prise de

© 2026 Oussama Ghorbel

rendez-vous.

Notez ces trois alias dans votre gestionnaire de mots de passe, avec une étiquette claire indiquant leur usage. À partir de maintenant, chaque nouvelle inscription dans l'une de ces catégories utilisera l'alias correspondant, et non plus votre adresse principale.

Exercice 2 : auditer votre boîte mail actuelle. Ouvrez votre boîte mail principale et recherchez les mots-clés suivants : « unsubscribe », « se désabonner », « confirmer votre inscription ». Parcourez les cinquante premiers résultats et identifiez au moins dix services auxquels vous êtes inscrit mais que vous n'utilisez plus activement. Pour chacun d'entre eux, prenez une décision : soit vous vous désabonnez purement et simplement, soit vous demandez la suppression complète du compte au titre du RGPD. Traitez au moins cinq de ces demandes dans la foulée, sans remettre à plus tard.

Exercice 3 : configurer une règle de filtrage. Dans votre nouvelle boîte mail chiffrée, créez une règle (ou un filtre, selon la terminologie du service) qui range automatiquement dans un dossier dédié tous les messages reçus sur l'un de vos alias. Par exemple, tous les messages arrivant sur l'alias e-commerce iront dans un dossier « Boutiques », ceux de l'alias social dans un dossier « Réseaux », et ainsi de suite. Cette organisation vous permettra, d'un seul coup d'œil, de voir quels services vous sollicitent le plus, et de détecter rapidement toute fuite de données : si vous recevez un message suspect sur un alias spécifique, vous saurez immédiatement quel service est en cause.

Ces trois exercices, réalisés sérieusement, constituent un premier pas décisif vers une identité numérique compartimentée. Vous ne reverrez plus jamais votre adresse email de la même manière. Et c'est exactement ce que nous cherchons : transformer une commodité devenue vulnérabilité en un instrument de contrôle retrouvé.

© 2026 Oussama Ghorbel

Chapitre 11 – Réseaux sociaux : verrouiller les écoutilles

Quitter les réseaux sociaux est une décision radicale qui s'apparente à un exil numérique. Pour beaucoup, cette rupture n'est ni souhaitable ni réaliste : ces plateformes sont devenues les infrastructures de nos liens familiaux, de notre veille professionnelle et de notre accès à l'information. L'objectif de ce chapitre n'est donc pas de vous pousser vers une déconnexion totale, mais de vous apprendre à naviguer en eaux hostiles avec un sous-marin furtif. Il s'agit de verrouiller les écoutilles.

Lorsqu'on accompagne des individus dans la reprise de contrôle de leur vie numérique, on constate souvent une résignation face aux géants du web. Une sorte de fatalisme qui murmure : « De toute façon, ils savent déjà tout. » C'est faux. Il y a une différence abyssale entre une plateforme qui connaît vos préférences publiques et une plateforme qui cartographie votre intimité, vos déplacements, vos relations et vos faiblesses psychologiques. En appliquant les configurations détaillées dans ce chapitre, vous allez transformer votre profil social : d'une mine d'or pour les courtiers en données, il deviendra une coquille vide, un leurre fonctionnel qui vous permet de consommer et d'interagir sans sacrifier votre âme numérique.

L'architecture de la surveillance sociale (Meta, X, TikTok)

Pour verrouiller les écoutilles, il faut d'abord comprendre la nature de l'océan dans lequel nous naviguons. Les réseaux sociaux ne sont pas de simples applications de partage ; ce sont des moteurs d'extraction comportementale. Chaque plateforme a développé sa propre architecture de surveillance, ciblant des facettes différentes de votre identité.

Meta (Facebook et Instagram) repose sur le « graphe social ». L'objectif de Meta est de cartographier l'intégralité de vos relations humaines. Qui connaissez-vous ? À quelle fréquence interagissez-vous avec eux ? Meta ne se contente pas de savoir que vous êtes ami avec une personne ; il analyse la densité de vos échanges, les groupes que vous partagez, et les événements auxquels vous participez ensemble. Cette matrice relationnelle permet à l'algorithme de déduire vos opinions

© 2026 Oussama Ghorbel

politiques, votre orientation religieuse ou votre situation financière par simple homophilie (le principe selon lequel les oiseaux de même plumage s'assemblent). Si vos dix contacts les plus proches interagissent avec des contenus liés à l'immobilier de luxe, l'algorithme en déduira que vous appartenez à la même catégorie socio-professionnelle, même si vous n'avez jamais liké une seule page sur le sujet.

X (anciennement Twitter) est architecturé autour du graphe idéologique et de l'attention en temps réel. La surveillance y est moins axée sur votre vie privée familiale que sur vos réactions cognitives et émotionnelles face à l'actualité. X mesure la vitesse à laquelle vous cliquez, le temps que vous passez à lire un thread polémique, et les mots-clés qui déclenchent chez vous une envie de partager ou de répondre. C'est une machine à profiler l'indignation et l'engagement intellectuel.

TikTok, enfin, a introduit une rupture technologique majeure : le profilage biométrique et comportemental passif. TikTok n'a pas besoin que vous suiviez vos amis pour vous profiler. Son architecture analyse la micro-gestuelle de votre attention. Combien de millisecondes votre doigt hésite-t-il avant de glisser vers la vidéo suivante ? Quel est votre rythme de frappe lorsque vous tapez un commentaire ? L'application a même été épinglée par le passé pour avoir tenté d'accéder au presse-papier des appareils iOS et pour avoir collecté des identifiants matériels (comme l'adresse MAC) afin de contourner les suppressions de cookies. TikTok cartographie votre système nerveux face à des stimuli visuels et sonores.

Comme le souligne la chercheuse Shoshana Zuboff dans son analyse du capitalisme de surveillance : « L'expérience humaine est revendiquée comme matière première gratuite pour être traduite en données comportementales. » Ces trois architectures ne cherchent pas à vous connaître pour vous servir ; elles vous dissèquent pour prédire et influencer vos futurs choix. Verrouiller les écoutilles, c'est priver ces architectures de la matière première dont elles ont besoin pour modéliser votre comportement.

Désactiver la personnalisation des publicités et le suivi hors-site

© 2026 Oussama Ghorbel

La première et la plus urgente des manœuvres consiste à couper le cordon ombilical entre votre activité sur le web et votre profil social. La grande illusion entretenue par les réseaux sociaux est de vous faire croire que leur surveillance s'arrête aux portes de leur application. C'est ignorer l'omniprésence de leurs outils de pistage.

Meta, par exemple, déploie le « Pixel Meta » sur des millions de sites web marchands, d'articles de presse et de blogs. Ce bout de code invisible signale à Meta que vous avez visité telle page, ajouté tel article à votre panier, ou lu tel contenu, et ce, même si vous n'êtes pas connecté à Facebook à ce moment-là. TikTok et X utilisent des SDK (Software Development Kits) intégrés dans d'innombrables applications mobiles tierces pour récolter des données similaires.

Pour contrer cela, vous devez accéder aux paramètres de confidentialité de chaque plateforme et chercher les sections intitulées « Activité en dehors de nos produits » (Meta) ou « Partage de données avec des partenaires » (X, TikTok).

Sur Meta, l'outil « Activité en dehors de Facebook » est une révélation souvent glaçante. Vous y découvrirez la liste exhaustive des entreprises, pharmacies, banques et médias qui renvoient des données vers votre profil. La première étape consiste à utiliser la fonction « Effacer l'historique ». Cela détache ces données de votre compte publicitaire. Ensuite, et c'est crucial, vous devez désactiver l'option « Gérer les futures activités » ou « Déconnecter l'activité future ». Attention, cela n'empêchera pas Meta de recevoir les données des sites web utilisant son pixel (les sites paient pour ce service), mais cela empêchera Meta d'associer ces données à votre compte personnel pour cibler des publicités. Vous devenez ainsi un fantôme pour leur régie publicitaire : ils voient qu'un utilisateur a visité un site, mais ignorent que c'était vous.

Sur les applications mobiles, cette bataille se joue également au niveau du système d'exploitation. Sur iOS, l'invite « Demander à l'app de ne pas effectuer de suivi » (App Tracking Transparency) est votre premier rempart. Refusez systématiquement. Sur Android, assurez-vous de supprimer l'identifiant publicitaire (IDAA) dans les paramètres de confidentialité du système, et révoquez les autorisations de suivi inter-applications. Couplé à un bloqueur de publicités et de trackers sur

© 2026 Oussama Ghorbel

votre navigateur (comme détaillé dans le chapitre 7), vous créez un brouillard épais entre vos navigations externes et vos identifiants sociaux.

Restreindre la visibilité des données biographiques et des listes d'amis

Votre profil social est souvent perçu comme une carte de visite numérique. Nous avons tendance à y accumuler des informations que nous ne donnerions jamais à un inconnu dans la rue : notre date de naissance exacte, notre ville natale, notre employeur, notre situation amoureuse, et surtout, notre liste d'amis.

La liste d'amis est la donnée la plus critique de votre profil. En la laissant publique, vous offrez aux algorithmes et aux courtiers en données (data brokers) le plan complet de votre réseau. Des entreprises spécialisées scrapent (aspirer automatiquement) ces listes publiques pour construire des bases de données de graphes sociaux qu'elles revendent ensuite à des assureurs, des recruteurs ou des agences de marketing. Si votre liste d'amis est masquée, le graphe social de Meta est obligé de se fier uniquement à vos interactions directes, ce qui réduit drastiquement la précision des inférences algorithmiques vous concernant. Allez dans les paramètres de confidentialité de Facebook et réglez « Qui peut voir votre liste d'amis ? » sur « Moi uniquement ».

Concernant les données biographiques, appliquez le principe de la minimisation stricte. Avez-vous vraiment besoin d'indiquer votre année de naissance ? L'âge est un segment démographique majeur pour le profilage. Indiquez plutôt une fausse date de naissance (en gardant en tête que cela peut compliquer une récupération de compte en cas de piratage, d'où l'importance des coffres-forts numériques vus au chapitre 17) ou masquez-la complètement.

Votre ville de résidence actuelle et votre lieu de travail sont des vecteurs d'identification croisée. En les rendant publics, vous facilitez le travail des moteurs de recherche de personnes (comme Spokeo ou Pipl) qui agrègent ces données pour lier votre profil Facebook à votre adresse postale réelle et à votre numéro de téléphone. Rendez ces informations visibles pour vos amis uniquement, ou mieux, supprimez-les de votre profil public. Votre biographie doit être un bouclier, pas un formulaire

© 2026 Oussama Ghorbel

de recensement.

Couper la géolocalisation et l'accès aux contacts

La géolocalisation et le carnet d'adresses sont les deux capteurs les plus intrusifs de votre smartphone. Les réseaux sociaux les convoitent avec une voracité particulière, souvent en masquant leur demande derrière des fonctionnalités apparemment innocentes comme « Trouver des amis à proximité » ou « Suggérer des contacts que vous connaissez peut-être ».

L'accès aux contacts est un piège moral et technique. Lorsque vous autorisez Instagram, TikTok ou X à « synchroniser vos contacts », vous ne leur donnez pas seulement votre numéro de téléphone. Vous leur livrez les numéros personnels de votre médecin, de votre avocat, de vos enfants, de votre patron et de vos relations éphémères. Vous trahissez la confidentialité de votre entourage en les aspirant dans la base de données du réseau social. C'est ainsi que les plateformes génèrent ces suggestions troublantes : « Vous connaissez peut-être [Nom de votre psychologue] ». L'algorithme a croisé les carnets d'adresses de plusieurs de vos connaissances pour déduire un lien.

La règle est absolue : **n'autorisez jamais l'accès aux contacts**. Si vous l'avez fait par le passé, rendez-vous immédiatement dans les paramètres de l'application (souvent sous « Centre de comptes » ou « Confidentialité ») pour trouver l'option « Gérer les contacts importés » et cliquez sur « Supprimer tous les contacts ». Ensuite, révoquez cette permission au niveau du système d'exploitation de votre téléphone.

La géolocalisation pose un problème tout aussi grave. Les métadonnées de localisation ne se limitent pas aux coordonnées GPS de vos photos. Les applications cartographient les réseaux Wi-Fi auxquels vous vous connectez et les antennes relais que vous croisez, créant un historique de vos déplacements d'une précision terrifiante. Elles peuvent en déduire votre domicile, votre lieu de travail, vos habitudes médicales (visites régulières à une clinique spécifique) ou vos affiliations politiques (participation à des rassemblements).

Désactivez la localisation précise pour toutes vos applications sociales. Sur iOS et Android, choisissez l'option « Position

© 2026 Oussama Ghorbel

approximative » si l'application exige une localisation pour fonctionner (par exemple, pour des filtres géographiques), mais dans 99 % des cas, l'option « Ne jamais autoriser » est la seule réponse acceptable. Lorsque vous publiez une photo, désactivez l'enregistrement des données EXIF (les métadonnées GPS intégrées à l'image) dans les paramètres de l'appareil photo de votre téléphone.

Limiter l'indexation par les moteurs de recherche externes

Il existe une porte dérobée que la majorité des utilisateurs oublient de verrouiller : celle qui relie votre profil social au reste du web ouvert. Par défaut, des plateformes comme Facebook, X ou LinkedIn autorisent les moteurs de recherche externes (Google, Bing, DuckDuckGo) à indexer votre profil.

Cela signifie que n'importe qui, qu'il soit journaliste, enquêteur privé, employeur, ou simple harceleur, peut taper votre nom, votre pseudonyme ou votre adresse email dans Google et voir apparaître en premier résultat votre profil social, avec votre photo, votre ville et vos affiliations. Dans le domaine de l'OSINT (Open Source Intelligence, ou renseignement d'origine sources ouvertes), cette indexation est le point de départ de la plupart des investigations numériques.

Pour couper ce pont, vous devez chercher dans les paramètres de confidentialité l'option « Indexation par les moteurs de recherche » ou « Autoriser les moteurs de recherche en dehors de [Plateforme] à créer un lien vers votre profil ». Désactivez-la.

Notez que cette action n'est pas instantanée. Il faut parfois plusieurs semaines pour que les caches de Google se mettent à jour et que votre profil disparaisse des résultats de recherche publics.

Cette étape est fondamentale si vous utilisez une stratégie de cloisonnement identitaire. Si vous souhaitez que votre identité civile (votre vrai nom) reste décorrélée de vos centres d'intérêt personnels ou de vos opinions politiques exprimés sur X, l'indexation croisée par Google est votre pire ennemie. En la bloquant, vous forcez les curieux à already posséder un lien direct vers votre profil ou à être connecté à la plateforme pour vous trouver, ce qui élève considérablement le niveau d'effort requis pour vous profiler.

© 2026 Oussama Ghorbel

Gérer les applications tierces connectées à votre compte

Nous avons tous, un jour, cédé à la facilité du bouton « Se connecter avec Facebook » ou « Continuer avec Google » pour accéder à un site d'actualités, un jeu mobile, ou un service de livraison. Ce protocole, appelé OAuth, est un cauchemar de confidentialité s'il n'est pas audité régulièrement.

Lorsque vous utilisez votre compte social comme passe-partout, vous accordez à l'application tierce un jeton d'accès (token). Selon les permissions que vous avez validées (souvent sans lire la fenêtre pop-up), cette application peut lire votre adresse email, accéder à votre liste d'amis, publier en votre nom, ou analyser vos messages privés. L'histoire de Cambridge Analytica nous a rappelé de façon spectaculaire comment une simple application de quiz psychologique, connectée via Facebook, a pu siphonner les données de dizaines de millions d'utilisateurs et de leurs amis pour orchestrer des campagnes de manipulation politique.

Le nettoyage des applications tierces est une tâche d'hygiène numérique indispensable. Rendez-vous dans la section « Applications et sites web » de vos paramètres de sécurité. Vous y trouverez la liste de tous les services auxquels vous avez délégué un accès.

Appliquez la règle du « sevrage impitoyable » :

1. **Révoquez** l'accès à toute application que vous n'avez pas utilisée au cours des six derniers mois.
2. **Révoquez** l'accès à toute application qui vous semble obscure, mal notée, ou dont vous ne comprenez pas la nécessité.
3. Pour les applications que vous devez conserver, **modifiez les permissions** pour les restreindre au strict minimum (généralement, seule votre adresse email publique est nécessaire).

À l'avenir, bannissez l'usage des boutons de connexion sociale. Comme nous l'avons vu dans le chapitre 10 dédié à l'emailing furtif, utilisez des alias d'email pour créer des comptes indépendants sur ces services tiers. Votre identifiant social ne doit jamais servir de clé universelle sur le web.

La stratégie du profil « fantôme » ou pseudonyme

© 2026 Oussama Ghorbel

Si vous êtes prêt à aller plus loin dans la reprise de contrôle, je vous propose d'adopter la stratégie du profil « fantôme ». Cette approche s'inspire des principes de compartimentation utilisés en sécurité informatique (OpSec). L'idée est de séparer radicalement votre identité civile de votre identité de consommateur de contenu.

Le profil fantôme n'est pas un compte jetable que l'on crée et abandonne. C'est un compte de longue durée, méticuleusement entretenu, mais totalement décorrélé de votre vie réelle. Son objectif est unique : vous permettre d'observer, de lire, de suivre des créateurs ou des sujets de niche, sans que l'algorithme ne puisse rattacher ces intérêts à votre identité professionnelle ou familiale.

Comment créer et maintenir un profil fantôme ?

1. **L'identité :** Utilisez un pseudonyme qui ne contient aucune partie de votre vrai nom, de vos surnoms, ou de vos dates de naissance. Choisissez une photo de profil générée par intelligence artificielle (comme celles proposées par le site *This Person Does Not Exist*) ou une illustration abstraite. N'utilisez jamais une photo de vous, de votre animal de compagnie, ou de votre paysage local.

2. **L'isolation technique :** Ne vous connectez jamais à ce profil fantôme depuis le même navigateur ou la même application mobile que votre compte principal. Utilisez un navigateur dédié (par exemple, Firefox avec un profil spécifique, ou le navigateur Tor pour une anonymisation forte) ou installez une application clone sur votre smartphone Android.

3. **L'alias email :** Créez ce compte avec un alias email jetable ou un service d'emailing chiffré (comme ProtonMail ou Tutanota) qui ne nécessite pas votre numéro de téléphone personnel pour la validation. Ne liez jamais votre carnet d'adresses.

4. **La discipline comportementale :** C'est ici que la plupart des gens échouent. Un profil fantôme ne doit jamais interagir avec votre réseau réel. Ne suivez pas vos amis, ne likez pas les publications de votre famille, ne vous connectez pas aux réseaux Wi-Fi de votre lieu de travail en l'utilisant. Si vous commentez sous votre vrai nom avec votre compte fantôme, les algorithmes de suggestion de Meta ou de X feront rapidement le lien sémantique et comportemental entre les

© 2026 Oussama Ghorbel

deux entités.

Le profil fantôme est une bulle de décompression. Il vous permet de satisfaire votre curiosité, d'explorer des sujets sensibles (santé, finance, politique, orientation) sans que ces recherches ne viennent polluer votre profil public et sans qu'elles ne soient revendues à des assureurs ou des employeurs potentiels. C'est la matérialisation de votre droit à l'oubli et à la segmentation de votre vie.

Exercice pratique : L'autopsie de votre archive numérique

La théorie est essentielle, mais rien ne remplace la confrontation avec la réalité de vos propres données. Le Règlement Général sur la Protection des Données (RGPD) en Europe, et des lois similaires ailleurs, vous donnent le droit inaliénable d'accéder à l'intégralité des données qu'une entreprise détient sur vous. Nous allons utiliser ce droit pour mener une autopsie de votre fantôme numérique.

Étape 1 : L'extraction

Rendez-vous sur Facebook et Instagram (la logique est similaire sur X et TikTok). Allez dans les *Paramètres* > *Confidentialité* > *Vos informations et autorisations* > *Télécharger vos informations*. Demandez l'archive complète au format JSON ou HTML (le HTML est plus lisible pour une première analyse). La génération de ce fichier peut prendre de quelques heures à plusieurs jours selon votre ancienneté sur la plateforme. Vous recevrez un email avec un lien de téléchargement sécurisé.

Étape 2 : L'analyse froide

Ouvrez l'archive. Ne vous contentez pas de regarder vos photos. Cherchez les dossiers nommés `ads_and_businesses`, `location`, `security_and_login_information`, et `messages`.

• **Dans `ads_and_businesses` :** Ouvrez le fichier `ad_interests.json`. Vous y trouverez la liste des milliers de catégories dans lesquelles l'algorithme vous a rangé. Vous serez probablement stupéfait de voir des intérêts qui vous sont totalement étrangers, déduits de votre simple appartenance à une tranche d'âge ou de votre code postal. Cherchez également le fichier

© 2026 Oussama Ghorbel

`advertisers_using_your_activity_or_information`. C'est la liste noire des entreprises qui ont uploadé votre email ou numéro de téléphone dans les bases de données de Meta pour vous cibler.

• **Dans `location` :** Consultez l'historique de vos localisations. Vous réaliserez l'ampleur de la télémétrie passive captée par votre smartphone.

• **Dans `messages` :** Vous découvrirez que Meta conserve parfois des métadonnées de messages que vous pensiez effacés, ou des historiques de conversations sur des applications tierces connectées.

Étape 3 : La purge et la révocation

Cette autopsie doit déboucher sur une action chirurgicale.

1. Pour chaque entreprise identifiée dans la liste des annonceurs qui utilisent vos données, rendez-vous dans les paramètres publicitaires et bloquez-les individuellement ou révoquez l'autorisation globale de ciblage par liste de clients (Customer List targeting).

2. Supprimez l'historique des localisations et désactivez la collecte future.

3. Si vous découvrez des applications tierces oubliées ayant encore accès à vos messages ou publications, révoquez-les immédiatement comme expliqué plus haut.

Faire cet exercice une fois par an est un rituel d'hygiène numérique puissant. Il brise l'abstraction de la surveillance. Voir de ses propres yeux comment une machine a réduit votre existence, vos joies, vos deuils et vos hésitations en une série de tags JSON destinés à vendre des chaussures ou du crédit à la consommation est souvent le déclic psychologique nécessaire pour maintenir, sur la durée, la discipline de verrouiller les écoutilles. Vous n'êtes pas un produit, à condition de refuser obstinément de vous laisser emballer.

© 2026 Oussama Ghorbel

Chapitre 12 – E-commerce et paiements sans traces

L'acte d'achat en ligne est sans doute le point de friction le plus critique de notre vie numérique. C'est le moment précis où l'illusion de la gratuité s'effondre pour laisser place à la réalité de la transaction financière. Pourtant, même lorsque vous sortez votre carte bancaire, la surveillance ne s'arrête pas ; elle s'intensifie. Le commerce électronique n'est pas seulement un moyen de vous livrer un produit à domicile, c'est une machine extraordinairement efficace pour cataloguer vos désirs, vos faiblesses, votre niveau de vie et vos habitudes de consommation.

Dans ce chapitre, nous allons décortiquer la mécanique du profilage commercial et mettre en place des stratégies concrètes pour acheter ce dont vous avez besoin, sans pour autant alimenter la base de données de ceux qui cherchent à vous revendre votre propre intimité. L'objectif n'est pas de devenir un ermite refusant toute consommation moderne, mais de reprendre le contrôle : acheter en ligne sans lier systématiquement vos habitudes de consommation à votre identité réelle.

Le profilage par l'historique d'achat et les cartes de fidélité

Pour comprendre comment nous en sommes arrivés là, il faut observer le supermarché moderne, qu'il soit physique ou numérique. Comme l'explique la chercheuse Shoshana Zuboff dans son ouvrage *L'Âge du capitalisme de surveillance* : « L'expérience humaine est désormais une matière première gratuite extraite pour être traduite en données comportementales. » Votre panier d'achat est la mine d'or de cette extraction.

Chaque article que vous ajoutez à votre panier, chaque produit que vous consultez sans acheter, et chaque achat finalisé crée une empreinte. Les algorithmes de *market basket analysis* (analyse du panier de la ménagère) ne se contentent pas de savoir que vous avez acheté des couches. Ils corrèlent cette information avec l'heure de l'achat, le mode de paiement, et les autres articles du panier (par exemple, l'achat simultané de vitamines spécifiques et de crèmes hydratantes non parfumées).

© 2026 Oussama Ghorbel

L'exemple le plus célèbre, souvent cité dans les écoles de commerce, est celui de la chaîne de magasins Target aux États-Unis. Il y a quelques années, leurs algorithmes d'analyse prédictive ont réussi à déduire la grossesse d'une adolescente avant même que son père ne le sache, simplement en analysant l'évolution de ses achats (passage à des lotions sans parfum, achat de compléments en zinc et magnésium). Target a ensuite envoyé des coupons de réduction pour des berceaux et des vêtements de bébé à son domicile. Ce qui ressemble à une légende urbaine est en réalité la norme absolue dans l'industrie du *retail* aujourd'hui.

Le cheval de Troie de cette surveillance massive est la carte de fidélité. On nous la présente comme un privilège, une récompense pour notre loyauté. En réalité, c'est un dispositif de pistage que vous acceptez de porter sur vous. En échange d'une remise de 5 % ou de points cumulables, vous acceptez de céder l'intégralité de votre historique de consommation. Le véritable danger réside dans l'agrégation des données. Les supermarchés physiques et les géants du e-commerce revendent ou partagent ces données avec des *data brokers* (courtiers en données) comme Acxiom ou Experian. Ces entreprises croisent votre historique d'achat en ligne avec vos achats en supermarché, vos abonnements à des magazines, et vos données de géolocalisation, pour créer un profil de consommateur d'une précision chirurgicale.

La première règle de l'hygiène numérique en matière de consommation est donc implacable : refusez systématiquement les programmes de fidélité. La remise immédiate ne compensera jamais la valeur à long terme de vos données personnelles, qui seront utilisées pour vous cibler avec des publicités manipulatrices, ajuster les prix à votre désavantage, ou être revendues à des tiers dont vous ignorez jusqu'à l'existence. Si un site e-commerce vous oblige à créer un compte pour acheter, utilisez un alias email (comme nous l'avons vu dans le chapitre 10) et fournissez le strict minimum d'informations légales requises pour la facturation.

Les cartes bancaires virtuelles et éphémères

Lorsque vous saisissez les 16 chiffres de votre carte bancaire physique sur un site e-commerce, vous prenez un risque monumental.

© 2026 Oussama Ghorbel

Vous faites confiance à l'infrastructure de sécurité de ce marchand, à ses hébergeurs, et à tous les plugins tiers intégrés à sa page de paiement. Or, les fuites de bases de données de commerçants sont légion. Si votre carte réelle est compromise, votre identité financière l'est aussi.

C'est ici qu'interviennent les cartes bancaires virtuelles et éphémères. Ces outils agissent comme un tampon, une couche d'abstraction entre votre véritable compte bancaire et le marchand. Le principe repose sur la tokenisation : votre banque ou un service tiers génère un numéro de carte, une date d'expiration et un code de sécurité (CVV) qui sont liés à votre compte, mais qui ne révèlent aucune information sur votre carte physique.

Il existe plusieurs typologies de cartes virtuelles, chacune répondant à un besoin spécifique de confidentialité et de sécurité :

1. **La carte à usage unique (Burner Card)** : Elle est détruite automatiquement après la première transaction. C'est l'outil idéal pour un achat ponctuel sur un site e-commerce peu familier, un site de dropshipping, ou une boutique en ligne dont l'infrastructure de sécurité vous inspire peu de confiance. Si la base de données du marchand est piratée le lendemain, les hackers ne récupéreront qu'un numéro de carte déjà inactif.

2. **La carte verrouillée par marchand (Merchant-Locked)** : Elle fonctionne uniquement avec un commerçant spécifique. Si vous l'utilisez pour un abonnement (par exemple, Netflix ou un service de cloud), et que cette carte fuite, elle sera inutile pour tout autre achat ailleurs sur le web.

3. **La carte à limite stricte (Amount-Capped)** : Vous définissez un plafond de dépense. C'est l'arme absolue contre les pièges des "essais gratuits" qui se transforment en abonnements payants à votre insu. Si vous autorisez une limite de 1 euro pour la période d'essai, toute tentative de prélèvement ultérieur de 49,99 euros sera automatiquement rejetée par le réseau bancaire.

Des services comme Privacy.com (très populaire aux États-Unis) ont pionnierisé ce modèle. En Europe, les néobanques comme Revolut ou N26 proposent des cartes virtuelles éphémères dont les numéros changent après chaque transaction. De nombreuses banques

© 2026 Oussama Ghorbel

traditionnelles (comme Boursorama Banque, Fortuneo, ou le Crédit Agricole avec son service e-Card) offrent également des solutions de cartes virtuelles générées via leur application mobile.

L'utilisation de ces cartes présente un avantage secondaire majeur pour la confidentialité : elle empêche le recoupement par le numéro de carte. Certains réseaux publicitaires et courtiers en données utilisent le "hachage" du numéro de carte bancaire (une empreinte cryptographique de vos 16 chiffres) pour lier vos achats sur différents sites web, même si vous utilisez des adresses email différentes. En générant un numéro virtuel unique pour chaque marchand, vous brisez cette chaîne de corrélation. Vous redevenez, aux yeux de l'algorithme, un consommateur isolé et imprévisible.

Le paiement par cryptomonnaie (Monero vs Bitcoin)

Pour atteindre un niveau de confidentialité supérieur, certains utilisateurs se tournent vers les cryptomonnaies. Cependant, il existe une idée reçue dangereuse qu'il faut immédiatement déconstruire : la plupart des cryptomonnaies, à commencer par le Bitcoin, ne sont pas anonymes. Elles sont pseudonymes.

Le Bitcoin repose sur un grand livre comptable public et immuable (la blockchain). Chaque transaction est visible par tous, pour l'éternité. Si vous achetez un bien en ligne avec du Bitcoin et que ce portefeuille est un jour lié à votre identité réelle (par exemple, via un échange centralisé où vous avez fourni votre pièce d'identité pour respecter les normes KYC - *Know Your Customer*), c'est l'ensemble de votre historique financier passé et futur qui peut être mis à nu. Des entreprises d'analyse comme Chainalysis ont bâti des empires en traçant les flux sur la blockchain du Bitcoin, reliant les pseudonymes à des identités réelles et à des activités illicites ou simplement privées. Utiliser du Bitcoin pour préserver son anonymat sur le web est donc une erreur stratégique.

La véritable réponse technologique au besoin de confidentialité financière se nomme **Monero (XMR)**. Contrairement au Bitcoin, Monero a été conçu dès son origine pour être une monnaie numérique privée, sécurisée et non traçable. Elle repose sur trois piliers cryptographiques qui garantissent l'opacité des transactions :

© 2026 Oussama Ghorbel

• **Les signatures de cercle (Ring Signatures)** : Elles mélangent la signature de l'expéditeur avec celles d'autres utilisateurs sur le réseau, rendant mathématiquement impossible l'identification de la véritable source des fonds.

• **Les adresses furtives (Stealth Addresses)** : Pour chaque transaction, une adresse unique et éphémère est générée pour le destinataire. Même si vous publiez votre adresse Monero sur votre site web, personne ne peut voir sur la blockchain quels fonds vous ont été envoyés ni quel est votre solde.

• **RingCT (Ring Confidential Transactions)** : Cette technologie masque le montant exact de la transaction aux yeux du public, tout en permettant au réseau de vérifier qu'aucune fausse monnaie n'a été créée.

Utiliser Monero pour le e-commerce offre une confidentialité comparable à celle de l'argent liquide. Cependant, le défi est pratique : très peu de marchands acceptent directement le XMR en raison de la pression réglementaire. La solution de contournement la plus élégante consiste à utiliser des services d'achat de cartes cadeaux (comme Bitrefill). Vous envoyez du Monero à la plateforme, et celle-ci vous génère un code de carte cadeau (Amazon, Carrefour, cartes Visa prépayées, etc.) que vous pouvez ensuite utiliser sur n'importe quel site e-commerce traditionnel. Vous cassez ainsi le lien entre votre identité bancaire, votre portefeuille crypto, et l'achat final du bien physique.

Les casiers et adresses de livraison alternatives

Vous avez masqué votre navigateur, utilisé un alias email, et payé avec une carte virtuelle ou en Monero. Pourtant, il reste un maillon faible béant dans votre chaîne de confidentialité : la livraison physique. Le "dernier kilomètre" est le point de convergence où le monde numérique percutte le monde réel. Fournir votre adresse personnelle, c'est ancrer votre profil fantôme à une localisation géographique précise, révélant votre quartier, votre niveau de revenu estimé, et votre foyer.

La livraison à domicile est un luxe qui se paie au prix fort en données personnelles. Les transporteurs et les géants du e-commerce cartographient les habitudes de réception, les horaires de présence, et la typologie des logements. Pour déconnecter l'achat de votre domicile,

© 2026 Oussama Ghorbel

vous devez adopter des adresses de livraison alternatives.

Les points relais et les commerces de proximité

C'est la solution la plus simple et la plus accessible. En choisissant une livraison en point relais (Mondial Relay, Relais Colis, Pickup), vous évitez que l'adresse de votre domicile ne soit intégrée dans les bases de données du vendeur et du transporteur. Cependant, attention : certains points relais exigent une pièce d'identité correspondant au nom sur le colis. Pour contourner cela, utilisez un pseudonyme cohérent (un alias que vous utilisez régulièrement pour vos démarches non officielles) ou assurez-vous que le point relais accepte la remise du colis sur simple présentation du code de retrait et d'un SMS, ce qui est de plus en plus la norme.

Les casiers automatiques (Lockers)

Les réseaux de casiers (comme Amazon Locker, InPost, ou les consignes de la Poste) offrent un niveau de confidentialité supérieur. L'ouverture du casier se fait via un code QR ou un code PIN envoyé sur votre téléphone. Aucune interaction humaine n'est requise, et aucune vérification d'identité n'est effectuée au moment du retrait. C'est la méthode idéale pour les achats sensibles ou discrets.

Les boîtes postales et services de réexpédition

Pour une séparation totale et durable, la location d'une boîte postale (BP) dans un centre de tri postal ou via un service privé de domiciliation d'entreprise permet de recevoir du courrier et des colis sous une adresse qui n'est pas la vôtre. Certains services de *mail forwarding* (réexpédition de courrier) poussent le concept plus loin : ils reçoivent vos colis, retirent les étiquettes d'expédition originales, les remballent, et vous les expédient à votre vraie adresse. Bien que coûteuse, cette méthode est utilisée par les journalistes d'investigation, les personnes sous protection, et les défenseurs de la vie privée les plus exigeants pour acheter du matériel sensible sans que le vendeur initial ne connaisse leur localisation finale.

Éviter les biais de prix dynamiques (yield management)

© 2026 Oussama Ghorbel

Le *yield management* (ou tarification dynamique) est une technique née dans l'industrie aérienne dans les années 1980, consistant à faire varier le prix d'un même siège d'avion en temps réel en fonction de la demande, de la date, et du profil de l'acheteur. Aujourd'hui, cette pratique a contaminé l'ensemble du e-commerce : hôtellerie, location de voitures, billetterie, et même les biens de consommation courante, les sneakers ou l'électronique.

L'algorithme de prix dynamique ne cherche pas seulement à optimiser les stocks ; il cherche à estimer votre "consentement à payer". Et pour cela, il vous espionne.

Plusieurs études et témoignages d'anciens employés du secteur ont mis en lumière des pratiques de discrimination tarifaire basées sur les données numériques. Le cas le plus célèbre remonte à 2012, lorsqu'il a été découvert que le site de voyage Orbitz affichait des options d'hôtels en moyenne 20 à 30 % plus chères aux utilisateurs naviguant sur un ordinateur Mac par rapport à ceux sur un PC Windows. La logique de l'algorithme était purement statistique et cynique : les données montraient que les utilisateurs de Mac dépensaient historiquement plus pour leurs voyages.

Aujourd'hui, les variables prises en compte par les algorithmes de tarification sont infiniment plus complexes :

• **L'historique de navigation** : Si vous avez consulté le même vol ou le même téléviseur cinq fois en trois jours, l'algorithme déduit un sentiment d'urgence et une forte intention d'achat. Le prix peut alors augmenter subtilement pour vous pousser à l'achat immédiat par peur de manquer l'offre (FOMO - *Fear Of Missing Out*).

• **La géolocalisation (IP)** : Les prix peuvent varier selon votre code postal ou votre pays de résidence, ciblant les zones à fort pouvoir d'achat.

• **Le référent (Referrer)** : Si vous arrivez sur le site via un lien comparateur de prix, le site peut afficher un prix plus bas pour vous convertir. Si vous arrivez en direct ou via une publicité ciblée sur les réseaux sociaux, le prix de base peut être plus élevé.

Comment déjouer le yield management ?

© 2026 Oussama Ghorbel

La contre-mesure principale est la rupture de continuité de votre profil de navigation. Avant d'effectuer un achat important (voyage, électronique, assurance), ouvrez toujours une fenêtre de navigation privée. Mieux encore, utilisez un navigateur dédié à la confidentialité comme Brave ou Firefox avec des protections strictes contre le fingerprinting.

Modifiez votre empreinte géographique en utilisant un réseau VPN pour apparaître comme naviguant depuis une autre région ou un autre pays, et comparez les prix. Changez de *User-Agent* (l'identifiant technique de votre navigateur) pour simuler une connexion depuis un smartphone Android d'entrée de gamme plutôt que depuis le dernier MacBook Pro. Enfin, ne vous connectez jamais à votre compte client fidélité avant d'avoir validé votre panier et vérifié le prix final ; l'identification permet au site d'accéder à votre historique complet et d'ajuster le prix en conséquence.

Gérer les retours et le service client de manière anonyme

Le parcours d'achat ne s'arrête pas au paiement et à la livraison. Le service après-vente (SAV), les retours de marchandises et le support client représentent des vecteurs majeurs de fuite de données. C'est le moment où le masque tombe, car les opérateurs humains ou les chatbots sont formés pour extraire de vous des informations de vérification.

Lorsque vous initiez une procédure de retour (RMA - *Return Merchandise Authorization*), le système vous demande souvent de confirmer votre numéro de téléphone, votre email, ou de répondre à des questions de sécurité. Si vous avez utilisé un alias email et une carte virtuelle, le service client peut bloquer votre demande de remboursement s'il n'arrive pas à faire correspondre ces données avec une "identité vérifiée".

Pour gérer les retours sans compromettre votre anonymat, appliquez ces règles :

1. **Centralisez les communications** : Utilisez toujours votre alias email dédié au e-commerce. Ne donnez jamais votre numéro de téléphone personnel réel lors de la commande, même si le champ semble obligatoire (utilisez un numéro de téléphone virtuel jetable

© 2026 Oussama Ghorbel

ou un faux numéro respectant le format national si le site ne vérifie pas par SMS). Si le transporteur a besoin de vous contacter pour la livraison, il utilisera le numéro fourni ; s'il est faux, le colis sera mis en point relais par défaut.

2. **Privilégiez l'écrit au vocal** : Évitez les appels téléphoniques au service client. À l'oral, il est facile pour un opérateur de vous manipuler émotionnellement ou de vous soutirer des informations personnelles "pour valider votre dossier". Préférez les tickets de support par email ou le chat en ligne, où vous pouvez contrôler vos réponses et vous en tenir strictement aux faits légaux de la transaction (numéro de commande, motif de retour prévu par la loi).

3. **La question de la garantie légale** : Certains fabricants exigent l'enregistrement du produit avec votre véritable nom et adresse pour activer la garantie constructeur. C'est un compromis à évaluer. Pour un appareil électronique coûteux (ordinateur, smartphone), la garantie peut valoir la perte de confidentialité auprès du fabricant (mais pas nécessairement du revendeur). Pour des biens de consommation courante, ignorez l'enregistrement de garantie.

4. **Attention aux étiquettes de retour** : Lorsque vous renvoyez un colis, n'inscrivez pas votre véritable nom sur l'expéditeur si vous le pouvez, ou utilisez le nom de l'alias sous lequel la commande a été passée. Les services de logistique scannent les étiquettes de retour et agrègent ces données de flux inverse.

La gestion de l'après-vente demande de la rigueur. Considérez chaque interaction avec le support client comme une négociation avec un agent du renseignement commercial : donnez le minimum légalement requis pour obtenir le remboursement ou l'échange, et rien de plus.

Exercice pratique : Générer une carte bancaire virtuelle

Passons de la théorie à la pratique. L'objectif de cet exercice est de vous familiariser avec la création d'une carte bancaire virtuelle à usage unique ou à limite stricte, afin de protéger votre compte principal lors de votre prochain achat sur un site e-commerce que vous ne connaissez pas bien.

Prérequis :

© 2026 Oussama Ghorbel

• Un compte dans une néobanque proposant des cartes virtuelles éphémères (ex: Revolut, N26, ou tout autre service bancaire européen offrant cette fonctionnalité comme Boursorama avec son service de carte virtuelle).

• Votre smartphone avec l'application bancaire installée et sécurisée (biométrie ou code PIN).

Étapes de l'exercice :

1. **Identification du besoin** : Choisissez un produit que vous souhaitez acheter sur un site e-commerce secondaire (par exemple, une boutique spécialisée, un site de pièces détachées, ou une marketplace internationale). Relevez le montant exact de l'achat, frais de port inclus (ex: 47,50 €).

2. **Génération de la carte** : Ouvrez votre application bancaire et accédez à la section "Cartes" ou "Cartes virtuelles". Sélectionnez l'option pour créer une nouvelle carte.

3. **Configuration des limites (Le point crucial)** :

• Si l'option **"Carte à usage unique"** (Disposable) est disponible, sélectionnez-la. Le numéro de carte s'autodétruira après le paiement.

• Si vous devez utiliser une carte virtuelle standard, configurez une **limite de transaction stricte**. Fixez le plafond à 50 € (juste au-dessus du montant de votre achat).

• *Astuce anti-abonnement* : Si vous souscrivez à un essai gratuit qui nécessite une empreinte bancaire, créez une carte virtuelle avec une limite globale de 1 € ou 2 €. L'essai sera validé, mais le prélèvement mensuel automatique sera rejeté, vous protégeant contre l'oubli de résiliation.

4. **Copie sécurisée** : L'application va afficher les 16 chiffres, la date d'expiration et le CVV. Copiez ces informations directement depuis l'application vers le presse-papier sécurisé, ou saisissez-les manuellement sur le site e-commerce. Ne faites jamais de capture d'écran de votre carte virtuelle.

5. **Validation et vérification** : Procédez au paiement sur le site e-commerce. Une fois la transaction approuvée, retournez dans votre application bancaire. Vérifiez que la carte à usage unique a bien été

© 2026 Oussama Ghorbel

désactivée ou détruite, ou que la limite de la carte standard a bien bloqué tout débit supérieur à votre plafond.

En réalisant cet exercice, vous venez de créer un mur de sécurité entre votre patrimoine financier et l'écosystème sauvage du commerce en ligne. Vous avez acheté un produit, mais vous n'avez pas vendu votre sécurité. C'est l'essence même de la frugalité numérique : consommer le monde, sans se laisser dévorer par lui.

© 2026 Oussama Ghorbel

Partie 3 : Le cœur du réacteur (Appareils et OS)

© 2026 Oussama Ghorbel

Chapitre 13 – iOS et Android : décortiquer la télémétrie

Votre smartphone vous connaît mieux que votre conjoint. Il sait à quelle heure vous vous réveillez, combien de temps vous passez aux toilettes, quels articles vous lisez en secret, avec qui vous échangez des messages à deux heures du matin, et même — grâce aux données de l'accéléromètre — si vous marchez d'un pas hésitant après un verre de trop. Cette intimité n'est pas un bug. C'est le produit.

Chaque fois que vous déverrouillez votre téléphone, un flux continu de données quitte votre poche pour rejoindre les serveurs d'Apple ou de Google. Ce phénomène porte un nom technique : la **télémétrie**. Littéralement, la « mesure à distance ». À l'origine conçue pour diagnostiquer les pannes et améliorer les logiciels, elle est devenue, au fil des années, une infrastructure de surveillance massive, intégrée au cœur même du système d'exploitation.

Dans ce chapitre, nous allons ouvrir le capot. Non pas pour diaboliser ces entreprises — leurs produits restent remarquablement conçus — mais pour comprendre précisément ce qui sort de votre appareil, pourquoi, et surtout comment reprendre la main. Car contrairement à une idée reçue, vous n'êtes pas totalement impuissant face à ces géants. Vous disposez de leviers. Encore faut-il savoir où ils se cachent.

Le modèle de confiance : Apple vs Google

Avant de plonger dans les réglages, il faut comprendre une vérité fondamentale : **Apple et Google ne fonctionnent pas selon le même modèle économique, et cela change tout** en matière de télémétrie.

Google est, à son cœur, une régie publicitaire. En 2025, près de 78 % de son chiffre d'affaires provient encore de la publicité ciblée. Android, son système d'exploitation mobile, équipe environ 72 % des smartphones dans le monde. Ce n'est pas un produit vendu, c'est un vecteur de distribution. Google ne vous facture pas Android parce qu'Android n'est pas le produit — *vous* êtes le produit, ou plus

précisément, votre attention et vos données comportementales le sont. Le système d'exploitation devient alors un capteur géant, capable de corréler vos recherches, vos déplacements, vos applications installées, vos emails, vos vidéos regardées, pour affiner un profil publicitaire d'une précision redoutable.

Apple, à l'inverse, vend du matériel à marge élevée. Son modèle repose sur l'idée que la confidentialité peut être un argument de vente premium. Une maxime bien connue du secteur le rappelle : « Si vous n'êtes pas un client, vous êtes le produit. » Chez Apple, la position martelée dès 2014 est claire : « Une grande expérience utilisateur ne peut pas se faire au détriment de votre vie privée. » Cette position, sincère dans ses grandes lignes, n'empêche pas Apple de collecter massivement des données — mais cette collecte est principalement orientée vers l'amélioration de ses propres services (Apple Music, App Store, Apple Pay) et non vers la revente à des tiers.

La différence est subtile mais essentielle. Google collecte pour **monétiser votre profil auprès d'annonceurs**. Apple collecte pour **optimiser son écosystème et vous y retenir**. Dans les deux cas, vos données circulent. Mais la finalité, l'ampleur et les destinataires diffèrent radicalement.

Cela ne signifie pas qu'Apple soit un paradis de la confidentialité et Google un enfer orwellien. Les deux entreprises ont fait l'objet d'enquêtes et de sanctions pour leurs pratiques. Apple a été épinglée pour la collecte de données via Apple News et Apple Stocks, et ses propres applications contournent parfois les règles qu'elle impose aux développeurs tiers. Google, de son côté, a renforcé ses outils de contrôle utilisateur sous la pression réglementaire européenne. Mais la structure fondamentale de leurs modèles reste un prisme indispensable pour interpréter chaque réglage que nous allons explorer.

Une métaphore, peut-être. Imaginez deux hôtels. Le premier, l'Hôtel Apple, vous facture cher la nuitée mais s'engage à ne pas revendre vos habitudes de consommation au restaurant de l'autre côté de la rue. Il observe néanmoins ce que vous mangez pour ajuster son propre menu. Le second, l'Hôtel Google, vous offre la chambre gratuitement, mais installe des caméras dans le couloir, note vos allées et venues, et revend ces informations aux commerces du quartier pour qu'ils vous envoient

© 2026 Oussama Ghorbel

des offres ciblées à votre sortie. Les deux hôtels vous surveillent. Mais la nature de la surveillance, et ce qu'ils en font, divergent profondément.

Cette distinction explique aussi pourquoi les leviers d'action ne sont pas les mêmes. Sur iOS, votre combat portera surtout sur les **applications tierces** et leurs tentatives de pistage. Sur Android, il faudra vous attaquer au **système lui-même**, à ses services intégrés, à la télémétrie embarquée dans les moindres recoins de l'OS.

L'App Tracking Transparency (ATT) d'Apple : comment l'utiliser

En avril 2021, avec la sortie d'iOS 14.5, Apple a déployé l'une des décisions les plus disruptives de l'histoire du web mobile : l'**App Tracking Transparency**, ou ATT. Le principe est d'une simplicité désarmante. Désormais, toute application qui souhaite suivre votre activité *à travers d'autres applications et sites web appartenant à d'autres entreprises* doit vous demander explicitement l'autorisation via une fenêtre pop-up.

Avant l'ATT, les applications utilisaient librement un identifiant unique appelé **IDFA** (Identifier for Advertisers), une sorte de numéro de sécurité sociale publicitaire collé à votre iPhone. Une application de météo pouvait lire votre IDFA, un réseau social aussi, un jeu également — et tous pouvaient transmettre cette donnée à des régies publicitaires qui reconstituaient, en rapprochant les IDFA, l'ensemble de votre parcours numérique. L'ATT n'a pas supprimé l'IDFA. Elle a simplement exigé que l'utilisateur donne son consentement *éclairé* avant qu'une application y accède.

Les résultats ont été spectaculaires. Selon les études de Flurry Analytics, environ **75 à 80 % des utilisateurs iOS refusent le suivi** lorsque la fenêtre ATT apparaît. Meta (Facebook) a estimé le manque à gagner à plusieurs milliards de dollars dès la première année. Le secteur de la publicité mobile a été secoué comme jamais.

Pour tirer pleinement parti de l'ATT, voici la démarche que je vous recommande.

Premièrement, vérifiez l'état global du suivi. Rendez-vous dans *Réglages > Confidentialité et sécurité > Suivi*. Vous y trouverez un

© 2026 Oussama Ghorbel

interrupteur général « Autoriser les apps à demander le suivi ». S'il est désactivé, aucune application ne pourra même vous poser la question — le refus est systématique. C'est, à mon sens, la position par défaut idéale. Vous gardez ainsi la main sans avoir à répondre à chaque pop-up.

Deuxièmement, auditez les autorisations déjà accordées. Dans ce même menu, la liste des applications ayant reçu votre autorisation s'affiche. Il n'est pas rare d'y découvrir des apps que vous aviez validées distraitement, au détour d'une installation précipitée. Révoquez sans hésiter. Vous pouvez le faire individuellement, ou d'un seul geste en désactivant l'interrupteur global.

Troisièmement, comprenez les limites de l'ATT. Elle ne bloque que le suivi *inter-applications* via l'IDFA. Une application peut parfaitement continuer à vous profiler *à l'intérieur de son propre écosystème*. Facebook sait ce que vous faites sur Facebook, Instagram et WhatsApp — ces trois services partagent leurs données en interne, sans passer par l'IDFA. L'ATT ne change rien à cela. De même, elle n'empêche pas les techniques de fingerprinting (empreinte numérique du navigateur) ni le pistage basé sur votre adresse email ou votre numéro de téléphone lorsque vous les renseignez.

Quatrièmement, activez les protections complémentaires d'iOS. Dans *Réglages > Confidentialité et sécurité > Sécurité*, assurez-vous que le « Verrouillage avancé des données » (Advanced Data Protection) est activé pour iCloud. Il étend le chiffrement de bout en bout à la quasi-totalité de vos sauvegardes, de sorte qu'Apple elle-même ne peut plus les déchiffrer. C'est un progrès majeur introduit avec iOS 16.2, trop souvent ignoré.

Enfin, lisez la demande avant de répondre. La fenêtre ATT affiche désormais le message personnalisé du développeur expliquant pourquoi il souhaite vous suivre. Certains sont honnêtes (« pour vous montrer des publicités pertinentes »), d'autres manipulateurs (« pour continuer à vous offrir ce service gratuitement »). Gardez en tête qu'une application peut très bien vivre sans vous pister — et que refuser ne désactive pas l'application.

L'ATT n'est pas une baguette magique. C'est un outil puissant, à condition de le combiner avec d'autres pratiques : utiliser Safari avec la «

© 2026 Oussama Ghorbel

Protection renforcée contre le pistage », préférer des applications respectueuses, et surtout, limiter les données que vous fournissez volontairement.

Le bac à sable (sandbox) et l'isolation des applications

Derrière ce terme technique se cache l'un des piliers les plus importants de la sécurité moderne : le **sandbox**, ou bac à sable. Le principe est simple. Chaque application installée sur votre smartphone s'exécute dans un environnement isolé, une sorte de cellule individuelle, qui l'empêche d'accéder aux données des autres applications ou aux fichiers système sans autorisation explicite.

Imaginez un immeuble où chaque locataire vit dans un appartement hermétiquement clos, sans couloir commun, sans possibilité de frapper à la porte du voisin. Si une application de lampe torche malveillante tente de lire vos messages WhatsApp, le sandbox l'arrête net. Elle n'a tout simplement pas accès à ce dossier.

Sur iOS, le sandbox est historiquement très strict. Apple l'a imposé dès le premier iPhone en 2007. Chaque app dispose de son propre conteneur de données, et la communication entre applications passe par des mécanismes très contrôlés (les « share extensions », les URL schemes, les App Groups pour les apps du même développeur). Le système d'exploitation lui-même applique une politique de « moindre privilège » : une application n'obtient que les permissions strictement nécessaires à son fonctionnement déclaré.

Sur Android, le sandbox existe également — chaque application s'exécute sous un identifiant utilisateur Linux unique — mais il a longtemps été plus poreux. Les applications pouvaient, jusqu'à Android 10, accéder librement à des dossiers partagés comme le stockage externe. Depuis Android 11, le « Scoped Storage » a considérablement réduit cette liberté, mais l'écosystème Android reste, par sa nature ouverte, plus exposé aux contournements. Les constructeurs ajoutent souvent leurs propres couches (One UI chez Samsung, MIUI/HyperOS chez Xiaomi) qui peuvent introduire des failles ou des collectes supplémentaires.

© 2026 Oussama Ghorbel

Ce que vous devez retenir, en tant qu'utilisateur, c'est que **le sandbox ne vous protège que si vous ne l'ouvrez pas vous-même**. Chaque fois que vous accordez une permission — accès aux contacts, à la localisation, au micro, aux photos — vous percez un trou dans le mur de votre cellule. L'art de la confidentialité mobile consiste donc à distribuer ces permissions avec une parcimonie extrême.

Voici une règle pratique éprouvée, à appliquer systématiquement. Pour chaque permission demandée, posez-vous trois questions :

1. **Cette permission est-elle indispensable au fonctionnement de l'application ?** Une application de navigation a besoin de la localisation. Une application de retouche photo a besoin d'accéder aux images. Une application de lampe torche n'a besoin de *rien* d'autre que de la caméra (flash). Tout le reste est suspect.

2. **Puis-je limiter la portée de la permission ?** Depuis iOS 14 et Android 11, vous pouvez accorder un accès « partiel » à vos photos, en sélectionnant uniquement les images nécessaires. De même, la localisation peut être limitée à « lorsque l'app est active » plutôt que « toujours ». Privilégiez toujours l'option la plus restrictive.

3. **Cette application mérite-t-elle ma confiance ?** Une permission n'est dangereuse que si l'éditeur en abuse. Avant d'installer une application, vérifiez son éditeur, son ancienneté, ses avis, sa politique de confidentialité. Les clones d'applications populaires, les éditeurs inconnus, les apps au nom orthographié bizarrement sont souvent des pièges.

Sur iOS, le menu *Confidentialité et sécurité* liste chaque permission et les applications qui y ont accès. Sur Android, le *Privacy Dashboard* (tableau de bord de confidentialité), apparu avec Android 12, offre une vision chronologique des accès aux capteurs sensibles (micro, caméra, localisation). Nous y reviendrons dans l'exercice de fin de chapitre.

Un point souvent négligé : **le presse-papiers**. Jusqu'à iOS 14, une application pouvait lire silencieusement ce que vous aviez copié, y compris des mots de passe ou des adresses. Désormais, iOS affiche une bannière « Untel a collé à partir de Untel » à chaque lecture. Sur Android 13+, le presse-papiers est automatiquement effacé après une heure, et les

© 2026 Oussama Ghorbel

accès sont journalisés. Gardez un œil sur ces notifications : elles révèlent parfois des comportements intrusifs insoupçonnés.

Désactiver la télémétrie et les diagnostics système sur Android

Android est un système ouvert, modulaire, et c'est à la fois sa force et sa faiblesse. La télémétrie y est omniprésente, dispersée entre Google, le constructeur du téléphone (Samsung, Xiaomi, Oppo, etc.) et parfois même l'opérateur mobile. Désactiver l'ensemble de ces collectes exige une approche méthodique, menu par menu.

Commençons par **la télémétrie Google**, la plus volumineuse. Rendez-vous dans *Paramètres > Google > Gérer votre compte Google > Données et confidentialité*. Là, vous accédez à une interface web qui récapitule l'ensemble des données que Google stocke à votre sujet. Trois actions prioritaires :

- **Désactiver l'historique des positions** (Location History). Par défaut, Google enregistre chacun de vos déplacements dans une base appelée « Timeline ». Même si vous avez coupé la localisation de certaines applications, cette collecte peut persister. Désactivez-la et supprimez l'historique existant.
- **Désactiver l'activité sur le Web et dans les applications** (Web & App Activity). Elle enregistre vos recherches, vos commandes vocales Google Assistant, vos interactions avec Maps, etc.
- **Désactiver l'historique YouTube** (YouTube History), séparé du reste.

Toujours dans *Paramètres > Google*, entrez dans *Paramètres des services Google > Utilisation et diagnostics*. Désactivez l'envoi automatique de rapports. Ces données, présentées comme utiles pour « améliorer Android », incluent des informations sur les applications que vous utilisez, la durée des sessions, les erreurs rencontrées.

Ensuite, attaquez-vous à **la télémétrie du constructeur**. Chaque marque a ses propres menus, souvent dissimulés. Voici les chemins les plus courants :

© 2026 Oussama Ghorbel

• **Samsung** : *Paramètres > Sécurité et confidentialité > Confidentialité > Autres paramètres de confidentialité*. Désactivez « Envoyer des données de diagnostic », « Personnalisation du service » et « Informations marketing personnalisées ».

• **Xiaomi** : *Paramètres > Mots de passe et sécurité > Autorisation et révocation*. Révoquez l'autorisation des applications système *msa* (MIUI System Ads) et *MiuiDaemon*. Ces deux composants sont responsables de la publicité intégrée et de la remontée de données vers les serveurs chinois.

• **Oppo / Realme / OnePlus** : *Paramètres > Confidentialité > Programme d'expérience utilisateur*. Désactivez-le intégralement.

• **Google Pixel** : *Paramètres > Sécurité et confidentialité > Confidentialité > Utilisation et diagnostic*. Désactivez.

Une étape supplémentaire, souvent oubliée, consiste à **désactiver l'identifiant publicitaire Android** (AAID). Allez dans *Paramètres > Google > Annonces*, puis choisissez « Supprimer l'identifiant publicitaire ». Sur Android 12 et versions ultérieures, vous pouvez également le désactiver complètement via un interrupteur, ce qui rend toute nouvelle collecte impossible sans votre consentement explicite.

Attention : désactiver la télémétrie n'a aucun impact négatif sur le fonctionnement de votre téléphone. Les mises à jour continueront d'arriver, les applications fonctionneront normalement. Vous perdez simplement la « contribution à l'amélioration du service », argument marketing derrière lequel se cache une collecte bien plus vaste.

Une nuance importante. Même après avoir tout désactivé, **votre téléphone Android continuera de communiquer avec les serveurs Google**. C'est inhérent à la nature des Google Play Services, le cœur battant de l'écosystème. Nous y reviendrons dans une section dédiée. Mais réduire la télémétrie explicite, c'est déjà supprimer une couche massive de collecte.

Les ROMs alternatives (GrapheneOS, CalyxOS) : pour qui ?

Pour les utilisateurs les plus exigeants en matière de confidentialité, il existe une voie radicale : remplacer Android par un système d'exploitation alternatif, appelé **ROM custom**. Deux noms dominent ce

© 2026 Oussama Ghorbel

paysage : **GrapheneOS** et **CalyxOS**. Examinons honnêtement ce qu'ils offrent, et à qui ils s'adressent.

GrapheneOS est un projet né en 2018, dirigé par Daniel Micay, ancien développeur du système de sécurité d'Android. Son objectif est clair : proposer un système d'exploitation mobile axé sur la sécurité et la confidentialité, sans compromettre la compatibilité avec les applications Android. GrapheneOS ne fonctionne officiellement que sur les **Google Pixel** — un paradoxe apparent, mais qui s'explique par la qualité du matériel (notamment la puce de sécurité Titan) et par la possibilité de verrouiller à nouveau le bootloader après installation, ce qui renforce la sécurité.

Les apports de GrapheneOS sont considérables :

• **Durcissement du noyau et de la mémoire** (hardened_malloc) contre les exploits.

• **Sandbox renforcé** pour chaque application, avec des permissions granulaires supplémentaires (accès réseau par app, accès aux capteurs, etc.).

• **Aucune télémétrie Google** par défaut. Le système est totalement dé-googlisé.

• **Compatibilité optionnelle** avec les Google Play Services, via un mode « sandboxed » qui les exécute comme une application ordinaire, sans privilèges système. C'est une prouesse technique unique.

• **Mises à jour de sécurité** parfois plus rapides que celles de Google lui-même.

CalyxOS, développé par la Calyx Institute, adopte une philosophie légèrement différente. Il vise un équilibre entre confidentialité et facilité d'utilisation. Il inclut par défaut des applications respectueuses (Signal, F-Droid, Tor Browser), propose microG (une implémentation libre des services Google) préinstallé, et fonctionne sur Pixel ainsi que sur quelques modèles Fairphone et Motorola.

CalyxOS est plus accessible aux non-techniciens. GrapheneOS est plus rigoureux, plus sécurisé, mais demande un peu plus d'effort pour configurer les services Google si vous en avez besoin.

© 2026 Oussama Ghorbel

À qui s'adressent ces ROMs ? Soyons francs. Elles ne conviennent pas à tout le monde. Elles s'adressent :

- Aux **journalistes, avocats, militants** manipulant des informations sensibles, pour qui la confidentialité est une question de sécurité physique.
- Aux **professionnels de la cybersécurité** et aux chercheurs souhaitant un environnement mobile maîtrisé.
- Aux **utilisateurs avertis** prêts à consacrer quelques heures à la configuration initiale et à accepter certaines limitations (applications bancaires parfois récalcitrantes, Google Pay moins fluide, etc.).

Pour l'utilisateur moyen, ces ROMs représentent un investissement en temps et en apprentissage disproportionné par rapport au gain. Mieux vaut, dans ce cas, optimiser un Android standard selon les méthodes décrites plus haut, ou basculer vers un iPhone correctement configuré.

Avertissement important : installer une ROM custom implique de déverrouiller le bootloader, ce qui peut annuler la garantie, effacer toutes vos données, et — si l'opération est mal réalisée — bloquer définitivement l'appareil (le fameux « brick »). Renseignez-vous longuement avant de vous lancer, suivez les guides officiels à la lettre, et ne tentez pas l'opération sur votre téléphone principal sans disposer d'un appareil de secours.

Enfin, une vérité qui dérange : **même GrapheneOS ne vous rend pas anonyme**. Il vous rend beaucoup plus difficile à pister, à profiler, à attaquer. Mais l'anonymat complet sur un smartphone connecté aux réseaux cellulaires est un mythe. Votre opérateur sait où vous êtes en permanence, grâce à la triangulation des antennes. Votre numéro de téléphone est un identifiant unique. La ROM custom est une couche de protection puissante, pas une cape d'invisibilité.

Gérer les services Google Play sur un appareil Android

Les **Google Play Services** sont l'élément le plus omniprésent et le plus mystérieux d'Android. Ils ne figurent pas dans votre liste d'applications comme une application normale. Pourtant, ils s'exécutent en permanence, en arrière-plan, avec des privilèges système élevés. Ils sont responsables des notifications push, de la localisation, de la

© 2026 Oussama Ghorbel

connexion aux comptes Google, de Google Pay, de la vérification des licences d'applications, et de bien d'autres fonctions invisibles.

La question que tout utilisateur soucieux de sa vie privée se pose est légitime : **peut-on s'en passer ?**

La réponse courte est : oui, mais avec de sérieuses conséquences pratiques. La réponse longue mérite d'être développée.

Les Google Play Services ne sont pas un simple accessoire. La majorité des applications du Play Store en dépendent, souvent sans que vous le sachiez. Uber les utilise pour la localisation. Votre application bancaire pour les notifications push. WhatsApp pour la sauvegarde sur Google Drive. Tinder pour la connexion via le compte Google. Supprimer les Play Services, c'est condamner de nombreuses applications à un fonctionnement dégradé, voire à l'arrêt complet.

Trois stratégies s'offrent à vous, par niveau d'engagement croissant.

Stratégie 1 : restreindre les permissions des Play Services. C'est l'approche la plus simple et la moins risquée. Rendez-vous dans *Paramètres > Applications > Services Google Play > Autorisations*. Révoquez tout ce qui n'est pas strictement nécessaire : localisation (sauf si vous utilisez Google Maps), contacts, téléphone, SMS, capteurs corporels. Conservez uniquement ce qui est indispensable à votre usage. Cette méthode réduit significativement la surface de collecte sans casser quoi que ce soit.

Stratégie 2 : utiliser microG. microG est une implémentation libre et open source des APIs Google Play Services. Elle « trompe » les applications qui croient s'adresser aux vrais services Google, tout en limitant drastiquement la collecte de données. microG peut être installé manuellement sur certains appareils, ou est préinstallé sur des ROMs comme CalyxOS, /e/OS, ou LineageOS avec microG.

La configuration de microG demande un peu de technique. Il faut notamment choisir quels serveurs utiliser pour la géolocalisation (Apple, Mozilla, ou aucun), et décider si vous activez la registration Google (nécessaire pour les notifications push de certaines apps). Une fois en place, microG offre un compromis remarquable : la plupart des applications fonctionnent normalement, tout en envoyant infiniment

© 2026 Oussama Ghorbel

moins de données à Mountain View.

Stratégie 3 : supprimer totalement les Google Play Services. C'est la voie empruntée par GrapheneOS (qui propose toutefois leur réinstallation en mode sandbox) et par les ROMs les plus pures. Dans ce cas, vous devez remplacer l'ensemble de votre écosystème :

- **Aurora Store** ou **F-Droid** pour installer des applications sans passer par le Play Store.
- **Signal, Threema ou Session** pour les messageries.
- **Organic Maps, OsmAnd** pour la navigation, en remplacement de Google Maps.
- **NewPipe** pour YouTube sans publicité ni pistage.
- **Nextcloud** pour la synchronisation de fichiers.

Cette stratégie est la plus radicale et la plus libératrice. Elle exige aussi une discipline de fer et une acceptation des frustrations quotidiennes. Certaines applications bancaires, certains jeux, certains services gouvernementaux refuseront tout simplement de fonctionner. C'est un choix de vie numérique, presque philosophique.

Une note sur le projet /e/OS, développé par la fondation française éponyme. Il s'agit d'une ROM Android « dé-googlisée » préinstallée sur des smartphones vendus directement par la fondation, ou installable sur de nombreux modèles. /e/OS propose son propre cloud souverain (Murena), ses applications maison, et une interface proche d'Android stock. C'est une option intéressante pour qui souhaite franchir le pas sans bricoler soi-même, moyennant l'achat d'un appareil dédié ou l'acceptation d'une procédure d'installation encadrée.

Quelle que soit la stratégie choisie, rappelez-vous que les Play Services ne sont qu'une pièce du puzzle. Votre opérateur mobile, les applications que vous installez, les sites web que vous visitez contribuent tous à votre empreinte numérique. Agir sur les Play Services, c'est s'attaquer au cœur du réacteur — mais ce n'est pas éteindre toute la centrale.

Exercice pratique : auditer le Privacy Dashboard de votre smartphone

© 2026 Oussama Ghorbel

La théorie, c'est bien. La pratique, c'est mieux. Je vous propose maintenant un exercice concret, réalisable en une vingtaine de minutes, qui vous donnera une vision claire des applications qui abusent de vos capteurs les plus sensibles.

Sur Android (version 12 ou ultérieure) :

1. Ouvrez les *Paramètres*, puis *Sécurité et confidentialité* (ou *Confidentialité* selon les marques), puis *Tableau de bord de confidentialité* (Privacy Dashboard).

2. Vous arrivez sur une timeline de 24 heures. Trois capteurs sont mis en avant par défaut : **Localisation**, **Caméra**, **Microphone**.

3. Pour chacun de ces capteurs, examinez la liste des applications qui y ont accédé. Notez les accès qui vous semblent injustifiés. Une application de recette de cuisine qui a consulté votre localisation à 3 h du matin ? Une lampe torche qui a activé le microphone ? Ce sont des signaux d'alerte.

4. Cliquez sur chaque application pour voir le détail des accès (heure exacte, durée). Android 13 et suivants permettent même de voir la justification fournie par le développeur.

5. Étendez l'audit aux autres permissions : *Contacts*, *SMS*, *Journal d'appels*, *Fichiers et contenus multimédias*. Les abus y sont fréquents.

6. Pour chaque application suspecte, deux options : **révoquer la permission** (via le menu dédié de l'application) ou **désinstaller** si l'application ne vous est pas indispensable.

Sur iOS (iOS 15 ou ultérieur) :

1. Ouvrez *Réglages*, puis *Confidentialité et sécurité*, puis *Rapport de confidentialité des apps* (App Privacy Report), que vous devrez peut-être activer au préalable.

2. Après quelques jours de collecte, ce rapport vous montre : la fréquence d'accès à la localisation, au micro, à la caméra, aux contacts, aux photos ; les domaines réseau contactés par chaque application ; et les domaines tiers (trackers) atteints indirectement.

3. Concentrez-vous sur la section « Activité du site web de l'app ». Vous y découvrirez, parfois avec stupeur, les dizaines de domaines

© 2026 Oussama Ghorbel

publicitaires auxquels une application apparemment anodine transmet des données.

4. Consultez également le menu *Confidentialité et sécurité > Enregistrement des apps* pour identifier les applications qui utilisent le micro ou la caméra en ce moment même (les pastilles orange et verte dans la barre d'état).

Ce que vous allez probablement découvrir. La plupart des utilisateurs, en faisant cet exercice pour la première fois, tombent des nues. Une application de jeux qui accède à la localisation toutes les dix minutes. Une calculatrice qui contacte une vingtaine de régies publicitaires. Une application de méditation qui lit vos contacts. Ces comportements ne sont pas des bugs, ce sont des choix délibérés de monétisation.

Ce que vous devez faire ensuite. Désinstallez sans état d'âme les applications les plus voraces, surtout si elles ne vous sont pas essentielles. Pour les applications indispensables, révoquez les permissions abusives et cherchez des alternatives plus respectueuses. F-Droid, AlternativeTo et le site *PrivacyTests.org* sont d'excellents points de départ pour trouver des substituts.

Tenez un journal. Notez, à la fin de cet audit, les cinq applications les plus problématiques que vous avez identifiées, et les actions que vous avez entreprises. Refaites l'exercice dans trois mois. Vous constaterez deux choses : d'abord, que votre téléphone est devenu plus rapide et économe en batterie (moins de collectes en arrière-plan, c'est moins de ressources consommées) ; ensuite, que de nouvelles applications auront tenté de prendre la place des anciennes dans votre intimité numérique. La vigilance n'est pas un acte ponctuel, c'est une hygiène.

La télémétrie mobile est l'une des formes les plus intimes de surveillance contemporaine, parce qu'elle s'exerce sur l'objet que nous touchons le plus, que nous gardons près de nous jour et nuit, dans lequel nous versons nos pensées les plus privées. Comprendre son fonctionnement, c'est déjà reprendre une part de contrôle. Agir sur elle, c'est tracer une frontière entre ce que nous acceptons de partager et ce que nous réservons à notre jardin secret.

© 2026 Oussama Ghorbel

Apple et Google ne disparaîtront pas demain. Leurs systèmes continueront d'évoluer, parfois vers plus de respect de la vie privée sous la pression des régulateurs et des utilisateurs, parfois vers de nouvelles formes de collecte plus subtiles. Votre rôle n'est pas de devenir un ermite numérique, mais un utilisateur lucide, capable de choisir en conscience ce qu'il concède et ce qu'il refuse.

Dans le chapitre suivant, nous descendrons d'un cran dans les réglages, en nous attaquant à l'une des tâches les plus fastidieuses mais les plus libératrices qui soient : le nettoyage méthodique des permissions de toutes vos applications mobiles. Vous verrez qu'en une après-midi de travail, vous pouvez réduire de moitié la surface d'exposition de votre vie privée. Le chantier commence maintenant.

© 2026 Oussama Ghorbel

Chapitre 14 – Le nettoyage des permissions mobiles

En cybersécurité, il existe une règle d'or, un pilier fondamental sur lequel repose la sécurité des systèmes d'information les plus critiques au monde : le principe du moindre privilège. Ce concept stipule qu'un utilisateur, un programme ou un processus ne doit se voir accorder que les droits d'accès strictement nécessaires à l'accomplissement de sa tâche, et rien de plus. Si un employé du service comptable n'a pas besoin d'accéder aux dossiers de la recherche et développement pour faire son travail, cet accès doit lui être refusé par défaut.

Pourtant, lorsque nous utilisons nos smartphones, nous bafouons allègrement ce principe des dizaines de fois par jour. Nous distribuons les clés de notre château numérique à des applications tierces avec une désinvolture qui ferait hurler n'importe quel administrateur réseau. Votre smartphone n'est pas un simple téléphone ; c'est un capteur biométrique et environnemental surpuissant, un panoptique de poche qui connaît vos déplacements, vos conversations, votre rythme cardiaque et vos insomnies.

Appliquer le principe du moindre privilège à votre écosystème mobile n'est pas une option de confort, c'est la première ligne de défense de votre identité numérique. Dans ce chapitre, nous allons décortiquer la mécanique des permissions, comprendre comment les applications abusent de votre confiance, et mettre en place une routine de nettoyage impitoyable pour reprendre le contrôle de vos capteurs et de vos données.

Le danger des permissions « toujours autoriser »

L'architecture des systèmes d'exploitation mobiles modernes, qu'il s'agisse d'iOS ou d'Android, est conçue autour du concept de « bac à sable » (sandboxing). Chaque application s'exécute dans un environnement isolé, incapable d'accéder aux données d'une autre application ou aux capteurs matériels du téléphone sans une autorisation explicite de votre part. Sur le papier, le système est robuste. Dans la pratique, le maillon faible, c'est vous.

© 2026 Oussama Ghorbel

Les développeurs d'applications et les concepteurs d'interfaces utilisateur (UX) ont perfectionné l'art des *dark patterns*, ces interfaces truquées destinées à manipuler vos choix. Lorsqu'une application vous demande l'accès à votre localisation ou à vos contacts, la fenêtre contextuelle qui s'affiche est souvent conçue pour créer un sentiment d'urgence ou de frustration. Le bouton « Toujours autoriser » est mis en valeur, parfois en gras ou en couleur, tandis que les options plus restrictives comme « Demander à chaque fois » ou « Autoriser seulement si l'app est active » sont reléguées au second plan, voire cachées derrière un menu déroulant.

Céder à la facilité en cliquant sur « Toujours autoriser » est une erreur aux conséquences profondes. Lorsque vous accordez ce privilège, vous donnez à l'application le droit de s'exécuter en arrière-plan, même lorsque votre téléphone est dans votre poche et que l'écran est éteint. L'application peut alors « réveiller » le processeur, activer les capteurs, établir des connexions réseau et transmettre des données à des serveurs distants.

Ce phénomène a deux impacts majeurs. Le premier est technique : c'est la cause principale de la dégradation de l'autonomie de votre batterie et de la consommation abusive de votre forfait de données mobiles. Si votre téléphone chauffe dans votre poche ou si votre batterie fond comme neige au soleil, c'est souvent le signe qu'une application s'active en coulisses. Le second impact est lié à la confidentialité. Une application de lampe torche ou de calculatrice qui possède l'accès permanent à votre localisation ou à votre presse-papiers n'a aucune justification technique pour ce privilège. En choisissant « Toujours autoriser », vous financez involontairement un modèle économique basé sur la collecte de données en continu, permettant aux courtiers en données (data brokers) de tisser une chronologie précise de vos habitudes, de vos lieux de fréquentation et de vos routines quotidiennes.

La règle du moindre privilège impose donc un changement de paradigme : par défaut, refusez. Si l'application a besoin de la permission pour fonctionner à l'instant T, choisissez « Autoriser seulement cette fois » ou « Lors de l'utilisation de l'app ». Si l'application refuse de fonctionner sans un accès permanent, posez-vous la question de sa légitimité sur votre appareil.

© 2026 Oussama Ghorbel

Gérer la localisation : approximative vs précise

La localisation est sans conteste la donnée la plus convoitée par l'industrie publicitaire et les courtiers en données. Contrairement à un identifiant publicitaire que vous pouvez réinitialiser, ou à une adresse IP qui peut changer, votre trajectoire physique dans le monde réel est une signature unique et infalsifiable. Elle révèle votre domicile, votre lieu de travail, votre médecin, vos convictions religieuses (via les lieux de culte fréquentés) et vos opinions politiques (via les manifestations).

Pendant des années, la localisation était binaire : soit vous donniez votre position GPS exacte (précise à quelques mètres près), soit vous bloquiez l'accès. Aujourd'hui, les systèmes d'exploitation ont introduit une nuance salvatrice : la localisation approximative.

Lorsque vous installez une application météo, quel est son besoin réel ? Elle doit savoir dans quelle ville ou quel quartier vous vous trouvez pour vous fournir des prévisions pertinentes. Elle n'a absolument aucun besoin de savoir que vous habitez au 14 rue de la Paix, au troisième étage. En activant l'option « Position approximative », le système d'exploitation floute volontairement vos coordonnées GPS. Au lieu de transmettre votre position exacte, le téléphone génère un périmètre aléatoire de plusieurs kilomètres carrés autour de vous. L'application reçoit une zone, pas un point. C'est l'illustration parfaite du principe du moindre privilège appliqué à la géographie.

Cependant, la localisation ne se limite pas au satellite GPS. Les applications contournent fréquemment vos restrictions en utilisant d'autres capteurs. Le Wi-Fi et le Bluetooth sont des outils de géolocalisation redoutables. Même si vous êtes connecté à un réseau Wi-Fi, votre téléphone scanne en permanence les environs pour détecter d'autres bornes. Les adresses MAC (les identifiants uniques) de ces bornes Wi-Fi et des balises Bluetooth (beacons) présentes dans les centres commerciaux sont cataloguées par des géants comme Google et Apple pour cartographier le monde. Une application qui obtient l'autorisation d'activer le Bluetooth ou de scanner les réseaux Wi-Fi à proximité peut en déduire votre position avec une précision diabolique, sans jamais demander la permission GPS.

© 2026 Oussama Ghorbel

Depuis les récentes mises à jour d'iOS et d'Android, l'accès au scan Wi-Fi et Bluetooth pour des besoins de localisation est désormais soumis aux mêmes règles strictes que le GPS. Soyez extrêmement vigilant lorsqu'une application, comme un logiciel de gestion de casques audio ou de montres connectées, vous demande l'accès à la « Localisation précise » pour pouvoir se connecter en Bluetooth. C'est souvent une exigence du système d'exploitation lui-même pour autoriser le couplage, mais vous devez vérifier si l'application envoie ces données sur ses propres serveurs. Dans le doute, accordez l'accès, effectuez le couplage, puis révoquez immédiatement la permission de localisation dans les réglages.

L'accès aux photos, au micro et à la caméra

Les capteurs sensoriels de votre téléphone — ses yeux, ses oreilles et sa mémoire visuelle — représentent l'intimité la plus brute. L'accès à ces composants a longtemps été une porte ouverte au pillage de données.

Prenons l'accès à la galerie photo. Jusqu'à récemment, autoriser une application de réseau social à accéder à vos photos signifiait lui donner les clés de l'intégralité de votre bibliothèque. L'application pouvait alors analyser, indexer et potentiellement exfiltrer des milliers de clichés. Pire encore, chaque photo numérique contient des métadonnées EXIF (Exchangeable image file format). Ces métadonnées invisibles à l'œil nu incluent le modèle de l'appareil, les réglages de l'objectif, la date et l'heure exactes, et surtout, les coordonnées GPS de l'endroit où la photo a été prise. En donnant un accès global à votre galerie, vous offriez sur un plateau la cartographie de vos voyages, de votre domicile et de vos proches.

Heureusement, le principe du moindre privilège a fini par s'imposer aux systèmes d'exploitation via la fonctionnalité de « Sélection de photos » (ou *Selected Photos*). Aujourd'hui, lorsqu'une application de retouche ou de partage vous demande d'importer une image, vous pouvez choisir de ne lui donner accès qu'aux trois photos spécifiques que vous venez de cocher. L'application ignore jusqu'à l'existence du reste de votre galerie. Adoptez ce réflexe systématiquement : ne donnez jamais un accès global à votre bibliothèque, sauf pour des applications de sauvegarde chiffrée de confiance.

© 2026 Oussama Ghorbel

Concernant le microphone et la caméra, la paranoïa ambiante veut que nos téléphones nous écoutent en permanence pour nous proposer des publicités ciblées. D'un point de vue purement technique et matériel, l'enregistrement audio en continu et l'upload de ces flux sur des serveurs représenteraient une consommation de batterie et de données si massive qu'elle serait immédiatement détectable par les outils d'analyse réseau. Le mythe de l'écoute publicitaire permanente est largement exagéré.

Le vrai danger du micro et de la caméra réside ailleurs. Il réside dans les assistants vocaux qui traitent vos requêtes sur des serveurs distants (où des sous-traitants humains écoutent parfois des extraits pour « améliorer le modèle »), et dans les métadonnées d'utilisation. De plus, les indicateurs de confidentialité (les fameux points verts ou oranges qui s'allument en haut de l'écran sur iOS et Android) ont été créés pour vous alerter en temps réel. Si vous naviguez sur une application de lecture d'articles et que le point vert (caméra) ou orange (micro) s'allume, vous êtes face à une violation flagrante du moindre privilège, voire à une tentative de malware. Ces indicateurs visuels sont votre première ligne de détection. Apprenez à les observer. Si une application de clavier tiers vous demande l'accès au micro pour la « dictée vocale », assurez-vous que le traitement se fait en local sur la puce de votre téléphone (on-device processing) et non dans le cloud.

Le suivi de l'activité et les données de santé

Il fut une époque où les données de santé étaient strictement protégées par le secret médical et des législations rigoureuses. Aujourd'hui, votre rythme cardiaque, la qualité de votre sommeil, votre cycle menstruel et vos niveaux de stress sont monnayés sur le marché libre par des applications de « bien-être » qui n'ont aucun statut médical.

Les données de santé sont le nouveau pétrole de l'industrie de la donnée. Un courtier en données peut déduire de votre suivi d'activité si vous êtes sédentaire, si vous souffrez d'insomnie chronique, ou si vous présentez les signes précurseurs d'une maladie neurodégénérative (via l'analyse de la tremblée de la main ou de la démarche, mesurée par l'accéléromètre et le gyroscope). Ces profils sont ensuite revendus à des assureurs, à des employeurs potentiels ou à des régies publicitaires ciblant les personnes vulnérables.

© 2026 Oussama Ghorbel

Lorsque vous connectez une montre intelligente ou une application de suivi sportif aux API centralisées de votre téléphone (Apple Santé / HealthKit ou Google Fit / Health Connect), vous créez un coffre-fort de données biométriques. Le principe du moindre privilège exige ici un cloisonnement strict. Par défaut, aucune application ne devrait avoir le droit de lire l'intégralité de votre historique de santé.

Lorsqu'une application de méditation vous demande l'accès à vos données de sommeil pour « calibrer vos séances », accordez-lui uniquement l'accès en *écriture* (pour qu'elle y ajoute ses propres données) mais refusez-lui l'accès en *lecture* globale. De même, méfiez-vous des applications de suivi de cycle menstruel. Les récentes évolutions législatives dans certains pays ont démontré que ces données, si elles sont hébergées sur des serveurs tiers non chiffrés ou partagées avec des partenaires analytiques, peuvent être utilisées à des fins de poursuites judiciaires ou de discrimination. Si vous devez utiliser ce type d'application, privilégiez celles qui garantissent un chiffrement de bout en bout et un stockage exclusif en local, sans aucune synchronisation cloud obligatoire.

Prenez l'habitude d'auditer les permissions de l'application « Santé » de votre OS. Sur iOS, allez dans Réglages > Confidentialité et sécurité > Santé. Sur Android, ouvrez l'application Health Connect. Vous y découvrirez souvent que des applications que vous avez oubliées, ou des jeux mobiles, ont conservé un accès en lecture à votre fréquence cardiaque ou à votre nombre de pas. Révoquez ces accès immédiatement.

Identifier et désinstaller les applications vampires

Le paysage applicatif de nos téléphones est encombré de ce que j'appelle les « applications vampires ». Ce sont des logiciels qui, bien que discrètement installés, aspirent en silence votre batterie, votre bande passante et vos données personnelles.

Les applications vampires se divisent en trois catégories. D'abord, les *bloatwares*, ces applications préinstallées par le fabricant de votre téléphone ou votre opérateur, souvent impossibles à désinstaller facilement, qui tournent en arrière-plan pour vous pousser des notifications promotionnelles ou collecter des statistiques d'usage.

© 2026 Oussama Ghorbel

Ensuite, les *applications zombies*, ces utilitaires que vous avez téléchargés pour un besoin ponctuel (un convertisseur de PDF, un scanner de QR code, une application de parking) et que vous n'avez jamais ouverts depuis des mois, mais qui conservent leurs permissions et s'actualisent en arrière-plan. Enfin, les *applications à SDK multiples*, souvent des jeux gratuits ou des utilitaires basiques, dont le code source est composé à 80 % de kits de développement (SDK) publicitaires qui pistent votre activité pour le compte de régies tierces.

Pour identifier ces vampires, les systèmes d'exploitation ont intégré des outils d'audit extrêmement puissants : les tableaux de bord de confidentialité. Sur Android, le « Tableau de bord confidentialité » (Privacy Dashboard) vous offre une chronologie visuelle sur 24 heures de chaque accès au micro, à la caméra et à la localisation. Sur iOS, le « Rapport de confidentialité des apps » enregistre chaque requête réseau et chaque accès aux capteurs sur les derniers jours.

Ces outils sont impitoyables. Ils mettent en lumière l'absurdité de certaines demandes. Vous pourriez y découvrir que votre application de recettes de cuisine a tenté d'accéder à votre localisation 47 fois dans la nuit de mardi à mercredi, alors que votre téléphone était en mode avion ou posé sur votre table de nuit. Cette activité en arrière-plan est le symptôme d'un SDK publicitaire qui tente de reconstituer votre profil réseau ou de mettre à jour des bases de données de géolocalisation par Wi-Fi.

La lutte contre les applications vampires nécessite une hygiène numérique régulière. Le stockage de nos téléphones a tellement augmenté que nous ne prenons plus la peine de faire le tri. Pourtant, chaque application installée est une surface d'attaque potentielle, une faille de sécurité qui attend sa mise à jour, et une sonde de télémétrie pour son éditeur. Désinstaller une application ne suffit pas toujours ; il faut aussi s'assurer qu'elle n'a pas créé de compte sur un service tiers ou qu'elle n'a pas lié votre identité à une base de données externe avant votre départ. Mais la désinstallation reste l'étape sine qua non pour stopper l'hémorragie de données en temps réel.

Les stores alternatifs (F-Droid, Aurora Store)

© 2026 Oussama Ghorbel

Pour appliquer le principe du moindre privilège, il faut aussi s'interroger sur la chaîne d'approvisionnement de vos logiciels. L'immense majorité des utilisateurs de smartphones s'approvisionnent exclusivement sur l'App Store d'Apple ou le Google Play Store. Ce duopole impose ses règles, ses algorithmes de recommandation et, surtout, son modèle économique, qui repose massivement sur la publicité et l'analyse de données.

Sur l'écosystème Android, l'ouverture du système permet d'explorer des stores alternatifs qui placent la confidentialité et le logiciel libre au cœur de leur philosophie. Le plus emblématique d'entre eux est **F-Droid**. F-Droid n'est pas un simple magasin d'applications ; c'est un catalogue de logiciels libres et open source (FOSS). Chaque application présente sur F-Droid est auditée, son code source est public, et les versions compilées sont reproductibles, ce qui garantit que le fichier que vous installez correspond exactement au code source publié, sans ajout de mouchards ou de SDK publicitaires cachés.

F-Droid met également en avant les « anti-fonctionnalités » (anti-features). Si une application open source contient un traqueur connu, une dépendance à un service propriétaire, ou une fonctionnalité de télémétrie non désactivable, F-Droid l'affiche clairement avec un pictogramme d'avertissement. C'est la transparence absolue, l'antithèse des boîtes noires du Play Store.

Pour ceux qui ont besoin d'applications propriétaires spécifiques (comme celle de leur banque ou un service de streaming) mais qui refusent de se connecter à un compte Google et de subir la télémétrie du Play Store, **Aurora Store** est une solution remarquable. Aurora Store est un client open source qui se connecte aux serveurs de Google Play de manière anonyme. Il génère des jetons de session temporaires, télécharge l'application dont vous avez besoin et l'installe sur votre téléphone, le tout sans que Google ne puisse lier le téléchargement à votre identité, votre adresse IP personnelle ou votre compte. C'est un outil indispensable pour les utilisateurs de smartphones Android « dégooglisés » (utilisant des systèmes d'exploitation alternatifs comme GrapheneOS, CalyxOS ou /e/OS).

Cependant, emprunter la voie des stores alternatifs et du *sideloading* (l'installation de fichiers APK manuellement) demande une

© 2026 Oussama Ghorbel

responsabilité accrue. Le principe du moindre privilège s'applique aussi à votre propre vigilance. En dehors des jardins clos d'Apple et de Google, c'est à vous de vérifier la réputation du développeur, de lire les avis sur des forums spécialisés et de vous assurer que vous téléchargez bien l'application depuis le site officiel de son éditeur. La liberté numérique a un prix : celui de l'attention et de l'esprit critique.

Exercice pratique : Le grand tri et la réinitialisation des privilèges

La théorie ne vaut rien sans l'action. Je vous propose de consacrer trente minutes, dès la fin de ce chapitre, à un exercice d'hygiène numérique qui va radicalement alléger votre téléphone et sécuriser votre vie privée. Cet exercice repose sur la règle des trois mois et le principe du moindre privilège.

Étape 1 : L'audit de l'inutilité (La règle des 3 mois)

Ouvrez la liste de toutes vos applications. Sur iOS, faites défiler votre bibliothèque d'apps. Sur Android, ouvrez le tiroir d'applications. Identifiez chaque application que vous n'avez pas ouverte volontairement au cours des trois derniers mois.

- Si c'est une application utilitaire saisonnière (ex: déclaration d'impôts, ski), conservez-la mais passez à l'étape 2.
- Si c'est un jeu, un réseau social secondaire, ou un outil que vous pensiez utiliser « un jour », désinstallez-la immédiatement. Ne vous encombrez pas de code mort.

Étape 2 : La purge des permissions (Le moindre privilège)

Pour les applications que vous conservez, rendez-vous dans les paramètres de confidentialité de votre OS.

- **Localisation :** Passez toutes les applications en « Position approximative », sauf les applications de navigation (GPS, VTC) et de sport en extérieur. Pour le reste (météo, actualités, réseaux sociaux), choisissez « Autoriser seulement si l'app est active » ou « Jamais ».
- **Photos et Médias :** Révoquez l'accès global à la galerie pour les réseaux sociaux et les applications de messagerie. Forcez l'utilisation

© 2026 Oussama Ghorbel

du sélecteur de photos natif de l'OS à chaque envoi.

• **Micro et Caméra :** Désactivez l'accès pour toutes les applications qui ne sont pas des outils de communication, de création vidéo ou de dictée vocale.

• **Suivi (Tracking) :** Sur iOS, exigez que toutes les applications arrêtent de « Demander le suivi ». Sur Android, désactivez la personnalisation des annonces et supprimez l'identifiant publicitaire dans les paramètres de confidentialité.

Étape 3 : Le nettoyage des comptes liés

Pour les applications que vous venez de désinstaller à l'Étape 1, n'oubliez pas que votre compte existe peut-être encore sur leurs serveurs. Avant de les supprimer définitivement de votre téléphone, prenez une minute pour vous connecter à leur interface web et utiliser la fonctionnalité légale de « Suppression de mon compte et de mes données » (une obligation imposée par le RGPD en Europe et le CCPA en Californie).

En appliquant ce nettoyage trimestriel, vous ne faites pas qu'économiser de la batterie et de l'espace de stockage. Vous fermez des centaines de fenêtres ouvertes sur votre intimité. Vous reprenez le contrôle. Vous redevenez invisible.

© 2026 Oussama Ghorbel

Chapitre 15 – Messageries et appels inviolables

Nous avons passé les chapitres précédents à blinder votre navigateur, à nettoyer votre système d'exploitation et à verrouiller vos identifiants. Pourtant, il reste une faille béante dans votre forteresse numérique, une porte par laquelle transitent vos pensées les plus intimes, vos secrets professionnels et vos confidences familiales : vos communications.

L'acte de communiquer est au cœur de l'expérience humaine. C'est aussi, par conséquent, la cible principale de la surveillance de masse et de l'exploitation commerciale. Lorsque vous envoyez un message texte, un vocal ou passez un appel vidéo, vous créez un lien direct entre vous et un autre individu. Si ce lien n'est pas protégé par une cryptographie robuste, il devient un tuyau transparent à travers lequel n'importe quel acteur disposant des bons outils d'interception peut observer votre vie. Dans ce chapitre, nous allons explorer comment transformer vos simples échanges numériques en conversations inviolables, à l'abri des regards indiscrets des géants de la tech, des cybercriminels et des agences de renseignement.

La différence entre chiffrement en transit et de bout en bout (E2EE)

Pour comprendre comment sécuriser une communication, il faut d'abord dissiper une confusion fréquente, savamment entretenue par le marketing de certaines entreprises : la différence entre le chiffrement en transit et le chiffrement de bout en bout (End-to-End Encryption, ou E2EE).

Imaginez que vous deviez envoyer un document confidentiel à un ami situé à l'autre bout du pays.

Le **chiffrement en transit** (souvent assuré par le protocole TLS/SSL, le petit cadenas dans votre navigateur) équivaut à placer votre document dans un camion blindé. Le trajet entre votre bureau et le centre de tri postal est sécurisé. Personne sur la route ne peut intercepter le camion et voler le document. Cependant, une fois arrivé au centre de tri

© 2026 Oussama Ghorbel

(les serveurs de l'entreprise de messagerie), le camion est ouvert, le document est lu, potentiellement copié, analysé par des machines, puis replacé dans un autre camion blindé pour la dernière partie du trajet. Le prestataire a accès au contenu. C'est ainsi que fonctionnent les emails traditionnels et les SMS.

Le **chiffrement de bout en bout (E2EE)**, en revanche, change radicalement la donne. Ici, vous placez votre document dans un coffre-fort indestructible dont vous seul et votre ami possédez la combinaison. Le camion blindé (le serveur de l'entreprise) transporte le coffre-fort, mais le chauffeur et l'entreprise de logistique n'ont absolument aucun moyen de l'ouvrir. Même s'ils sont contraints par la justice, piratés ou simplement curieux, ils ne peuvent livrer qu'une boîte noire impénétrable. Seuls l'expéditeur et le destinataire (les deux "bouts" de la communication) possèdent les clés cryptographiques pour déchiffrer le message.

Techniquement, l'E2EE moderne repose sur des prouesses mathématiques comme l'algorithme du "Double Ratchet" (le double cliquet). Ce mécanisme assure deux propriétés fondamentales :

1. **La confidentialité persistante (Forward Secrecy) :** Si un pirate parvient à voler votre clé privée aujourd'hui, il ne pourra pas déchiffrer les messages que vous avez envoyés hier. Chaque message utilise une clé éphémère unique, dérivée des clés précédentes mais impossible à recalculer à rebours.
2. **La sécurité post-compromission :** Si votre appareil est compromis puis nettoyé, le système génère automatiquement de nouvelles clés pour les messages futurs, sans intervention de votre part, limitant les dégâts dans le temps.

Comprendre cette distinction est crucial. Lorsque vous choisissez une application de messagerie, la simple mention du mot "chiffrement" ne suffit pas. Il faut exiger l'E2EE par défaut, systématique et inconditionnel.

Signal : l'étalon-or de la messagerie privée

S'il ne fallait retenir qu'un seul nom dans l'univers de la messagerie sécurisée, ce serait Signal. Développée par la Signal Foundation, une

© 2026 Oussama Ghorbel

organisation à but non lucratif, cette application n'est pas simplement un outil ; c'est une déclaration de principes sur la manière dont la technologie devrait respecter les droits humains fondamentaux.

Pourquoi Signal est-il considéré comme l'étalon-or par les cryptographes, les journalistes d'investigation et les défenseurs des droits numériques ?

D'abord, pour son **protocole open source**. Le protocole Signal est entièrement documenté, auditable et a été passé au crible par les meilleurs experts en sécurité indépendants. Contrairement aux solutions propriétaires qui reposent sur la "sécurité par l'obscurité" (l'idée que cacher le fonctionnement du système le rend sûr), Signal prouve sa robustesse par la transparence. C'est d'ailleurs ce même protocole qui a été licencié et intégré par d'autres géants, prouvant son efficacité.

Ensuite, pour son **modèle économique et sa structure**. Signal est financé par des dons et des subventions, et non par du capital-risque exigeant un retour sur investissement via la monétisation des données. L'application ne collecte littéralement rien d'exploitable sur ses utilisateurs.

L'une des innovations les plus fascinantes de Signal est le **"Sealed Sender" (expéditeur scellé)**. Dans un système E2EE classique, le serveur doit savoir qui envoie le message à qui pour pouvoir le router, même s'il ne peut pas lire le contenu. Signal a conçu un système où le serveur de routage ne connaît même pas l'identité de l'expéditeur. Les métadonnées d'envoi sont elles-mêmes chiffrées. Résultat : si la justice américaine (ou toute autre autorité) exige de savoir qui vous a contacté, Signal ne peut fournir qu'une date de création de compte et la date de la dernière connexion. C'est une prouesse d'ingénierie de la vie privée.

Signal propose également des fonctionnalités de sécurité pragmatiques : les messages éphémères (qui s'autodétruisent après lecture ou après un délai défini), le verrouillage de l'inscription (pour empêcher le détournement de votre numéro par un pirate via une attaque SIM swap), et la sécurité de l'écran (qui empêche les captures d'écran et masque l'application dans le sélecteur de tâches de votre téléphone). C'est l'outil que je recommande systématiquement pour remplacer les SMS et les applications grand public pour toute conversation nécessitant

© 2026 Oussama Ghorbel

une confidentialité réelle.

WhatsApp et Telegram : démêler le vrai du faux

L'hégémonie de WhatsApp et la popularité croissante de Telegram créent un paysage où la désinformation sur la sécurité règne en maître. Il est temps de disséquer ces deux géants avec un regard critique.

WhatsApp : le cheval de Troie de Meta

WhatsApp utilise bien le protocole Signal pour le chiffrement de bout en bout de vos messages et appels. Sur le plan strict du *contenu* en transit, c'est techniquement solide. Cependant, le problème de WhatsApp ne réside pas dans ce qu'il chiffre, mais dans ce qu'il collecte autour.

WhatsApp appartient à Meta (Facebook). L'application aspire une quantité colossale de métadonnées : qui vous contactez, à quelle heure, depuis quelle adresse IP, avec quel type d'appareil, votre niveau de batterie, vos informations de paiement, et la fréquence de vos interactions. Ces métadonnées sont ensuite croisées avec votre profil Facebook et Instagram pour affiner le profilage publicitaire et algorithmique.

De plus, WhatsApp propose des sauvegardes dans le cloud (iCloud pour Apple, Google Drive pour Android). Par défaut, ces sauvegardes ne sont pas chiffrées de bout en bout. Cela signifie qu'Apple, Google, ou toute autorité disposant d'un mandat peut accéder à l'intégralité de votre historique de messages en saisissant simplement votre sauvegarde cloud, contournant ainsi allègrement le chiffrement E2EE de l'application elle-même. (Notez que WhatsApp a récemment ajouté une option pour chiffrer ces sauvegardes, mais elle est désactivée par défaut et rarement activée par l'utilisateur lambda).

Telegram : le mirage de la confidentialité

Telegram, fondé par les frères Durov, se présente souvent comme le bastion de la liberté d'expression et de la vie privée. C'est une excellente application pour la diffusion de masse (les canaux publics), la constitution de communautés et le contournement de la censure dans les régimes autoritaires. Mais pour la messagerie privée interpersonnelle,

© 2026 Oussama Ghorbel

c'est un piège cryptographique.

Contrairement à Signal ou WhatsApp, **les conversations Telegram ne sont PAS chiffrées de bout en bout par défaut**. Vos messages "standards" sont stockés en clair (ou avec un chiffrement dont Telegram détient les clés) sur les serveurs de l'entreprise. Cela permet la synchronisation transparente entre tous vos appareils, mais signifie que les employés de Telegram, ou des pirates s'introduisant dans leurs serveurs, pourraient techniquement lire vos échanges.

Pour obtenir de l'E2EE sur Telegram, vous devez initier manuellement un "Échange secret" (Secret Chat). Cette fonctionnalité est cachée dans les menus, n'existe pas pour les groupes, et ne se synchronise pas sur le cloud. Pire encore, Telegram utilise son propre protocole cryptographique maison, appelé MTProto, qui a été régulièrement critiqué par la communauté cryptographique pour ses excentricités et ses potentielles failles, là où le consensus scientifique exige l'utilisation de standards éprouvés. Telegram est un excellent réseau social, mais une très mauvaise messagerie sécurisée.

Le protocole Matrix et la décentralisation (Element)

Si Signal est l'étalon-or de la simplicité et de la sécurité centralisée, Matrix représente l'avenir de la souveraineté numérique décentralisée.

Pour comprendre Matrix, il faut imaginer le fonctionnement de l'email. Lorsque vous envoyez un email depuis une adresse Gmail vers une adresse ProtonMail, les serveurs de Google et de ProtonMail communiquent entre eux pour acheminer le message. Vous n'avez pas besoin d'être sur le même serveur que votre destinataire. C'est ce qu'on appelle la **fédération**.

Matrix applique ce principe de fédération à la messagerie instantanée, mais en y ajoutant le chiffrement de bout en bout par défaut. Le protocole Matrix est un standard ouvert. N'importe qui peut héberger son propre serveur (appelé "Homeserver") sur son propre matériel ou chez un hébergeur de confiance.

Element est le client (l'application) le plus populaire pour interagir avec le réseau Matrix. Lorsque vous utilisez Element, vous pouvez choisir de vous inscrire sur le serveur public géré par les créateurs de

© 2026 Oussama Ghorbel

Matrix (matrix.org), sur un serveur communautaire, ou sur le serveur privé de votre entreprise ou de votre association.

Les avantages de Matrix sont immenses pour ceux qui cherchent une indépendance totale :

1. **Aucun point de défaillance unique :** Si le serveur matrix.org tombe ou est censuré, votre serveur personnel ou celui de votre organisation continue de fonctionner et de communiquer avec le reste du réseau fédéré.
2. **Souveraineté des données :** Pour une entreprise ou une famille soucieuse de sa privacy, héberger son propre serveur Matrix signifie que les données ne quittent jamais votre infrastructure physique.
3. **Les passerelles (Bridges) :** Matrix permet de créer des "ponts" vers d'autres réseaux. Vous pouvez, depuis votre interface Element, recevoir et répondre à des messages provenant de Signal, Telegram, WhatsApp, Slack ou même des SMS, centralisant ainsi vos communications dans une interface unique et sécurisée que vous contrôlez.

L'inconvénient majeur de Matrix réside dans sa complexité. La gestion des clés cryptographiques (le "cross-signing" pour valider vos différents appareils) peut s'avérer déroutante pour les néophytes. L'expérience utilisateur, bien qu'en nette amélioration, reste un cran en dessous de la fluidité parfaite de Signal. Matrix est la solution idéale pour les utilisateurs avancés, les organisations, les journalistes opérant en réseau et les entreprises souhaitant s'émanciper des solutions SaaS américaines.

Protéger ses métadonnées (qui parle à qui et quand)

Michael Hayden, ancien directeur de la NSA et de la CIA, a un jour déclaré lors d'une conférence : *"Nous tuons des gens en nous basant sur les métadonnées."* Cette phrase glaçante résume une réalité que le grand public a du mal à appréhender : le contenu de vos messages importe souvent moins que le contexte de vos échanges.

Les métadonnées sont les données sur vos données. Dans le cadre d'une messagerie, cela inclut :

© 2026 Oussama Ghorbel

• Les identifiants des participants (numéros de téléphone, adresses IP).

• Les horodatages (date et heure exactes de chaque message).

• La fréquence et la durée des échanges.

• La taille des fichiers transférés.

• Votre carnet d'adresses complet.

Si un algorithme analyse vos métadonnées, il n'a pas besoin de lire vos messages pour tout savoir de vous. Il saura que vous contactez un avocat spécialisé en divorce tous les soirs à 23h. Il saura que vous avez échangé 40 messages avec un numéro inconnu juste avant d'acheter un billet d'avion pour un pays en crise. Il saura qui sont vos proches, vos collègues, vos amants, et vos complices. L'analyse de graphe social permet de cartographier l'intégralité de votre réseau d'influence et de confiance.

Comment protéger ses métadonnées ?

1. **Choisir les bons outils :** Comme évoqué, Signal minimise drastiquement la collecte de métadonnées grâce au Sealed Sender. Meta (WhatsApp) en fait son fonds de commerce.

2. **Limiter la taille des groupes :** Dans un groupe WhatsApp de 50 personnes, Meta sait exactement qui appartient à quel cercle social. Dans Signal, la gestion des groupes est chiffrée et le serveur ne connaît pas la liste des membres.

3. **Dissocier l'identité du numéro de téléphone :** Le point faible de Signal et WhatsApp est l'obligation d'utiliser un numéro de téléphone comme identifiant. Pour une confidentialité extrême, l'idéal est d'utiliser un numéro VoIP (comme ceux fournis par certains services en ligne payants) ou une carte SIM prépayée achetée anonymement (là où la législation le permet encore) dédiée uniquement à votre identité Signal.

4. **Utiliser les messages éphémères :** Configurer une durée de vie limitée pour les messages (par exemple, 7 jours) empêche l'accumulation d'un historique qui, en cas de saisie physique de votre téléphone, pourrait être analysé pour en extraire des métadonnées comportementales.

© 2026 Oussama Ghorbel

5. **Le routage en oignon (Tor) :** Pour les utilisateurs à haut risque, il est possible de configurer Signal (sur Android) ou Element (sur desktop) pour qu'ils se connectent à leurs serveurs via le réseau Tor, masquant ainsi votre adresse IP et votre géolocalisation au fournisseur du service.

Les appels vocaux et vidéo sécurisés

La voix et l'image en temps réel représentent un défi technique bien plus complexe que le texte. Acheminer des flux vidéo haute définition avec une latence quasi nulle tout en maintenant un chiffrement de bout en bout robuste relève de l'acrobatie informatique.

La plupart des applications modernes utilisent le framework WebRTC pour établir la communication audio/vidéo. Pour sécuriser ces flux, le chiffrement DTLS-SRTP est employé, garantissant que le flux média est illisible pour quiconque se trouverait sur le chemin des paquets réseau.

Cependant, un danger spécifique guette les appels vocaux et vidéo : **la fuite d'adresse IP**.

Dans une architecture purement "Peer-to-Peer" (P2P), votre téléphone doit connaître l'adresse IP du téléphone de votre correspondant pour lui envoyer le flux vidéo directement. C'est le cas de certaines anciennes implémentations ou d'applications moins rigoureuses. Si votre correspondant (ou un logiciel malveillant sur son téléphone) enregistre votre adresse IP, il peut la faire remonter à votre fournisseur d'accès internet, obtenir votre adresse postale approximative, et prouver que vous étiez connectés à tel moment précis.

Signal a résolu ce problème de manière élégante. Par défaut, les appels Signal passent par leurs serveurs relais. Le flux est chiffré de bout en bout (les serveurs ne voient que du bruit numérique), mais l'avantage est que votre téléphone ne communique qu'avec l'adresse IP des serveurs de Signal, et non avec celle de votre contact. Votre adresse IP reste masquée. (Il est possible de désactiver cette option dans les paramètres pour améliorer la latence en passant en P2P direct, mais je vous le déconseille formellement si vous tenez à votre anonymat géographique).

© 2026 Oussama Ghorbel

La vérification d'identité (Safety Numbers)

Comment être certain que vous parlez bien à votre ami, et non à un pirate qui se serait inséré au milieu de la connexion (une attaque de l'homme du milieu, ou Man-in-the-Middle) ?

Lors d'un appel Signal, vous pouvez afficher le "numéro de sécurité" (ou empreinte cryptographique). Il s'agit d'une suite de chiffres ou d'un QR code unique généré par la combinaison de vos clés respectives. Si vous et votre contact vérifiez de vive voix (ou en scannant le QR code en personne) que ces numéros correspondent, vous avez la certitude mathématique absolue que la ligne n'est pas sur écoute. C'est une étape indispensable avant de partager des informations critiques lors d'un appel.

Exercice pratique : Migrer ses conversations de groupe sensibles

La théorie est essentielle, mais c'est dans la pratique que se joue votre souveraineté numérique. L'obstacle principal à l'adoption de Signal ou de Matrix n'est pas technique, il est social. Vos amis, votre famille et vos collègues sont déjà sur WhatsApp. Le coût social de changer d'outil semble souvent supérieur au bénéfice perçu pour la vie privée.

Votre mission pour ce chapitre est de **migrer au moins deux conversations de groupe sensibles** (par exemple, le groupe "Famille", "Organisation mariage", ou "Projet confidentiel travail") de WhatsApp vers Signal ou une instance Matrix.

Voici la méthodologie en quatre phases pour y parvenir sans braquer votre entourage :

Phase 1 : L'Audit et la Préparation

• Identifiez les groupes où se partagent des informations personnelles (adresses, photos d'enfants, coordonnées bancaires pour un cadeau commun, secrets d'entreprise).

• Installez Signal (ou Element) sur votre appareil. Configurez votre profil, activez le verrouillage de l'inscription et définissez un code PIN robuste.

© 2026 Oussama Ghorbel

• Créez le nouveau groupe sur la nouvelle application. Configurez dès le départ les "messages éphémères" sur une durée raisonnable (ex: 30 jours) pour instaurer une culture de l'hygiène numérique dès le départ.

Phase 2 : Le "Pitch" (L'argumentaire pédagogique)

Ne parlez pas de "surveillance de masse" ou de "NSA", cela braque les gens ou passe pour de la paranoïa. Utilisez des arguments pragmatiques et centrés sur leur propre bénéfice :

• *Pour la famille :* "J'ai lu que les sauvegardes WhatsApp sur le cloud n'étaient pas sécurisées et que n'importe quel pirate pourrait voler les photos des enfants et nos adresses. J'ai créé un groupe sur Signal, c'est une appli gratuite, sans publicité, qui ne scanne pas nos données pour vendre des trucs. Installez-la, c'est l'interface est exactement la même."

• *Pour le travail :* "Pour des raisons de conformité RGPD et de secret des affaires, nous ne pouvons pas laisser les métadonnées de nos échanges stratégiques être aspirées par les serveurs de Meta. Nous passons sur Matrix/Signal."

Phase 3 : L'Onboarding (L'accompagnement)

• Ne vous contentez pas d'envoyer un lien. Proposez votre aide pour l'installation lors d'un repas de famille ou d'une pause café.

• Montrez-leur comment importer leurs contacts et configurer une photo de profil.

• Envoyez le premier message sur le nouveau groupe avec un ton chaleureux pour initier la dynamique.

Phase 4 : La Purge (Le point de non-retour)

• Une fois que 80% des membres actifs sont sur le nouveau groupe, annoncez sur l'ancien groupe WhatsApp : *"Bonjour à tous, pour des raisons de confidentialité et pour éviter la pollution publicitaire, nous allons cesser d'utiliser ce groupe WhatsApp dans 48h. Merci de rejoindre le nouveau groupe sur Signal via ce lien [Lien du groupe]. Passé ce délai, je quitterai ce groupe."*

© 2026 Oussama Ghorbel

• Tenez votre promesse. Quittez le groupe WhatsApp. Si vous restez "au cas où", vous échouerez à créer une nouvelle norme sociale. La friction doit être déplacée vers l'ancien outil, pas vers le nouveau.

En réalisant cet exercice, vous ne faites pas que protéger vos propres données. Vous devenez un nœud de résistance. Vous élevez le niveau de sécurité de votre entourage en les sortant, souvent sans qu'ils s'en rendent compte, de la matrice de surveillance commerciale. Chaque groupe migré est une petite victoire pour la frugalité numérique et le respect de l'intimité.

Dans le chapitre suivant, nous quitterons le domaine des communications pour nous attaquer à un autre pilier de notre vie numérique : le stockage de nos données. Nous verrons comment bâtir un Cloud souverain et maîtriser l'art du chiffrement de vos fichiers, pour que même si l'on saisit vos disques durs, vos secrets restent à jamais hors de portée.

© 2026 Oussama Ghorbel

Chapitre 16 – Le Cloud souverain et le chiffrement

Au fil de notre progression dans cet ouvrage, nous avons méthodiquement fortifié vos appareils, vos navigateurs et vos communications. Nous avons appris à bloquer les mouchards, à contourner les algorithmes de pistage et à verrouiller vos identifiants. Pourtant, il demeure un angle mort colossal dans la stratégie de défense de la majorité des utilisateurs : l'endroit même où reposent leurs souvenirs, leurs documents administratifs, leurs projets professionnels et leurs données de santé.

Ce lieu, c'est le « cloud ».

Dans ce chapitre, nous allons nous attaquer à l'un des piliers de l'économie de la surveillance moderne. Reprendre le contrôle de sa vie numérique implique inévitablement de redéfinir la notion de propriété et de souveraineté de ses données. Héberger sa vie entière sur les serveurs de multinationales dont le modèle économique repose sur l'extraction et l'analyse de l'information est une aberration en matière de confidentialité. Il est temps de démystifier le nuage, de comprendre les architectures qui protègent réellement votre intimité, et de mettre en place une stratégie de stockage qui vous appartienne vraiment.

Le mythe du cloud : les données sont toujours sur l'ordinateur de quelqu'un d'autre

Le terme « cloud » (nuage) est sans doute la plus grande réussite marketing de la dernière décennie dans le domaine de la technologie. Il évoque quelque chose d'éthéré, d'immatériel, de flottant et d'inaccessible. Cette sémantique soigneusement choisie a pour but de vous faire oublier une réalité physique et juridique implacable : le cloud n'existe pas. Il n'y a pas de nuage. Il n'y a que l'ordinateur de quelqu'un d'autre.

Lorsque vous synchronisez vos photos de famille sur Google Photos, vos documents sur Microsoft OneDrive ou vos sauvegardes sur Apple iCloud, vous transférez en réalité des octets sur des disques durs

© 2026 Oussama Ghorbel

physiques situés dans des data centers en Virginie, en Irlande ou à Singapour. Vous confiez la garde de votre vie intime à des entités tierces.

Le problème ne réside pas uniquement dans la localisation physique de ces serveurs, mais dans la nature du contrat qui vous lie à leur propriétaire. Les géants du numérique (les GAFAM) utilisent un chiffrement dit « au repos » (encryption at rest) et « en transit ». Ils vous assurent que vos données sont chiffrées. C'est techniquement vrai. Mais la question cruciale est la suivante : *qui détient la clé de chiffrement ?*

Dans le modèle traditionnel du cloud grand public, c'est le fournisseur qui génère, conserve et utilise les clés de chiffrement. Cela signifie que Google, Apple ou Microsoft ont la capacité technique de déchiffrer vos fichiers à la volée. Pourquoi auraient-ils besoin de cette capacité ? Officiellement, pour vous offrir des services « intelligents » : analyser vos photos pour reconnaître les visages de vos proches, indexer vos PDF pour vous permettre de faire des recherches par mots-clés, ou scanner vos emails pour suggérer des réponses automatiques.

Officieusement, cette architecture permet à ces entreprises de répondre aux réquisitions judiciaires (parfois abusives) et d'alimenter leurs modèles d'intelligence artificielle. Plus inquiétant encore, le *CLOUD Act* américain, promulgué en 2018, permet aux forces de l'ordre américaines d'exiger l'accès aux données stockées par une entreprise américaine, et ce, même si les serveurs physiques sont situés sur le sol européen. Vos données hébergées chez un géant américain sont donc soumises à une juridiction étrangère, contournant de fait les protections offertes par le RGPD en Europe.

De plus, les conditions générales d'utilisation (CGU) de ces services évoluent constamment. Récemment, plusieurs acteurs majeurs ont mis à jour leurs CGU pour s'octroyer des licences mondiales et gratuites sur les contenus que vous hébergez, afin de « former leurs algorithmes d'IA générative ». En acceptant ces conditions pour bénéficier de 15 Go de stockage gratuit, vous avez transformé vos archives personnelles en matière première gratuite pour l'entraînement de modèles de langage et d'images.

© 2026 Oussama Ghorbel

La souveraineté numérique commence par ce constat : tant que vous n'avez pas le contrôle exclusif de la clé cryptographique qui verrouille vos données, vous n'êtes pas le propriétaire de votre cloud. Vous n'en êtes qu'un locataire toléré, dont l'intimité peut être inspectée à tout moment par un algorithme ou un employé de l'hébergeur.

Les alternatives chiffrées : Proton Drive, Filen et kDrive

Pour sortir de cette matrice, il faut se tourner vers des architectures dites « Zero-Knowledge » (à connaissance nulle). Dans ce modèle, le chiffrement de bout en bout (End-to-End Encryption, ou E2EE) s'applique au stockage. Vos données sont chiffrées *sur votre appareil*, avec une clé dérivée de votre mot de passe, *avant* même d'être envoyées sur les serveurs. L'hébergeur ne reçoit que du bruit cryptographique illisible. S'il reçoit une réquisition judiciaire, il ne peut remettre aux autorités que des fichiers chiffrés qu'il est mathématiquement incapable d'ouvrir.

Voici trois alternatives solides, chacune répondant à des besoins et des modèles de menaces légèrement différents.

Proton Drive : la forteresse suisse

Née de l'écosystème Proton (créateurs de Proton Mail), cette solution bénéficie de la juridiction suisse, l'une des plus protectrices au monde en matière de vie privée, et strictement en dehors de l'Union Européenne et des États-Unis. Proton Drive utilise le chiffrement de bout en bout pour les fichiers, mais aussi pour les métadonnées (les noms des fichiers et des dossiers sont chiffrés). L'architecture est open-source et régulièrement auditée par des chercheurs en sécurité indépendants. C'est l'option de choix pour ceux qui recherchent une intégration transparente avec une suite d'outils déjà axés sur la confidentialité (mail, calendrier, VPN). Son interface est épurée, bien que ses fonctionnalités collaboratives soient encore en développement par rapport aux géants du secteur.

Filen : l'outsider allemand

Filen est un acteur plus récent mais techniquement impressionnant, basé en Allemagne (soumise au RGPD et à des lois fédérales strictes sur la protection des données). Filen propose une architecture

© 2026 Oussama Ghorbel

Zero-Knowledge stricte. Chaque fichier est découpé en fragments, chiffré localement avec l'algorithme AES-256-GCM, puis distribué sur leurs serveurs. Filen se distingue par une politique de prix agressive et une excellente gestion de la synchronisation sur ordinateur de bureau. C'est une alternative très crédible pour remplacer Dropbox ou Google Drive au quotidien, avec l'assurance que même en cas de piratage de leurs serveurs, les attaquants ne récupéreraient que des blocs de données inutiles sans votre mot de passe maître.

kDrive (Infomaniak) : la souveraineté européenne

Infomaniak est un hébergeur suisse indépendant qui a fait le pari de la souveraineté numérique européenne. kDrive n'est pas « Zero-Knowledge » au sens strict (Infomaniak gère l'infrastructure de manière à permettre des fonctionnalités avancées d'édition collaborative en ligne, ce qui nécessite un déchiffrement temporaire en mémoire serveur). Cependant, Infomaniak s'engage contractuellement et juridiquement à ne jamais analyser vos données, à ne jamais les utiliser pour de la publicité ou de l'IA, et à ne pas les transférer hors de Suisse. kDrive est la solution idéale pour les professionnels, les associations ou les familles qui ont besoin d'une suite bureautique complète (équivalent à Google Workspace ou Microsoft 365) avec un respect absolu du RGPD et une indépendance totale face aux GAFAM. C'est le choix de la confiance juridique et de l'éthique entrepreneuriale plutôt que de la preuve cryptographique pure.

Le chiffrement côté client avant envoi : Cryptomator et Rclone

Que faire si vous êtes déjà deeply ancré dans un écosystème spécifique, si votre entreprise vous impose un cloud d'entreprise, ou si vous avez besoin de centaines de téraoctets de stockage à bas prix que seuls les géants peuvent proposer ? Vous pouvez continuer à utiliser leurs serveurs, mais en les transformant en simples disques durs muets, incapables de comprendre ce que vous y stockez. C'est le principe du chiffrement côté client.

Cryptomator : le coffre-fort virtuel

© 2026 Oussama Ghorbel

Cryptomator est un logiciel open-source, gratuit sur ordinateur (et disponible à tarif unique et modique sur mobile), qui a révolutionné la manière d'aborder le cloud public. Son fonctionnement est d'une élégance redoutable.

Lorsque vous installez Cryptomator, vous créez un « coffre-fort » (vault) à l'intérieur de votre dossier de synchronisation cloud (par exemple, dans votre dossier Google Drive ou iCloud). Cryptomator monte alors un disque dur virtuel sur votre système d'exploitation.

Tout ce que vous glissez dans ce disque virtuel est chiffré à la volée avant d'être écrit dans le dossier du cloud. Mais la magie de Cryptomator réside dans son obfuscation structurelle. Non seulement le contenu des fichiers est chiffré (AES-256), mais les noms des fichiers, les extensions et l'arborescence des dossiers sont également hachés et rendus illisibles.

Si vous ouvrez votre dossier Google Drive via l'interface web, vous ne verrez qu'une soupe de dossiers aux noms aléatoires (ex: `0x8F3A...`) contenant des fichiers `.bin` incompréhensibles. Google ne sait pas si vous stockez des films, des relevés bancaires ou des romans inachevés. Pour vous, au quotidien, c'est transparent : vous ouvrez le coffre avec votre mot de passe, vous travaillez sur vos fichiers normalement, et vous le verrouillez en partant.

Rclone : le couteau suisse de la ligne de commande

Pour les utilisateurs plus techniques, les administrateurs système ou ceux qui souhaitent automatiser des sauvegardes massives vers des fournisseurs de stockage à bas coût (comme Backblaze B2, Wasabi ou Scaleway), Rclone est l'outil de référence. Surnommé le « rsync du cloud », Rclone s'utilise en ligne de commande et supporte plus de 70 fournisseurs de stockage.

Sa fonctionnalité `crypt` permet de créer une couche de chiffrement par-dessus n'importe quelle destination distante. Vous configurez Rclone pour qu'il agisse comme un intermédiaire : il chiffre les données localement, obscurcit les chemins d'accès, et pousse le tout vers le serveur distant. Rclone est particulièrement utile pour mettre en place des routines de sauvegarde nocturnes chiffrées vers des serveurs distants, garantissant que votre plan de reprise d'activité (PRA) ne compromette pas la confidentialité de vos archives.

© 2026 Oussama Ghorbel

L'auto-hébergement accessible : Nextcloud et le NAS domestique

Si la confiance envers un tiers, même chiffré, vous fait défaut, il ne reste qu'une seule option : devenir votre propre hébergeur. L'auto-hébergement a longtemps été réservé à une élite de geeks capables de configurer des serveurs Linux dans leur garage. Aujourd'hui, il est devenu accessible, fiable et remarkably élégant.

Le NAS (Network Attached Storage)

Un NAS est un petit ordinateur dédié au stockage, connecté à votre réseau local. Des marques comme Synology ou QNAP proposent des appareils « clé en main ». Vous y insérez deux disques durs (ou plus), et le système d'exploitation du NAS gère la redondance des données (via le RAID). Si un disque dur tombe en panne, l'autre prend le relais sans perte de données.

Le NAS devient alors le cœur de votre réseau domestique. Il peut servir de serveur multimédia, de centre de téléchargement, et surtout, de cloud privé. Cependant, une mise en garde s'impose : **le RAID n'est pas une sauvegarde**. Le RAID protège contre la panne matérielle d'un disque. Il ne protège pas contre l'incendie, le vol, la surtension électrique, ou le ransomware qui chiffrerait l'ensemble de votre réseau local.

C'est ici qu'intervient la règle d'or de l'archivage numérique, la règle **3-2-1** :

- **3** copies de vos données (l'original + 2 sauvegardes).
- **2** supports de stockage différents (ex: le NAS et un disque dur externe USB débranché).
- **1** copie hors site (off-site). C'est là que le cloud chiffré (via Cryptomator ou Rclone vers un serveur distant) reprend tout son sens pour servir de filet de sécurité ultime en cas de destruction physique de votre domicile.

Nextcloud : le système d'exploitation de votre cloud

Avoir du matériel, c'est bien. Avoir une interface logicielle pour y accéder depuis n'importe où dans le monde, c'est mieux. Nextcloud est

© 2026 Oussama Ghorbel

une plateforme open-source qui s'installe sur un NAS, un Raspberry Pi ou un serveur privé (VPS).

Nextcloud remplace purement et simplement l'écosystème Google. Il offre :

- La synchronisation de fichiers et de dossiers.
- Un calendrier et un carnet de contacts (via CalDAV et CardDAV) qui se synchronisent nativement avec iOS et Android, sans jamais passer par les serveurs d'Apple ou de Google.
- Une suite bureautique collaborative (Nextcloud Office).
- Un gestionnaire de mots de passe intégré.
- Une application de notes, de tâches, et même de visioconférence (Nextcloud Talk).

L'auto-hébergement avec Nextcloud redonne un sens au mot « souveraineté ». Vous possédez le silicium, vous possédez le code, vous possédez les données. Le revers de la médaille est la responsabilité. Vous devez gérer les mises à jour de sécurité, configurer votre routeur pour autoriser les accès externes (de préférence via des tunnels sécurisés comme Tailscale ou Cloudflare Tunnels, plutôt qu'en ouvrant des ports sur votre box), et surveiller l'état de santé de vos disques durs. C'est le prix à payer pour une véritable indépendance numérique.

La synchronisation des photos sans analyse faciale par l'IA

Nos smartphones sont devenus les témoins silencieux de nos vies. Ils capturent nos enfants, nos voyages, nos documents, nos écrans. Par défaut, ces milliers de clichés sont aspirés vers Google Photos ou Apple Photos.

Ce que la plupart des utilisateurs ignorent, c'est l'ampleur de l'analyse biométrique et contextuelle qui s'opère dans les coulisses. Les algorithmes de ces plateformes ne se contentent pas de stocker l'image. Ils la dissèquent.

- **Reconnaissance faciale :** L'IA cartographie la géométrie du visage de vos proches, créant une base de données biométrique non consentie de votre cercle social.

© 2026 Oussama Ghorbel

• **Analyse sémantique :** L'IA identifie les objets, les marques, les lieux, les races d'animaux.

• **Géolocalisation et temporelle :** En croisant les métadonnées EXIF (GPS) et l'heure de prise de vue, l'algorithme déduit votre domicile, votre lieu de travail, vos habitudes de vacances, et même vos fréquentations (en identifiant que le téléphone X et le téléphone Y sont régulièrement au même endroit à la même heure).

Cette cartographie visuelle de votre intimité est le carburant le plus riche pour le profilage publicitaire et l'entraînement des IA de reconnaissance d'images.

Pour reprendre le contrôle de vos photos, deux approches s'offrent à vous, selon votre appétence technique :

L'alternative Cloud Zero-Knowledge : Ente

Ente est une application de sauvegarde de photos open-source qui a émergé comme le véritable antidote à Google Photos. Basée sur une architecture de chiffrement de bout en bout stricte, Ente chiffre chaque photo et vidéo sur votre téléphone avant de l'envoyer sur leurs serveurs (hébergés dans des bunkers en Europe). L'interface est fluide, la synchronisation est rapide, et les fonctionnalités de partage d'albums sont chiffrées. L'entreprise a un modèle économique transparent : vous payez pour le stockage, et en échange, ils garantissent mathématiquement qu'ils ne peuvent pas voir vos photos.

L'alternative Auto-hébergée : Immich

Si vous possédez un NAS ou un serveur Nextcloud, Immich est la révolution actuelle. C'est une application open-source conçue pour être une copie conforme de l'expérience utilisateur de Google Photos, mais qui tourne sur *votre* matériel. Immich propose une application mobile qui sauvegarde vos photos en arrière-plan vers votre serveur domestique. Mieux encore, Immich intègre ses propres modèles de Machine Learning qui tournent *localement* sur votre serveur. La reconnaissance faciale et la recherche par objets existent, mais elles sont exécutées sur votre propre machine, pour vos yeux uniquement. Aucune donnée biométrique ne quitte votre réseau local. C'est l'alliance parfaite entre le confort technologique moderne et la souveraineté absolue.

© 2026 Oussama Ghorbel

Gérer le partage de fichiers de manière éphémère

La souveraineté de vos données ne s'arrête pas à leur stockage ; elle s'étend à leur transmission. Trop souvent, pour envoyer un document volumineux à un client ou un proche, nous utilisons des services comme WeTransfer ou des liens publics Google Drive.

Ces services sont des passoires à métadonnées. WeTransfer, par exemple, scanne les fichiers pour s'assurer de l'absence de contenus illégaux, enregistre les adresses IP de l'expéditeur et du destinataire, et conserve des logs de transfert. Un lien Google Drive partagé, s'il n'est pas configuré avec une extrême minutie, peut rester indexé et accessible indéfiniment, exposant vos données à des robots d'indexation ou à des fuites.

Le partage de fichiers doit être pensé comme une communication éphémère, soumise au principe de minimisation et d'expiration.

Les services de transfert chiffrés et souverains

• **SwissTransfer :** Proposé par Infomaniak, ce service permet d'envoyer jusqu'à 50 Go de données gratuitement, sans inscription. Les fichiers sont hébergés en Suisse, et vous pouvez définir une date d'expiration automatique (ex: suppression après 1 jour ou après 1 téléchargement) ainsi qu'une protection par mot de passe.

• **Wormhole :** Un service de partage de fichiers qui utilise le chiffrement de bout en bout. Le fichier est chiffré dans votre navigateur avant d'être uploadé. Le lien généré contient la clé de déchiffrement dans l'ancre de l'URL (la partie après le `#`), qui n'est jamais envoyée au serveur. Le serveur ne voit que du contenu chiffré. De plus, Wormhole permet le partage en Peer-to-Peer (P2P) pour les fichiers très lourds, où le transfert se fait directement de votre machine à celle du destinataire sans jamais être stocké sur un serveur intermédiaire.

L'hygiène des métadonnées (EXIF)

Avant de partager une photo ou un document, rappelez-vous qu'un fichier transporte des métadonnées invisibles. Une photo prise avec un smartphone contient souvent les coordonnées GPS exactes de l'endroit où vous vous trouviez, le modèle de l'appareil, et parfois même

© 2026 Oussama Ghorbel

l'orientation de l'écran. Un document Word ou PDF conserve l'historique des modifications, le nom de l'auteur original, et le temps d'édition.

Prenez l'habitude d'utiliser des outils de « stripping » (nettoyage) de métadonnées avant un envoi sensible. Sur mobile, des applications comme *ExifEraser* (Android) ou les raccourcis iOS permettent de purger ces données. Sur ordinateur, des outils comme *ExifTool* ou *MAT2* (Metadata Anonymisation Toolkit) sont indispensables pour stériliser vos fichiers avant de les confier à un tiers.

Exercice pratique : Blindez votre cloud actuel avec Cryptomator

Passons de la théorie à la pratique. L'objectif de cet exercice est de vous permettre de conserver votre abonnement cloud actuel (qu'il soit gratuit ou payant) tout en le rendant totalement opaque et illisible pour votre fournisseur. Nous allons utiliser Cryptomator pour créer une zone de quarantaine chiffrée.

Étape 1 : Installation et préparation

1. Rendez-vous sur le site officiel de Cryptomator (cryptomator.org) et téléchargez la version correspondant à votre système d'exploitation (Windows, macOS, Linux). Installez le logiciel.

2. Ouvrez votre explorateur de fichiers et localisez le dossier de synchronisation de votre cloud actuel (ex: le dossier `Google Drive`, `OneDrive`, ou `iCloud Drive`).

Étape 2 : Création du coffre-fort (Vault)

1. Lancez Cryptomator et cliquez sur « Ajouter un coffre-fort » (Add Vault) puis « Créer un nouveau coffre-fort ».

2. Donnez un nom à ce coffre-fort (par exemple, `Archive_Privee`).

3. Choisissez comme emplacement de sauvegarde le dossier de votre cloud (ex: `C:\Utilisateurs\Vous\Google Drive\Archive_Privee`).

4. Définissez un mot de passe robuste. C'est le seul et unique sésame qui permettra de déchiffrer vos données. S'il est perdu, vos données le sont définitivement. (Utilisez votre gestionnaire de mots de passe pour le générer et le stocker).

© 2026 Oussama Ghorbel

5. Terminez la création. Cryptomator génère une structure de dossiers et de fichiers de configuration chiffrés dans votre dossier cloud.

Étape 3 : Utilisation au quotidien

1. Dans l'interface de Cryptomator, sélectionnez votre coffre-fort et cliquez sur « Déverrouiller » (Unlock). Entrez votre mot de passe.

2. Un nouveau lecteur réseau (ou disque virtuel) apparaît dans votre système d'exploitation (comme une clé USB virtuelle).

3. Ouvrez ce lecteur. Glissez-y vos documents sensibles (relevés fiscaux, scans de passeports, contrats).

4. Observez ce qui se passe dans le dossier de votre cloud (Google Drive/OneDrive) : vous verrez des dossiers aux noms incompréhensibles et des fichiers avec des extensions bizarres apparaître en temps réel. C'est la version chiffrée et obfusquée de vos documents. Le cloud les synchronise sur ses serveurs, mais ne peut pas les lire.

5. Lorsque vous avez terminé, retournez dans Cryptomator et cliquez sur « Verrouiller » (Lock). Le disque virtuel disparaît. Vos données sont désormais en sécurité, tant sur votre disque dur local que sur les serveurs distants.

Note importante : Ne modifiez, ne déplacez et ne renommez jamais manuellement les fichiers chiffrés à l'intérieur du dossier du cloud via votre explorateur classique. Vous corromprirez le coffre-fort. Toute manipulation doit se faire *uniquement* à l'intérieur du disque virtuel déverrouillé par Cryptomator.

La reprise de contrôle de votre vie numérique ne se résume pas à bloquer des publicités ou à utiliser un navigateur respectueux. Elle exige une réflexion profonde sur la localisation et la protection de votre patrimoine informationnel. Le cloud souverain n'est pas une simple option technique, c'est un acte de résistance contre une économie qui a décidé que votre intimité était une marchandise comme les autres. En choisissant le chiffrement, en comprenant les architectures Zero-Knowledge, et en assumant la responsabilité de vos propres

© 2026 Oussama Ghorbel

sauvegardes, vous faites bien plus que sécuriser des octets : vous rétablissez la frontière sacrée entre votre vie privée et le reste du monde. Dans le chapitre suivant, nous nous attaquerons au dernier bastion de la télémétrie invasive : votre ordinateur de bureau et les systèmes d'exploitation qui le gouvernent.

© 2026 Oussama Ghorbel

Chapitre 17 – Coffres-forts numériques et authentification

Nous avons tous connu ce moment de flottement. Le curseur clignote dans le champ « Mot de passe », et notre esprit s'emballe. Était-ce avec un « M » majuscule ? Ai-je ajouté un point d'exclamation à la fin ? Étais-je en 2019 ou 2021 lorsque j'ai créé ce compte ? Cette friction quotidienne, cette micro-frustration, est le symptôme d'une architecture de sécurité obsolète que nous tentons désespérément de faire reposer sur la mémoire humaine.

Dans ce chapitre, nous allons aborder la pierre angulaire de votre forteresse numérique : l'authentification. C'est la frontière invisible qui sépare votre vie privée, vos économies et votre identité du reste du monde. Si le chiffrement est le coffre-fort, l'authentification en est la serrure. Et il est grand temps de remplacer les cadenas en plastique par des mécanismes de haute précision.

La mort du mot de passe unique et mémorisable

L'être humain est fondamentalement inadapté à la cryptographie. Notre cerveau est conçu pour retenir des schémas, des histoires, des émotions, et non des chaînes aléatoires de caractères alphanumériques. Face à la multiplication des services en ligne, nous avons développé des stratégies de survie désastreuses : le mot de passe unique réutilisé partout, ou la variation mineure (ajouter « !2024 » à la fin de son mot de passe habituel).

Cette paresse cognitive est le carburant de l'industrie cybercriminelle. L'attaque la plus répandue aujourd'hui n'est pas le piratage sophistiqué d'un serveur bancaire, mais le *credential stuffing* (bourrage d'identifiants). Imaginons qu'un site de e-commerce obscur, sur lequel vous vous êtes inscrit il y a cinq ans pour acheter une housse de téléphone, subisse une fuite de données. Les pirates récupèrent votre email et votre mot de passe. Puisque vous avez réutilisé ce même mot de passe pour votre boîte email principale, votre compte bancaire et vos impôts, les pirates utilisent des scripts automatisés pour tester ces identifiants sur des milliers de services critiques en quelques secondes.

© 2026 Oussama Ghorbel

Le tour est joué.

La complexité traditionnelle des mots de passe est un mythe entretenu par des règles de validation archaïques. On nous a appris à créer des mots de passe comme `Tr0ub4dor&3`. Du point de vue de l'entropie (la mesure du désordre et de l'imprévisibilité), ce mot de passe est faible. Il suit des schémas de substitution prévisibles (un zéro à la place d'un O, un 4 à la place d'un A) que les algorithmes de cassage par dictionnaire intègrent par défaut. De plus, il est cauchemardesque à taper sur un clavier de smartphone.

À l'inverse, une phrase de passe (passphrase) composée de quatre ou cinq mots aléatoires, comme `cheval-batterie-agrafeuse-correct`, possède une entropie mathématiquement supérieure. Elle résistera des milliers d'années aux attaques par force brute actuelles, tout en étant facile à mémoriser pour un cerveau humain grâce à la création d'une image mentale.

Cependant, même avec cette méthode, vous ne pouvez pas retenir 150 phrases de passe uniques pour chacun de vos services. La solution n'est pas d'améliorer votre mémoire, mais d'accepter la défaite de celle-ci et de déléguer cette tâche à une machine. Le mot de passe unique et mémorisable est mort. Bienvenue à l'ère du gestionnaire de mots de passe.

Choisir et configurer son gestionnaire de mots de passe

Un gestionnaire de mots de passe (Password Manager, ou PM) est un coffre-fort numérique qui génère, stocke et remplit automatiquement des identifiants complexes et uniques pour chaque service que vous utilisez. Vous ne connaissez plus qu'un seul mot de passe : la « clé maîtresse » (Master Password) qui déchiffre le coffre.

Il existe deux grandes philosophies dans l'univers des gestionnaires de mots de passe : le cloud synchronisé et le stockage local.

L'approche Cloud : Bitwarden

Bitwarden est aujourd'hui la référence absolue pour le grand public et les experts. C'est un logiciel open-source, dont le code a été audité par des firmes de cybersécurité indépendantes. Son architecture repose sur le

© 2026 Oussama Ghorbel

principe de la « connaissance nulle » (Zero-Knowledge). Cela signifie que vos données sont chiffrées localement, sur votre appareil, *avant* d'être envoyées sur les serveurs de Bitwarden. Si les serveurs de l'entreprise sont compromis, les attaquants ne récupèrent que des blobs de données illisibles, chiffrés avec une clé qu'ils ne possèdent pas (votre mot de passe maître). Bitwarden propose des applications sur tous les navigateurs et systèmes d'exploitation, assurant une synchronisation fluide.

L'approche Locale : KeePassXC

Pour ceux qui refusent catégoriquement de confier leurs données, même chiffrées, à un serveur tiers, KeePassXC est la solution. Le coffre-fort est un simple fichier crypté (`.kdbx`) stocké sur votre disque dur. C'est à vous de gérer la synchronisation entre vos appareils, par exemple en plaçant ce fichier dans un dossier Nextcloud auto-hébergé ou en utilisant Syncthing. C'est une approche qui demande plus de rigueur technique, mais qui offre un contrôle absolu sur l'emplacement physique de vos secrets.

La configuration du coffre-fort

Le point de rupture de votre sécurité repose désormais sur un seul élément : votre mot de passe maître. S'il est compromis, l'intégralité de votre vie numérique tombe.

Pour le créer, utilisez la méthode des dés (Diceware) ou générez une phrase de passe de 5 à 6 mots aléatoires séparés par des tirets. Notez-la sur un papier, mémorisez-la, puis détruisez le papier. Ne la stockez *jamais* dans un fichier texte sur votre ordinateur.

Ensuite, vous devez durcir les paramètres de chiffrement de votre gestionnaire. Dans les options de sécurité de Bitwarden ou KeePassXC, recherchez le paramètre concernant l'algorithme de hachage (KDF). Par défaut, il s'agit souvent de PBKDF2-SHA256 avec un certain nombre d'itérations. Si l'option est disponible, basculez vers **Argon2id**. Argon2 est un algorithme moderne conçu pour résister aux attaques par GPU (les cartes graphiques utilisées par les pirates pour casser les mots de passe en parallèle). Augmentez le nombre d'itérations ou la limite de mémoire jusqu'à ce que le déchiffrement prenne environ une demi-seconde sur votre machine. Ce léger délai est imperceptible pour vous à l'ouverture,

© 2026 Oussama Ghorbel

mais il multiplie par des millions le temps nécessaire à un attaquant pour tenter de deviner votre mot de passe maître.

La double authentification (2FA) : SMS vs TOTP vs Clés physiques

Le mot de passe, aussi robuste soit-il, peut être volé. Un keylogger sur votre ordinateur, une extension de navigateur malveillante, ou une campagne de phishing sophistiquée peuvent capturer vos identifiants en temps réel. C'est ici qu'intervient l'authentification à deux facteurs (2FA ou MFA). Le principe est simple : combiner quelque chose que vous *savez* (le mot de passe) avec quelque chose que vous *possédez* (un téléphone, une clé) ou quelque chose que vous *êtes* (votre empreinte digitale).

Toutes les méthodes de 2FA ne se valent pas. Il est crucial de comprendre leurs vulnérabilités.

Le SMS : le maillon faible

Recevoir un code par SMS est mieux que rien, mais c'est la méthode la plus vulnérable. Le réseau téléphonique (SS7) n'a pas été conçu pour la sécurité, mais pour l'interopérabilité. De plus, le *SIM swapping* (échange de carte SIM) est une technique d'ingénierie sociale redoutable. Un attaquant appelle votre opérateur mobile en se faisant passer pour vous, prétextant la perte de votre téléphone, et parvient à transférer votre numéro sur une carte SIM en sa possession. Dès lors, il reçoit tous vos appels et vos SMS de validation bancaire.

Note : ce contenu est informatif et ne constitue pas un conseil financier personnalisé, mais il est impératif de contacter votre banque pour désactiver la validation par SMS au profit de méthodes plus robustes ou de leurs applications propriétaires.

Le TOTP (Time-based One-Time Password)

C'est le standard actuel de la sécurité grand public. Il s'agit de ces codes à 6 chiffres qui changent toutes les 30 secondes, générés par des applications comme Raivo OTP, Aegis (sur Android), 2FAS, ou directement intégrés à votre gestionnaire de mots de passe.

© 2026 Oussama Ghorbel

Le fonctionnement repose sur un secret partagé (une graine cryptographique) scanné via un QR code lors de l'activation. L'algorithme combine ce secret avec l'heure actuelle pour générer un code éphémère.

L'avantage est immense : le code est généré localement sur votre appareil, hors ligne. Il ne transite par aucun réseau et ne peut être intercepté par un opérateur téléphonique.

Attention cependant : si vous stockez vos mots de passe ET vos codes TOTP dans le même gestionnaire (ex: Bitwarden), et que votre mot de passe maître est compromis, l'attaquant a les deux facteurs. L'idéal est de séparer les deux (mots de passe dans Bitwarden, TOTP dans Aegis/2FAS sur le téléphone), ou d'accepter le risque en sécurisant extrêment le coffre-fort avec une clé physique.

Les notifications Push

De plus en plus d'applications (Microsoft, Google, banques) envoient une notification « Est-ce vous qui essayez de vous connecter ? » avec un bouton « Oui/Non ». C'est pratique, mais cela a donné naissance à la « fatigue MFA » (ou push bombing). Un attaquant possédant votre mot de passe déclenche des dizaines de demandes de connexion en pleine nuit, espérant que, par agacement ou somnolence, vous cliquerez sur « Oui » pour qu'il vous laisse tranquille.

Les clés de sécurité matérielles (YubiKey et au-delà)

Si vous cherchez le summum de la sécurité, la clé matérielle est votre Graal. Des dispositifs comme la YubiKey ou la Titan Security Key de Google ressemblent à une petite clé USB. Elles implémentent les protocoles FIDO U2F et FIDO2.

Leur magie réside dans la cryptographie à clé publique. Lorsque vous liez une YubiKey à votre compte Google, la clé génère une paire de clés cryptographiques unique pour ce service. La clé publique est envoyée à Google, tandis que la clé privée reste physiquement scellée dans la puce de la YubiKey. Elle n'en sort *jamais*.

Lors de la connexion, le serveur de Google envoie un défi cryptographique. Votre navigateur le transmet à la clé USB. Vous devez

© 2026 Oussama Ghorbel

alors toucher physiquement le capteur tactile de la clé. La clé signe le défi avec sa clé privée et le renvoie au serveur.

Pourquoi est-ce infaillible ? Parce que le protocole FIDO2 intègre la vérification du nom de domaine. Si vous recevez un email de phishing vous redirigeant vers `g00gle.com` (avec des zéros), votre navigateur transmettra ce faux domaine à la YubiKey. La clé, ne reconnaissant pas le domaine `google.com` pour lequel elle a été programmée, refusera de signer le défi. **Le phishing devient mathématiquement impossible.** Même si un hacker vous observe taper votre mot de passe, il ne peut pas voler la signature physique de votre clé.

Je recommande l'usage de clés matérielles pour les comptes dits « à effet de levier » : votre gestionnaire de mots de passe, votre boîte email principale (qui sert de récupération pour tous les autres), votre hébergeur cloud, et vos plateformes d'investissement ou d'échange de cryptomonnaies. Gardez toutefois à l'esprit que tout investissement comporte des risques financiers et ne doit être entrepris qu'après une évaluation personnelle.

Le plan de secours : que faire si on perd son téléphone ?

La hantise de l'utilisateur de la 2FA est simple : « Et si je perds mon téléphone avec mon application TOTP, ou si ma YubiKey tombe dans les toilettes ? »

Si vous n'avez pas anticipé cette eventualité, vous risquez de perdre l'accès définitif à vos comptes les plus critiques. Le plan de secours n'est pas une option, c'est une obligation.

Les codes de récupération (Recovery Codes)

Lorsque vous activez la 2FA sur un service (Google, GitHub, votre banque), le site vous propose presque toujours de télécharger ou d'afficher une liste de 8 à 10 codes de secours à usage unique. Ces codes sont des « brise-glaces » : ils permettent de contourner la 2FA en cas de perte de votre appareil.

Imprimez ces codes. Ne les stockez pas dans votre coffre-fort numérique (si vous perdez l'accès au coffre, vous perdez les codes). Placez cette feuille dans une enveloppe scellée, dans un coffre-fort

© 2026 Oussama Ghorbel

physique, ou dans le coffre d'une banque.

La règle du double matériel

Si vous adoptez les clés de sécurité physiques, la règle d'or est absolue : **on achète toujours les clés par deux**.

La clé primaire (ex: YubiKey 5 NFC) va sur votre trousseau de clés quotidiennes. La clé secondaire (ex: YubiKey 5 Nano, plus petite) reste à la maison, dans un tiroir sécurisé ou un coffre, et est enregistrée sur tous vos comptes comme méthode de secours. Si vous perdez votre trousseau, vous rentrez chez vous, sortez la clé de secours, et vous révoquez immédiatement la clé perdue depuis les paramètres de sécurité de vos comptes.

L'accès d'urgence (Emergency Access)

Certains gestionnaires comme Bitwarden Premium proposent une fonctionnalité d'accès d'urgence. Vous pouvez désigner un contact de confiance (votre conjoint, un frère). Si vous êtes incapable d'accéder à votre coffre, ce contact peut faire une demande d'accès. Vous recevez une notification et vous avez un délai (par exemple 7 jours) pour refuser la demande. Si vous ne faites rien (parce que vous êtes dans le coma, ou décédé), le contact obtient l'accès à votre coffre-fort. C'est une fonctionnalité vitale pour la continuité de votre vie administrative.

Partager des accès de manière sécurisée avec ses proches

Le partage de mots de passe au sein d'un foyer est un casse-tête quotidien. Les couples partagent des comptes Netflix, des accès à la box internet, des comptes bancaires joints ou des factures d'énergie. La méthode habituelle consiste à envoyer le mot de passe par WhatsApp, SMS, ou pire, à le laisser sur un Post-it collé à l'écran. Ces méthodes sont des autoroutes pour les malware qui scrutent les historiques de conversations et les bureaux d'ordinateurs.

Les gestionnaires de mots de passe modernes intègrent des fonctions de partage chiffré.

Avec **Bitwarden Send**, vous pouvez créer un lien sécurisé contenant un mot de passe. Vous pouvez configurer ce lien pour qu'il s'autodétruise après une heure, ou après une seule consultation, et exiger

© 2026 Oussama Ghorbel

un mot de passe secondaire pour l'ouvrir. Vous envoyez le lien par email, et le mot de passe d'ouverture par SMS (séparation des canaux).

Pour un partage à long terme (ex: le code de l'alarme de la maison, le mot de passe du Wi-Fi, le compte d'épargne commun), Bitwarden et 1Password proposent des « Coffres partagés » ou des « Familles ». Vous créez un dossier partagé, et les membres de votre famille y ont accès via leur propre compte personnel. Si vous vous séparez, ou si un membre de la famille perd son appareil, vous révoquez simplement l'accès au dossier partagé sans avoir à changer le mot de passe du service lui-même et à le redistribuer à tout le monde.

L'héritage numérique

La mort physique n'arrête pas la vie numérique. Que deviennent vos photos, vos économies en ligne, vos domaines web, vos cryptomonnaies si vous disparaissez demain ? Vos proches se retrouveront face à des murs de chiffrement infranchissables.

Il est de votre responsabilité de préparer un protocole d'héritage numérique. Cela peut passer par le dépôt de votre mot de passe maître et de vos codes de récupération 2FA chez un notaire, ou via l'utilisation de services de « Dead Man's Switch » (interrupteur de l'homme mort). Ces services vous envoient un email tous les 6 mois vous demandant de cliquer sur un lien pour confirmer que vous êtes en vie. Si vous ne cliquez pas après un certain délai, le service envoie automatiquement un email prédéfini contenant les instructions d'accès à votre coffre-fort à vos bénéficiaires désignés.

L'avenir sans mot de passe (Passkeys et FIDO2)

L'industrie de la cybersécurité a acté l'échec du mot de passe. La solution pour l'éradiquer complètement s'appelle les **Passkeys** (clés d'accès). Derrière ce terme marketing se cache le standard WebAuthn / FIDO2, adapté pour le grand public et synchronisé via le cloud.

Concrètement, une Passkey transforme votre smartphone ou votre ordinateur en clé de sécurité matérielle. Lorsque vous vous connectez à un site compatible, le site demande une Passkey. Votre appareil vous demande alors de vous authentifier localement via votre biométrie (FaceID, TouchID, empreinte digitale Windows Hello). Une fois votre

© 2026 Oussama Ghorbel

identité biologique confirmée, l'appareil signe le défi cryptographique et vous connecte.

Les avantages sont monumentaux :

1. **Zéro phishing :** Comme avec la YubiKey, la Passkey est liée au nom de domaine exact.
2. **Zéro fuite serveur :** Le serveur du site web ne stocke plus de mot de passe, ni même de hash de mot de passe. Il ne stocke qu'une clé publique inutile pour un attaquant.
3. **Fluidité :** Plus de clavier à sortir, plus de codes à copier-coller. Un regard vers votre téléphone, et vous êtes connecté.

Les défis actuels :

Le problème majeur des Passkeys réside dans l'interopérabilité des écosystèmes. Si vous créez une Passkey sur votre iPhone, elle est stockée dans le Trousseau iCloud. Si vous passez ensuite sur un PC Windows sous Android, l'accès peut devenir complexe, bien que les géants (Apple, Google, Microsoft) aient mis en place un système de QR code pour permettre à un appareil de signer pour un autre via Bluetooth.

De plus, la perte de l'accès à votre compte Apple ou Google (qui hébergent vos Passkeys) devient un point de défaillance unique catastrophique.

Nous sommes dans une ère de transition hybride. Les Passkeys vont progressivement remplacer les mots de passe pour les services grand public, mais le gestionnaire de mots de passe restera indispensable pour les services qui ne les supportent pas encore, pour générer des alias, et pour conserver une souveraineté sur vos identifiants hors des écosystèmes fermés d'Apple ou de Google. Mon conseil est d'adopter les Passkeys quand elles sont proposées par des services critiques (Google, Apple, PayPal), mais de toujours conserver une copie de secours (mot de passe + TOTP) dans votre coffre-fort personnel comme Bitwarden ou KeePass.

Exercices pratiques : Sécuriser votre périmètre critique

La théorie ne vous protégera pas. C'est l'application méthodique de ces concepts qui construira votre forteresse. Ne tentez pas de tout migrer

© 2026 Oussama Ghorbel

en un week-end, vous risquez de vous enfermer dehors. Procédez par étapes.

Exercice 1 : L'installation et le blindage du coffre-fort

1. Créez un compte sur Bitwarden (ou installez KeePassXC).
2. Générez votre mot de passe maître (4 à 6 mots aléatoires). Mémorisez-le.
3. Dans les paramètres du coffre, activez la 2FA sur le coffre-fort lui-même.
4. Modifiez l'algorithme de hachage pour Argon2id si disponible.
5. Téléchargez l'extension pour votre navigateur et les applications mobiles. Activez le remplissage automatique et la biométrie sur mobile.

Exercice 2 : La migration du Top 10 Critique

Identifiez les 10 comptes qui, s'ils étaient compromis, détruiraient votre vie financière ou administrative. Généralement :

- Votre boîte email principale (Gmail, Outlook, ProtonMail)
- Votre gestionnaire de mots de passe (Bitwarden)
- Vos comptes bancaires en ligne
- Le portail des impôts
- Votre opérateur mobile
- Votre compte Apple / Google (pour la récupération d'appareils)
- Vos réseaux sociaux principaux (Twitter/X, LinkedIn)
- Vos plateformes d'investissement / crypto (si applicable)
- Votre hébergeur de fichiers (Dropbox, OneDrive, Nextcloud)
- Votre compte d'administration de votre Box Internet

Pour chacun de ces 10 comptes :

1. Connectez-vous, générez un mot de passe aléatoire de 20 caractères via votre gestionnaire et sauvegardez-le.
2. Allez dans les paramètres de sécurité du service.

© 2026 Oussama Ghorbel

3. Activez la 2FA. **Bannissez le SMS.** Choisissez TOTP (via votre application ou le coffre) ou, idéalement, enregistrez une clé matérielle (YubiKey).

4. **Étape cruciale :** Téléchargez les codes de récupération (Recovery Codes) de ce service. Imprimez-les ou notez-les, et rangez-les dans votre dossier physique de sécurité à la maison.

Exercice 3 : L'audit du SIM Swapping

Appelez votre opérateur mobile ou connectez-vous à votre espace client. Vérifiez les options de sécurité de votre ligne. Certains opérateurs permettent d'activer un "Code PIN opérateur" ou une restriction de portabilité qui empêche un conseiller téléphonique de transférer votre numéro vers une autre carte SIM sans un code secret préalable ou une validation en agence physique. Activez cette option immédiatement.

En accomplissant ces trois exercices, vous venez d'élever votre niveau de sécurité au-delà de celui de 99 % des internautes. Vous n'êtes plus une cible facile, un fruit à portée de main pour les bots et les scripts automatisés. Vous êtes devenu une forteresse. Et dans le monde de la surveillance et du profilage, l'ennemi cherche toujours le chemin de la moindre résistance. En lui barrant la route de vos accès critiques, vous le forcez à abandonner, et vous reprenez, brique par brique, le contrôle de votre vie numérique.

© 2026 Oussama Ghorbel

Chapitre 18 – L'ordinateur de bureau : Windows, Mac et Linux

L'ordinateur de bureau, qu'il soit portable ou fixe, occupe une place singulière dans notre écosystème numérique. Contrairement au smartphone, qui est l'outil de la consommation immédiate, de la géolocalisation permanente et de la communication fragmentée, l'ordinateur est le lieu de la production. C'est sur ces machines que nous rédigeons nos documents confidentiels, que nous gérons nos finances complexes, que nous stockons nos archives familiales et que nous développons nos projets professionnels. Pourtant, une illusion dangereuse persiste : celle de croire que parce que nous sommes assis à un bureau, dans la sphère privée de notre domicile ou derrière les portes closes de notre entreprise, nous sommes en sécurité.

La réalité est tout autre. Votre système d'exploitation (OS) n'est pas un simple gestionnaire de ressources matérielles ; c'est le propriétaire de votre maison numérique. Il possède les clés de chaque pièce, le droit de regard sur chaque tiroir et la capacité d'inviter des tiers à l'intérieur sans même que vous en soyez informé. La télémétrie intégrée aux systèmes d'exploitation modernes a transformé nos machines de travail en terminaux de collecte de données massives. Dans ce chapitre, nous allons décortiquer les mécanismes de surveillance de Windows, macOS et Linux, et nous vais vous guider pas à pas pour transformer votre ordinateur en une véritable forteresse souveraine.

Windows 10/11 : désactiver la télémétrie et Cortana/Copilot

Microsoft a opéré un changement de paradigme fondamental avec Windows 10, confirmé et amplifié par Windows 11 : le système d'exploitation n'est plus un produit que vous achetez, mais un service auquel vous vous abonnez (Windows as a Service). Ce modèle économique repose en grande partie sur la collecte continue de données, officiellement justifiée par l'amélioration de l'expérience utilisateur, la sécurité et, de plus en plus, l'alimentation des modèles d'intelligence artificielle.

© 2026 Oussama Ghorbel

La télémétrie de Windows s'infiltre à plusieurs niveaux. Par défaut, le système envoie à Microsoft des données de diagnostic, des informations sur les plantages d'applications, et même des échantillons de votre saisie clavier et de votre écriture manuscrite (pour améliorer la reconnaissance vocale et tactile).

Désactiver la télémétrie native

La première étape consiste à restreindre ces flux via les paramètres officiels, bien que Microsoft rende cette option volontairement labyrinthique.

1. Rendez-vous dans **Paramètres > Confidentialité et sécurité > Diagnostics et commentaires**.
2. Désactivez l'option **Envoyer des données de diagnostic facultatives**. Ne laissez activé que le strict minimum requis pour que le système fonctionne.
3. Dans la même section, décochez **Améliorer la saisie manuscrite et la personnalisation** ainsi que **Expériences personnalisées**.
4. Allez ensuite dans **Paramètres > Confidentialité et sécurité > Général** et désactivez les quatre options proposées, notamment celle permettant aux applications d'utiliser votre identifiant publicitaire.

Le cas de l'IA : de Cortana à Copilot et Recall

L'intégration de l'intelligence artificielle dans Windows 11 a radicalement modifié la surface d'attaque de votre vie privée. Cortana, désormais remisée, a laissé place à Copilot. Ce dernier, lorsqu'il est activé en mode profond, peut analyser le contexte de votre écran, de vos fenêtres ouvertes et de vos documents pour vous assister. Plus controversée encore est la fonctionnalité *Recall* (introduite sur les PC "Copilot+"), conçue pour prendre des captures d'écran constantes de votre activité afin de créer une base de données consultable de tout ce que vous avez vu ou fait sur votre machine. Même si Microsoft a dû repousser et sécuriser cette fonction face au tollé des experts en cybersécurité, elle illustre la direction prise par l'OS.

Pour désactiver Copilot et ses intégrations :

© 2026 Oussama Ghorbel

• Dans **Paramètres > Personnalisation > Barre des tâches**, désactivez l'icône Copilot.

• Pour les utilisateurs de Windows 11 Professionnel, ouvrez l'éditeur de stratégie de groupe locale (`gpedit.msc`), naviguez vers **Configuration ordinateur > Modèles d'administration > Composants Windows > Copilot Windows**, et activez la stratégie **Désactiver Copilot Windows**.

• Sous Windows Famille, il faut passer par l'Éditeur du Registre (`regedit`). Naviguez vers `HKEY_CURRENT_USER\Software\Policies\Microsoft\Windows\WindowsCopilot`, créez une valeur DWORD nommée `TurnOffWindowsCopilot` et fixez-la à `1`.

Enfin, pour nettoyer le menu Démarrer qui affiche souvent des suggestions d'applications (qui sont en réalité des publicités déguisées), allez dans **Paramètres > Personnalisation > Démarrer** et désactivez **Afficher les recommandations**.

Les outils de débloat : O&O ShutUp10 et WPD

Modifier manuellement les paramètres de Windows est un jeu de whack-a-mole (taper sur la taupe) épuisant. À chaque mise à jour majeure (les "Feature Updates" semestrielles ou annuelles), Microsoft a la fâcheuse habitude de réinitialiser certains paramètres de confidentialité à leurs valeurs par défaut, réactivant ainsi la télémétrie que vous aviez patiemment désactivée.

C'est ici qu'interviennent les outils de "debloat" (allègement) et de confidentialité. Ces utilitaires automatisent la modification de centaines de clés de registre et de services Windows pour verrouiller le système.

O&O ShutUp10++

C'est l'outil que je recommande en priorité pour sa pédagogie et sa sécurité. O&O ShutUp10++ est un utilitaire gratuit, portable (il ne nécessite aucune installation, ce qui évite d'ajouter des traces inutiles sur le système) et développé par une entreprise allemande réputée pour ses logiciels de récupération de données.

Son interface liste des centaines de paramètres classés par catégories (télémétrie, localisation, comportement du navigateur Edge, mises à

© 2026 Oussama Ghorbel

jour, etc.). Pour chaque option, le logiciel fournit une explication claire de son impact et propose trois choix : Oui, Non, ou Non défini (valeur par défaut de Microsoft). La fonction "Appliquer tous les paramètres recommandés" offre un excellent équilibre entre confidentialité stricte et maintien de la stabilité du système.

WPD (Windows Privacy Dashboard) et les scripts open-source

WPD est une autre excellente alternative, offrant une interface moderne et la possibilité de bloquer directement les adresses IP et les domaines de télémétrie de Microsoft via le pare-feu Windows intégré.

Pour les utilisateurs plus avancés, la communauté open-source a développé des scripts puissants, comme le *Chris Titus Tech Windows Utility* (winutil) ou le script *Sophia*. Exécutés via PowerShell, ces outils permettent non seulement de couper la télémétrie, mais aussi de désinstaller en profondeur les applications préinstallées indésirables (les "bloatwares" comme les jeux sponsorisés, les versions d'essai d'antivirus, ou les intégrations forcées à OneDrive et TikTok).

Avertissement crucial : Avant d'utiliser l'un de ces outils, créez systématiquement un **Point de restauration système**. Désactiver certains services (comme *Connected User Experiences and Telemetry* ou le service de *Remise des mises à jour*) peut parfois perturber des fonctionnalités spécifiques comme le Microsoft Store, Xbox Game Pass, ou le partage de connexion. La frugalité numérique exige que vous compreniez ce que vous sacrifiez au nom de votre vie privée.

macOS : limiter le suivi d'Apple et les rapports d'analyse

Apple a bâti une partie de sa valorisation boursière et de son image de marque sur la promesse de la confidentialité. Leurs campagnes publicitaires affirment que "ce qui se passe sur votre iPhone reste sur votre iPhone". Cependant, cette vision est celle de la "privacy washing" (écoblanchiment de la vie privée) : Apple protège vos données contre les courtiers tiers et les annonceurs externes, mais l'écosystème Apple lui-même reste une vaste machine de collecte centralisée. Le jardin clos (walled garden) d'Apple est extrêmement sécurisé contre les voleurs, mais le propriétaire du jardin vous observe en permanence.

Désactiver les rapports d'analyse et l'amélioration des services

© 2026 Oussama Ghorbel

Par défaut, votre Mac envoie quotidiennement des rapports techniques à Apple et aux développeurs d'applications tierces.

1. Ouvrez les **Réglages Système > Confidentialité et sécurité > Analyse et améliorations**.
2. Décochez impitoyablement toutes les cases : **Partager l'analyse du Mac**, **Partager avec les développeurs d'apps**, **Partager l'analyse iCloud**, et **Améliorer Siri et la dictée**. Cette dernière option est particulièrement intrusive, car elle envoie des extraits audio de vos commandes vocales sur les serveurs d'Apple pour "entraîner" leurs algorithmes.

Le pare-feu applicatif : reprendre le contrôle des connexions sortantes

Le pare-feu intégré de macOS est conçu pour bloquer les connexions *entrantes* non sollicitées, mais il est notoirement permissif pour les connexions *sortantes*. Si une application malveillante ou un logiciel de télémétrie décide d'envoyer vos données vers un serveur distant, le pare-feu natif d'Apple le laissera faire sans vous avertir.

Pour reprendre le contrôle, l'installation d'un pare-feu applicatif est indispensable. **LuLu** (développé par l'expert en sécurité Patrick Wardle d'Objective-See) est gratuit, open-source, et vous alertera à chaque fois qu'un processus tente de se connecter à Internet pour la première fois. **Little Snitch** (payant, mais référence absolue dans l'industrie) offre une cartographie visuelle et géographique de toutes les connexions sortantes de votre Mac, vous permettant de bloquer les requêtes vers les serveurs de suivi publicitaire ou les API de télémétrie d'Apple (comme `ocsp.apple.com`, utilisé pour vérifier les certificats de sécurité des applications, mais qui a soulevé des débats sur la capacité d'Apple à savoir quelles applications vous lancez et quand).

Safari et la protection contre le suivi

Si vous utilisez Safari, assurez-vous d'activer **Empêcher le suivi intersite** et **Masquer l'adresse IP aux traqueurs** dans les préférences de confidentialité. Cependant, comme nous le verrons dans d'autres chapitres, reposer sa navigation sur un navigateur lié à un écosystème commercial reste une vulnérabilité structurelle.

© 2026 Oussama Ghorbel

Linux : la solution souveraine pour les utilisateurs avancés

Si Windows est un centre commercial sous surveillance vidéo, et macOS un hôtel de luxe où le concierge note vos allées et venues, Linux est la terre sauvage où vous construisez votre propre cabane. Pour quiconque place la souveraineté numérique au sommet de ses priorités, migrer vers Linux n'est pas seulement un choix technique, c'est un acte philosophique.

Contrairement aux systèmes propriétaires, le noyau Linux et la grande majorité des distributions (distros) sont open-source. Cela signifie que le code qui exécute votre machine peut être audité par n'importe quel expert en sécurité dans le monde. Il n'y a pas de "porte dérobée" (backdoor) de télémétrie dissimulée dans le noyau, car la communauté l'aurait découverte et supprimée.

Choisir sa distribution

Toutes les distributions ne se valent pas en termes de confidentialité.

• **Linux Mint** ou **Pop!_OS** sont d'excellentes portes d'entrée pour les utilisateurs venant de Windows ou macOS. Ils sont stables, ergonomiques et, par défaut, ne collectent aucune donnée personnelle. (Notez que la distribution *Ubuntu*, bien que très populaire, a inclus par le passé des outils de télémétrie opt-in ou des intégrations avec des services comme Amazon ou Snap qui ont fait grincer des dents les puristes de la vie privée).

• **Fedora** ou **Debian** offrent un contrôle plus granulaire et un engagement fort envers le logiciel libre.

• Pour les utilisateurs exigeants en matière de sécurité, **Qubes OS** ou **Tails** représentent le summum de l'isolation (nous y reviendrons dans la section sur les machines virtuelles).

Le modèle des dépôts et la fin des stores espions

Sous Linux, vous n'installez pas vos logiciels en téléchargeant des `.exe` ou des `.dmg` depuis des sites web obscurs bourrés de publicités. Vous utilisez un gestionnaire de paquets qui puise dans des dépôts officiels, signés cryptographiquement et maintenus par la communauté. C'est la fin des installateurs tiers qui en profitent pour glisser des adwares ou des mouchards sur votre disque dur.

© 2026 Oussama Ghorbel

La contrepartie de cette liberté est la responsabilité. Sous Linux, vous êtes l'administrateur. Le système ne vous prendra pas par la main pour configurer votre pare-feu, et il ne vous suggérera pas d'assistant vocal pour lire vos emails. C'est le prix à payer pour une machine qui vous obéit réellement, sans rendre de comptes à une multinationale.

Le chiffrement complet du disque : BitLocker, FileVault et LUKS

Toutes les configurations logicielles du monde ne serviront à rien si votre ordinateur portable est oublié dans un train ou volé lors d'un cambriolage. La confidentialité en ligne doit être doublée d'une sécurité physique. Le chiffrement complet du disque (Full Disk Encryption, ou FDE) est la seule barrière efficace pour protéger vos données "au repos" (data at rest). Sans la clé de déchiffrement (votre mot de passe ou votre puce de sécurité), le disque dur n'est qu'un bloc de bruit aléatoire illisible, même si un attaquant le démonte pour le brancher sur une autre machine.

Windows et BitLocker : attention à la clé de secours

BitLocker est la solution native de Microsoft, disponible sur les éditions Professionnel et Entreprise de Windows. Il utilise le standard AES (souvent en mode XTS) pour chiffrer l'intégralité du volume.

Cependant, il existe un piège majeur. Lors de l'activation de BitLocker sur un PC connecté à un compte Microsoft, le système génère une "clé de récupération" de 48 chiffres et **l'envoie automatiquement sur les serveurs cloud de Microsoft**. Si votre compte Microsoft est compromis, ou si une agence gouvernementale émet une réquisition légale auprès de Microsoft, votre disque peut être déchiffré.

La parade : Avant d'activer BitLocker, déconnectez votre compte Microsoft, ou utilisez l'invite de commandes/PowerShell pour forcer la sauvegarde de la clé de récupération sur une clé USB locale ou une impression papier, puis supprimez-la de votre compte en ligne via le tableau de bord Microsoft.

Pour les utilisateurs de Windows Famille (qui n'ont pas accès à BitLocker complet), le logiciel open-source **VeraCrypt** est l'alternative de référence pour créer des volumes chiffrés ou chiffrer la partition

© 2026 Oussama Ghorbel

système.

macOS et FileVault : l'élégance matérielle

Sur les Mac modernes (équipés de la puce T2 ou des processeurs Apple Silicon M1/M2/M3), le chiffrement du disque est en réalité toujours actif au niveau matériel. Ce que vous activez dans les réglages sous le nom de **FileVault**, c'est la protection de la clé de chiffrement par votre mot de passe de session et le *Secure Enclave* (une puce dédiée à la sécurité cryptographique). L'activation de FileVault est simple, rapide et transparente. Assurez-vous simplement de ne pas stocker votre clé de récupération dans votre compte iCloud si vous ne faites pas une confiance absolue à Apple ou si vous craignez les réquisitions légales.

Linux et LUKS

Sous Linux, le standard est **LUKS** (Linux Unified Key Setup). La plupart des installateurs modernes (comme celui de Fedora, Mint ou Ubuntu) proposent une case à cocher lors du partitionnement du disque : "Chiffrer la nouvelle installation pour plus de sécurité".

LUKS est robuste, audité et indépendant de tout fournisseur cloud. La force de votre chiffrement reposera entièrement sur la robustesse de votre phrase de passe (passphrase) au démarrage de la machine. Oubliez les mots de passe courts ; optez pour une phrase de passe de 5 à 7 mots aléatoires, mémorisable mais impossible à casser par force brute.

Les machines virtuelles et l'isolation des tâches à risque

Le chiffrement protège vos données lorsque l'ordinateur est éteint. Mais comment protéger le système d'exploitation lui-même lorsque vous êtes en train de l'utiliser ? Comment ouvrir un document PDF suspect reçu par email, tester un logiciel dont la provenance est douteuse, ou naviguer sur des réseaux non sécurisés sans risquer de contaminer votre machine principale, celle qui contient vos mots de passe et vos données bancaires ?

La réponse réside dans la compartimentation, via les machines virtuelles (VM) et les hyperviseurs.

Le principe de l'isolation

© 2026 Oussama Ghorbel

Une machine virtuelle est un ordinateur simulé par logiciel, qui s'exécute dans une fenêtre de votre ordinateur réel (l'hôte). Si vous téléchargez un virus dans la VM, ou si vous visitez un site qui exploite une faille de votre navigateur, seul le système virtuel est infecté. Votre machine hôte reste intacte. Mieux encore, les hyperviseurs permettent de créer des "instantanés" (snapshots). Avant d'effectuer une action risquée, vous prenez un snapshot. Si la machine est compromise, un simple clic sur "Restaurer" la ramène à son état de pureté initial en une fraction de seconde.

Des logiciels comme **VirtualBox** (gratuit et open-source) ou **VMware Workstation Player** permettent de mettre en place cette isolation facilement sur Windows et Linux.

Qubes OS : la sécurité par le cloisonnement extrême

Pour les journalistes d'investigation, les avocats traitant des dossiers sensibles, ou les passionnés de cybersécurité, **Qubes OS** est le graal. Edward Snowden lui-même l'a recommandé. Qubes ne se contente pas de vous proposer de créer des machines virtuelles ; il *est* un hyperviseur (basé sur Xen).

Dans Qubes, il n'y a pas de système d'exploitation unique. Chaque tâche s'exécute dans son propre "qube" (une VM légère et isolée). Vous avez un qube pour votre navigation personnelle, un autre pour votre travail, un autre pour votre banque, et un "qube jetable" (disposable VM) qui se détruit intégralement dès que vous le fermez. Si vous ouvrez une pièce jointe malveillante dans le qube jetable, l'attaque est contenue et meurt avec la fermeture de la fenêtre. L'interface graphique unifie tout cela de manière transparente, avec un code couleur strict pour vous rappeler le niveau de confiance de chaque fenêtre.

Whonix et l'anonymat réseau

Si votre menace inclut la surveillance réseau et la correlation d'adresse IP, la machine virtuelle **Whonix** est indispensable. Whonix s'exécute en deux parties : une "Gateway" qui force absolument tout le trafic à passer par le réseau Tor, et une "Workstation" où vous travaillez, totalement isolée et incapable de connaître votre véritable adresse IP, même si un malware avec les droits d'administrateur parvient à la compromettre.

© 2026 Oussama Ghorbel

L'isolation demande des ressources matérielles (RAM et processeur), mais c'est le seul moyen de concilier l'usage d'un outil numérique moderne avec la certitude qu'une erreur de clic ne détruira pas des années de vie numérique.

Exercice pratique : Prendre le contrôle avec O&O ShutUp10

La théorie ne vaut rien sans l'action. Si vous utilisez Windows 10 ou 11, votre système envoie actuellement des données à Microsoft à votre insu. Nous allons y mettre fin en moins de cinq minutes.

Objectif : Appliquer un profil de confidentialité strict sans briser les fonctionnalités essentielles de votre système.

Étapes à suivre :

1. **Préparation et Sauvegarde :**

Avant toute modification du registre, créez un point de restauration. Tapez "Créer un point de restauration" dans la barre de recherche Windows, sélectionnez votre disque système (C:), cliquez sur "Créer" et nommez-le "Avant ShutUp10".

2. **Téléchargement Sécurisé :**

Rendez-vous sur le site officiel de l'éditeur (oo-software.com) et téléchargez **O&O ShutUp10++**. Ne le téléchargez jamais depuis un site tiers. L'avantage majeur est qu'il s'agit d'un fichier exécutable portable : aucune installation n'est requise, ce qui évite d'inscrire des clés d'installation dans votre registre.

3. **Analyse et Application :**

Lancez le logiciel en tant qu'administrateur (clic droit > Exécuter en tant qu'administrateur). L'interface va scanner votre système.

Plutôt que de tout désactiver manuellement, cliquez sur le menu **Actions** en haut, puis sélectionnez **Appliquer tous les paramètres recommandés**.

Note : Les paramètres "recommandés" par les développeurs désactivent la télémétrie de diagnostic, le pistage publicitaire, la localisation abusive et les suggestions de Cortana/Copilot, tout en

© 2026 Oussama Ghorbel

laissant fonctionnels Windows Update et le pare-feu.

4. **Exportation de la configuration :**

Toujours dans le menu Actions, choisissez **Exporter les paramètres**. Sauvegardez le fichier `.ini` sur une clé USB ou un disque externe. Si une future mise à jour de Windows réinitialise vos préférences, vous n'aurez qu'à importer ce fichier pour restaurer votre bouclier en une seconde.

5. **Redémarrage et Vérification :**

Fermez le logiciel et redémarrez votre ordinateur. Au redémarrage, vous constaterez souvent un système légèrement plus réactif, libéré des processus d'arrière-plan qui indexaient et envoyaient vos métadonnées.

Vous venez de reprendre le contrôle de votre machine. Votre ordinateur de bureau n'est plus un mouchard de luxe ; il est redevenu ce qu'il n'aurait jamais dû cesser d'être : un outil à votre service exclusif. La souveraineté numérique commence toujours par le sol sur lequel on se tient, et ce sol, c'est votre système d'exploitation.

© 2026 Oussama Ghorbel

Partie 4 : La forteresse domestique et l'identité

© 2026 Oussama Ghorbel

Chapitre 19 – Le routeur : sentinelle du réseau local

Nous passons des heures à configurer nos navigateurs, à éplucher les permissions de nos applications mobiles et à chiffrer nos disques durs. Pourtant, dans la grande majorité des foyers, un boîtier clignotant, souvent poussé derrière un meuble de salon ou relégué dans un placard, ignore royalement toutes ces précautions. Ce boîtier, c’est votre routeur. Il est la frontière absolue entre votre réseau domestique et l’immensité sauvage d’Internet.

Dans la quête de souveraineté numérique, on constate systématiquement le même paradoxe : nous installons des portes blindées à l’entrée de nos chambres, mais nous laissons la grille du domaine grande ouverte avec la clé sur la serrure. Le routeur n'est pas un simple câble qui relie votre box à l'extérieur. C'est un ordinateur à part entière, doté de son propre système d'exploitation, de sa propre mémoire et de ses propres règles de routage. C'est le point de passage obligé de chaque octet qui entre et sort de votre intimité numérique. Si votre routeur est compromis, ou simplement mal configuré, toutes les protections de vos appareils individuels peuvent être contournées, contredites ou rendues inutiles.

Ce chapitre est consacré à la transformation de cet équipement négligé en une véritable forteresse. Nous allons reprendre le contrôle sur ce qui se passe en amont de vos écrans, en sécurisant l'infrastructure même qui donne vie à votre connexion.

Changer les identifiants par défaut et mettre à jour le firmware

La première vulnérabilité d'un routeur n'est pas technique, elle est humaine. Lorsque vous installez un routeur, qu'il soit fourni par votre Fournisseur d'Accès à Internet (FAI) ou acheté dans le commerce, il est configuré avec des identifiants d'administration par défaut. Le tristement célèbre duo « admin / admin » ou « admin / password » a fait les beaux jours des cybercriminels pendant des décennies.

L'interface d'administration de votre routeur est le saint des saints. Celui qui y accède peut rediriger votre trafic vers des serveurs malveillants, intercepter vos données, ou ouvrir des portes dérobées vers vos appareils connectés. Les botnets, ces vastes réseaux d'appareils zombifiés utilisés pour lancer des attaques par déni de service ou envoyer du spam, se nourrissent de cette négligence. Le botnet Mirai, qui a paralysé une partie d'Internet en 2016, s'est propagé en scannant aveuglément des millions d'adresses IP et en tentant de se connecter aux routeurs avec une poignée d'identifiants par défaut.

La règle d'or de l'authentification locale

Votre première action doit être de vous connecter à l'interface de gestion (généralement via une adresse comme `192.168.1.1` ou `192.168.0.1`) et de modifier le mot de passe administrateur. N'utilisez pas le même mot de passe que celui de votre réseau Wi-Fi. Créez une phrase de passe robuste, unique, et stockez-la dans votre coffre-fort numérique. Si votre routeur le permet, créez un compte utilisateur secondaire avec des droits limités pour les réglages du quotidien, et réservez le compte « administrateur » aux modifications critiques.

Le nerf de la guerre : le firmware

Le firmware est le système d'exploitation de votre routeur. Comme tout logiciel, il contient des bugs et des failles de sécurité. Le chercheur en sécurité Bruce Schneier le résume parfaitement : « La sécurité n'est pas un produit, mais un processus. » Un routeur sécurisé à l'achat devient vulnérable six mois plus tard si son firmware n'est pas mis à jour.

Les box fournies par les FAI sont généralement mises à jour automatiquement et de manière opaque, ce qui pose un problème de confiance et de contrôle. Pour les routeurs du commerce, la mise à jour est souvent à votre charge. Je vous recommande de vérifier manuellement les mises à jour au moins une fois par trimestre sur le site officiel du fabricant. Méfiez-vous des routeurs d'entrée de gamme dont les fabricants abandonnent le support logiciel au bout d'un an. Un routeur qui ne reçoit plus de correctifs de sécurité est un routeur qui doit être remplacé ou dont le firmware doit être changé par une solution open source, comme nous le verrons plus loin.

© 2026 Oussama Ghorbel

Le DNS chiffré (DoH, DoT) pour masquer ses requêtes au FAI

Pour comprendre l'importance du DNS (Domain Name System), imaginez que vous souhaitez appeler un ami, mais que vous ne connaissez que son nom. Vous devez consulter un annuaire pour obtenir son numéro de téléphone. Sur Internet, le DNS est cet annuaire. Lorsque vous tapez `www.exemple.com` dans votre navigateur, votre appareil interroge un serveur DNS pour obtenir l'adresse IP correspondante (par exemple, `93.184.216.34`), afin de pouvoir s'y connecter.

Historiquement, les requêtes DNS sont envoyées en texte clair (sur le port 53). Cela signifie que votre FAI, ou quiconque surveille votre trafic sur le réseau local, peut lire chaque requête DNS que vous émettez. Même si vous visitez un site en HTTPS (où le contenu de la page est chiffré), votre FAI sait exactement *quels* domaines vous contactez, à quelle fréquence, et à quel moment. C'est une mine d'or pour le profilage publicitaire et la surveillance de masse. C'est d'ailleurs sur cette base que de nombreux FAI revendent des données agrégées de navigation à des courtiers en données.

DoT et DoH : l'annuaire sous scellés

Pour contrer cette fuite de métadonnées, la communauté de la cybersécurité a développé deux protocoles de chiffrement du DNS :

1. **DoT (DNS over TLS)** : Il encapsule la requête DNS dans une connexion TLS standard (le même protocole qui sécurise le HTTPS), généralement sur le port 853.
2. **DoH (DNS over HTTPS)** : Il fait transiter les requêtes DNS via le protocole HTTPS classique (port 443), les rendant indiscernables du trafic web normal pour un observateur externe.

En configurant votre routeur pour utiliser DoH ou DoT, vous masquez l'annuaire que vous consultez. Votre FAI voit que vous communiquez avec un serveur DNS (par exemple, celui de Cloudflare ou de Quad9), mais il est incapable de voir les domaines spécifiques que vous recherchez.

Attention toutefois : le DNS chiffré ne vous rend pas anonyme sur le web. Une fois l'adresse IP obtenue, votre connexion directe au serveur

© 2026 Oussama Ghorbel

web révèle cette adresse IP à votre FAI. Cependant, couplé à l'utilisation de SNI chiffré (ESNI/ECH) et aux réseaux Tor ou VPN, le DNS chiffré est une brique indispensable pour aveugler la télémétrie de votre fournisseur d'accès. De nombreux routeurs modernes permettent aujourd'hui d'activer le DoH ou le DoT directement dans leurs paramètres réseau globaux, protégeant ainsi l'ensemble du foyer sans avoir à configurer chaque appareil individuellement.

Pi-hole et AdGuard Home : le filtrage DNS domestique

Si le DNS chiffré protège votre vie privée vis-à-vis de votre FAI, le filtrage DNS, lui, protège votre réseau contre les trackers, les publicités et les domaines malveillants. C'est ici qu'interviennent des solutions magiques pour la frugalité numérique : Pi-hole et AdGuard Home.

Le concept du "trou noir" (Sinkhole)

Le principe est d'une élégance redoutable. Vous installez un petit serveur DNS sur votre réseau local (généralement sur un Raspberry Pi, un vieux PC portable, ou un conteneur Docker sur un NAS). Vous configurez ensuite votre routeur pour qu'il indique à tous vos appareils (téléphones, ordinateurs, télévisions, objets connectés) d'utiliser ce serveur local comme annuaire exclusif.

Lorsqu'un appareil demande l'adresse IP d'un site légitime, Pi-hole ou AdGuard Home fait suivre la requête à un résolveur DNS upstream (comme Quad9) et vous renvoie la réponse. Mais si votre smartphone tente de contacter `tracker.publicitaire.com` ou `telemetry.smart-tv.net`, le logiciel vérifie sa liste de blocage (souvent composée de centaines de milliers de domaines connus pour le pistage). Si le domaine est sur la liste, le serveur local renvoie une adresse IP nulle (`0.0.0.0`) ou l'adresse de votre réseau local. La requête tombe dans un "trou noir". Le tracker ne charge pas, la publicité ne s'affiche pas, et la télémétrie de votre téléviseur connecté est réduite au silence.

Pourquoi c'est indispensable

Dans le chapitre sur les extensions de navigateur, nous avons vu comment uBlock Origin nettoie le web sur nos ordinateurs. Mais que faire pour votre smartphone sous iOS qui ne supporte pas facilement les extensions système ? Que faire pour votre console de jeu, votre liseuse

© 2026 Oussama Ghorbel

électronique, ou votre assistant vocal qui intègrent des mouchards impossibles à désactiver via un navigateur ?

Le filtrage DNS domestique agit comme un bouclier au niveau de l'infrastructure. Il ne nécessite aucune installation sur les appareils clients. Dès qu'ils se connectent à votre Wi-Fi, ils sont protégés. AdGuard Home offre une interface très moderne et supporte nativement le DNS chiffré (DoH/DoT) vers l'extérieur, combinant ainsi le filtrage et la confidentialité vis-à-vis du FAI en une seule solution.

Les limites à connaître

Je me dois d'être transparent : le filtrage DNS a ses limites. Il ne peut pas bloquer les publicités servies depuis le même domaine que le contenu principal (comme les publicités intégrées dans les vidéos YouTube ou les posts sponsorisés sur certains réseaux sociaux), car bloquer le domaine couperait l'accès au contenu lui-même. Pour ces cas spécifiques, les extensions de navigateur et les applications dédiées restent nécessaires. Néanmoins, pour éliminer 80 % du bruit de fond, des bannières invasives et de la télémétrie sournoise, Pi-hole et AdGuard Home sont des outils d'une puissance inégalée.

Segmenter son réseau avec des VLANs (Invités, IoT, Principal)

L'une des erreurs d'architecture les plus courantes dans nos maisons connectées est le "réseau plat". Par défaut, un routeur place tous les appareils connectés dans le même réseau local (LAN). Votre ordinateur portable contenant vos déclarations d'impôts, votre smartphone avec vos emails professionnels, votre NAS avec vos photos de famille, mais aussi votre ampoule connectée à 15 euros, votre frigo intelligent et la caméra de surveillance bon marché achetée sur une marketplace asiatique, cohabitent sur le même segment réseau.

Le danger de l'IoT (Internet of Things)

Les objets connectés (IoT) sont notoirement peu sécurisés. Leurs fabricants privilégient le coût et la rapidité de mise sur le marché au détriment de la sécurité informatique. Leurs firmwares sont rarement mis à jour, leurs mots de passe sont souvent codés en dur, et leurs communications sont rarement chiffrées. Si un pirate parvient à

© 2026 Oussama Ghorbel

compromettre votre ampoule connectée via une faille connue, il se retrouve sur votre réseau local. Depuis cette ampoule, il peut scanner votre réseau, attaquer votre NAS par force brute, ou intercepter le trafic de votre ordinateur portable.

La solution : la segmentation par VLAN

Un VLAN (Virtual Local Area Network) permet de créer plusieurs réseaux logiques distincts sur une même infrastructure physique. C'est l'équivalent numérique des compartiments étanches d'un sous-marin. Si une voie d'eau (une compromission) survient dans un compartiment, les autres restent secs et le navire ne coule pas.

Je vous recommande de diviser votre réseau domestique en trois zones distinctes :

1. **Le réseau Principal** : Réservé à vos appareils de confiance (ordinateurs personnels, smartphones, NAS, imprimante sécurisée). C'est votre zone de haute sécurité.
2. **Le réseau IoT** : Dédié exclusivement aux objets connectés (ampoules, thermostats, assistants vocaux, électroménager connecté). Ces appareils ont besoin d'accéder à Internet pour fonctionner, mais n'ont absolument aucune raison de communiquer avec votre ordinateur portable.
3. **Le réseau Invités** : Un réseau isolé pour les amis de passage, ou pour les appareils de test dont vous vous méfiez. Il donne accès à Internet, mais coupe tout accès aux ressources locales.

Mise en place des règles de pare-feu (Firewall)

Créer les VLANs ne suffit pas, il faut définir les règles de circulation entre eux. Sur votre routeur ou pare-feu, vous devez instaurer une règle stricte : le réseau IoT peut sortir vers Internet, mais toute tentative de connexion *du* réseau IoT *vers* le réseau Principal doit être bloquée (Drop/Reject).

Si vous devez contrôler vos ampoules depuis votre téléphone (qui est sur le réseau Principal), vous pouvez autoriser des connexions spécifiques dans le sens Principal vers IoT, mais jamais l'inverse. Cette architecture demande un peu de réflexion initiale, mais elle vous met à l'abri des dégâts collatéraux liés à la compromission d'un objet connecté

© 2026 Oussama Ghorbel

vulnérable.

Désactiver les fonctionnalités UPnP et WPS

Dans la quête d'une expérience utilisateur "sans friction", les fabricants de routeurs ont intégré des fonctionnalités de confort qui s'avèrent être de véritables autoroutes pour les attaquants. Deux d'entre elles doivent être désactivées sans le moindre état d'âme : l'UPnP et le WPS.

L'UPnP (Universal Plug and Play) : la porte ouverte

L'UPnP a été conçu pour faciliter la vie des utilisateurs et des applications, notamment pour les jeux vidéo en ligne et les serveurs multimédias. Il permet à un appareil sur votre réseau local de demander au routeur d'ouvrir automatiquement un port sur le pare-feu et de le rediriger vers lui, sans aucune intervention humaine ni validation.

En théorie, c'est pratique. En pratique, c'est un cauchemar de sécurité. Si un malware infecte l'un de vos appareils, il peut utiliser l'UPnP pour demander au routeur d'ouvrir un port vers l'extérieur, créant ainsi une brèche permanente dans votre forteresse pour permettre à l'attaquant d'accéder à votre réseau depuis Internet, ou pour transformer votre machine en relais pour des activités illégales. Désactivez systématiquement l'UPnP dans les paramètres de votre routeur. Si un jeu ou une application nécessite une redirection de port, faites-le manuellement et de manière spécifique (Port Forwarding).

Le WPS (Wi-Fi Protected Setup) : la faille mathématique

Le WPS est ce fameux bouton physique sur votre routeur (ou ce code PIN à 8 chiffres) censé vous permettre de connecter un appareil au Wi-Fi sans avoir à taper le mot de passe. Le problème du WPS par code PIN réside dans sa conception cryptographique défaillante.

Un code PIN à 8 chiffres devrait offrir 100 millions de combinaisons possibles. Cependant, le protocole WPS divise ce PIN en deux moitiés et valide chacune indépendamment. De plus, le dernier chiffre est une simple somme de contrôle. Résultat : au lieu de 100 millions de tentatives, un attaquant n'a besoin que d'environ 11 000 tentatives pour deviner le PIN par force brute. Avec les outils actuels, casser le WPS

© 2026 Oussama Ghorbel

d'un routeur prend quelques heures, voire quelques minutes. Une fois le PIN trouvé, l'attaquant récupère votre véritable mot de passe Wi-Fi WPA2/WPA3 en texte clair.

La conclusion est sans appel : désactivez le WPS dans l'interface de votre routeur. La connexion d'un nouvel appareil vous demandera de taper votre mot de passe Wi-Fi, ce qui est un léger inconvénient comparé à la garantie de ne pas voir votre réseau sans fil s'effondrer en quelques minutes face à un script automatisé.

Choisir un routeur ouvert (OpenWrt, pfSense)

Les box fournies par les opérateurs télécoms sont des boîtes noires. Leur code source est fermé, leurs fonctionnalités sont bridées par le FAI, et leur interface d'administration est souvent un enchevêtrement d'options simplifiées qui cachent les véritables paramètres de sécurité. De plus, elles intègrent parfois des mécanismes de télémétrie ou des portes dérobées pour permettre au support technique du FAI d'y accéder à distance.

Pour reprendre véritablement le contrôle de votre sentinelle, le passage à un routeur ouvert est l'étape ultime. Cela signifie remplacer le système d'exploitation du routeur par un firmware alternatif, ou remplacer le matériel lui-même par une solution dédiée.

OpenWrt : donner une seconde vie au matériel

OpenWrt est une distribution Linux conçue pour les routeurs et les appareils embarqués. C'est un système d'exploitation complet qui remplace le firmware figé du fabricant par un environnement modulaire. Avec OpenWrt, vous accédez à un gestionnaire de paquets (comme sur Debian ou Ubuntu) vous permettant d'installer des outils avancés : serveurs VPN WireGuard, filtrage DNS avec AdGuard Home, gestion fine des VLANs, et contrôle total du pare-feu via `iptables` ou `nftables`.

L'installation d'OpenWrt requiert de vérifier la compatibilité de votre routeur sur le "Table of Hardware" du projet. C'est une solution idéale pour recycler un vieux routeur Wi-Fi de bonne facture et le transformer en machine de guerre pour la confidentialité.

pfSense et OPNsense : l'artillerie lourde

© 2026 Oussama Ghorbel

Si vous êtes prêt à investir un peu de temps et d'argent pour une solution de niveau entreprise à la maison, les pare-feu basés sur FreeBSD comme pfSense ou son fork communautaire OPNsense sont la référence absolue.

Contrairement à OpenWrt qui s'installe sur des routeurs Wi-Fi tout-en-un, pfSense/OPNsense s'installe généralement sur un mini-PC dédié (souvent équipé de processeurs Intel avec plusieurs ports Ethernet). Le Wi-Fi est alors géré par des "bornes" (Access Points) séparées et dédiées uniquement à l'émission du signal.

Cette séparation physique entre le routage/pare-feu et l'émission Wi-Fi est une excellente pratique de sécurité. pfSense et OPNsense offrent des interfaces graphiques extrêmement puissantes pour configurer des VLANs complexes, mettre en place un système de détection et de prévention d'intrusion (IDS/IPS comme Suricata), et gérer des tunnels VPN globaux pour tout votre domicile. La courbe d'apprentissage est raide, mais le niveau de contrôle et de visibilité sur votre trafic réseau est sans commune mesure. Vous saurez exactement qui parle à qui, et vous pourrez bloquer la télémétrie de Microsoft, Apple ou Google au niveau même de la passerelle.

Exercice pratique : Configurer un DNS respectueux de la vie privée

La théorie est essentielle, mais la pratique ancre les réflexes. Pour cet exercice, nous allons modifier les paramètres DNS de votre routeur actuel pour cesser d'utiliser les serveurs de votre FAI, qui journalisent vos requêtes, au profit d'un résolveur axé sur la confidentialité et la sécurité. Nous utiliserons **Quad9** ou **Mullvad DNS**, deux services qui s'engagent contractuellement et techniquement à ne pas conserver de logs de vos requêtes.

Étape 1 : Accéder à l'interface de votre routeur

Connectez-vous à votre réseau local, ouvrez un navigateur et tapez l'adresse IP de votre passerelle (souvent `192.168.1.1` ou `192.168.0.1`). Identifiez-vous avec vos nouveaux identifiants administrateur sécurisés.

Étape 2 : Localiser les paramètres DNS

© 2026 Oussama Ghorbel

Cherchez dans les menus l'intitulé « WAN », « Internet », ou « Paramètres Réseau ». Vous y trouverez une section dédiée au DNS, souvent réglée sur « Automatique » ou « Fourni par le FAI ». Décochez cette option pour passer en mode « Manuel » ou « Statique ».

Étape 3 : Entrer les adresses des résolveurs

Choisissez l'un des fournisseurs suivants et entrez leurs adresses IP dans les champs DNS Primaire et Secondaire :

Option A : Quad9 (Filtre les domaines malveillants, ne garde pas de logs)

• DNS Primaire IPv4 : `9.9.9.9`

• DNS Secondaire IPv4 : `149.112.112.112`

• *(Si votre routeur gère l'IPv6)* Primaire IPv6 : `2620:fe::fe` / Secondaire IPv6 : `2620:fe::9`

Option B : Mullvad DNS (Axé vie privée, propose différents filtres optionnels)

• DNS Primaire IPv4 (Sans filtre) : `194.242.2.2`

• DNS Secondaire IPv4 (Bloque publicités/trackers) : `194.242.2.3`

Étape 4 : Activer le chiffrement (si supporté)

Si votre routeur dispose d'une option pour le **DNS over TLS (DoT)** ou **DNS over HTTPS (DoH)**, activez-la. Vous devrez alors fournir l'URL du serveur au lieu de l'IP.

• Pour Quad9 (DoT) : `dns.quad9.net`

• Pour Mullvad (DoT) : `dns.mullvad.net`

Étape 5 : Sauvegarder, redémarrer et tester

Appliquez les paramètres et redémarrez votre routeur pour vous assurer que tous les appareils du réseau obtiennent la nouvelle configuration via le DHCP.

Une fois le réseau rétabli, rendez-vous sur le site `dnsleaktest.com` depuis un ordinateur connecté à votre Wi-Fi. Lancez le test standard. Les résultats doivent afficher les serveurs de Quad9 ou de Mullvad (souvent localisés dans un pays tiers ou affichant le nom de l'organisation), et non

© 2026 Oussama Ghorbel

plus les serveurs de votre fournisseur d'accès Internet local.

Félicitations. Vous venez de rendre aveugle votre FAI sur l'annuaire que consulte l'ensemble de votre foyer. Vous avez posé la première pierre de votre forteresse domestique. Le routeur n'est plus un simple passe-plat, il est devenu le premier gardien de votre invisibilité numérique.

© 2026 Oussama Ghorbel

Chapitre 20 – La maison connectée et l'IoT

Notre foyer a toujours été notre sanctuaire, le lieu où nous baissons la garde, où nous nous reposons des exigences du monde extérieur. Pourtant, au cours de la dernière décennie, nous avons volontairement invité des milliers de capteurs, de micros et de caméras à franchir le seuil de nos maisons. Sous la promesse alléchante du confort, de l'automatisation et de la sécurité, l'Internet des Objets (IoT) a transformé nos salons, nos cuisines et nos chambres en de vastes réseaux de collecte de données. Dans ce chapitre, nous allons décortiquer les rouages de la maison connectée, comprendre pourquoi votre réfrigérateur n'a pas besoin de connaître votre adresse IP, et surtout, apprendre à reprendre le contrôle de votre intimité domestique.

L'IoT : le cauchemar de la sécurité et de la vie privée

L'expression « Internet des Objets » (Internet of Things, ou IoT) évoque souvent des images futuristes : des lumières qui s'adaptent à notre humeur, des thermostats qui anticipent notre retour, ou des cafetières qui se déclenchent au son de notre réveil. La réalité est infiniment moins poétique et beaucoup plus lucrative pour les géants de la technologie et les courtiers en données.

Pour comprendre le cauchemar que représente l'IoT pour la vie privée, il faut d'abord s'interroger sur le modèle économique de ces appareils. Pourquoi une brosse à dents, une balance ou une ampoule ont-ils besoin d'une connexion Wi-Fi ? La réponse tient en un mot : la télémétrie. Le matériel est souvent vendu à prix coûtant, voire à perte. Le véritable produit, c'est vous. Chaque interaction, chaque heure d'allumage, chaque variation de température ou de poids est captée, agrégée et revendue pour affiner votre profil de consommateur. Votre machine à café connectée ne se contente pas de chauffer de l'eau ; elle informe le fabricant de vos habitudes de sommeil, de votre rythme de vie, et potentiellement de la taille de votre foyer.

Outre l'aspect purement mercantile de la collecte de données, l'IoT est un désastre en matière de cybersécurité. Le marché est inondé

© 2026 Oussama Ghorbel

d'appareils bon marché, conçus à la hâte par des fabricants qui n'ont aucune culture de la sécurité informatique. Ces objets sont expédiés avec des mots de passe par défaut impossibles à modifier, des protocoles de chiffrement obsolètes, et, pire encore, sans aucune perspective de mise à jour de sécurité.

L'expert en sécurité Bruce Schneier qualifie souvent l'IoT d'« Internet of Trash » (l'Internet des déchets), soulignant que nous intégrons des ordinateurs peu sécurisés dans des objets du quotidien, créant ainsi des failles béantes dans nos réseaux domestiques. Un thermostat connecté vulnérable peut sembler anodin, mais il partage le même réseau que votre ordinateur portable, votre smartphone et votre serveur de stockage (NAS). Si un pirate ou un logiciel malveillant prend le contrôle de votre ampoule intelligente, il dispose d'un point d'entrée pour pivoter vers vos appareils personnels et voler vos données sensibles, vos identifiants bancaires ou vos photos privées.

La frugalité numérique commence ici, par une question fondamentale avant chaque achat : *cet objet a-t-il réellement besoin d'être connecté à Internet pour remplir sa fonction première ?* Si la réponse est non, choisissez la version analogique ou déconnectée. Vous économiserez de l'argent, de l'énergie, et vous préserverez votre intimité.

Assistants vocaux (Alexa, Siri, Google) : des micros sur écoute

Parmi tous les objets connectés, les assistants vocaux occupent une place à part. Posés sur la table de chevet, trônant dans la cuisine ou dissimulés dans le salon, ces cylindres et ces sphères ont normalisé la présence de micros ouverts en permanence dans nos espaces les plus intimes.

Le fonctionnement de base d'un assistant vocal repose sur un « mot de réveil » (wake word), comme « Alexa », « Dis Siri » ou « Ok Google ». Le fabricant vous assure que l'appareil n'écoute pas en continu, mais qu'il se contente d'analyser en local une boucle audio de quelques secondes, en attendant de détecter ce mot magique pour envoyer la requête vers le cloud. Sur le papier, c'est rassurant. Dans la pratique, c'est beaucoup plus trouble.

© 2026 Oussama Ghorbel

Premièrement, les faux positifs sont légion. L'appareil croit entendre son mot de réveil dans une conversation, un extrait de film ou un bruit ambiant, et commence à enregistrer et à envoyer vers les serveurs du fabricant des bribes de votre vie privée. Deuxièmement, l'analyse acoustique ne se limite pas à la transcription de vos mots. Les algorithmes modernes sont capables d'analyser le bruit de fond (la télévision allumée, le bruit d'une dispute, la présence d'enfants), le ton de votre voix (stress, fatigue, maladie) et l'identité des locuteurs. C'est une mine d'or pour le profilage contextuel. Si Google détecte que vous parlez de rénovation le week-end, ne soyez pas surpris de voir des publicités pour des matériaux de construction apparaître sur votre téléphone le lundi matin.

Plus inquiétant encore : la validation humaine. Pour améliorer leurs algorithmes de reconnaissance vocale, les géants de la tech ont recours à des sous-traitants du monde entier qui écoutent, transcrivent et annotent des extraits audio capturés chez les utilisateurs. En 2019, des enquêtes journalistiques ont révélé que des employés d'Amazon, d'Apple et de Google écoutaient quotidiennement des enregistrements intimes, parfois déclenchés par erreur, incluant des conversations médicales, des disputes conjugales ou des bruits de chambre à coucher. Bien que ces entreprises aient depuis ajouté des options pour refuser ce « partage pour amélioration », le paramètre est souvent activé par défaut, noyé dans des sous-menus obscurs.

L'assistant vocal n'est pas un majordome bienveillant ; c'est un cheval de Troie acoustique. Il est conçu pour faciliter vos achats (dans le cas d'Amazon), pour capter vos intentions de recherche (dans le cas de Google) ou pour verrouiller votre écosystème matériel (dans le cas d'Apple). Si vous tenez à la confidentialité de vos conversations familiales, la solution la plus radicale et la plus efficace reste de débrancher ces appareils, ou à défaut, d'utiliser le bouton « mute » physique (coupe-micro) dès que vous n'interagissez pas avec eux.

Les caméras de surveillance : garder les flux en local

Le besoin de sécuriser son domicile est légitime. Mais l'ironie tragique des caméras de surveillance connectées grand public est qu'elles créent souvent plus de risques qu'elles n'en préviennent. Des marques

© 2026 Oussama Ghorbel

très populaires, souvent rachetées par des géants comme Amazon (Ring) ou Google (Nest), ont bâti leur modèle économique sur le cloud.

Lorsque vous installez une caméra cloud, les flux vidéo de votre salon, de votre jardin ou de votre porte d'entrée sont envoyés en continu vers les serveurs du fabricant. Vous dépendez entièrement de leur infrastructure pour accéder à vos propres images. Les conséquences en termes de vie privée sont multiples :

1. **Les fuites de données :** Les serveurs centralisés de millions de caméras domestiques sont des cibles de choix pour les cybercriminels. Une brèche, et les vidéos de votre intimité se retrouvent sur le dark web.
2. **L'accès par les employés :** Comme pour les assistants vocaux, les équipes techniques et les sous-traitants ont potentiellement accès aux flux pour des raisons de « maintenance » ou de « support ».
3. **Les partenariats avec les forces de l'ordre :** Certaines entreprises ont mis en place des programmes permettant à la police locale d'accéder aux vidéos des particuliers sans mandat judiciaire préalable, transformant les porchers des citoyens en un vaste réseau de surveillance d'État décentralisé.

La philosophie de la frugalité et de la souveraineté numérique dicte une règle simple : **vos images ne doivent jamais quitter votre domicile.**

Pour ce faire, il faut s'orienter vers des caméras qui fonctionnent en local. Recherchez des appareils compatibles avec les protocoles **RTSP** (Real Time Streaming Protocol) et **ONVIF** (un standard mondial pour les produits de sécurité IP). Ces protocoles permettent à la caméra d'envoyer son flux vidéo directement à un enregistreur local (NVR - Network Video Recorder) situé chez vous, sur un disque dur qui vous appartient.

Des marques orientées « prosumer » (entre le grand public et le professionnel) ou spécialisées dans la sécurité locale proposent des caméras PoE (Power over Ethernet). L'avantage du PoE est double : un seul câble réseau suffit pour alimenter la caméra et transmettre les données, et surtout, cela vous permet de brancher l'ensemble de votre système de vidéosurveillance sur un réseau isolé, totalement coupé

© 2026 Oussama Ghorbel

d'Internet. Votre caméra filmera votre porte d'entrée, enregistrera sur votre serveur local, et vous pourrez consulter les images depuis votre smartphone via une connexion sécurisée (comme un VPN), sans qu'aucune multinationale n'ait jamais accès à votre jardin.

Les alternatives open-source (Home Assistant)

Si vous souhaitez conserver le confort de la domotique (allumer les lumières au coucher du soleil, baisser le chauffage quand vous partez) sans sacrifier votre vie privée sur l'autel des clouds propriétaires, il existe une alternative puissante, élégante et respectueuse de vos données : **Home Assistant**.

Home Assistant est un logiciel open-source de domotique qui s'installe sur un petit ordinateur local (comme un Raspberry Pi, un mini-PC, ou un NAS). Son principe fondateur est le « local-first » (le local d'abord). Contrairement aux applications des fabricants qui font transiter vos commandes par leurs serveurs en Chine ou en Californie avant de les renvoyer à votre ampoule, Home Assistant communique directement avec vos appareils sur votre réseau local.

Si votre connexion Internet tombe, votre maison continue de fonctionner. Vos interrupteurs physiques répondent, vos automatisations s'exécutent, et aucune donnée de télémétrie n'est envoyée à l'extérieur. Home Assistant est agnostique : il ne se soucie pas de la marque de votre matériel. Il peut unifier des ampoules Philips, des thermostats Netatmo, des capteurs de porte Xiaomi et des caméras Reolink dans une seule et même interface, élégante et personnalisable.

Pour aller plus loin dans l'indépendance, Home Assistant permet d'intégrer des protocoles de domotique locaux comme **Zigbee** ou **Z-Wave**. En branchant une simple clé USB Zigbee sur votre serveur Home Assistant, vous créez votre propre réseau maillé d'objets connectés. Vous pouvez alors acheter des capteurs de mouvement, des boutons ou des prises connectées génériques, les associer à votre réseau local, et les couper totalement d'Internet. Vous reprenez ainsi le contrôle du « cerveau » de votre maison. C'est une démarche qui demande un léger investissement en temps pour l'apprentissage et la configuration, mais le résultat est une forteresse domotique qui vous appartient à 100 %, sans abonnement mensuel et sans espionnage.

© 2026 Oussama Ghorbel

Isoler les objets connectés du réseau principal

Même avec les meilleures intentions et du matériel respectueux, il est inévitable d'avoir chez soi quelques objets connectés propriétaires (une télévision intelligente, un aspirateur robot, une enceinte offerte par un opérateur). La règle d'or de la sécurité réseau s'applique ici comme dans n'importe quelle entreprise : **la segmentation**.

Imaginez votre réseau Wi-Fi comme un bâtiment. Votre ordinateur portable, votre smartphone et votre NAS contenant vos documents fiscaux et vos photos de famille se trouvent dans le bureau sécurisé. Votre aspirateur robot et votre télévision connectée, eux, sont des invités dont vous ne connaissez pas vraiment les intentions. Leur donner les clés de votre bureau est une absurdité. Pourtant, c'est exactement ce que vous faites si tous vos appareils sont connectés au même réseau Wi-Fi principal.

Pour isoler les objets connectés, vous devez utiliser les fonctionnalités de votre routeur :

1. **Le réseau « Invité » (Guest Network) :** C'est la solution la plus simple, disponible sur la plupart des box des fournisseurs d'accès à Internet et les routeurs grand public. Créez un réseau Wi-Fi secondaire nommé « Maison_IoT ». Connectez-y exclusivement vos objets intelligents (TV, ampoules, assistants vocaux, électroménager). La plupart des réseaux invités intègrent une option « Isoler les clients » (Client Isolation), qui empêche les appareils connectés à ce réseau de communiquer entre eux et d'accéder au réseau principal. Votre aspirateur pourra ainsi contacter ses serveurs pour télécharger une mise à jour, mais il lui sera impossible de scanner votre ordinateur portable.

2. **Les VLAN (Virtual Local Area Networks) :** Pour les utilisateurs plus avancés disposant de routeurs prosumer (comme Ubiquiti, pfSense, OPNsense), les VLANs permettent une segmentation chirurgicale. Vous pouvez créer un VLAN dédié à l'IoT, et établir des règles de pare-feu strictes (Firewall Rules). Par exemple, vous pouvez autoriser votre smartphone à envoyer des commandes aux ampoules du VLAN IoT, mais bloquer toute tentative du VLAN IoT d'initier une connexion vers votre VLAN

© 2026 Oussama Ghorbel

principal.

3. **Le blocage DNS et le Pi-hole :** De nombreux objets connectés essaient de contacter des dizaines de serveurs de pistage en arrière-plan. En configurant un serveur DNS local comme **Pi-hole** ou **AdGuard Home** sur votre réseau, vous pouvez bloquer les requêtes vers les domaines de télémétrie connus. Votre télévision intelligente cessera soudainement d'essayer de charger des publicités dans ses menus, et votre aspirateur arrêtera d'envoyer le plan de votre appartement aux serveurs du fabricant.

En appliquant ces couches d'isolation, vous transformez votre réseau domestique en une série de sas de décontamination. Les objets connectés peuvent fonctionner, mais leur capacité à nuire à votre vie privée et à votre sécurité informatique est drastiquement réduite.

Désactiver les améliorations de produit et les partages de données

L'installation d'un objet connecté ne s'arrête pas à son branchement électrique. Elle passe inévitablement par le téléchargement de l'application mobile du fabricant, véritable champ de mines de « dark patterns » (interfaces manipulatoires) conçus pour vous faire consentir à un maximum de partages de données.

Lors de la création de votre compte et de l'association de l'appareil, vous serez confronté à une série de cases à cocher ou d'interrupteurs à activer. Le vocabulaire utilisé est volontairement flou et culpabilisant. On vous demandera si vous souhaitez « Participer à l'amélioration de nos produits », « Partager des données d'utilisation anonymisées pour aider la communauté », ou « Bénéficier d'une expérience personnalisée ».

Sous ces appellations altruistes se cache la monétisation de votre comportement. Les données « anonymisées » sont un mythe : il est prouvé que quelques points de données (géolocalisation, horaires d'utilisation, modèle de l'appareil) suffisent à ré-identifier un individu. De plus, ces partages servent souvent à entraîner des algorithmes d'intelligence artificielle qui seront ensuite revendus à des tiers.

Pour reprendre le contrôle, vous devez adopter une posture de méfiance systématique lors de la configuration initiale :

© 2026 Oussama Ghorbel

• **Refusez tout partage de données d'utilisation.** L'appareil fonctionnera parfaitement sans que le fabricant sache à quelle fréquence vous l'utilisez.

• **Désactivez les programmes d'amélioration par écoute humaine** (particulièrement crucial pour les assistants vocaux et les robots aspirateurs qui cartographient votre intérieur).

• **Audit régulier des permissions de l'application mobile.** Pourquoi l'application de votre ampoule connectée demande-t-elle l'accès à votre géolocalisation précise, à vos contacts et à votre stockage de fichiers ? Sur Android comme sur iOS, révoquez toutes les permissions qui ne sont pas strictement nécessaires au fonctionnement de base (généralement, le Bluetooth ou le réseau local suffisent).

La frugalité numérique, c'est aussi ce refus de céder à la fatigue du consentement. Prenez les cinq minutes nécessaires pour lire les écrans de configuration, cherchez les paramètres avancés de confidentialité, et coupez les vivres à ceux qui cherchent à siphonner les données de votre foyer.

Exercices pratiques : Reprendre le contrôle de votre salon

La théorie ne vaut rien sans la pratique. Prenez votre smartphone, asseyez-vous dans votre salon, et exécutez les exercices suivants pour assainir votre environnement connecté.

Exercice 1 : Le grand nettoyage acoustique (Assistants Vocaux)

Si vous possédez des assistants vocaux et que vous choisissez de les conserver, votre premier devoir est de purger l'historique de ce qu'ils ont entendu.

• **Pour Amazon Alexa :** Ouvrez l'application Alexa > *Plus* > *Paramètres* > *Confidentialité Alexa* > *Historique des voix*. Sélectionnez « Tout l'historique » et supprimez tous les enregistrements.

• **Pour Google Assistant :** Ouvrez l'application Google > *Paramètres* > *Assistant Google* > *Confidentialité et partage* > *Gérer*

© 2026 Oussama Ghorbel

l'activité de l'Assistant. Supprimez l'activité par période (choisissez « Toutes les données »).

• **Pour Apple Siri :** Allez dans les *Réglages* de votre iPhone > *Siri et recherche > Historique de Siri et des dictées > Supprimer l'historique*.

Exercice 2 : Couper les oreilles humaines (Désactiver l'amélioration continue)

Toujours dans les paramètres de confidentialité de ces mêmes applications, vous devez impérativement désactiver l'option qui autorise des employés ou des sous-traitants à écouter vos requêtes pour « améliorer le service ».

• **Alexa :** Dans *Confidentialité Alexa*, cherchez l'option « Gérer la façon dont vos données améliorent les services Alexa » et désactivez « Utiliser les demandes pour améliorer les services Alexa ».

• **Google :** Dans les paramètres de confidentialité de l'Assistant, désactivez l'option « Inclure l'activité vocale et audio » dans le cadre des améliorations de produits.

• **Apple :** Dans *Réglages > Confidentialité et sécurité > Analyse et améliorations*, désactivez « Améliorer Siri et la dictée ».

Exercice 3 : La quarantaine réseau (Isolation IoT)

Connectez-vous à l'interface d'administration de votre box internet ou de votre routeur (gén ralement via une adresse comme `192.168.1.1` ou `192.168.0.1` depuis votre navigateur web).

1. Localisez la section « Wi-Fi Invité » (Guest Wi-Fi) ou « Réseau Secondaire ».

2. Activez ce réseau et donnez-lui un nom clair (ex: `Maison_IoT`).

3. **Crucial :** Cochez l'option « Isoler les appareils » ou « Empêcher l'accès au réseau local ».

4. Prenez votre télévision connectée, votre aspirateur robot et vos enceintes intelligentes, et connectez-les exclusivement à ce nouveau réseau.

© 2026 Oussama Ghorbel

5. Vérifiez que votre smartphone et votre ordinateur restent sur le réseau principal.

En réalisant ces trois exercices, vous venez de faire taire des milliers de micros fantômes, d'effacer des heures d'enregistrements de votre vie privée, et de construire votre premier mur de défense réseau au sein de votre propre foyer. Votre maison redevient, enfin, votre sanctuary.

Le bon usage de la domotique : entre confort et sobriété

Après toutes ces mises en garde, on pourrait croire que la maison connectée est un déclin absolu, à bannir sans concession. Il serait simpliste de le présenter ainsi. Le véritable enjeu n'est pas de faire la croisade contre la technologie, mais de rétablir une hiérarchie claire : la technologie doit servir l'occupant, jamais l'inverse. Un foyer intelligent n'est pas nécessairement une maison bourrée d'objets connectés ; c'est une maison où chaque élément connecté a été choisi délibérément, où chaque donnée produite reste sous le contrôle de celui qui l'a engendrée.

Pensez-y en termes d'utilité réelle avant de céder à la démonstration de magie en vitrine. L'ampoule qui change de couleur au gré de vos playlists est un confort décoratif ; l'ampoule que vous allumez d'un geste quand vos bras chargés de courses n'ont pas de main libre relève d'un vrai gain opérationnel. Le réfrigérateur qui vous propose des recettes en fonction de son contenu est une curiosité gadget ; la sonnette qui vous alerte sur votre téléphone quand un livreur approche de votre porte répond à un besoin concret. Distinguer le superflu de l'utile, c'est déjà pratiquer la frugalité numérique à l'échelle domestique.

Cette discipline d'achat se double d'une discipline d'usage. Un objet connecté n'a aucune raison de tourner à plein régime quand vous n'êtes pas chez vous ou quand vous dormez. Les routines de mise en veille, les interrupteurs physiques coupant l'alimentation électrique des objets les plus intrusifs, les horaires de fonctionnement limités : autant de gestes simples qui réduisent la fenêtre d'exposition sans nuire au confort. Une prise connectée standard sur laquelle repose votre cafetière, programmée pour couper l'alimentation à 22 heures, neutralise en une seconde toute capacité de surveillance nocturne potentielle de l'appareil.

© 2026 Oussama Ghorbel

La communication avec les autres membres du foyer constitue le dernier maillon de cette chaîne de responsabilité. Une maison connectée n'est jamais l'affaire d'une seule personne. Si votre conjoint, vos enfants ou vos colocataires partagent l'espace, ils partagent également les données générées. Il est essentiel de poser collectivement les règles : quels appareils sont acceptés dans les espaces communs, quels enregistrements sont conservés et pendant combien de temps, qui a accès aux caméras et aux journaux d'événements. Installer une caméra d'intérieur « pour surveiller le chat » alors qu'un membre du foyer s'oppose à cette idée, c'est déjà entamer la confiance domestique bien avant que la donnée ne parte sur un serveur distant.

Anticiper la fin de vie et l'obsolescence des objets connectés

Un aspect rarement abordé, mais décisif, concerne le sort de vos objets connectés lorsqu'ils sortent du cadre de votre vie. Revendre une enceinte intelligente, jeter un ancien thermostat, donner un smartphone ancien : chacune de ces opérations implique un transfert de données que la plupart des gens ignorent.

Les objets IoT conservent souvent des traces numériques persistantes. Une enceinte intelligente mémorise votre réseau Wi-Fi, vos identifiants de streaming, votre historique de commandes vocales. Un ancien smartphone contient encore vos comptes connectés s'ils n'ont pas été déconnectés. Une caméra de surveillance peut héberger en mémoire les dernières images capturées dans votre intérieur. Les réinitialiser d'usine n'est pas un rituel anodin : c'est le geste d'hygiène numérique qui clôt le cycle de vie de l'objet.

Pour chaque appareil que vous vous apprêtez à céder ou à recycler, la procédure est toujours la même :

• déconnectez-le de votre compte fabricant depuis l'application associée ;

• déconnectez-le de votre réseau Wi-Fi et de votre écosystème domotique local ;

• lancez une réinitialisation d'usine complète (consultez le manuel ou le site du fabricant pour la procédure exacte) ;

© 2026 Oussama Ghorbel

- pour les appareils à batterie ou à stockage interne, vérifiez qu'aucune fonction de persistance ne subsiste ;
- effacez l'application associée de votre téléphone si vous n'en aurez plus besoin.

Ce dernier point mérite qu'on s'y attarde. Désinstaller l'application ne supprime pas le compte. Un compte fantôme chez un fabricant que vous n'utilisez plus depuis cinq ans, c'est une porte de sortie permanente pour vos données, un actif dormant qui peut être compromis lors d'une future violation. Supprimez définitivement les comptes dont vous n'avez plus besoin, conformément à votre droit à l'effacement consacré par le RGPD.

Vers une maison sobre, consciente et souveraine

La trajectoire que ce chapitre propose peut sembler exigeante au premier abord. Elle demande un temps d'apprentissage, une remise en question des habitudes d'achat impulsif, et une volonté de lire des écrans de configuration que la plupart des gens cliquent « Suivant » sans jamais les ouvrir. Pourtant, cette démarche n'est pas une privation : c'est une récupération.

Chaque micro que vous faites taire, chaque flux vidéo que vous gardez chez vous, chaque réseau que vous segmentez, chaque case à décocher dans un menu de confidentialité, c'est un fragment de votre vie intime que vous arrachez à la logique extractive. Et contrairement à ce que les industriels du numérique voudraient vous faire croire, rien de tout cela ne vous prive du confort moderne. Vous pouvez toujours allumer vos lumières à la voix, regarder votre caméra de surveillance depuis votre téléphone en déplacement, ou automatiser votre chauffage pour votre retour du bureau. Vous le faites simplement sur votre territoire, avec vos règles, à votre rythme.

La maison n'a jamais cessé d'être un refuge. L'Internet des Objets n'a rien changé à cette vocation première : c'est nous qui avons, par confort et par négligence, laissé des intrus s'installer dans les murs. Les rappeler à l'ordre, limiter leurs prérogatives, parfois les congédier purement et simplement, relève d'un acte de dignité numérique aussi simple que de verrouiller la porte d'entrée le soir.

© 2026 Oussama Ghorbel

Votre foyer vous appartient. La donnée qu'il produit, également. Il ne reste plus qu'à le faire savoir aux appareils eux-mêmes.

© 2026 Oussama Ghorbel

Chapitre 21 – Biométrie, santé et objets portables

Nous avons passé les chapitres précédents à fortifier les murailles de votre vie numérique : nous avons bloqué les traqueurs web, chiffré vos communications, et assaini vos systèmes d'exploitation. Mais il reste une frontière que l'industrie de la donnée convoite avec une voracité sans précédent, une frontière qui n'est ni faite de code ni de silicium, mais de chair, de sang et d'ADN. Votre corps.

L'ère du « quantified self » (le moi quantifié) nous a promis une meilleure compréhension de nous-mêmes grâce à la technologie. En réalité, elle a surtout offert aux courtiers en données et aux géants de la tech un accès en temps réel à notre intimité la plus absolue. Votre rythme cardiaque au réveil, la régularité de vos cycles biologiques, la cartographie 3D de votre visage et le code source génétique de vos ancêtres sont devenus des actifs monétisables. Dans ce chapitre, nous allons explorer comment protéger les données les plus intimes qui soient, car contrairement à un mot de passe compromis, vous ne pourrez jamais changer vos empreintes digitales, votre visage ou votre génome.

Le stockage des données biométriques (Secure Enclave vs Cloud)

La biométrie est aujourd'hui omniprésente. Nous déverrouillons nos téléphones avec notre visage, nous payons nos courses avec notre empreinte digitale, et nous accédons à nos comptes bancaires par reconnaissance de l'iris. Une question qui se pose souvent est la suivante : « Si mon téléphone est piraté, est-ce que le hacker peut voler mon empreinte digitale ? »

Pour répondre à cette question, il faut comprendre la différence fondamentale entre l'authentification biométrique locale et la vérification biométrique à distance.

Sur les appareils modernes (qu'il s'agisse d'iPhone avec la Secure Enclave ou de smartphones Android haut de gamme avec l'architecture TrustZone), vos données biométriques ne sont **jamais** stockées sous

© 2026 Oussama Ghorbel

forme d'images. Lorsque vous enregistrez votre empreinte, le capteur ne prend pas une simple photo ; il analyse les crêtes, les vallées et les pores de votre doigt pour en extraire une représentation mathématique, un algorithme complexe qui ne peut pas être inversé pour recréer votre empreinte originale. Cette donnée chiffrée est ensuite isolée dans une puce dédiée, physiquement séparée du processeur principal et du système d'exploitation. Même si le noyau de votre téléphone est compromis par un malware, l'attaquant ne peut pas extraire la donnée biométrique. Il peut seulement demander à la Secure Enclave : « Cette empreinte correspond-elle à celle du propriétaire ? », et la puce répondra par un simple « Oui » ou « Non ». C'est un modèle de sécurité brillant, conçu pour que votre biométrie ne quitte jamais l'appareil.

Le véritable danger ne réside pas dans le déverrouillage de votre téléphone, mais dans les applications et les services qui vous demandent de « vérifier votre identité » en envoyant une photo de votre visage ou une empreinte à leurs serveurs. C'est le cas de nombreuses applications bancaires, de plateformes d'échange de cryptomonnaies, ou de services de location de véhicules qui exigent une procédure KYC (Know Your Customer) avec un selfie vidéo.

Dès l'instant où votre visage quitte votre appareil pour être hébergé sur le cloud d'une entreprise, il devient une donnée comme une autre, sujette aux fuites, aux piratages et aux partages avec des tiers. L'histoire récente regorge d'exemples de bases de données biométriques mal sécurisées par des sous-traitants, exposant des millions de visages et d'empreintes sur le dark web.

La règle d'or de la biométrie : Utilisez la biométrie locale (via les standards FIDO2 et WebAuthn) pour remplacer vos mots de passe, car elle reste confinée dans votre matériel. En revanche, refusez autant que possible de fournir vos traits biométriques bruts (selfies, scans de rétine) à des serveurs distants. Si une application exige un scan facial pour prouver que vous êtes humain, privilégiez les solutions qui effectuent l'analyse localement et ne renvoient qu'un certificat de validation, sans jamais transmettre l'image. Votre visage est la clé maîtresse de votre identité physique ; ne la confiez pas à des serveurs cloud dont vous ne contrôlez ni la sécurité ni la juridiction.

© 2026 Oussama Ghorbel

Les montres connectées et le profilage de santé

Les montres connectées et les bracelets d'activité sont devenus des extensions de nos poignets. Apple Watch, Garmin, Fitbit (désormais propriété de Google), Samsung Galaxy Watch : ces appareils sont de véritables laboratoires médicaux miniaturisés. Ils utilisent la photopléthysmographie (PPG) – ces lumières vertes clignotantes au dos du boîtier – pour mesurer le volume de sang dans vos vaisseaux, déduisant ainsi votre fréquence cardiaque, votre variabilité de fréquence cardiaque (VFC), et votre saturation en oxygène (SpO2).

Ces données, prises isolément, semblent anodines. Mais agrégées sur plusieurs mois, elles dressent un portrait d'une précision terrifiante de votre état physiologique et psychologique. La VFC, par exemple, est un indicateur clé de l'état de votre système nerveux autonome. Une VFC basse et constante indique un stress chronique, de la fatigue, ou un état inflammatoire.

Pourquoi ces données intéressent-elles les géants de la tech ? Parce que l'état physiologique dicte le comportement. Des études en neuromarketing ont démontré qu'un individu en état de stress chronique ou de fatigue cognitive (détectable par une montre connectée) est beaucoup plus enclin aux achats impulsifs, à la consommation de malbouffe, ou à la recherche de gratifications immédiates. Si l'écosystème de votre montre est lié à votre profil publicitaire global (comme c'est le cas lorsque l'on intègre un tracker Fitbit dans l'écosystème Google), vos données de santé deviennent des variables d'ajustement pour les enchères publicitaires en temps réel. On ne vous ciblera pas avec une publicité pour un médicament contre l'anxiété en se basant sur votre historique de recherche, mais en se basant sur l'analyse algorithmique de votre rythme cardiaque nocturne et de la fragmentation de votre sommeil.

De plus, la télémétrie de ces appareils inclut le GPS. Les routes que vous empruntez pour votre jogging matinal, les parcs que vous fréquentez, et même les arrêts imprévus que vous faites (cliniques, lieux de culte, domiciles de proches) sont enregistrés avec une précision centimétrique. Strava, l'application sociale de sport par excellence, a par le passé révélé involontairement l'emplacement de bases militaires secrètes simplement en agrégeant les cartes de chaleur des parcours de

© 2026 Oussama Ghorbel

course à pied des soldats.

Comment reprendre le contrôle ?

1. **Désactivez l'amélioration des produits :** Dans les paramètres de votre montre et de l'application compagnon, décochez systématiquement les options « Partager les données pour améliorer le service » ou « Participer aux études de santé ».

2. **Limitez le GPS en arrière-plan :** Configurez votre application de sport pour n'autoriser l'accès à la localisation que « Lorsque l'app est active ». Ne laissez pas l'application tracer vos déplacements 24h/24 sous prétexte de compter vos pas ; l'accéléromètre suffit amplement pour cette tâche.

3. **Faussez les pistes de profilage :** Si vous utilisez une montre connectée principalement pour le sport, envisagez de la dissocier de votre compte principal (votre compte Google ou Apple principal utilisé pour les emails et les achats). Créez un compte secondaire dédié uniquement à la télémétrie sportive, coupant ainsi le pont entre votre profil de consommateur et votre profil physiologique.

Les applications de suivi menstruel et la protection des données

Peu de sujets illustrent aussi brutalement la collision entre la vie intime, la technologie et les conséquences sociétales que les applications de suivi menstruel. Des millions de femmes utilisent des applications comme Flo, Clue, ou les outils intégrés d'Apple Health pour suivre leurs cycles, prédire leurs périodes de fertilité, et monitorer leur santé hormonale.

Ces applications exigent des informations d'une sensibilité extrême : dates des rapports sexuels, symptômes physiques, humeurs, prises de médicaments, et résultats de tests de grossesse. Pendant des années, l'industrie a traité ces données avec une désinvolture effrayante. En 2021, des enquêtes ont révélé que certaines de ces applications partageaient des identifiants publicitaires et des données de cycle avec des réseaux sociaux comme Facebook, permettant de cibler des femmes enceintes avec des publicités pour des articles de puériculture avant même qu'elles n'aient annoncé leur grossesse à leurs proches.

© 2026 Oussama Ghorbel

Mais le danger a changé d'échelle avec l'évolution des législations sur l'avortement dans plusieurs régions du monde, notamment aux États-Unis avec la révocation de l'arrêt Roe v. Wade. Les données de suivi menstruel sont devenues des preuves potentielles dans des enquêtes criminelles. Les courtiers en données (data brokers) agrègent ces informations avec des données de géolocalisation (par exemple, la visite prolongée d'un utilisateur dans une clinique spécialisée) pour créer et vendre des profils de « probabilité de grossesse » ou de « recherche d'avortement ».

L'argument souvent avancé par les éditeurs de ces applications est l'anonymisation des données. C'est un mythe. En croisant la date de vos règles, votre code postal, votre âge et votre modèle de téléphone, la ré-identification d'un individu est triviale pour n'importe quel analyste de données. De plus, la sauvegarde cloud de ces applications contourne souvent le chiffrement de votre téléphone. Si les forces de l'ordre saisissent votre appareil ou émettent une réquisition auprès des serveurs de l'entreprise, votre historique intime est exposé.

La stratégie de protection :

Si vous devez utiliser une application de suivi, la confidentialité absolue n'existe que dans le chiffrement de bout en bout (E2EE) ou le stockage strictement local.

• Privilégiez des applications open-source et locales, comme *Periodical* (sur Android) ou *Drip*, qui ne possèdent pas de serveurs et ne requièrent aucune connexion internet pour fonctionner. Vos données restent sur la puce mémoire de votre téléphone.

• Si vous utilisez Apple Health, sachez que les données de santé sont chiffrées sur l'appareil et en transit. Cependant, si vous activez la « Sauvegarde iCloud standard », la clé de chiffrement de cette sauvegarde est détenue par Apple, qui peut techniquement y accéder sur réquisition légale. Pour une protection réelle, vous devez activer l'option « Données d'avancées » (Advanced Data Protection) d'iCloud, qui force le chiffrement de bout en bout, rendant vos données illisibles même pour Apple.

• Méfiez-vous des applications gratuites financées par la publicité : si le service est gratuit et que vous n'êtes pas le client, votre intimité

© 2026 Oussama Ghorbel

hormonale est le produit.

Les tests ADN grand public : un piège génétique

Cracher dans un tube, l'envoyer par la poste, et recevoir quelques semaines plus tard une carte colorée de vos origines ethniques et une liste de cousins éloignés. Des entreprises comme 23andMe, AncestryDNA ou MyHeritage ont démocratisé la génomique, transformant l'ADN en cadeau de Noël populaire. C'est, à mon sens, l'une des plus graves erreurs de confidentialité qu'un individu puisse commettre au XXIe siècle.

Votre ADN n'est pas une donnée personnelle. C'est une donnée **familiale et générationnelle**. En soumettant votre salive à une entreprise privée, vous ne prenez pas seulement une décision pour vous-même ; vous prenez une décision irrévocable pour vos parents, vos frères et sœurs, vos enfants, et vos descendants à naître. Vous ne pourrez jamais « changer » votre ADN en cas de fuite de données, contrairement à un numéro de carte bancaire.

Le modèle économique de ces entreprises repose rarement sur la simple vente du kit de test à 99 euros. La véritable mine d'or réside dans l'agrégation et la monétisation de bases de données génétiques massives. 23andMe, par exemple, a signé des accords de plusieurs centaines de millions de dollars avec des géants de l'industrie pharmaceutique, comme GlaxoSmithKline (GSK), pour leur permettre d'utiliser les données génétiques de leurs clients afin d'accélérer la recherche et le développement de nouveaux médicaments. Vous payez pour qu'ils vous disent d'où vous venez, et en échange, vous leur donnez les droits d'exploitation de votre code biologique.

De plus, la question de l'accès par les forces de l'ordre a radicalement changé la donne. L'affaire du « Golden State Killer » aux États-Unis a démontré que la police pouvait utiliser des bases de données génétiques ouvertes ou semi-ouvertes (comme GEDmatch) pour identifier des suspects par filiation, même si ces suspects n'avaient jamais craché dans un tube. Il suffit qu'un cousin au troisième degré ait fait le test pour que votre arbre généalogique devienne un outil d'investigation policière.

© 2026 Oussama Ghorbel

Enfin, que se passe-t-il si l'entreprise fait faillite ? Lors de la liquidation de ses actifs, votre base de données génétiques, considérée comme un actif incorporel de l'entreprise, peut être vendue aux enchères au plus offrant, échappant à tout contrôle de votre part.

La position de principe : Ne faites pas de test ADN grand public par simple curiosité généalogique. Le prix à payer en termes de souveraineté biologique est infiniment supérieur au divertissement de découvrir que vous avez 4 % d'ADN néandertalien. Si vous avez une raison médicale impérieuse de faire un séquençage génétique, passez par un laboratoire médical réglementé, soumis au secret médical et aux lois strictes sur la protection des données de santé (comme le RGPD en Europe ou l'HIPAA aux États-Unis), et exigez la destruction de l'échantillon physique et numérique une fois le diagnostic rendu.

Limiter le partage de données de santé avec les assureurs

L'industrie de l'assurance repose sur un principe fondamental : la mutualisation du risque. Tout le monde paie un peu pour que ceux qui tombent malades ou subissent un accident soient couverts. Cependant, l'avènement des objets connectés et des applications de santé a fait naître un rêve pour les actuaires : l'individualisation extrême du risque basée sur la surveillance continue.

De plus en plus d'assureurs santé et d'assureurs-vie proposent des programmes de « bien-être » (wellness programs). Le principe est alléchant et gamifié : « Connectez votre montre intelligente, partagez vos pas quotidiens, votre temps de sommeil et votre fréquence cardiaque avec nous, et en échange, nous vous offrons des réductions sur vos cotisations, des cartes cadeaux, ou des points de fidélité. »

Sur le papier, cela ressemble à un contrat gagnant-gagnant qui vous incite à prendre soin de votre santé. Dans les faits, il s'agit d'un cheval de Troie. En acceptant de partager votre télémétrie corporelle avec votre assureur, vous lui donnez les clés de votre évaluation actuarielle future.

Aujourd'hui, vous êtes récompensé pour vos 10 000 pas quotidiens. Mais que se passera-t-il le jour où votre variabilité de fréquence cardiaque (VFC) indiquera un stress chronique ? Que se passera-t-il si les algorithmes de l'assureur détectent, grâce à l'analyse de votre

© 2026 Oussama Ghorbel

sommeil et de votre rythme cardiaque au repos, les signes précurseurs d'une maladie cardiovasculaire ou d'une dépression sévère, bien avant que vous-même ou votre médecin ne vous en rendiez compte ? L'assureur aura alors une asymétrie d'information totale. Il saura que vous représentez un risque financier croissant à long terme.

Bien que les lois actuelles dans de nombreuses juridictions interdisent la discrimination directe basée sur les données des objets connectés pour augmenter les primes de manière punitive, les assureurs trouvent des moyens détournés : modification des franchises, exclusion de certaines garanties optionnelles, ou simplement refus de renouvellement de contrats spécifiques. De plus, en signant ces programmes, vous acceptez souvent des clauses de partage de données avec des « partenaires de recherche » ou des « filiales du groupe », qui ne sont pas tenues par les mêmes restrictions réglementaires que la branche assurance.

Le principe de précaution : Gardez vos données de santé et vos données financières dans des silos strictement étanches. Votre assureur n'a besoin de connaître que les événements passés (vos déclarations de sinistres, vos antécédents médicaux déclarés via un questionnaire encadré par la loi). Il n'a aucun droit légitime à exercer une surveillance panoptique et continue de votre hygiène de vie. Refusez les programmes de gamification de la santé proposés par les institutions financières. Le « discount » de quelques dizaines d'euros par an ne vaut pas la cession de votre intimité physiologique.

Le droit à l'opacité corporelle

Au-delà des paramètres techniques, des puces de sécurité et des clauses contractuelles, la protection de notre biométrie et de notre santé soulève une question philosophique majeure : avons-nous encore le droit à l'opacité ?

La sociologue Shoshana Zuboff, dans son ouvrage fondateur *L'Âge du capitalisme de surveillance*, explique comment l'industrie technologique est passée de l'extraction de nos données comportementales (ce que nous cliquons, ce que nous achetons) à l'extraction de notre expérience humaine brute, y compris nos émotions et nos réactions physiologiques. Le corps humain est devenu la dernière

© 2026 Oussama Ghorbel

terre vierge à coloniser pour en extraire de la donnée prédictive.

Le mouvement du « quantified self » nous a conditionnés à croire que tout ce qui n'est pas mesuré ne peut pas être amélioré. Nous nous sommes volontairement transformés en tableaux de bord, optimisant notre sommeil, notre nutrition et notre stress comme s'il s'agissait de moteurs de voiture. Mais cette obsession de la mesure a un coût caché : elle nous dépossède de notre rapport intuitif à nous-mêmes et nous place dans une dépendance permanente envers les algorithmes d'entreprises privées pour nous dire comment nous nous sentons.

Revendiquer le droit à l'opacité corporelle, c'est affirmer que notre rythme cardiaque, nos cycles hormonaux et notre code génétique ne sont pas des matières premières destinées à nourrir des réseaux de neurones artificiels. C'est rétablir la frontière sacrée entre l'individu et la machine. Votre corps vous appartient. Il n'a pas à être indexé, catégorisé, ni monétisé.

La frugalité numérique, appliquée à la santé, ne signifie pas refuser les progrès de la médecine connectée lorsqu'ils sont nécessaires pour sauver des vies (comme un pacemaker connecté ou un moniteur de glyc mie en continu pour un diabétique). Elle signifie refuser la surveillance de confort, le pistage de complaisance, et la marchandisation de notre biologie. C'est choisir, consciemment, de laisser certaines parties de nous-mêmes dans l'ombre, hors de portée des capteurs et des serveurs.

Exercice pratique : Auditer et verrouiller son dossier médical numérique

Votre téléphone centralise aujourd'hui des milliers de points de données sur votre santé, qu'ils proviennent de votre montre, de vos saisies manuelles, ou d'applications tierces. Il est temps de faire le ménage dans les autorisations de partage.

Sur iOS (Apple Health / Santé) :

1. Ouvrez l'application **Santé** (Health).
2. Touchez votre **profil** (votre photo ou initiale) en haut à droite.
3. Descendez jusqu'à la section **Confidentialité** et touchez **Apps et services** (ou *Apps* dans les anciennes versions).

© 2026 Oussama Ghorbel

4. Vous verrez ici la liste de toutes les applications qui ont demandé un accès à vos données de santé.

5. **L'audit :** Cliquez sur chaque application (par exemple, une application de régime, un réseau social de sport, ou un jeu connecté).

6. **L'action :** Désactivez systématiquement les catégories de données qui ne sont pas strictement nécessaires au fonctionnement de base de l'application. Une application de comptage de calories n'a pas besoin de lire votre « Variabilité de fréquence cardiaque » ou votre « Cycle menstruel ».

7. **La révocation :** Si vous n'utilisez plus une application, touchez **Supprimer l'accès** ou désinstallez l'application, puis revenez dans ce menu pour vous assurer qu'elle ne conserve aucun droit de lecture en arrière-plan.

8. *Optionnel mais recommandé :* Toujours dans le profil, allez dans **Appareils** et vérifiez que seules vos montres/bracelets actuels ont l'autorisation d'écrire des données. Supprimez les anciens appareils perdus ou vendus.

Sur Android (via Health Connect / Connexion Santé) :

Android a centralisé les échanges de données de santé via l'API *Health Connect* (Connexion Santé).

1. Ouvrez les **Paramètres** de votre téléphone.

2. Allez dans **Sécurité et confidentialité** > **Confidentialité** > **Gestionnaire d'autorisations** (le chemin peut varier légèrement selon la marque du téléphone, cherchez « Connexion Santé » ou « Health Connect » dans la barre de recherche des paramètres).

3. Ouvrez **Connexion Santé** (Health Connect).

4. Touchez **Autorisations des applications**.

5. **L'audit :** Vous verrez deux listes : les applications qui *lisent* vos données et celles qui *écrivent* des données.

6. **L'action :** Pour chaque application listée (comme Strava, MyFitnessPal, Samsung Health, etc.), vérifiez les données autorisées. Révoquez l'accès aux données sensibles (Sommeil, Cycle menstruel, Fréquence cardiaque au repos) pour les applications qui n'ont qu'une fonction sociale ou de gamification.

© 2026 Oussama Ghorbel

7. **La recherche médicale :** Dans les paramètres de Connexion Santé, vérifiez si vous avez accidentellement opté pour des « Programmes de recherche » ou des partages avec des instituts tiers, et désactivez-les.

En réalisant cet exercice, vous couperez les vivres à des dizaines d'agrégateurs de données qui profitaient silencieusement de votre transparence biologique. Vous reprendrez ainsi le contrôle du périmètre le plus intime de votre existence : votre propre corps.

© 2026 Oussama Ghorbel

Chapitre 22 – Chasser les courtiers en données

« Ce qui est gratuit, c'est souvent vous le produit. »

— Souvent attribué au monde du numérique

Vous avez suivi les chapitres précédents : navigateur blindé, extensions anti-pistage, recherche furtive, messageries chiffrées. Pourtant, tapez votre nom dans un moteur de recherche : votre ancienne adresse, l'entreprise où vous travailliez il y a six ans, parfois le nom de vos proches apparaissent en quelques secondes. Vous n'avez jamais donné ces informations à ces sites. Ce sont des **courtiers en données**, ces intermédiaires discrets qui collectent, agrègent, enrichissent et revendent votre vie sous forme de fichiers.

Ce chapitre est le plus « opérationnel » de la partie 4. Son objectif n'est pas de vous faire peur, mais de vous rendre actif : comprendre comment fonctionnent ces marchands d'identité, savoir qui ils sont, utiliser les outils qui automatisent le retrait, faire valoir vos droits, surveiller les réapparitions, et, lorsque c'est pertinent, sécuriser vos dossiers de crédit.

Avertissement honnête d'emblée : la chasse aux courtiers n'est jamais un combat qu'on gagne définitivement en un week-end. Vos données peuvent réapparaître, de nouveaux sites naissent, d'anciens revendent leurs bases. Il s'agit d'une **hygiène**, pas d'un nettoyage unique. Vous ne deviendrez pas invisible du jour au lendemain — mais vous pouvez réduire drastiquement votre surface d'exposition, et c'est déjà considérable.

Comment fonctionnent les annuaires inversés et les agrégateurs

Le principe de l'annuaire inversé

Un annuaire classique répond à la question : « Qui habite à telle adresse ? » ou « Quel est le numéro de cette entreprise ? ». Un **annuaire**

© 2026 Oussama Ghorbel

inversé retourne la logique : « Qui est joignable à ce numéro ? », « Qui a habité ici ? », « Quelle personne correspond à cet email ? ». C'est exactement ce qui rend ces services redoutables : alors que vous ne savez peut-être pas à qui appartient un numéro inconnu qui vous appelle, un courtier, lui, relie en une fraction de seconde numéro, nom, adresse, âge, proches et historique de déplacements.

La chaîne de valeur de la donnée

Pour comprendre comment vous y atterrir, il faut voir la chaîne complète. Elle fonctionne à peu près ainsi :

1. **La collecte amont.** Les données proviennent de sources extrêmement variées : annuaires traditionnels, registres publics (certaines informations d'état civil ou foncières sont, selon les pays, consultables), sites web que vous visitez (via cookies, empreintes techniques, scripts de suivi), applications mobiles qui revendent des localisations, réseaux sociaux, formulaires que vous remplissez sans lire les cases pré-cochées, concours, garanties de produits, mutuelles, et même des achats de bases de données entre entreprises.

2. **L'enrichissement.** Une adresse email seule vaut peu. Reliée à un nom, un prénom, un numéro de téléphone, une date de naissance, une adresse postale, un ensemble d'intérêts, un profil d'achat et une localisation approximative, elle devient une **fiche d'identité commerciale**. C'est le cœur du métier des agrégateurs : croiser des dizaines de sources faibles pour produire une fiche riche.

3. **La résolution d'identité.** Les algorithmes devinent que « O. Ghorbel » de Lyon, l'adresse `o...@gmail.com` et le numéro `06..` désignent la même personne, même sans que vous ayez jamais créé de compte chez ce courtier. On appelle cela du *match* ou de la résolution d'identité : relier des fragments épars pour reconstituer un individu.

4. **L'enrichissement comportemental.** Certains courtiers ajoutent des données dérivées : segments « voyageurs fréquents », « propriétaires », « parents d'enfants en bas âge », « sensibles aux offres de crédit ». Ces catégories sont ce que les annonceurs appellent des *audiences*.

© 2026 Oussama Ghorbel

5. **La revente.** La fiche est ensuite vendue : à des spécialistes du marketing, à des plateformes publicitaires, mais aussi à des entreprises de *background check* (vérification d'antécédents), à des détectives privés, à des avocats, parfois à des personnes privées curieuses — un ex-conjoint, un harceleur, un arnaqueur.

Pourquoi les annuaires inversés sont un risque concrètement

La donnée « nue » ne tue personne. C'est sa **combinaison** qui crée le danger. Savoir que vous vous appelez X ne suffit pas à vous nuire. Savoir que vous appelez X, que vous vivez à tel adresse, que vous sortez de tel hôpital, que vos enfants vont à telle école, que vous cherchez un emploi ou un crédit, c'est du matériel pour l'usurpation d'identité, l'hameçonnage ciblé, le démarchage abusif, le harcèlement, voire le cambriolage (les gens qui publient leurs absences en vacances alimentent, sans le savoir, des bases exploitées par des malfaiteurs).

Un autre risque est **l'erreur**. Les courtiers devinent, infèrent, rattachent parfois la mauvaise personne à une mauvaise adresse. Vous pouvez vous retrouver associé à des dettes, des antécédents ou des adresses qui ne sont pas les vôtres. La qualité des données n'est jamais garantie — mais l'erreur vous nuit quand même.

Qui sont les acheteurs ?

Pour bien mesurer l'enjeu, pensez à la diversité des acheteurs :

• Les **annonceurs** veulent vous cibler ;

• les **éditeurs de logiciels** de vérification d'identité veulent croiser vos données avec les leurs ;

• les **sécuritaires** du recrutement consultent parfois des bases de ce type (l'usage varie selon les pays et la législation) ;

• les **médias** vérifient des personnes (c'est utile, mais aussi intrusif) ;

• les **particuliers** veulent retrouver un ancien ami — ou suivre quelqu'un.

Le même outil sert un journaliste et un stalker. C'est la ambiguïté fondamentale du secteur : transparence utile pour certains, vecteur de danger pour d'autres.

© 2026 Oussama Ghorbel

Les principaux courtiers en données (Spokeo, Whitepages, Pipl)

Le marché mondial des courtiers est immense et fragmenté : des centaines d'acteurs, aux noms souvent interchangeables, certains rachetant les bases des autres. Il est impossible de tous les lister — et inutile : beaucoup de petits sites ne sont que des façades qui affichent les données de plus gros fournisseurs. En revanche, en connaître les principaux, et leurs logiques, vous permet d'agir sur la racine.

Voici les noms qui reviennent le plus souvent dans les recherches francophones et anglophones. Les décrire ici ne constitue évidemment aucune accusation de faute : il s'agit d'entreprises légales exerçant un métier encadré — ou insuffisamment encadré — par les lois locales.

Spokeo

Spokeo est l'un des annuaires inversés les plus visibles, particulièrement présent dans le monde anglophone. L'utilisateur tape un nom, un numéro ou une adresse ; le site affiche une fiche agrégée : adresses (actuelles et anciennes), numéros de téléphone associés, emails, noms de proches, parfois données professionnelles et localisation approximative. Le modèle économique est hybride : une partie de l'information est affichée gratuitement pour inciter à la curiosité, le détail complet étant payant.

Ce qui rend Spokeo représentatif du secteur, c'est son rôle de **vitrine**. Le site n'est pas seulement consommateur de données : il est aussi producteur d'une présence dans les résultats de recherche. Une fiche Spokeo bien référencée attire d'autres courtiers, qui copient, croisent, revendent. Supprimer votre fiche principale, c'est couper une branche — il faudra ensuite tailler les autres.

Whitepages

Whitepages fait remonter le fil de l'annuaire téléphonique américain à l'ère numérique. Historiquement centré sur l'annuaire, il est devenu un agrégateur d'adresses et de numéros avec des services de *reverse lookup* (recherche inversée) et de vérification de personnes. Là encore, la mécanique est la même : collecte, enrichissement, affichage partiel

© 2026 Oussama Ghorbel

gratuit, détail premium.

Whitepages illustre bien le problème de la **liste de diffusion** : votre numéro apparaît non seulement sur votre propre fiche, mais parfois dans les fiches des membres de votre foyer, ce qui multiplie les points d'entrée. Retirer un numéro peut nécessiter de traiter plusieurs fichiers.

Pipl

Pipl se positionne différemment : il s'adresse moins au grand public curieux qu'aux professionnels — entreprises de vérification, institutions, services de renseignement privés, avocats. Pipl vend de l'*intelligence* sur les personnes : résolution d'identité à grande échelle, croisement de réseaux sociaux, de forums, de sites professionnels, de bases de données tierces. C'est le côté « B2B » du métier, souvent moins visible que les annuaires grand public, mais tout aussi documenté.

L'intérêt de connaître Pipl, c'est de comprendre qu'**une présence retirée d'un annuaire public peut subsister dans une base professionnelle**. Si votre nom circule dans un réseau social oublié, sur un ancien forum, dans un CV déposé sur un site que vous ne consultez plus, ces fragments peuvent être ingérés par ce type de services.

Les autres acteurs à connaître

Sans prétendre à l'exhaustivité, d'autres noms reviennent fréquemment selon les pays : **BeenVerified**, **PeopleFinders**, **Intelius**, **FastPeopleSearch**, **TruePeopleSearch**, **US Search**, **Radaris**, **MyLife** (ce dernier a fait l'objet de controverses notables sur la qualité et la sensibilité de ses données), ou encore des acteurs européens et français qui agrègent des sources publiques et commerciales. En France et en Europe, certains sites d'annuaires téléphoniques et « anti-arnaques » affichent aussi des données personnelles étendues.

Deux règles pratiques pour naviguer dans cette jungle :

• **Cherchez d'abord les « consolidateurs ».** Plutôt que de traiter cinquante petits sites un par un, repérez ceux qui affichent le plus d'informations sur vous et ceux qui reviennent le plus souvent dans les résultats de recherche : c'est là que votre temps est le mieux investi.

© 2026 Oussama Ghorbel

• **Méfiez-vous des clones.** Un site qui vous propose de « vérifier qui vous appelle » est souvent le même réseau qu'un autre site. Lire les mentions légales (« conditions d'utilisation », « politique de confidentialité ») révèle parfois des sociétés mères communes.

Comment naît votre fiche

Pour bien visualiser : vous avez rempli un formulaire sur un site de petits annonces il y a cinq ans. Ce site a revendu sa base. Un courtier a croisé cette entrée avec des données d'inscription à un événement, puis avec un fichier d'adresses public enrichi. Un algorithme a fusionné les profils. Trois ans plus tard, un site que vous n'avez jamais visité affiche votre ancienne adresse et le prénom de votre conjoint. Personne n'a « hacké » quoi que ce soit : la donnée a simplement circulé, légalement ou dans une zone grise, de main en main.

Comprendre cette mécanique est essentiel, parce que cela change la méthode de défense : on ne peut pas « empêcher » la collecte à 100 %, mais on peut **désinscrire, contester, purger et surveiller**.

Les services automatisés d'opt-out (DeleteMe, Incogni)

Le problème : l'infinitude des retraits

Voici le calcul qui décourage la plupart des gens : si les principaux courtiers sont quelques dizaines, les sites d'annuaires et de données secondaires se comptent en centaines, voire en milliers. Chacun a sa procédure : un formulaire à trouver (souvent caché), un email à envoyer, parfois une copie de pièce d'identité à fournir (ce qui, ironiquement, implique de *transmettre* des données personnelles), un délai de traitement variable, puis une vérification que la page a bien disparu.

Faire cela à la main pour cinq sites : réalisable. Pour cent : c'est un travail à temps plein, qui doit être refait régulièrement.

C'est exactement le vide que remplissent les **services d'opt-out automatisés**.

Comment fonctionnent ces services

© 2026 Oussama Ghorbel

Des sociétés comme **DeleteMe** (anciennement un service de Abine) ou **Incogni** (rattaché à l'écosystème d'ExpressVPN) proposent, contre un abonnement, de gérer pour vous les procédures de retrait. Le principe général est le suivant :

1. Vous créez un compte et fournissez les informations nécessaires à l'identification : nom, adresses précédentes, emails, numéros de téléphone, âge. Autrement dit, vous donnez volontairement à un tiers de confiance ce que vous essayez de faire disparaître des autres. Le choix de la confiance est donc central.
2. Le service identifie vos fiches sur une liste de courtiers couverts (souvent entre 40 et plus de 100, selon les offres).
3. Il envoie les demandes de suppression ou de désinscription, à votre place ou en votre nom, selon les configurations légales locales.
4. Il vérifie périodiquement si vos données réapparaissent et relance les demandes.

Ce que ces services font — et ne font pas

Soyons lucides sur ce que l'abonnement achète et ce qu'il n'achète pas.

Ce qu'il apporte :

• Un **gain de temps considérable**, souvent le principal argument ;

• une **couverture large** de courtiers que vous ne connaîtriez pas autrement ;

• une **surveillance continue**, avec rapports périodiques (certains services envoient un récapitulatif : « 27 fiches traitées, 3 en attente, 2 refus ») ;

• une **méthode** : pas besoin de comprendre les subtilités de chaque formulaire.

Ce qu'il ne promet pas — et que vous ne devez pas attendre :

• La **disparition totale et définitive** de vos données sur Internet. Aucun service honnête ne peut garantir cela, et la promesse inverse doit vous mettre en alerte.

© 2026 Oussama Ghorbel

• La couverture de **tous** les courtiers. Chaque service publie une liste de sites couverts : comparez-la à vos propres recherches.

• La suppression des données dans les bases **privées** (celles d'entreprises chez qui vous êtes client), des **registres publics officiels**, ou des publications que vous avez vous-même faites sur les réseaux sociaux.

Choisir : des critères concrets

Avant de payer un abonnement, posez-vous ces questions :

• **Quels sites couvre-t-il, exactement ?** Demandez ou consultez la liste. Un service couvrant 150 courtiers n'est pas comparable à un autre qui en couvre 40.

• **À quelle fréquence relance-t-il les demandes ?** Un opt-out n'est pas une garantie : certaines bases se remplissent à nouveau. La périodicité (trimestrielle, semestrielle, annuelle) compte.

• **Que fait-il de mes données ?** Lisez la politique de confidentialité du service lui-même. Un service de protection de la vie privée qui revendrait vos données serait un comble — mais vérifier coûte cinq minutes.

• **Comment résilie-t-on ?** Méfiez-vous des abonnements volontairement compliqués à annuler.

• **Quelle est ma situation géographique ?** Les procédures et les droits diffèrent entre Europe (RGPD), États-Unis (lois par État, notamment la Californie et le CCPA/CPRA), et reste du monde. Un service pensé pour les États-Unis peut être moins efficace pour un résident européen, et inversement.

Automatiser sans déléguer aveuglément

Mon conseil : utiliser un service automatisé comme **socle**, pas comme absolution. Concrètement :

• commencez par une **recherche manuelle de votre propre nom** (vous verrez dans la section suivante comment) ;

• activez le service pour traiter le gros du travail ;

© 2026 Oussama Ghorbel

- gardez pour vous les sites les plus sensibles — ceux qui affichent votre adresse exacte, celle de vos proches, ou vos numéros — et suivez-les à la main ;
- relisez les rapports du service au lieu de les archiver sans les ouvrir.

Pensez-y comme au jardinage : la tondeuse automatisée gère la pelouse, mais c'est vous qui surveillez les ronces au bord du mur.

Un point financier, pour être complet : ces services sont payants (généralement une dizaine à quelques dizaines d'euros ou de dollars par mois, parfois moins pour un engagement annuel). Ce n'est pas un placement, ce n'est pas un produit financier : c'est un abonnement de services, dont l'utilité dépend de votre exposition. Rien ici ne constitue un conseil financier personnalisé ; à vous d'arbitrer selon votre budget et votre situation. Si le budget est serré, la procédure manuelle gratuite reste parfaitement viable — elle demande surtout de la rigueur.

Faire valoir son droit à l'effacement manuellement

Vos armes juridiques

Dans l'Union européenne, le **RGPD** (Règlement général sur la protection des données) vous dote d'outils puissants. L'article 17 consacre le **droit à l'effacement** (« droit à l'oubli ») : sous certaines conditions, vous pouvez demander la suppression de vos données personnelles. Les motifs incluent notamment le fait que les données ne sont plus nécessaires au regard de l'objectif initial, le retrait du consentement, ou le traitement illicite.

En pratique, ce droit s'applique aux **responsables de traitement**. Un courtier en données est, dans la plupart des configurations, un responsable de traitement de vos données : vous pouvez donc lui adresser une demande. Il doit vous répondre dans un délai d'un mois (prolongeable de deux mois pour les demandes complexes, avec information).

Aux États-Unis, plusieurs États ont adopté des lois similaires — le **CCPA** révisé par le **CPRA** en Californie, le **Virginia CDPA**, et d'autres

© 2026 Oussama Ghorbel

— offrant notamment le droit de savoir quelles données sont collectées et de demander leur suppression. Les modalités varient : certains États exigent un « opt-out » de la vente de données, d'autres un vrai droit d'effacement. Le site de la California Privacy Protection Agency, ou l'équivalent de votre État, répertorie les procédures.

Ailleurs (Canada — LPPD et lois provinciales, Royaume-Uni — UK GDPR, Suisse, etc.), des droits analogues existent. Renseignez-vous sur le cadre de votre pays : c'est la base de toute démarche.

La méthode manuelle, pas à pas

Quand vous voulez traiter un site précis — un annuaire, un agrégateur — voici la méthode en sept étapes :

1. Localisez votre fiche.

Tapez dans le moteur de recherche : `site:exemple-annuaire.fr "votre nom"` ou utilisez directement la fonction de recherche du site. Notez l'URL exacte de votre fiche. Sans URL, pas de demande ciblée.

2. Trouvez la page de désinscription.

Cherchez dans le pied de page : « Privacy », « Do Not Sell My Personal Information », « Opt-Out », « Remove my listing », « Supprimer mes données », « Vos droits ». En Europe, cherchez aussi « Demande d'exercice des droits ». Ces liens sont souvent discrets — c'est volontaire, mais ce n'est pas illégal.

3. Identifiez le responsable.

Lisez la politique de confidentialité : quelles est la société responsable ? Où est-elle domiciliée ? Ses coordonnées ? Gardez ces informations : elles sont utiles en cas d'escalade.

4. Remplissez le formulaire avec précision.

Indiquez les URLs exactes, vos variantes de nom, vos adresses et numéros susceptibles d'apparaître. Plus votre demande est précise, moins le site pourra répondre « introuvable ».

5. Conservez la preuve.

Capture d'écran du formulaire envoyé, email de confirmation, numéro de demande, date. Dans un dossier numérique nommé

© 2026 Oussama Ghorbel

`effacement-donnees`, archivez tout. Si le site ne répond pas dans les délais, vous aurez les éléments pour une réclamation.

6. Suivez le délai.

Un mois en Europe, des délais variables ailleurs. Si le silence persiste : relancez par écrit, en citant l'article applicable.

7. Vérifiez la suppression effective.

Attendez, puis relancez la recherche. Une page parfois reste en cache chez Google ou Bing : utilisez la **demande de suppression d'URL** des moteurs (Google propose un outil public pour cela) pour effacer le résultat de recherche, même si la page source a disparu.

Quand une demande est refusée

Un courtier peut refuser dans certains cas : données manifestement inexactes (il peut préférer les corriger plutôt que les supprimer), demande manifestement abusive ou excessive, obligations légales de conservation (comptabilité, litiges). Un refus doit être motivé.

Si vous estimez le refus abusif :

- en Europe, saisissez la **CNIL** (ou l'autorité de votre pays) : la plainte est gratuite ;
- aux États-Unis, consultez le site de votre autorité de protection des données étatique, ou la FTC (Federal Trade Commission) pour les pratiques trompeuses ;
- conservez tout : dates, copies, échanges.

La CNIL le rappelle régulièrement : le droit à l'effacement n'est pas absolu, mais il est réel. Un refus purement commercial — « nous avons le droit de publier car la source est publique » — n'est pas toujours une fin de non-recevoir définitive : la répétition de données personnelles agrégées peut excéder ce que la personne raisonnable accepterait, notamment quand elle révèle des informations sur la vie privée familiale ou professionnelle.

Les formulations qui fonctionnent

Quelques conseils de rédaction, parce que le ton compte :

© 2026 Oussama Ghorbel

• soyez **factuel** : « Je vous demande de supprimer mes données personnelles apparaissant sur [URL], conformément à l'article 17 du RGPD » ;

• listez **vos identifiants** concernés (nom, adresses, emails, numéros) pour faciliter le travail — oui, c'est paradoxal, mais une demande vague est plus facile à « perdre » ;

• fixez un **délai** : « dans le délai d'un mois prévu par le RGPD » ;

• restez **calme** : l'agressivité est souvent utilisée comme prétexte pour classer un dossier.

Surveiller la réapparition de ses données

Pourquoi vos données reviennent

Supprimer une fiche, c'est couvrir un arbre. La forêt, elle, continue de croître. Vos données réapparaissent pour des raisons simples :

• vous restez **référencé** à d'autres sources (vos anciens employeurs, annuaires professionnels, forums) qui alimentent à nouveau les courtiers ;

• un **site partenaire** republie une base non nettoyée ;

• vous vous **inscrivez** quelque part sans y penser (concours, wifi gratuit, application, nouveau service) ;

• un **fournisseur** existant (banque, opérateur, assurance) transmet ou rend publiques des données dans le cadre d'un accord ;

• le courtier a **archivé** votre fiche et la restaure lorsqu'une source amont la resoumet.

Bref : la suppression est un point dans le temps, pas une garantie éternelle.

La surveillance active

Voici une routine simple, à programmer tous les deux ou trois mois — ou tous les mois si votre exposition est forte (personne publique, professionnel libénal exposé, victime de harcèlement) :

1. La recherche de vous-même (vanity search, version défensive).

© 2026 Oussama Ghorbel

Ouvrez un navigateur en **navigation privée** (pour éviter les résultats personnalisés), tapez :

- `votre nom complet`
- `"votre nom" ville`
- `"votre nom" adresse` (l'adresse exacte)
- `"votre numéro de téléphone"`
- `"votre email"`

Utilisez plusieurs moteurs : Google, Bing, et si possible un moteur respectueux de la vie privée (voir le chapitre 9). Les résultats diffèrent d'un moteur à l'autre.

2. Les alertes.

Google Alerts (`google.com/alerts`) permet de recevoir un email quand votre nom apparaît dans un nouveau contenu indexé. Ce n'est pas exhaustif — les fiches de courtiers indexées parfois lentement — mais c'est un excellent premier capteur, gratuit.

3. Les outils de suivi.

Certains services (y compris ceux évoqués plus haut) proposent des tableaux de bord : fiches trouvées, fiches traitées, fiches réapparues. Consultez-les : un rapport lu vaut mieux qu'un rapport payé et ignoré.

4. Le contrôle de vos variantes.

Votre identité n'est pas seulement « Prénom Nom ». Préparez une liste : anciens noms (jeune fille, pseudonymes), anciens numéros, anciens emails, adresses anciennes. Les courtiers adorent les historiques — c'est vous qui devez fouiller les leurs.

Que faire quand une fiche réapparaît

- **Si c'est un site déjà traité** : réactivez la demande, joignez la preuve de votre précédente demande. L'historique accélère souvent le traitement.
- **Si c'est un nouveau site** : appliquez la procédure manuelle en sept étapes décrite plus haut.

© 2026 Oussama Ghorbel

• **Si la suppression est impossible** : envisagez l'**obsolescence** plutôt que l'effacement : publier du contenu neutre à votre sujet peut « noyer » une information ancienne dans les résultats. C'est une stratégie imparfaite, discutable éthiquement (vous ne contrôlez pas les résultats à 100 %), mais parfois utile — sans jamais céder à la tentation de dénigrer qui que ce soit pour brouiller les pistes : la désinformation sur soi-même se retourne toujours.

• **Si la fiche est fausse ou nuisible** : demandez d'abord la correction (droit de rectification, article 16 du RGPD), puis l'effacement. En cas de refus, escaladez vers l'autorité de protection des données.

Surveiller ses proches, avec leur accord

Vos données sont souvent reliées à celles de vos proches : conjoint, enfants, parents. Une fiche qui affiche votre adresse affiche peut-être celle de votre mère. Le sujet est délicat : **toujours demander leur accord** avant de déposer une demande en leur nom, et leur expliquer la démarche. On ne gère pas la vie privée des autres par surprise — même avec les meilleures intentions.

Le gel de ses dossiers de crédit (si applicable)

De quoi parle-t-on ?

Dans certains pays, notamment les **États-Unis**, votre « crédit file » (dossier de crédit) chez les grandes agences (Equifax, Experian, TransUnion notamment) concentre des informations financières très sensibles : prêts, cartes, soldes, paiements. Un malfaiteur qui usurpe votre identité peut essayer d'ouvrir un crédit à votre nom. Le **credit freeze** (gel de dossier) empêche une nouvelle demande de crédit d'être traitée tant que le gel est actif : pour ouvrir un compte, le prêteur doit vérifier votre identité auprès de vous via un code.

Le gel est généralement **gratuit** aux États-Unis, contrairement au *fraud alert* (alerte à la fraude), qui a un fonctionnement différent. Les démarches se font auprès de chaque agence séparément, en ligne, par téléphone ou par courrier, et vous recevez des codes de dégel à conserver précieusement.

© 2026 Oussama Ghorbel

Et en France et en Europe ?

Il n'existe pas d'équivalent strict du gel américain. En revanche, plusieurs mécanismes existent :

- les **fichiers des incidents de remboursement** tenus par la Banque de France (FICP notamment) : vous pouvez consulter si vous y figurez, ce qui est une étape utile en cas de doute, mais il ne s'agit pas d'un « gel » activable à volonté ;
- la **consultation de votre situation** auprès des organismes de crédit : en France, vous avez notamment le droit de consultation des informations vous concernant détenues par les organismes mentionnant un refus de crédit (dans certaines conditions légales) ;
- les **alertes de fraude** proposées par certaines banques et assureurs (souscription d'une option, parfois payante) ;
- la **vérification régulière** de vos relevés, contrats d'énergie, abonnements et déclarations fiscales — la fraude se détecte souvent tôt, quand les prélèvements sont encore rares.

Ce point relève du **domaine financier** : les informations ci-dessus sont données à titre général et informatif, et ne constituent en aucun cas un conseil financier personnalisé. Les procédures, tarifs, agences et droits évoluent selon les pays et le temps. Vérifiez toujours les sources officielles : sites des agences de crédit concernées, de la Banque de France, de la CNIL, des autorités de protection des données de votre État ou pays.

Les réflexes qui limitent les dégâts

Quel que soit votre pays, des réflexes simples réduisent le risque :

- **Ne conservez pas de documents d'identité en clair** dans vos emails ou sur votre ordinateur : numéros de pièce d'identité et relevés d'identité bancaire sont des matériaux d'usurpation.
- **Méfiez-vous du « vishing »** : un appel vous demandant de confirmer un code, un virement, une identité — même en prétendant appartenir à votre banque — est suspect. Raccrochez, rappelez le numéro officiel.

© 2026 Oussama Ghorbel

• **Diffusez le moins possible** vos informations de vérification : date de naissance, nom de jeune fille de votre mère, adresse de naissance : ces questions de sécurité bancaire sont souvent des questions dont la réponse se trouve... dans un annuaire inversé. C'est précisément pour cela que ce chapitre existe.

• **Signalez** en cas d'usurpation : plainte, signalement à la plateforme de votre pays (ThePhar en France, IC3 ou IdentityTheft.gov aux États-Unis), information de vos établissements financiers.

Exercices : ouvrez le feu sur vos annuaires

À la fin de chaque chapitre, je vous propose des exercices courts et concrets. Faites-les maintenant : la théorie sur les courtiers ne sert à rien si vous ne traitez pas votre propre cas.

Exercice 1 — La reconnaissance (30 à 45 minutes)

1. Ouvrez un navigateur en **navigation privée**.

2. Choisissez **trois sites d'annuaire ou d'annuaire inversé** auxquels vous êtes vraisemblablement exposé. Idéalement : un grand annuaire général (du type Pages Blanches / Whitepages selon votre pays), un annuaire inversé type Spokeo ou équivalent, et un site d'agrégateur qui apparaît pour votre nom dans les résultats de recherche.

3. Recherchez sur chacun :

• votre **nom et prénom** ;

• votre **adresse email** principale ;

• votre **numéro de téléphone**.

4. Pour chaque résultat trouvé, notez dans un tableau :

• le **nom du site** ;

• l'**URL exacte** de la fiche ;

• les **données visibles** (adresse, proches, emails, etc.) ;

• la **date** de votre constat ;

• le **lien vers la procédure de retrait** si vous l'avez trouvé.

© 2026 Oussama Ghorbel

Vous venez de réaliser votre **premier audit de courtier**. Ce tableau est votre plan de bataille.

Exercice 2 — Lancer trois procédures d'opt-out (45 à 60 minutes)

Pour **chacun** des trois sites identifiés :

1. Trouvez la page d'opt-out ou de suppression (« Privacy », « Do Not Sell My Personal Information », « Remove my listing », « Opt-Out », « Supprimer mes données »).

2. Remplissez la demande en fournissant l'URL exacte de votre fiche et les informations demandées.

3. Si le site l'exige par email, envoyez la demande depuis une adresse que vous contrôlez, avec l'objet explicite : *Demande de suppression de données personnelles — [Votre nom]*.

4. **Archivez la preuve** : capture d'écran du formulaire, email de confirmation, date, numéro de dossier s'il y en a un.

5. Notez dans votre tableau la date d'envoi et le délai annoncé.

Critère de réussite : trois demandes envoyées, trois preuves archivées. Pas besoin de tout régler aujourd'hui.

Exercice 3 — Mettre un rappel de vérification (5 minutes)

Dans votre calendrier, programmez un rappel **dans 30 jours** : *« Vérifier la suppression de mes fiches d'annuaires »*. Le même jour, ajoutez un deuxième rappel **tous les 3 mois** : *« Audit rapide de mes données en ligne »* (recherche de votre nom, de votre email, de votre numéro en navigation privée).

La surveillance, dans ce domaine, n'est pas de la paranoïa : c'est de la méthode. Sans rappel, les opt-out oubliés sont des opt-out perdus.

Exercice bonus — Un seul mot de passe, un seul message

Si, en remplissant les formulaires, vous découvrez que vous utilisez le même mot de passe sur l'un de ces sites : **changez-le immédiatement**, et vérifiez s'il figure dans une fuite de données connue (voir le chapitre 17 sur les coffres-forts et l'authentification). Un compte d'annuaire compromis est un compte qui peut afficher — ou revendre — ce que vous vouliez effacer.

© 2026 Oussama Ghorbel

Le mot de la fin

Chasser les courtiers en données, c'est un travail de fond : méthodique, parfois répétitif, souvent frustrant — car chaque site a ses règles et ses lenteurs. Mais chaque fiche supprimée est une porte fermée. Chaque adresse retirée est un profil un peu moins complet. Chaque appel démarchage qui n'arrive plus est une preuve tangible que l'action fonctionne.

Vous ne contrôlerez pas tout. Vous pouvez en revanche contrôler l'essentiel : être moins trouvable, moins associable, moins vendable. Dans la forteresse que nous bâtissons depuis le début de ce livre, la chasse aux courtiers est la patrouille qui fait les rondes de nuit. Elle ne remplace ni les murs (chapitres précédents), ni l'entretien (prochain chapitre) — mais sans elle, les murs ne suffisent pas.

Prenez ce tableau d'audit, trois sites, trois demandes, un rappel au calendrier. C'est comme ça que commence la discrétion : par une case cochée.

© 2026 Oussama Ghorbel

Chapitre 23 – Gérer les fuites et le vol d'identité

Gérer les fuites et le vol d'identité

Il existe un moment particulièrement inconfortable dans le parcours de toute personne attentive à sa vie numérique. C'est celui où l'on découvre que l'une de ses adresses email, associée à un mot de passe que l'on croyait unique, circule déjà quelque part sur Internet. Le sentiment initial est presque toujours le même : un mélange de stupéfaction et d'impuissance. « Mais j'ai pourtant été prudent », se dit-on. Et souvent, c'est vrai. La prudence individuelle ne suffit pas face à des systèmes qui collectent, stockent et protègent — parfois mal — les données de millions de personnes à la fois.

Ce chapitre ne cherche pas à vous effrayer. Il cherche à vous armer. Parce que si une fuite de données est un événement qui arrive *à* vous, la manière dont vous la traitez, dont vous limiterez les dégâts et dont vous vous en remettrez, elle, reste entre vos mains. Mon objectif ici est de vous aider à construire deux choses complémentaires : un système d'alerte précoce, et une procédure de réaction rapide. Car c'est précisément le délai entre la compromission et votre prise de conscience qui détermine l'ampleur des dégâts.

Comprendre l'économie souterraine des données volées

Avant de parler d'outils, il faut comprendre le marché. Tant que l'on ignore la mécanique, on ne peut pas évaluer correctement le niveau d'urgence d'une fuite. On croit souvent que voler des données est une activité réservée à des hackers solitaires tapotant sur un clavier dans une pièce sombre. La réalité est bien plus industrielle.

L'économie souterraine des données fonctionne comme n'importe quel marché : il y a des producteurs, des intermédiaires, des acheteurs et des consommateurs. Les producteurs sont ceux qui obtiennent les données — par l'exploitation de failles dans des serveurs d'entreprises, par l'achat de listes auprès de fournisseurs de services compromis, par

© 2026 Oussama Ghorbel

l'infection de machines par des logiciels malveillants, ou simplement par le travail d'ingénierie sociale. Les intermédiaires revendent ces données, souvent sous forme de « dumps » : d'énormes fichiers contenant des millions d'entrées email/mot de passe. Les acheteurs, eux, vont des escrocs opportunistes aux organisations criminelles structurées, en passant par des acteurs géopolitiques.

Que trouve-t-on dans ces dumps ? En général, trois niveaux d'information, du moins sensible au plus sensible.

Le premier niveau, le plus courant, comprend les identifiants : adresses email, pseudonymes, mots de passe en clair ou hachés. Un mot de passe haché peut être cassé relativement facilement s'il est mal protégé — c'est pourquoi le type de hachage importe, et pourquoi certains services mettent plus de temps à notifier une faille que d'autres.

Le deuxième niveau contient les données personnelles : nom, prénom, date de naissance, numéro de téléphone, adresse postale, questions de sécurité. Ces informations ne permettent pas de se connecter à un compte, mais elles alimentent directement l'usurpation d'identité et le ciblage du phishing.

Le troisième niveau, le plus préoccupant, inclut les données financières et de localisation : numéros de cartes bancaires, historiques d'achats, relevés de déplacements, données de santé. C'est là que l'on quitte le terrain du désagrément pour entrer dans celui du préjudice réel.

Un point souvent sous-estimé : ce qui est peu valuable pris isolément devient puissant en masse. Un seul numéro de téléphone ne vaut presque rien. Dix millions de numéros associés à des noms et à des adresses physiques, en revanche, constituent un actif commercial que des organisations entières sont prêtes à acheter. Les données ne sont pas volées pour leur valeur intrinsèque, mais pour ce qu'elles permettent de prédire, de cibler et de manipuler.

Il y a aussi une dimension temporelle. Une donnée n'a pas la même valeur selon le moment. Votre préférence politique, votre état de santé ou votre situation financière captée au bon moment peuvent orienter une campagne de désinformation, une offre de crédit abusive ou une tentative d'escroquerie. C'est pourquoi la surveillance commerciale et le vol de données sont deux faces d'un même phénomène : dans les deux

© 2026 Oussama Ghorbel

cas, quelqu'un décide que votre comportement mérite d'être enregistré, conservé, et éventuellement revendu.

Pour aller plus loin sur les mécaniques de profilage qui nourrissent cette économie, je vous renvoie au chapitre 2, où nous avions disséqué la fabrication du profil fantôme. Ce que nous avions vu là comme un processus de construction, nous le voyons ici comme un processus de fuite : mêmes données, mêmes conséquences, simplement déclenchées autrement.

Enfin, il faut dissiper une illusion rassurante : « je ne suis pas assez important pour être ciblé ». En réalité, l'automatisation a rendu la sélection indifférente. Les robots ne choisissent pas leurs victimes en fonction de leur notoriété. Ils traitent des listes entières. Vous n'êtes pas ciblé personnellement ; vous êtes ciblé *statistiquement*. Et c'est précisément cette banalité de la cible qui rend la menace universelle.

Configurer des alertes de fuite

La première ligne de défense n'est pas de réagir, c'est de savoir. Or, dans le monde des fuites, savoir vite, c'est déjà agir. Heureusement, des services existent précisément pour vous prévenir lorsque vos adresses apparaissent dans une base de données compromise.

Have I Been Pwned est le service de référence. Créé par le chercheur en sécurité Troy Hunt, il agrège des dizaines de millions de comptes compromissés et vous permet de vérifier si votre adresse email figure dans l'une de ces bases. Le principe est simple : vous saisissez votre adresse, le service vous indique dans quelles fuites elle apparaît, et quelles données ont été exposées — mots de passe, téléphones, adresses postales, etc.

Ce qui rend ce service particulièrement utile, c'est sa fonction d'alerte. Vous pouvez vous abonner à des notifications pour une ou plusieurs adresses. Dès qu'une nouvelle fuite contenant l'une de ces adresses est ajoutée à la base, vous recevez un email. L'abonnement est gratuit pour les alertes email.

Un point de vigilance important : n'utilisez jamais un service de vérification de fuites qui vous demande de saisir votre mot de passe. Un tel service est, par définition, suspect. On vérifie une adresse email, pas

© 2026 Oussama Ghorbel

un secret d'authentification. Si un site vous demande votre mot de passe pour « vérifier s'il a fuité », c'est une tentative de phishing déguisée en service de sécurité.

Firefox Monitor, aujourd'hui évolutif vers Firefox Monitor intégré aux fonctionnalités de vie privée de Mozilla, repose sur la base de données de Have I Been Pwned et s'intègre au navigateur. Son intérêt principal est la simplicité : l'alerte arrive sans que vous ayez à penser à vérifier manuellement. Pour les personnes qui utilisent Firefox comme navigateur principal, c'est un point d'entrée naturel et peu chronophage.

Au-delà de ces deux services, certains gestionnaires de mots de passe intègrent également des surveillances de fuites. Si vous utilisez déjà un coffre-fort numérique — et je vous encourage à le faire, comme détaillé au chapitre 17 — vérifiez s'il propose une fonction d'alerte en cas d'exposition d'un de vos mots de passe. L'avantage est que l'alerte arrive directement à côté du mot de passe concerné, ce qui réduit le temps entre la découverte et l'action.

Configurer une alerte SMS. Pour les fuites les plus sensibles — ou simplement pour ceux qui n'ouvrent pas leurs emails plusieurs fois par jour — il est possible d'aller plus loin. Certains services proposent des notifications par SMS. Firefox et d'autres outils ont, selon les époques et les régions, proposé des alertes mobiles. Si votre service préféré ne propose pas le SMS natif, une solution intermédiaire consiste à créer une règle de filtrage dans votre messagerie : dès qu'un email contenant les mots-clés d'alerte d'un service de fuite arrive, il est immédiatement transféré vers un raccourci sur votre écran d'accueil, ou déclenche une notification prioritaire. L'objectif n'est pas la sophistication, c'est la réduction de la latence.

Les alias comptent aussi. Si vous avez mis en place la discipline des alias d'email, comme je le suggère au chapitre 10, chaque alias doit être surveillé séparément. L'avantage des alias est double : d'une part, ils vous indiquent immédiatement *quel service* a fuité (car chaque alias est lié à un usage précis) ; d'autre part, ils limitent la portée du dégât, puisqu'un alias compromis n'expose pas l'ensemble de votre identité numérique.

© 2026 Oussama Ghorbel

Pour les numéros de téléphone, le paysage est plus fragmenté. Il n'existe pas d'équivalent universel et gratuit de Have I Been Pwned pour les téléphones. En revanche, vérifier votre numéro dans les fuites signalées par les services email reste utile : si votre numéro apparaît dans un dump, anticipez le risque de spam, de phishing par SMS (smishing) et, dans les cas extrêmes, de SIM swapping.

Voici une procédure simple, à réaliser une fois, et à rejouer tous les six mois :

1. Lister toutes les adresses email que vous utilisez — principale, alias, professionnelles, anciennes.
2. Les vérifier une par une sur Have I Been Pwned.
3. S'abonner aux alertes pour chacune d'elles.
4. Activer les notifications du gestionnaire de mots de passe, le cas échéant.
5. Noter, pour chaque fuite détectée, la date et la nature des données exposées. Ce journal deviendra votre référence en cas d'incident.

Ce dernier point est crucial. En cas de vol, les autorités, votre banque ou votre opérateur vous demanderont des éléments précis : quand avez-vous découvert la fuite, quelles données étaient concernées, quelles actions avez-vous entreprises. Un simple fichier texte daté vous fera gagner un temps précieux.

Réagir face au phishing ciblé

Le phishing ordinaire est un filet large : des milliers de messages identiques, envoyés à des listes achetées, espérant quelques proies. Le **spear-phishing** — le phishing ciblé — est une autre affaire. Le message est conçu pour vous, ou du moins pour ressembler à quelque chose que vous attendiez réellement.

Les signaux d'alerte varient, mais la structure est presque toujours la même. Un contexte crédible : votre banque, votre employeur, une administration, un fournisseur chez qui vous avez commandé. Une urgence artificielle : votre compte sera suspendu, une facture est impayée, une livraison est bloquée. Une action demandée : cliquer sur un lien, télécharger une pièce jointe, communiquer un code reçu par

© 2026 Oussama Ghorbel

SMS. Et parfois, une personnalisation troublante : votre nom complet, votre numéro de client, le nom de votre entreprise.

Face à un message de ce type, la règle est la même que celle que je vous recommande d'appliquer à toutes les sollicitations : **ne jamais agir dans l'urgence**. Le spear-phishing exploite précisément votre réflexe d'obéissance face à l'autorité et votre réflexe de peur face à l'échéance. Désactivez mentalement ces deux boutons.

Les gestes concrets sont d'une banalité désarmante, et c'est pour cela qu'ils fonctionnent quand on les oublie :

- **Ne cliquez jamais sur le lien.** Allez au site en tapant l'adresse vous-même dans votre navigateur, ou via l'application officielle si vous en avez une installée.
- **Vérifiez l'adresse exacte de l'expéditeur.** Une différence d'un caractère, un domaine proche mais différent, un suffixe inhabituel : autant de signaux d'alerte. Les adresses usurpées sont souvent construites avec des fautes de frappe volontaires ou des sous-domaines trompeurs.
- **Méfiez-vous des pièces jointes inattendues**, surtout les fichiers .zip, .exe, .html ou les documents exigeant l'activation des macros.
- **En cas de doute, contactez l'organisme par un canal officiel** — le numéro au dos de votre carte, le site que vous connaissez déjà, le standard de votre entreprise.

Un mot sur le phishing par SMS, de plus en plus répandu. Le réflexe est le même, mais le format est plus dépouillé : un lien raccourci, un message court, souvent un prétexte de livraison ou d'amende. Les liens raccourcis masquent la destination réelle. Si vous devez vérifier, passez par l'application du service concernée, jamais par le lien reçu.

Si vous avez cliqué et saisi vos identifiants : ne perdez pas de temps à regretter. Changez immédiatement le mot de passe concerné, activez l'authentification à deux facteurs, vérifiez les règles de transfert automatique dans votre messagerie (les pirates en installent souvent), et surveillez les sessions connectées. Si vous avez saisi des informations bancaires, prévenez votre banque dans la foulée.

© 2026 Oussama Ghorbel

Le spear-phishing est aussi un excellent révélateur de l'état de votre exposition. Plus votre vie numérique est exposée, plus il est facile pour un attaquant de rendre un message crédible. Réduire vos traces, comme nous le faisons depuis le début de cet ouvrage, réduit mécaniquement la qualité des armes disponibles contre vous.

Que faire en cas de SIM swapping

Le SIM swapping, ou portabilité frauduleuse du numéro de téléphone, est l'une des attaques les plus dévastatrices que l'on puisse subir, précisément parce qu'elle frappe un point que l'on considère à tort comme fiable : votre numéro de mobile.

Le scénario est le suivant. Un attaquant, ayant récolté suffisamment d'informations personnelles sur vous — souvent issues justement d'une fuite de données — se présente auprès de votre opérateur ou d'un revendeur, et obtient le transfert de votre numéro vers une carte SIM qu'il contrôle. En quelques minutes, vous perdez la réception des appels et des SMS. Lui, les reçoit. Or, de nombreux services utilisent le SMS comme second facteur d'authentification. Votre numéro, qui servait de filet de sécurité, devient la clé du coffre.

Les signes sont nets : vos SMS s'arrêtent d'arriver, les appels tombent dans le vide ou renvoient un message d'indisponibilité, et vous pouvez recevoir des alertes de tentatives de connexion à vos comptes. Si vous constatez une perte de réseau inhabituelle et persistante — en dehors d'une zone blanche ou d'une panne avérée —, agissez immédiatement.

Première action : contacter votre opérateur par un autre canal, idéalement en boutique avec une pièce d'identité, ou par le service client depuis une autre ligne. Signalez la suspicion de portabilité frauduleuse. Demandez la suspension du numéro si nécessaire, puis sa restitution. Notez la date et l'heure exactes : elles seront utiles si vous devez porter plainte.

Deuxième action : protéger les comptes qui dépendent du SMS. Tant que votre numéro est compromis, tout code envoyé par SMS l'est aussi. Si vous avez la possibilité d'accéder à vos comptes, désactivez temporairement l'authentification par SMS et passez à une application

© 2026 Oussama Ghorbel

d'authentification ou à une clé de sécurité physique. Si vous n'avez plus accès, utilisez des codes de secours fournis lors de la configuration de l'authentification à deux facteurs — c'est exactement pour ce cas de figure qu'on les enregistre.

Troisième action : prévenir votre banque. De nombreux services bancaires envoient des codes par SMS. Signalez la situation, demandez si des opérations ont été initiées, et activez si possible des moyens de vérification alternatifs. Ce point touche à vos finances : les démarches décrites ici visent uniquement à vous informer et à vous aider à réagir, et ne constituent pas un conseil financier personnalisé.

La prévention passe par plusieurs étapes concrètes :

• **Demandez à votre opérateur un verrouillage de portabilité** ou une protection spécifique contre la reprogrammation de la SIM. Les procédures varient selon les pays et les opérateurs, mais la plupart proposent désormais un dispositif.

• **Utilisez un code PIN SIM** sur votre carte. Il empêche l'utilisation de votre SIM amochée dans un autre appareil.

• **Ne liez pas votre identité à votre numéro plus que nécessaire.** Plus de services dépendent de votre numéro, plus il devient une cible de haute valeur.

• **Privilégiez les applications d'authentification** (TOTP) ou les clés matérielles au SMS pour l'authentification à deux facteurs. Le SMS n'est pas inutile, mais il est le maillon le plus faible des secondes facteurs.

• **Séparez les canaux.** Si possible, utilisez un numéro différent pour les opérations sensibles et pour les inscriptions quotidiennes.

Le SIM swapping illustre une leçon plus large : ne confondez pas *commodité* et *sécurité*. Ce qui est simple à récupérer pour vous l'est souvent aussi pour l'attaquant.

Signaler les usurpations d'identité aux autorités

Il arrive que la fuite ne reste pas virtuelle. Un compte vous échappe, un faux profil utilise votre nom, un emprunt est contracté à votre identité, un courrier d'huissier vous parvient pour une dette que vous

© 2026 Oussama Ghorbel

n'avez jamais contractée. À ce stade, on quitte le terrain de la cybersécurité pour entrer dans celui du droit et de la procédure. Et là, l'improvisation coûte cher.

Constituez une preuve avant tout. Avant de signaler quoi que ce soit, figez la situation : captures d'écran datées, URLs des faux profils, adresses email des messages reçus, références de transactions, numéros d'affaires, échanges avec les services concernés. Enregistrez tout dans un dossier unique. Les captures d'écran ne sont pas infaillibles juridiquement, mais elles constituent un point de départ. Pour les éléments importants, envisagez des constats d'huissier ou des services de preuve datée, selon la gravité et votre juridiction.

Portez plainte. En cas d'usurpation d'identité, d'accès frauduleux à un compte ou d'atteinte à vos données personnelles, le dépôt de plainte est la démarche de référence. Rendez-vous dans le commissariat ou la gendarmerie, ou utilisez le service de plainte en ligne lorsque votre pays en propose un. Présentez-vous avec votre dossier de preuves organisé chronologiquement. Demandez une copie du récépissé de plainte : vous en aurez besoin auprès des banques, des opérateurs et des plateformes.

Signalez sur les plateformes. Les réseaux sociaux, les sites d'annonce et les services en ligne disposent de formulaires de signalement d'usurpation. Un compte se faisant passer pour vous viole presque toujours leurs conditions d'utilisation. Le signalement est souvent plus rapide qu'une procédure judiciaire pour obtenir la fermeture d'un faux profil.

Avertissez les organismes concernés. Si des données financières sont en jeu, prévenez votre banque, votre établissement de crédit et, le cas échéant, les organismes de crédit. Si des données de santé ont fuité, contactez l'établissement de santé concerné et l'autorité de protection des données compétente. Dans l'Union européenne, le RGPD vous donne des droits précis en cas de violation de données à caractère personnel — je les détaille au chapitre 5. Vous avez notamment le droit d'être informé de la violation et d'introduire une réclamation auprès de la CNIL ou de l'autorité équivalente de votre pays.

Mettez en place une surveillance d'identité. Selon les pays, des services existent pour détecter l'utilisation frauduleuse de votre identité :

© 2026 Oussama Ghorbel

alertes sur les inscriptions au fichier des chèques sans provision, monitoring du nom de domaine, alertes sur les publications de données personnelles. Ces services ne remplacent pas la vigilance, mais ils élargissent votre champ de perception.

Un mot sur les délais. Plus vous signalez tôt, plus vous limitez la casse. Une usurpation d'identité non signalée pendant des semaines peut se transformer en litige complexe avec des créanciers. Le premier réflexe, après avoir sécurisé vos comptes, doit être le signalement.

Le nettoyage post-piratage

Passons maintenant à la phase la plus méthodique : la remise en état. Après une compromission avérée — un compte pris, une fuite confirmée, un accès indésirable détecté —, il faut procéder à un nettoyage systémique. L'erreur classique est de changer un mot de passe et de s'arrêter là. Un pirate qui a eu accès à un compte ne s'est généralement pas contenté d'y entrer : il a lu, exporté, installé, parfois configuré.

Voici l'ordre de priorité que je recommande.

1. Reprendre le contrôle du compte compromis. Récupérez l'accès en priorité. Vérifiez d'abord l'adresse email de récupération associée : si elle a été modifiée, c'est elle qu'il faut reconquérir en premier. Ensuite, changez le mot de passe avec un mot de passe long et unique. Révoquez toutes les sessions connectées et les tokens d'application — les options existent dans la plupart des services, souvent dans les paramètres de sécurité. Déconnectez tous les appareils que vous ne reconnaissez pas.

2. Examiner les règles invisibles. C'est l'étape que l'on oublie le plus, et c'est là que les pirates s'installent durablement. Dans votre messagerie, cherchez : des règles de transfert automatique vers une adresse externe, des filtres qui masquent des messages spécifiques, des adresses de récupération ajoutées, des adresses de confiance ajoutées pour contourner la vérification en deux étapes. Supprimez tout ce que vous n'avez pas configuré vous-même.

3. Balayer les comptes liés. Un email compromis, c'est potentiellement une dizaine de comptes en danger, parce que l'email est la clé universelle de réinitialisation. Listez les services où cette adresse

© 2026 Oussama Ghorbel

est utilisée et changez les mots de passe, en commençant par les plus sensibles : messagerie, banque, opérateur téléphonique, hébergeur, cloud, réseaux sociaux. C'est ici que la discipline de l'unicité des mots de passe paie : si chaque service avait son propre secret, la compromission reste localisée.

4. Renforcer l'authentification. Activez l'authentification à deux facteurs sur tous les comptes sensibles, en préférant les applications d'authentification ou les clés matérielles au SMS. Enregistrez vos codes de secours en lieu sûr. Vérifiez que l'adresse et le numéro de récupération sont bien les vôtres.

5. Scanner les appareils. Si vous avez téléchargé une pièce jointe ou cliqué un lien, examinez les appareils concernés : analyse antivirus à jour, vérification des extensions de navigateur, contrôle des programmes au démarrage. Parfois, le vrai problème n'est pas le compte cloud mais le terminal que vous utilisez pour y accéder.

6. Prévenir les contacts. Si votre compte a servi à envoyer des messages à votre carnet d'adresses, prévenez vos proches. Un simple message : « J'ai subi une compromission, si vous avez reçu un lien ou une demande de ma part ces derniers jours, ne cliquez pas. » C'est un geste de responsabilité qui coupe court à la propagation.

7. Mettre à jour votre plan de fuite. Revenez au journal dont je parlais plus haut. Notez la date de découverte, les comptes touchés, les mesures prises. Dans les semaines qui suivent, restez en alerte : les pirates reviennent parfois, soit parce qu'ils ont laissé une porte dérobée, soit parce que vos données ont été revendues.

Le nettoyage post-piratage n'est pas une corvée administrative. C'est le moment où l'on reprend la main sur une situation qui, par définition, nous a échappé. Et comme toutes les opérations de reprise, elle est infiniment plus simple si l'on s'y est préparé à l'avance.

La culture de la résilience

Je voudrais terminer ce chapitre sur une note qui dépasse la technique. La fuite de données et le vol d'identité ne sont pas des événements improbables réservés aux négligents. Ils font partie du paysage. Les traiter comme des accidents existeriels, c'est se condamner

© 2026 Oussama Ghorbel

à la panique à la première alerte. Les traiter comme des incidents gérables, avec des alertes en place, une procédure de réaction et un journal de suivi, c'est changer de posture.

La résilience numérique n'est pas l'absence d'incident. C'est la capacité à encaisser un incident sans que votre vie bascule. Elle repose sur trois piliers que nous avons construits tout au long de ce livre : **réduire l'exposition** (moins de données collectées, moins de comptes inutiles, moins de traces dispersées), **détecter tôt** (alertes de fuites, surveillance des comptes, hygiène régulière), et **réagir vite** (procédures connues à l'avance, preuves conservées, signalements effectués).

Si vous ne deviez retenir qu'une seule chose de ce chapitre, ce serait celle-ci : la vitesse de votre réaction dépend de la qualité de votre préparation. Les deux exercices proposés ci-dessous sont volontairement simples. Réalisez-les cette semaine. Le temps que vous y consacrerez est très inférieur au temps que vous économiserez le jour où l'alerte arrivera.

Exercices

Exercice 1 — Mettre en place votre système d'alerte de fuite

1. Lister l'ensemble de vos adresses email : principale, aliases, professionnelles, anciennes que vous utilisez encore pour récupérer des comptes.

2. Créer un compte sur Have I Been Pwned et abonner chacune de ces adresses à la notification de fuite. Si vous utilisez Firefox, activez également la surveillance intégrée de Firefox Monitor.

3. Vérifier si votre gestionnaire de mots de passe propose une surveillance d'exposition ; le cas échéant, l'activer.

4. Configurer une alerte rapide : soit une notification SMS via un service qui le propose, soit une règle de messagerie qui remonte les emails d'alerte de fuites en priorité sur votre téléphone.

5. Pour chaque fuite détectée, noter dans un fichier dédié : la date de découverte, le service concerné, les types de données exposées, et l'action immédiate engagée (changement de mot de passe, révocation de sessions, etc.).

© 2026 Oussama Ghorbel

6. Programmer un rappel récurrent — tous les six mois — pour rejouer l'ensemble de la vérification.

© 2026 Oussama Ghorbel

Chapitre 24 – La routine d'hygiène numérique

Tout au long de ce livre, nous avons démonté la machine : les modèles économiques du profilage, l'anatomie du profil fantôme, les algorithmes de l'influence, puis, chapitre après chapitre, les outils concrets pour reprendre le contrôle — navigateur, extensions, moteurs de recherche, e-mails, réseaux sociaux, appareils, réseau domestique, coffres-forts et gestion des fuites. Vous avez constitué votre arsenal. Vous avez probablement déjà changé quelques réglages, installé quelques extensions, créé vos premiers alias.

Mais la vie privée n'est pas un chantier que l'on termine un dimanche après-midi pour ensuite l'oublier. C'est un jardin. Un jardin entretenu avec rigueur reste fertile et respirable ; un jardin abandonné six mois est envahi par les ronces en quelques semaines. Les logiciels vieillissent, les permissions s'accumulent comme des couches de tartine, les comptes dormants deviennent des portes déverrouillées, les abonnements oubliés continuent de prélever, et surtout, vos propres habitudes évoluent — vous installez de nouvelles applications, vous connectez de nouveaux appareils, vous acceptez des conditions générales d'une traite parce que vous êtes pressé.

L'objectif de ce dernier chapitre est simple et, je l'espère, libérateur : transformer la protection de la vie privée en une routine. Pas en une obsession, pas en une corvée de trois heures le dimanche soir, mais en un rituel léger, répété, intégré à votre calendrier comme le sont le courses ou la révision de la voiture. La discipline douce bat la grande résolution héroïque. Mieux vaut vingt minutes chaque semaine, menées sans efforts, que trois heures de motivation débordante une fois par an, jamais renouvelées.

Je vais vous proposer trois niveaux de rythme — hebdomadaire, mensuel, annuel — puis élargir la question à votre entourage, avant de traiter d'un point délicat : comment rester informé sans basculer dans la paranoïa. Concluons ensemble sur ce que tout cela change vraiment.

Le rituel hebdomadaire : mises à jour et nettoyage

© 2026 Oussama Ghorbel

La première ligne de défense de n'importe quel système, numérique ou physique, n'est pas un dispositif exotique : c'est la maintenance. Un logiciel non mis à jour est une porte dont la serrure a été copiée mille fois. Les failles de sécurité — les fameuses failles zéro-day, ou les correctifs publiés après découverte d'une faille — sont exploitées par des pirates automatisés qui balayent l'internet en quelques heures. Attendre trois semaines pour mettre à jour, c'est laisser la porte grande ouverte pendant tout ce délai.

Votre rituel hebdomadaire commence donc par les mises à jour. Choisissez un moment précis — le dimanche soir après le dîner, le lundi matin avant de commencer à travailler, peu importe — et consacrez-y quinze minutes. Mettez à jour le système d'exploitation de votre ordinateur, celui de votre téléphone, votre navigateur, vos extensions, vos applications les plus sensibles (messageries, banque, gestionnaire de mots de passe). Activez si ce n'est pas déjà fait la mise à jour automatique partout où c'est possible : sur iOS, sur Android, sur Windows, sur macOS, la majorité des systèmes modernes savent se mettre à jour seuls. Votre rôle consiste alors à vérifier que ces mises à jour automatiques sont bien activées et qu'elles ont bien été appliquées.

Attention à une nuance importante : les mises à jour automatiques « silencieuses » sont parfaites pour la sécurité, mais elles n'illuminent pas toujours l'écran. Prenez l'habitude de vérifier rapidement la date de la dernière mise à jour appliquée. Sur Windows, c'est dans Paramètres -> Windows Update ; sur macOS, dans Réglages Système -> Général -> Mise à jour du logiciel ; sur Android, dans Paramètres -> Sécurité ou Système ; sur iOS, dans Réglages -> Général -> Mise à jour du logiciel.

Vient ensuite le nettoyage. Pas un grand nettoyage, un nettoyage de surface. En dix minutes :

• Vérifiez les notifications et les autorisations demandées par les applications que vous avez utilisées la semaine. Ce petit badge rouge, c'est souvent une application qui réclame un accès nouveau. Refusez par défaut ce dont vous n'avez pas besoin.

• Passez en revue les téléchargements récents. Supprimez les fichiers que vous n'ouvrirez jamais, en particulier les installateurs (.exe, .dmg, .apk) dont vous n'avez plus besoin après installation. Un

© 2026 Oussama Ghorbel

fichier installateur oublié sur le bureau est un risque inutile et un encombrement.

• Videz la corbeille. Sur les appareils partagés, c'est une évidence ; sur les vôtres, c'est une bonne habitude.

• Fermez les sessions ouvertes. La plupart des messageries, services cloud et réseaux sociaux proposent une page « appareils connectés » ou « sessions actives ». Un coup d'œil hebdomadaire suffit : si vous voyez un appareil que vous ne reconnaissez pas, déconnectez-le immédiatement et changez votre mot de passe.

• Déconnectez les services dont vous n'avez pas besoin ce jour-là. Désactiver Bluetooth et Wi-Fi lorsque vous ne les utilisez pas, sur un téléphone, limite les connexions non sollicitées ; couper le réseau à un objet connecté inactif évite qu'il émette en continu.

Un point sur le stress : le but de ce rituel n'est pas de cocher vingt cases. Si vous ne faites que les trois premières — mises à jour, permissions, sessions — vous avez déjà fait l'essentiel. La perfection est l'ennemie de la constance. Il est fréquent de voir des personnes abandonner leurs bonnes résolutions parce qu'elles s'étaient fixé un standard impossible à tenir. Mieux vaut un rituel tenable à 100 % qu'un protocole idéal tenu une fois.

Pensez aussi à automatiser ce qui peut l'être : un rappel récurrent dans votre agenda, un post-it sur le frigo, une notification sur votre téléphone. Le dimanche soir, l'alerte se déclenche, vous savez ce qu'il vous reste à faire, et l'effort de décision — souvent le plus coûteux — a déjà été fait pour vous.

L'audit mensuel des permissions et des abonnements

Une fois par mois, on élargit le périmètre. Là où la semaine s'attache aux correctifs de sécurité et au désencombrement immédiat, le mois s'attache aux droits accordés et aux flux d'argent et de données. Comptez trente à quarante-cinq minutes, une fois par mois, idéalement le même jour pour en faire un rendez-vous.

Les permissions mobiles. Sur Android comme sur iOS, les applications demandent — parfois à répétition — l'accès à la localisation, au micro, à l'appareil photo, aux contacts, au stockage, à la

© 2026 Oussama Ghorbel

liste des applications installées, au clipboard (le presse-papiers). Chaque permission accordée est une petite fenêtre ouverte sur votre vie. Auditez-les une par une : Paramètres -> Confidentialité -> Gestion des autorisations (Android) ou Paramètres -> Confidentialité et sécurité -> Localisation / Micro / Caméra (iOS). Posez une question simple à chaque ligne : « Cette application a-t-elle besoin de cette donnée *maintenant*, pour fonctionner ? » Une application de lampe torche n'a jamais besoin de votre carnet d'adresses. Un lecteur de fichiers PDF n'a jamais besoin de votre micro. La localisation « toujours » est presque toujours excessive : « pendant l'utilisation de l'application » suffit dans l'énorme majorité des cas.

Sur ordinateur, n'oubliez pas les autorisations données dans le navigateur — notifications, caméra, micro, géolocalisation — et dans les applications de bureau. Un site qui a reçu l'autorisation de vous envoyer des notifications le mois dernier continue souvent de l'avoir ce mois-ci. Revoyez la liste et révoquez sans regret.

Les abonnements et les services. C'est souvent la partie la plus négligée, et pourtant la plus concrète. Un abonnement à un service que vous n'utilisez plus, c'est à la fois de l'argent gaspillé et un compte dormant — un compte dormant, c'est une base de données quelque part qui contient votre e-mail, parfois vos coordonnées bancaires, et qui peut fuiter sans que vous vous en rendiez compte pendant des années. Passez en revue vos prélèvements bancaires du mois, vos abonnements App Store et Google Play (dans les paramètres de votre compte), et les services en ligne auxquels vous êtes inscrit. Résiliez ce qui ne sert plus. Pour le reste, demandez-vous : ce service collecte-t-il des données sur moi ? Puis-je le payer sans le lier à ma carte principale ?

Profitez-en pour vérifier les rappels d'identifiants de votre gestionnaire de mots de passe : certains alertent sur des mots de passe réutilisés ou compromis. Un audit mensuel, c'est aussi le moment de repérer le service qui utilise toujours l'ancien mot de passe que vous avez changé partout ailleurs.

Les données partagées. Vérifiez les partages actifs : Google Drive, iCloud, Dropbox, OneDrive, les dossiers partagés avec un collègue, les albums photo partagés avec une ancienne connaissance, les comptes familiaux. Chaque partage est une porte supplémentaire. Révoquez ce

© 2026 Oussama Ghorbel

qui n'a plus lieu d'être. Idem pour les comptes connectés : ces fameux « Se connecter avec Google », « Se connecter avec Facebook », qui prolifèrent. Déconnectez les applications tierces que vous ne reconnaissez plus — dans les paramètres de votre compte Google ou Apple, la liste est souvent plus longue qu'on ne le croit.

Les sauvegardes. Un audit mensuel, c'est aussi le moment de confirmer que vos sauvegardes fonctionnent vraiment. Une sauvegarde qui n'a pas abouti depuis six semaines n'existe plus, pratiquement. Vérifiez la date du dernier backup de votre téléphone, de votre ordinateur, de vos fichiers importants. Testez de temps en temps la restauration d'un fichier : une sauvegarde jamais testée est une promesse, pas une garantie.

Enfin, notez dans un carnet ou un document chiffré ce que vous avez modifié. Ce journal de bord, quelques lignes par mois, vous sera précieux quand, plus tard, vous vous demanderez « quand est-ce que j'ai révoqué cet accès ? » ou quand vous devrez réagir vite face à un incident.

Le bilan annuel de son empreinte numérique

Une fois par an, on change d'échelle. C'est le moment de faire un vrai bilan, comme on fait le bilan comptable ou la visite médicale annuelle. Bloquez une à deux heures dans votre agenda, un jour sans précipitation.

Inventaire des comptes. Listez tous les comptes que vous possédez : réseaux sociaux, services cloud, forums, boutiques en ligne, applications abandonnées. Un tableur, une liste simple dans votre gestionnaire de notes, peu importe. L'objectif est d'avoir la carte complète de votre présence en ligne. Pour les comptes que vous avez oubliés, profitez-en pour les supprimer définitivement — pas seulement « déconnecter », supprimer. La suppression réduit la surface d'attaque et le volume de données que vous laissez derrière vous.

Si vous cherchez à retrouver les comptes que vous avez créés au fil des ans, plusieurs pistes : la recherche dans votre boîte mail sur les mots-clés « confirmer votre inscription », « bienvenue », « vérifiez votre adresse » ; les listes d'applications connectées à vos comptes Google, Apple, Facebook ou Microsoft ; l'historique de votre navigateur. C'est un

© 2026 Oussama Ghorbel

travail d'archéologie, parfois surprenant, souvent révélateur.

L'empreinte visible. Recherchez-vous sur les principaux moteurs de recherche, en mode navigation privée, avec votre nom complet, votre pseudonyme, votre e-mail, votre numéro de téléphone. Ce que vous trouvez, d'autres le trouvent aussi : recruteurs, voisins, arnaqueurs. Vérifiez les résultats d'images, les résultats vidéo, les cartes, et les « personnes pourraient aussi connaître ». Si une donnée sensible apparaît — une ancienne adresse, un numéro personnel —, demandez sa suppression. Les moteurs de recherche proposent des formulaires de retrait (le droit à l'oubli, nous l'avons vu au chapitre 5) ; les sites tiers ont des procédures de désindexation. C'est long, parfois laborieux, mais chaque donnée retirée est une donnée retirée.

Les courtiers en données. Une fois par an, c'est aussi le moment de contacter les courtiers en données que vous avez identifiés au chapitre 22, et d'exercer vos droits : accès, rectification, effacement, opposition au partage. Conservez les réponses. Le nombre de sociétés qui répondent diminue-t-il ? Certaines effacent-elles réellement ? Le bilan annuel vous permet de mesurer l'évolution.

Les réseaux et la réputation. Passez en revue vos publications, vos likes, vos abonnements publiques sur les réseaux sociaux. Ce que vous avez partagé il y a trois ans vous ressemble-t-il encore ? Les publications anciennes peuvent être ressorties, citées hors contexte, archivées par des tiers. Archiver, puis supprimer ou restreindre ce qui ne vous représente plus, est un travail annuel raisonnable. Vérifiez aussi qui suit vos comptes, qui sont vos amis : un réseau gonflé d'inconnus est un réseau bruyant et risqué.

Les appareils. Faites l'inventaire matériel : ordinateurs, téléphones, tablettes, disques durs externes, clés USB, objets connectés. Lequel peut être revendu, recyclé, formaté ? Lequel contient encore des données que vous croyez effacées ? Un vieil appareil en tiroir est un risque : chiffrez-le, réinitialisez-le, ou détruisez-le physiquement si sa réinitialisation n'est pas fiable. Vérifiez que la recherche de l'appareil et le chiffrement du disque sont activés sur tous les appareils en service.

Les mots de passe et l'authentification. Une fois par an, auditez l'hygiène de vos identifiants : tous vos comptes sensibles ont-ils un mot

© 2026 Oussama Ghorbel

de passe unique ? Le double facteur est-il activé partout où c'est possible, de préférence par application d'authentification ou clé physique plutôt que par SMS ? Vos codes de secours sont-ils conservés dans un endroit sûr, accessible si vous perdez votre téléphone ? Un compte protégé par un excellent mot de passe mais sans code de secours récupérable, c'est un compte dont vous pouvez être définitivement exclu.

Le budget. Enfin, chiffrez. Combien payez-vous pour des services de cloud, de VPN, de stockage, de gestionnaire de mots de passe ? Combien vous coûte le temps passé à gérer tout cela ? La vie privée a un coût — modeste, si on le compare aux gains — mais ce coût doit rester choisi, pas subi. Si une solution payante ne vous apporte rien de plus qu'une solution gratuite et fiable, simplifiez.

Sortez de ce bilan avec trois à cinq objectifs pour l'année à venir. Pas trente. Par exemple : « migrer ma messagerie vers un fournisseur plus respectueux », « chiffrer mon vieil ordinateur », « supprimer trois comptes dormants par mois », « faire un atelier avec mes parents ». Une année, c'est long pour un ordinateur, court pour une habitude : visez réalisable.

Éduquer et protéger son cercle familial

Aucune routine individuelle ne protège entièrement un foyer si les autres portes restent ouvertes. Votre conjoint, vos enfants, vos parents, vos amis proches utilisent souvent les mêmes services, les mêmes réseaux, et publient des informations qui vous concernent — vous, vos enfants, votre adresse. Le partage familial crée des chaînes : la sécurité d'une chaîne, on le sait, se juge à son maillon le plus faible.

Je mets volontairement ensemble « éduquer » et « protéger », parce que l'un sans l'autre ne suffit pas. Éduquer sans protéger, c'est donner un manuel à quelqu'un qui n'a pas les mains libres. Protéger sans éduquer, c'est prendre des décisions à la place de l'autre, ce qui finit par être contourné.

Commencez par le diagnostic, pas par le sermon. Personne n'aime qu'on lui explique comment il doit vivre. Partagez plutôt ce que vous avez découvert : « J'ai réalisé que mon téléphone envoyait ma position en continu, regarde comment on coupe ça. » Montrez, proposez,

© 2026 Oussama Ghorbel

accompagnez. Un atelier familial de deux heures, avec un café, un ordinateur et une check-list, vaut mieux que six mois de remarques acides à table.

Priorisez les personnes vulnérables. Les personnes âgées, les enfants et les adolescents sont les plus ciblés par l'arnaque, l'hameçonnage et l'ingénierie sociale. Avec vos parents ou grands-parents : verrouillez les réglages de base, activez la double authentification sur leur messagerie et leur banque, installez un bloqueur de publicités et d'hameçonnage sur leur navigateur, établissez ensemble une règle simple — « si un appel, un e-mail ou un message me demande un code, un virement ou un téléchargement en urgence, je raccroche et je rappelle moi-même ». Créez un canal de vérification : un numéro connu à l'avance, une phrase secrète familiale pour confirmer qu'il s'agit bien d'eux.

Avec les enfants : la priorité n'est pas l'espionnage, c'est le cadre. Expliquez pourquoi on ne met pas sa géolocalisation publique, pourquoi une photo au bord de la piscine peut être récupérée et retouchée, pourquoi un jeu gratuit monétise l'attention. Paramétrez ensemble les comptes (contrôle parental, restrictions iOS, Family Link sur Android), mais surtout construisez la compréhension : un enfant qui comprend le *pourquoi* résiste mieux qu'un enfant qui subit un *comment*.

Avec votre conjoint ou vos proches adultes, alignez les bases : gestionnaire de mots de passe partagé pour les comptes du foyer (factures, opérateur, assurance), sauvegardes communes, procédure en cas de perte de téléphone, liste des personnes autorisées à accéder à quelqu'en cas d'urgence. Un foyer qui sait comment réagir ensemble en cas d'incident est un foyer bien mieux protégé qu'un foyer où chacun improvise.

Ne négligez pas le travail. Les frontières entre vie professionnelle et vie personnelle sont poreuses : un ordinateur professionnel utilisé la semaine pour des courses, un e-mail professionnel donné à un club de sport, un portable qui mélange les deux boîtes. Discutez de ces frontières avec votre entourage proche : quelles données du foyer ne doivent jamais figurer sur un outil professionnel ? Quels outils professionnels ne doivent jamais être utilisés à des fins personnelles ? Le RGPD, dans l'entreprise, est aussi votre allié : n'hésitez pas à exercer vos droits en

© 2026 Oussama Ghorbel

tant que salarié lorsque vos données sont concernées.

Partagez sans surprotéger. Il existe une tentation inverse : vouloir tout verrouiller, refuser toute photo, couper tout réseau. Cette posture isole, épuise, et finit par être abandonnée. L'objectif n'est pas de disparaître, c'est de choisir ce qui est partagé, avec qui, et pour combien de temps. La vie privée n'est pas l'absence de vie sociale : c'est le contrôle des conditions de cette vie sociale.

Enfin, institutionnalisez : un point famille trimestriel de dix minutes suffit. « As-tu des mises à jour à faire ? As-tu reçu un message bizarre ? Un nouveau service auquel on s'est inscrit ? » Transformez la protection en affaire de maison, pas en affaire d'un seul.

Rester informé sans tomber dans la paranoïa

La paranoïa numérique est un échec, autant que l'indifférence. Elle se manifeste de plusieurs façons : l'impossibilité de faire confiance à n'importe quel outil, l'angoisse permanente à l'idée d'être observé, la surcharge de précautions qui finit par rendre la vie technologique ingérable — et donc, souvent, par pousser à tout abandonner d'un coup. Entre « je m'en fiche » et « je ne peux plus rien utiliser », il y a une position tenable : l' vigilance proportionnée.

Distinguez le risque réel du risque théorique. Le piratage de masse d'une base de données d'une grande entreprise, c'est fréquent. Le hasard de vous voler personnellement vos données par un individu qui vous cible spécifiquement, c'est rare, sauf si vous êtes une cible à fort profil (journaliste, militaire, personne publique, détenteur de secrets d'entreprise). Adaptez le niveau de protection à la menace réelle. Pour la plupart des gens, les grands classiques suffisent : mots de passe uniques, double authentification, mises à jour, méfiance envers les liens et les pièces jointes inattendues, sauvegardes, et un minimum de sobriété dans ce qu'on publie.

Méfiez-vous des deux marchands de peur. D'un côté, les entreprises de sécurité qui vendent la terreur pour vous vendre leur produit, et les titres qui annoncent la mort de la vie privée chaque semaine. De l'autre, les géants du numérique qui minimisent le tracking au nom de la « personnalisation » et de la « fluidité de l'expérience ».

© 2026 Oussama Ghorbel

Lisez les informations avec méthode : qui parle ? Qu'est-ce qu'il vend ? Quelles sont les preuves ? Une faille décrite avec précision, un CVE identifié, un correctif disponible : voilà de l'information utile. Un article alarmiste sans nom d'auteur, sans source technique, avec un « on nous espionne » en boucle : voilà du bruit.

Choisissez vos sources. Quelques-unes suffisent. Des organismes de référence comme l'ANSSI en France, l'EFF, le CNIL, Mozilla, ou des publications spécialisées qui expliquent les vulnérabilités sans enflammer le propos. Abonnez-vous à une ou deux newsletters de veille, désinstallez les applications d'alerte en continu. La sur-information produit le même effet que l'information désinfectée : l'impuissance. Vous n'avez pas besoin de connaître chaque CVE pour dormir tranquille — vous avez besoin que votre système se mette à jour tout seul.

Transformez l'information en geste. La règle que je m'applique à suivre : chaque nouvelle inquiétude doit se traduire en une action concrète et bornée. « Un tel service a fuité des mots de passe » -> je vérifie si mon adresse y figure, je change le mot de passe concerné, j'active la double authentification si ce n'est pas fait, et je passe à autre chose. « Une nouvelle loi élargit le champ de la surveillance » -> je vérifie mes réglages de confidentialité, j'ajoute ou retire une extension, je note dans mon carnet. Si une information ne peut pas se traduire en action, elle est soit à laisser passer, soit à mettre de côté pour le prochain bilan annuel.

Acceptez l'incertitude. Aucune mesure n'est infaillible. Le chiffrement n'est pas magique, le VPN n'est pas un imperméable, l'anonymat parfait n'existe pas dans la pratique. Ce que vous construisez, c'est un rapport de coût : rendre le profilage de vous plus difficile, plus cher, plus hasardeux, et surtout, reprendre la main sur ce qui dépend de vous. La maîtrise n'est pas le contrôle total ; c'est le contrôle de ce qui est contrôlable — vos réglages, vos habitudes, vos décisions.

Si vous vous surprenez à relire dix fois par jour les paramètres de confidentialité de vos appareils, à refuser toute connexion internet par principe, ou à ne plus oser rien installer : faites une pause. Revenez au rituel hebdomadaire minimal, resserrez le cercle de vos outils, parlez-en à quelqu'un. La sérénité fait partie de la protection : une personne stressée fait plus d'erreurs qu'une personne confiante et méthodique.

© 2026 Oussama Ghorbel

Conclusion : la liberté par la maîtrise de ses outils

Nous voici au terme du parcours. De la Partie 1, où nous avons démonté l'économie de l'attention et du profilage, jusqu'à cette routine d'hygiène, nous n'avons jamais prétendu vous rendre invisible — l'impossible n'aide personne. Nous avons surtout cherché à rendre votre visibilité *choisie*.

La routine d'hygiène numérique n'est pas une pénitence. C'est l'inverse : c'est ce qui vous permet d'utiliser vos outils sans arrière-pensée, de dormir avec un téléphone qui ne s'est pas transformé en fuite permanente, de laisser vos proches utiliser Internet sans craindre chaque clic. Comme le dentiste, comme le gym, comme l'entretien de la voiture : quelques minutes régulières évitent les urgences coûteuses.

Trois principes résument, je crois, l'esprit de ce chapitre, et peut-être de tout ce livre :

La constance l'emporte sur l'intensité. Vingt minutes par semaine, une quarantaine de minutes par mois, deux heures par an. Trois niveaux de rythme, aucun d'effort héroïque. Écrivez-les dans votre agenda, tenez-les, et la protection deviendra une habitude comme une autre — invisible elle aussi, mais cette fois à votre avantage.

La simplicité l'emporte sur l'accumulation. Un gestionnaire de mots de passe, un bloqueur de traqueurs, un moteur de recherche respectueux, des mises à jour activées, des sauvegardes vérifiées : ce socle, tenu avec discipline, vaut mieux qu'une collection de dix-sept outils utilisés à moitié. Chaque outil supplémentaire est une maintenance supplémentaire, une faille potentielle supplémentaire, une source d'abandon supplémentaire.

La compréhension l'emporte sur la recette. Vous savez désormais *pourquoi* vous coupez la localisation, *pourquoi* vous créez un alias, *pourquoi* vous refusez une permission, *pourquoi* vous supprimez un compte dormant. Cette compréhension, personne ne peut vous la reprendre. Les interfaces changent, les menus se déplacent, les noms de fonction varient d'une version à l'autre — mais le raisonnement, lui, reste valable. C'est la différence entre suivre un tutoriel et savoir conduire.

© 2026 Oussama Ghorbel

La liberté, ici, n'est pas l'absence d'outils : c'en est la maîtrise. Un artisan libre n'est pas celui qui n'a pas d'outils, c'est celui qui sait les choisir, les entretenir et s'en passer quand ils ne servent plus. Vous êtes devenu, au fil de ces vingt-quatre chapitres, l'artisan de votre propre espace numérique.

Alors, place à la routine. Et place à la vie — celle qui se déroule, désormais, un peu plus de votre côté.

Exercices pratiques

Exercice 1 — Créer votre rendez-vous récurrent

Ouvrez votre application de calendrier (Google Agenda, Apple Agenda, Outlook, ou tout autre outil que vous utilisez réellement). Créez un événement récurrent, par exemple **« Hygiène numérique »**, le **premier dimanche du mois de 10 h à 11 h**. Dans la description de l'événement, collez la liste suivante :

1. Mises à jour de sécurité : système d'exploitation, navigateur, extensions, applications, appareils connectés.
2. Audit des permissions mobiles et du navigateur (localisation, micro, caméra, contacts, notifications).
3. Revue des sessions et appareils connectés ; déconnexion de tout appareil inconnu.
4. Revue des prélèvements et abonnements ; résiliation de ce qui ne sert plus.
5. Vérification de la date des sauvegardes, et test de restauration d'un fichier.
6. Recherche de soi-même sur les moteurs de recherche (mode navigation privée).
7. Mise à jour du journal de bord : noter ce qui a été modifié.

Ajoutez une seconde récurrence, plus courte : **« Point hebdo »**, tous les dimanches, **10 minutes** — uniquement les points 1, 2 et 3. Collez l'événement sur le premier dimanche du mois et laissez le calendrier faire le reste. Enfin, créez un rappel annuel, à la date de votre choix, **« Bilan annuel de l'empreinte numérique — 2 heures »**, avec comme description l'inventaire des comptes, le suivi des droits exercés, l'état des

© 2026 Oussama Ghorbel

appareils et trois objectifs pour l'année.

Exercice 2 — Le journal de bord

Créez un document (de préférence chiffré ou stocké dans votre gestionnaire de notes sécurisé) intitulé **« Journal d'hygiène numérique »**. Pour chacune de vos sessions — hebdomadaire, mensuel, annuel — notez en cinq lignes maximum : la date, ce que vous avez vérifié, ce que vous avez modifié, ce que vous avez découvert d'inattendu, ce que vous reportez au prochain rendez-vous. Relisez le journal complet à chaque bilan annuel : il deviendra votre carte de progression et votre mémoire face aux incidents futurs.

© 2026 Oussama Ghorbel

Conclusion

Conclusion : L'aube de votre souveraineté numérique

Vous voici parvenu au terme de ce voyage. Lorsque j'ai entrepris la rédaction de cet ouvrage, mon objectif n'était pas de vous transformer en ermite numérique, coupé du monde et paranoïaque à la moindre connexion Wi-Fi. Mon ambition était bien plus profonde, et j'espère qu'au fil de ces pages, vous l'avez ressentie : il s'agissait de vous rendre votre libre arbitre.

Pendant des années, l'industrie technologique nous a vendu un contrat faussé, dissimulé derrière la brillance des écrans et la commodité des services dits « gratuits ». Nous avons accepté, souvent par résignation ou par méconnaissance, de devenir la matière première d'une économie de l'attention et de la prédiction comportementale. Mais aujourd'hui, en refermant ce livre, vous n'êtes plus la même personne qu'au moment de l'ouvrir. Vous avez appris à voir les fils invisibles de la matrice. Vous avez compris que l'invisibilité n'est pas un acte de dissimulation honteuse, mais l'expression la plus pure de la souveraineté personnelle. Comme le rappelait si justement l'expert en cryptographie Bruce Schneier : *« La vie privée est le pouvoir de se présenter au monde comme on le souhaite. »*

Désormais, ce pouvoir est entre vos mains.

Le chemin parcouru : de la matrice à la maîtrise

Reprenons un instant le chemin que nous avons parcouru ensemble. Tout a commencé par une prise de conscience : le vrai prix de la gratuité. Nous avons disséqué l'anatomie de votre profil fantôme, cette ombre numérique qui vous précède partout sur la toile, agrège vos désirs, vos peurs, vos habitudes d'achat et vos opinions politiques. Vous avez compris que les algorithmes de l'influence ne se contentent pas de prédire votre comportement ; ils le façonnent, orientant vos choix conscients par des micro-stimulations invisibles.

© 2026 Oussama Ghorbel

Face à ce constat, la fatalité n'était pas une option. Nous avons donc forgé votre premier bouclier. En blindant votre navigateur web, en déployant un arsenal d'extensions anti-pistage rigoureusement sélectionnées, et en abandonnant les moteurs de recherche qui monnaient vos requêtes, vous avez érigé une première ligne de défense. Vous avez appris l'art de l'emailing furtif, utilisant des alias pour cloisonner votre identité et empoisonner les bases de données des courtiers en informations.

Vous avez également compris que les réseaux sociaux, par leur nature même, sont des machines à extraire de la donnée. Plutôt que de les quitter systématiquement – ce qui n'est pas toujours envisageable socialement ou professionnellement – vous avez appris à verrouiller les écoutilles, à restreindre les permissions, à limiter la surface d'attaque de votre vie privée. De même, vos achats en ligne ne sont plus des occasions de laisser une trace financière indélébile ; vous maîtrisez désormais les techniques de paiement sans traces et de livraison discrète.

Cette première grande étape de votre transformation a été marquée par un changement de paradigme : vous êtes passé du statut de produit à celui d'utilisateur souverain. Vous ne subissez plus l'architecture du web ; vous la naviguez avec intention, armé des droits que vous confère le RGPD et d'une compréhension fine de votre propre exposition numérique.

L'architecture de la forteresse : du silicium au salon

Mais le web n'est que la partie émergée de l'iceberg. La véritable bataille pour votre vie privée se joue au cœur même de vos appareils et de votre foyer. C'est ce que nous avons exploré dans les parties les plus techniques de ce livre, en plongeant dans le cœur du réacteur.

Vous avez découvert avec une certaine stupéfaction l'ampleur de la télémétrie intégrée à iOS et Android. Ces systèmes d'exploitation, que nous gardons dans nos poches et sur nos tables de nuit, sont des capteurs omniscients. En décortiquant leurs paramètres, en nettoyant les permissions mobiles avec une rigueur chirurgicale, vous avez coupé les vivres aux géants de la Silicon Valley. Vous avez compris que la sécurité de vos communications repose sur le chiffrement de bout en bout, faisant de vos messageries et de vos appels des bulles inviolables,

© 2026 Oussama Ghorbel

imperméables aux regards indiscrets des annonceurs comme des États.

Nous avons ensuite sécurisé votre infrastructure. Le Cloud, ce concept nébuleux qui a si souvent servi d'excuse à la dépossession de nos données, est devenu pour vous un espace souverain, chiffré de telle sorte que même votre fournisseur de stockage n'en possède pas les clés. Vos mots de passe, ces sésames fragiles, ont été remplacés par des coffres-forts numériques et des méthodes d'authentification robustes, telles que les clés physiques et les passkeys. Que vous soyez sur Windows, Mac ou Linux, votre ordinateur de bureau n'est plus une passoire télémétrique, mais un outil de travail asservi à vos seuls besoins.

Enfin, nous avons fortifié votre sanctuary : votre domicile. Le routeur, trop longtemps ignoré, a repris sa place de sentinelle du réseau local, filtrant le trafic à la source et bloquant les requêtes malveillantes avant même qu'elles n'atteignent vos appareils. Vous avez appris à vous méfier de la maison connectée et de l'Internet des Objets (IoT), ces chevaux de Troie modernes qui écoutent, observent et rapportent. Vous avez également pris la mesure des enjeux liés à la biométrie et aux objets portables de santé, comprenant que vos données biologiques sont l'ultime frontière de votre intimité, celles que l'on ne peut ni changer ni révoquer en cas de fuite.

En apprenant à chasser les courtiers en données et à gérer les inévitables fuites d'identités avec sang-froid, vous avez bâti une forteresse en profondeur. Aucune muraille n'est imprenable, mais vous avez rendu le coût de l'attaque si élevé, et la valeur de la donnée récoltée si faible, que les prédateurs numériques préféreront toujours passer leur chemin.

La frugalité numérique : l'élégance du minimum vital

Au-delà des configurations techniques, des extensions et des protocoles de chiffrement, ce livre vous a proposé une philosophie : celle de la frugalité numérique. C'est peut-être l'enseignement le plus précieux de notre parcours.

La meilleure donnée est celle qui n'est jamais générée. Le meilleur compte est celui qui n'est jamais créé. La meilleure application est celle

© 2026 Oussama Ghorbel

que vous avez désinstallée. Dans un monde qui nous pousse à la surconsommation d'outils, de services et de contenus, la frugalité est un acte de résistance profondément élégant. Elle ne consiste pas à se priver de la technologie, mais à la dépouiller de son superflu pour ne garder que son utilité réelle.

C'est pourquoi la routine d'hygiène numérique, détaillée dans le dernier chapitre, n'est pas une corvée, mais un rituel d'ancrage. Tout comme vous fermez la porte de votre maison à double tour le soir, vous devez auditer vos permissions, vider vos caches, mettre à jour vos systèmes et supprimer les comptes orphelins. Cette discipline, légère mais régulière, est le prix de votre tranquillité d'esprit. Elle vous permet de maintenir un écosystème numérique sain, rapide, et surtout, aligné avec vos valeurs.

En embrassant cette frugalité, vous libérez non seulement votre bande passante et la mémoire de vos appareils, mais aussi votre charge mentale. L'invisibilité numérique apporte avec elle un silence cognitif rare et précieux. Moins de publicités ciblées, moins de notifications manipulatoires, moins de sollicitations algorithmiques : c'est l'espace qui se rouvre pour vos propres pensées, vos propres désirs, votre propre vie.

Perspectives : l'horizon de l'IA, du quantique et de la régulation

Alors que vous posez les bases de votre souveraineté, le monde numérique, lui, ne cesse de muter. L'horizon technologique se dessine avec une rapidité fulgurante, et il est de notre devoir d'anticiper les prochaines menaces autant que les nouvelles opportunités.

L'avènement de l'intelligence artificielle générative et des grands modèles de langage (LLM) a redéfini les règles du pistage. Demain, le profilage ne se basera plus seulement sur les liens que vous cliquez, mais sur la sémantique de vos conversations, la tonalité de votre voix, la micro-hésitation de votre regard face à un écran. Face à cette surveillance cognitive, la réponse résidera dans l'IA locale. Les appareils de demain intégreront des puces dédiées au traitement neuronal sur le device (Edge AI), permettant de bénéficier des avantages de l'assistance intelligente sans qu'aucune donnée ne quitte votre salon. Votre défi sera de privilégier systématiquement les solutions qui garantissent un

© 2026 Oussama Ghorbel

traitement local et transparent, en rejetant les services qui aspirent votre contexte personnel vers des serveurs distants pour y être moulinés par des boîtes noires algorithmiques.

Parallèlement, l'informatique quantique pointe à l'horizon. Bien qu'elle promette des avancées scientifiques majeures, elle représente une menace existentielle pour les standards de chiffrement actuels qui protègent vos communications et vos coffres-forts numériques. La stratégie du « collect now, decrypt later » (collecter maintenant, déchiffrer plus tard) est déjà à l'œuvre chez certains acteurs étatiques. C'est pourquoi, dans les années à venir, la migration vers la cryptographie post-quantique deviendra un standard incontournable. Restez vigilant sur les mises à jour de vos outils de chiffrement et privilégiez les protocoles qui intègrent déjà cette résilience face au calcul quantique.

Sur le plan législatif, l'Europe continue de tracer la voie avec des régulations comme le Digital Markets Act (DMA), le Digital Services Act (DSA) et l'AI Act. Ces textes imposent une interopérabilité et une transparence qui jouent en votre faveur. Cependant, la loi ne sera jamais qu'un bouclier de papier face à l'ingéniosité des architectures de contournement. La régulation vous donne des droits, mais c'est votre maîtrise technique, celle que vous avez acquise dans ce livre, qui vous donne le pouvoir de les faire appliquer dans la réalité du code. La privacy de demain sera le fruit d'une alliance entre une régulation stricte, une cryptographie robuste et une vigilance citoyenne constante.

Le manifeste de l'invisible : votre nouveau pacte avec le monde

Il est temps pour moi de vous laisser. Ce livre n'était qu'une carte ; c'est à vous qu'il appartient désormais de tracer votre route.

Au moment de refermer ces pages, j'aimerais que vous gardiez à l'esprit une vérité essentielle : la perfection n'existe pas en matière de sécurité numérique. Il y aura des jours où vous cliquerez sur un lien hâtivement, où vous accepterez des cookies par fatigue, où vous partagerez une photo sans penser aux métadonnées EXIF qu'elle contient. Ne vous culpabilisez pas. L'objectif n'est pas l'asepsie totale, mais la réduction drastique de votre surface d'attaque. Chaque trace

© 2026 Oussama Ghorbel

effacée est une victoire. Chaque alias créé est un rempart. Chaque permission refusée est une affirmation de votre existence en tant qu'individu libre, et non en tant que point de données.

Devenir invisible, ce n'est pas fuir le monde. C'est choisir les termes de votre engagement avec lui. C'est pouvoir chercher des informations médicales sensibles sans que votre assureur n'en soit informé. C'est pouvoir explorer des idées politiques minoritaires sans être enfermé dans une bulle de filtrage radicale. C'est pouvoir acheter un cadeau pour un proche sans que les algorithmes ne gâchent la surprise en vous inondant de publicités ciblées sur tous vos écrans. C'est, en somme, préserver l'intimité de votre jardin secret, ce lieu où votre identité se construit à l'abri des regards et des jugements marchands.

Vous faites désormais partie d'une communauté grandissante de citoyens numériques éveillés. Vous n'êtes pas seul dans cette démarche. Autour de vous, des développeurs open-source veillent, des associations de défense des droits numériques luttent, et des millions d'utilisateurs reprennent, jour après jour, le contrôle de leurs machines. Partagez vos connaissances. Aidez vos proches à configurer leurs navigateurs, à choisir leurs messageries, à comprendre les enjeux de leur empreinte numérique. La privacy est un bien commun ; elle ne s'épanouit que lorsqu'elle est partagée et défendue collectivement.

Votre vie numérique vous appartient. Elle est le prolongement de votre esprit, de votre corps et de votre volonté. Ne la laissez plus en pâture à ceux qui cherchent à la monnayer. Reprenez le contrôle. Configurez, chiffrez, bloquez, et surtout, vivez.

L'aube de votre souveraineté numérique se lève aujourd'hui. À vous de la faire briller.

L'impact sociétal : de la protection individuelle à la résilience collective

Il serait tentant de considérer la protection de la vie privée comme une démarche purement égoïste, une bulle de confort que l'on érige pour soi-même en ignorant le reste du monde. Ce serait une erreur profonde. Votre décision de devenir invisible a une résonance qui dépasse largement le cadre de votre foyer ou de votre smartphone. Elle s'inscrit

© 2026 Oussama Ghorbel

dans un enjeu de société majeur : la préservation de notre tissu démocratique et de notre libre arbitre collectif.

L'architecture de la surveillance de masse, qu'elle soit le fait d'États autoritaires ou de conglomérats technologiques, repose sur un principe simple : la normalisation de la transparence totale. Lorsque chacun accepte d'être observé, analysé et noté en permanence, la société glisse insidieusement vers un panoptique numérique où l'autocensure devient la norme. On n'ose plus chercher certaines informations, on n'ose plus exprimer certaines opinions, on n'ose plus explorer des chemins de traverse, de peur que l'algorithme ne nous classe, ne nous juge ou ne nous marginalise. En refusant ce contrat, en brouillant les pistes et en chiffrant vos communications, vous brisez ce miroir déformant. Vous rapprenez à la société que le droit à l'opacité est une condition sine qua non de la liberté d'expression et de la dissidence créatrice.

De plus, chaque fois que vous bloquez un traqueur, chaque fois que vous utilisez un moteur de recherche respectueux de votre anonymat, chaque fois que vous refusez de céder vos données biométriques à une application de loisir, vous privez l'industrie de la donnée de son carburant. Le capitalisme de surveillance ne peut survivre que s'il parvient à extraire, agréger et monétiser le comportement de milliards d'individus. En devenant un « grain de sable » dans cette immense machine, vous participez à un mouvement de résistance passive mais redoutablement efficace. Si des millions de lecteurs de ce livre appliquent ne serait-ce que la moitié des configurations recommandées, c'est le modèle économique entier du profilage prédictif qui s'effondre, faute de matière première fiable. Votre hygiène numérique personnelle est, en réalité, un acte de militantisme silencieux.

La psychologie de l'ombre : reconquérir son temps de cerveau

Au-delà des enjeux politiques et économiques, il est une dimension que nous avons effleurée tout au long de cet ouvrage, mais qui mérite d'être explicitée en cette conclusion : l'impact psychologique de votre nouvelle invisibilité.

L'économie de l'attention a été conçue par les meilleurs ingénieurs comportementaux de la planète pour capter, retenir et monétiser chaque

© 2026 Oussama Ghorbel

fraction de seconde de votre temps de cerveau disponible. Les notifications, les fils d'actualité infinis, les recommandations hyper-ciblées ont pour seul but de vous maintenir dans un état d'alerte permanente, de susciter en vous des micro-doses de dopamine ou de cortisol. Cette sursollicitation constante est l'une des causes majeures de l'épidémie d'anxiété, de troubles de l'attention et d'épuisement cognitif qui frappe nos sociétés modernes.

En reprenant le contrôle de vos appareils et en verrouillant les écoutilles, vous n'avez pas seulement protégé vos données ; vous avez protégé votre esprit. Un navigateur qui ne charge pas de scripts de pistage est un navigateur plus rapide, mais c'est aussi une fenêtre sur le monde qui ne cherche plus à vous manipuler. Un téléphone débarrassé de ses permissions abusives et de ses applications superflues cesse d'être un distributeur de distractions pour redevenir ce qu'il n'aurait jamais dû cesser d'être : un outil au service de votre volonté.

Vous allez redécouvrir le pouvoir de l'ennui, cette matrice oubliée de la créativité humaine. Vous allez redécouvrir la sérendipité, cette capacité à faire des découvertes heureuses par hasard, plutôt que de vous voir servir en boucle ce que l'algorithme a déduit que vous aimiez déjà. En sortant de la bulle de filtrage, vous vous exposez à nouveau à la complexité du monde, à ses contradictions, à ses beautés imprévues. Le silence numérique que vous avez instauré autour de vous n'est pas un vide ; c'est un espace fertile où vos propres pensées peuvent enfin s'enraciner et s'épanouir sans être constamment interrompues par l'injonction à consommer ou à réagir.

Le legs numérique : quelle empreinte pour les générations futures ?

Nous sommes la première génération de l'histoire humaine à devoir gérer la question de l'immortalité numérique et de l'héritage de données. Avant l'avènement du web, nos ancêtres laissaient derrière eux quelques lettres, des photographies jaunies, des objets chargés de mémoire. Aujourd'hui, nous laissons des téraoctets de métadonnées, d'histoires de géolocalisation, de messages éphémères archivés à notre insu sur des serveurs distants.

© 2026 Oussama Ghorbel

Que laisserons-nous à ceux qui nous succéderont ? Voulons-nous que nos enfants et nos petits-enfants héritent d'un profil publicitaire exhaustif de nos vies, d'une base de données de nos faiblesses, de nos colères et de nos achats compulsifs ? La gestion de notre identité post-mortem est un sujet que le droit peine encore à encadrer de manière satisfaisante, malgré les avancées du RGPD sur le sort des données après le décès. C'est pourquoi la frugalité numérique prend ici tout son sens : moins vous générez de données superflues de votre vivant, moins votre ombre numérique sera lourde à porter pour vos descendants, et moins elle sera exploitable par des entités malveillantes après votre disparition.

Mais le véritable legs ne se trouve pas dans les serveurs ; il se trouve dans la transmission de vos valeurs. Éduquer les plus jeunes à la souveraineté numérique est sans doute le défi le plus urgent de notre époque. Il ne s'agit pas de diaboliser la technologie, qui leur offrira des opportunités formidables, mais de leur en expliquer les rouages cachés. Apprenez-leur très tôt à distinguer un contenu organique d'une publicité déguisée. Montrez-leur comment fonctionne un algorithme de recommandation. Expliquez-leur pourquoi leur jeu vidéo gratuit leur demande l'accès à leur carnet d'adresses. En leur transmettant les clés de la matrice, vous ne leur offrez pas seulement des compétences techniques ; vous leur offrez l'armure intellectuelle nécessaire pour naviguer dans le monde de demain sans en devenir les esclaves consentants.

Le serment de l'ombre : vivre pleinement dans le monde réel

Alors que nous arrivons au point final de cet ouvrage, je vous invite à accomplir un dernier geste, peut-être le plus important de tous. Fermez ce livre. Éteignez votre écran. Et allez vivre.

Toutes les configurations de ce livre, tous les pare-feu, tous les protocoles de chiffrement et tous les alias n'ont qu'une seule et unique finalité : vous permettre d'oublier la technologie. Le but ultime de la maîtrise de vos outils numériques est qu'ils s'effacent de votre conscience pour vous laisser tout entier à l'expérience du monde réel.

La vie ne se trouve pas dans le nombre de likes, dans la perfection d'un profil en ligne, ou dans la validation d'une audience fantôme. Elle se trouve dans le regard de ceux que vous aimez, dans la sensation du

© 2026 Oussama Ghorbel

vent sur votre visage, dans la profondeur d'une conversation qui n'est ni enregistrée, ni transcrite, ni analysée par une intelligence artificielle. Elle se trouve dans ces moments d'intimité absolue qui n'ont pas besoin d'être partagés pour exister, et qui tirent leur valeur de leur caractère éphémère et secret.

Devenir invisible en ligne, c'est choisir d'être pleinement visible et présent dans la vraie vie. C'est reprendre possession de son corps, de son temps et de son espace. C'est refuser que notre existence soit réduite à une série de points de données optimisables.

Vous avez désormais les connaissances, les outils et la philosophie pour marcher la tête haute dans l'arène numérique. Vous savez comment vous défendre, comment attaquer les failles du système, et comment bâtir votre propre forteresse. Mais n'oubliez jamais que la forteresse n'est pas une prison. C'est un refuge qui vous permet de sortir chaque matin dans le monde, confiant et serein, sachant que vos arrières sont gardés.

Je vous souhaite un voyage extraordinaire dans cette nouvelle vie numérique. Une vie où vous êtes le seul maître à bord. Une vie où vos secrets vous appartiennent encore. Une vie, enfin, qui soit véritablement la vôtre.

Avec ma profonde conviction et mon entier soutien,

Oussama Ghorbel

© 2026 Oussama Ghorbel

Bibliographie commentée

Shoshana Zuboff, *The Age of Surveillance Capitalism* (2019).

Idée maîtresse : Les géants de la tech transforment l'expérience humaine en données comportementales pour prédire et contrôler nos actions à des fins lucratives.

Apport : Comprendre le modèle économique adverse pour mieux déjouer ses mécanismes de collecte et expliquer au lecteur pourquoi la guerre des données a lieu.

Bruce Schneier, *Data and Goliath* (2015).

Idée maîtresse : La collecte de données est un problème systémique impliquant à la fois les entreprises et les gouvernements, nécessitant une approche de modélisation des menaces.

Apport : Méthodologie pour évaluer les risques personnels et prioriser les configurations de sécurité et de confidentialité sur les appareils.

Cal Newport, *Digital Minimalism* (2019).

Idée maîtresse : L'utilisation intentionnelle et minimaliste de la technologie améliore la qualité de vie et réduit l'exposition aux algorithmes.

Apport : Philosophie de la désintoxication numérique et du nettoyage drastique des applications mobiles superflues.

Cory Doctorow, *How to Destroy Surveillance Capitalism* (2020).

Idée maîtresse : Le capitalisme de surveillance repose sur des monopoles ; l'interopérabilité adversariale et les outils de blocage sont des actes de résistance.

Apport : Stratégies avancées pour utiliser des extensions de navigateur et des outils de contournement des murs clos (walled gardens).

Kevin Mitnick, *The Art of Invisibility* (2017).

Idée maîtresse : L'anonymat en ligne et la sécurité des données nécessitent des pratiques quotidiennes strictes et une méfiance envers les réseaux par défaut.

© 2026 Oussama Ghorbel

Apport : Tutoriels pratiques sur le durcissement des systèmes d'exploitation et l'utilisation de réseaux privés virtuels (VPN) et de Tor.

Julia Angwin, *Dragnet Nation* (2014).

Idée maîtresse : Une enquête journalistique sur les tentatives d'effacement de l'empreinte numérique face à une industrie de la donnée omniprésente.

Apport : Techniques de suppression de données auprès des courtiers en informations (data brokers) et de création d'identités secondaires.

Carissa Véliz, *Privacy is Power* (2020).

Idée maîtresse : La vie privée n'est pas seulement un choix individuel mais un bien collectif et politique nécessaire à la démocratie.

Apport : Cadrage éthique pour motiver le lecteur à agir au-delà de son simple intérêt personnel, en protégeant son entourage.

Kashmir Hill, *Your Face Belongs to Us* (2023).

Idée maîtresse : La reconnaissance faciale et les données biométriques représentent la frontière ultime de la perte de vie privée.

Apport : Configuration des paramètres biométriques sur les smartphones et gestion des photos sur les réseaux sociaux.

Marc Goodman, *Future Crimes* (2015).

Idée maîtresse : L'hyper-connexion des objets du quotidien (IoT) crée des vulnérabilités massives exploitables pour la surveillance et le piratage.

Apport : Sécurisation du réseau domestique, des assistants vocaux et des objets connectés (caméras, enceintes).

Frank Pasquale, *The Black Box Society* (2015).

Idée maîtresse : Les algorithmes opaques gouvernent nos réputations, nos finances et nos opportunités sans aucun droit de regard.

Apport : Compréhension de l'impact du profilage publicitaire sur les assurances, les crédits et les offres d'emploi.

Adam Alter, *Irresistible* (2017).

© 2026 Oussama Ghorbel

Idée maîtresse : Les applications sont conçues pour créer une dépendance comportementale en exploitant les failles psychologiques humaines.

Apport : Désactivation des notifications, des lectures automatiques et des fils d'actualité algorithmiques.

Edward Snowden, *Permanent Record* (2019).

Idée maîtresse : L'infrastructure de la surveillance de masse repose sur les outils grand public que nous utilisons tous les jours.

Apport : Bases du chiffrement de bout en bout (E2EE) et choix de messageries sécurisées (Signal, Matrix).

Roger McNamee, *Zucked* (2019).

Idée maîtresse : Les plateformes sociales manipulent les émotions pour maximiser l'engagement et la collecte de données psychographiques.

Apport : Audit complet et verrouillage des paramètres de confidentialité des réseaux sociaux (Meta, X, LinkedIn).

Michael Bazzell, *Extreme Privacy: What It Takes to Disappear* (2019).

Idée maîtresse : L'OSINT (Open Source Intelligence) permet à quiconque de compiler un profil dévastateur à partir de données éparpillées.

Apport : Techniques avancées d'utilisation d'alias, de cartes bancaires virtuelles et d'adresses de redirection.

Jaron Lanier, *Ten Arguments for Deleting Your Social Media Accounts Right Now* (2018).

Idée maîtresse : Les réseaux sociaux dégradent la vérité et la liberté individuelle en transformant les utilisateurs en produits de conditionnement.

Apport : Alternatives aux réseaux sociaux et stratégies de communication décentralisée pour reprendre le contrôle de son audience.

© 2026 Oussama Ghorbel